网络安全与
计算机犯罪勘查技术学

张越今 著

清华大学出版社
北京

内 容 简 介

本书分两篇。上篇系统阐述了网络安全的相关技术，共5章；下篇详细论述了计算机犯罪勘查技术学的原理、方法、步骤和具体应用，共8章。上、下篇既相对独立，又衔接成一个整体，可使读者对网络安全、计算机犯罪和犯罪勘查有一个全面的理解和认识。

本书既有体系性描述、基本概念阐述，又有技术细节和技能技巧的知识，可供从事计算机犯罪侦查的技术人员参考，也可作为从事电信与计算机网络工作的科研人员和工程技术人员的参考书。

版权所有，翻印必究。
本书封面贴有清华大学出版社激光防伪标签，无标签者不得销售。

图书在版编目(CIP)数据

网络安全与计算机犯罪勘查技术学/张越今著. 北京：清华大学出版社，2003
ISBN 7-302-06862-3

Ⅰ.网… Ⅱ.张… Ⅲ.①计算机网络—安全技术 ②计算机犯罪—刑事侦察—中国
Ⅳ.①TP393.08 ②D924.399

中国版本图书馆CIP数据核字(2003)第070755号

出 版 者：清华大学出版社　　地　　址：北京清华大学学研大厦
　　http://www.tup.com.cn　　邮　　编：100084
　　社总机：010-62770175　　客户服务：010-62776969
组稿编辑：王一玲
文稿编辑：赵从棉
版式设计：刘祎森
印 刷 者：三河市春园印装有限公司
发 行 者：新华书店总店北京发行所
开　　本：175×245　印张：15.5　字数：294千字
版　　次：2003年9月第1版　2003年9月第1次印刷
书　　号：ISBN 7-302-06862-3/TP·5091
印　　数：1～2000
定　　价：25.00元

序

北京市公安局张越今博士的这部书稿，放在我手中已有些时间了。仔细阅读，思考再三，我觉得这本书有两个特点并引申出一系列重要的技术与法理问题。

本书上、下两篇既相互参见，又相互独立。上篇概述了网络安全的框架结构与重点应用技术；下篇详细地描述了对计算机犯罪进行刑事侦查的现场勘查与取证的实务。前部分内容表明了作者对信息安全技术的全面理解，以及作者的理论技术功底；而后部分则充分表明了作者的业务素养，反映了作者将现代信息技术与刑侦业务结合起来的真知灼见和远见卓识。本书在普及信息安全一般性理论和重要技术概念，把艰深复杂的计算机技术转化为在犯罪现场勘查取证的业务与程序中这两个方面，以及对公安战线广大干警和其他从事刑事侦查的同志适应信息技术时代打击计算机犯罪的技术化要求而言，都具有十分现实的借鉴与指导意义。

本书引申出另一个重要的技术与法理问题，即在信息化程度越来越高的情况下，犯罪现场的技术法律属性的确定和数字化证据与犯罪行为之间的法律关系的确定。我认为这是相当困难的问题，是一个需要从技术机理和法学原理的层面上才能解决的问题。当然，这不是本书的任务，但我寄希望于越今博士和更多的青年学者，希望他们能在这一点上有所突破。这样，不仅能使我国的刑事法学在信息技术领域有突破性的发展，而且对我国真正进入信息化时代后，有效打击日益广泛的信息化犯罪，保护社会和国家安全，都能起到关键性的作用。

沈昌祥　院士

2003 年 3 月

前言

市场上有大量关于犯罪勘查取证的书籍，但是关于计算机犯罪勘查取证的书籍却非常少。虽然计算机及网络技术的迅猛发展带来了各种勘查工具的相应改变，但是掌握计算机犯罪勘查和电子证据获取的原理对于案件侦查是至关重要的。

计算机犯罪，广义上指任何运用计算机或网络作为作案工具以及把计算机或网络作为作案对象的犯罪活动。提及计算机犯罪，人们常常会联想到网络入侵案件，事实上远不止入侵案件，其他类型的计算机犯罪案件包括：

- 建立色情网站或匿名的个人色情网页。如设立贴图网站供不特定第三人张贴色情、淫秽图片；提供超链接色情网站；网上提供、散布性交易信息。
- 建立聊天室等交互式栏目，教授他人制作爆炸装置等暴力恐怖活动。
- 利用互联网销赃及以匿名的方式在网上低价出售赃物。
- 利用网络进行诈骗，如虚设金融账号、网上传销等。
- 入侵他人网站。
- 在网上发布不实议论，辱骂他人，侵犯他人权益，损害他人名誉。
- 制造传播计算机病毒。
- 设立赌博网站，从事网上赌博活动。
- 网上泄露他人机密或隐私。

本书基于国内网络安全领域的最新发展动态和作者在国外学习及博士后工作期间的研究成果。本书分两篇。上篇系统阐述了网络安全的相关技术，共5章；下篇详细论述了计算机犯罪勘查技术学的原理、方法、步骤和具体应用，共8章。两部分既相对独立，又衔接成一个整体，可使读者对网络安全、计算机犯罪和犯罪勘查有一个全面

的理解和认识。本书既有体系性描述、基本概念阐述，又有技术细节和技能技巧的知识，适合于从事计算机犯罪侦查的技术人员参考。

关于计算机犯罪及其勘查方面的技术和方法的适用性问题，由于受到国家法律和管理体制的制约，请读者根据自己从事业务和所处的工作环境变通采用和参考，完全照搬和对号是不可取的。

本书的编写出版得到了市委组织部北京市优秀人才培养专项资金资助和北京市科技新星计划的支持和帮助，在此表示衷心的感谢。

作　者

2003 年 4 月

目 录

上篇 网络安全技术基础

第 1 章 网络安全概述 …… 2

1.1 开放的网络环境及其安全问题 …… 2

1.1.1 开放系统的基本概念 …… 2

1.1.2 开放系统的特征 …… 2

1.1.3 OSI 参考模型 …… 3

1.2 TCP/IP …… 8

1.2.1 TCP/IP 参考模型 …… 8

1.2.2 TCP/IP 的安全问题 …… 10

1.3 网络信息安全 …… 12

1.3.1 网络信息安全保护的对象 …… 12

1.3.2 信息安全的基本目标 …… 13

1.3.3 信息安全的基本内容 …… 14

1.3.4 信息安全的基础保障 …… 15

1.3.5 网络安全服务 …… 16

1.4 安全威胁 …… 20

1.4.1 黑客及恶意攻击者的攻击 …… 20

1.4.2 对网络系统的攻击 …… 21

1.4.3 利用扫描工具发现安全弱点并制定攻击策略 …… 21

1.4.4 利用明文传输和电磁泄漏直接获取所需信息资源 …… 21

1.4.5 来自内部的恶意攻击以及内外勾结进行的网络攻击 …… 21

1.4.6 病毒 …… 21

第 2 章 网络安全标准、需求定义及配置 …… 23
2.1 安全标准 …… 23
2.1.1 可信任计算机标准评估准则 …… 23
2.1.2 我国的计算机信息安全标准 …… 23
2.2 intranet 安全性 …… 24
2.2.1 intranet 安全的趋势及问题 …… 25
2.2.2 设计和实现 intranet 的安全策略 …… 25
2.2.3 intranet 安全标准 …… 26
2.3 局部安全问题 …… 27
2.3.1 安全策略 …… 27
2.3.2 口令控制 …… 28
2.4 安全需求定义 …… 30
2.4.1 家庭办公室 …… 30
2.4.2 小商业公司 …… 31
2.4.3 专业公司 …… 31
2.4.4 制造商 …… 31
2.4.5 政府机关 …… 32
2.4.6 大学 …… 32
2.4.7 因特网服务供应商 …… 32
2.4.8 在线商务公司 …… 33
2.4.9 金融机构 …… 33
2.4.10 医院 …… 34
2.4.11 军事部门 …… 34
2.4.12 情报机关 …… 34
2.5 配置规则 …… 35
2.5.1 注意级(awareness) …… 35
2.5.2 关注级(concern) …… 35
2.5.3 警惕级(caution) …… 38
2.5.4 严格级(strictness) …… 40
2.5.5 超常级(transcendency) …… 41

第 3 章 信息安全产品分类 …… 42
3.1 安全防御类 …… 42
3.1.1 鉴别和认证产品 …… 42

3.1.2 访问控制产品 …… 42
3.1.3 加密产品 …… 43
3.2 安全管理类 …… 43
3.2.1 入侵检测产品 …… 43
3.2.2 安全性扫描产品 …… 45
3.2.3 信息审计系统 …… 47
3.2.4 防病毒产品 …… 47

第4章 防火墙技术 …… 48
4.1 防火墙基本知识 …… 48
4.2 防火墙的常见配置 …… 49
4.2.1 屏蔽过滤路由器 …… 49
4.2.2 堡垒主机 …… 49
4.2.3 双宿主网关 …… 49
4.2.4 IP 过滤 …… 49
4.2.5 代理 …… 50
4.3 防火墙技术 …… 50
4.3.1 包过滤 …… 50
4.3.2 代理 …… 60
4.3.3 网络地址转换 …… 73

第5章 密码技术基础 …… 86
5.1 对称密码体制 …… 86
5.2 非对称密码体制 …… 87
5.3 散列算法(hash) …… 89
5.4 数字签名 …… 90
5.5 数字证书 …… 91
5.6 密钥协商 …… 93
5.6.1 密钥分配 …… 93
5.6.2 密钥共识 …… 94

下篇 计算机犯罪勘查技术学

第6章 计算机犯罪勘查概述 …… 98
6.1 计算机犯罪的概念、范畴及类型 …… 99

6.1.1 计算机犯罪的概念 …… 99
6.1.2 计算机犯罪的范畴 …… 99
6.1.3 计算机犯罪的类型 …… 101
6.2 计算机犯罪现场的特征及勘查对策 …… 104
6.2.1 计算机犯罪现场的特征 …… 104
6.2.2 计算机犯罪现场的勘查对策 …… 107
6.3 计算机犯罪现场勘查的重点 …… 111
6.3.1 审计跟踪概述 …… 111
6.3.2 UNIX 系统的审计跟踪 …… 111
6.3.3 Windows NT 的审计跟踪 …… 115

第 7 章 计算机犯罪现场勘查 …… 117
7.1 预先评估现场 …… 117
7.2 建立调查队 …… 118
7.2.1 调查总监 …… 118
7.2.2 讯问小组 …… 118
7.2.3 素描及影像小组 …… 118
7.2.4 物理搜查小组 …… 118
7.2.5 安全及逮捕小组 …… 119
7.2.6 技术证据没收及笔录小组 …… 119
7.3 建立一个攻击计划 …… 119
7.3.1 位置 …… 119
7.3.2 任务 …… 120
7.3.3 执行 …… 120
7.3.4 进入和撤退的路径 …… 120
7.3.5 通信 …… 120
7.4 准备搜查令 …… 120
7.5 执行搜查 …… 120
7.5.1 敲门并通知 …… 121
7.5.2 逐字写出通知 …… 121
7.5.3 保护现场 …… 121
7.5.4 调查队成员各司其职 …… 121
7.6 完成搜查 …… 122

第8章 勘查工具箱 …… 123
8.1 硬件 …… 123
8.1.1 常用的五金工具 …… 123
8.1.2 用于备份的硬件 …… 123
8.1.3 桌面电脑 …… 123
8.1.4 便携式电脑 …… 125
8.1.5 其他有用的工具 …… 126
8.2 软件程序 …… 128
8.2.1 计算机搜查程序 …… 128
8.2.2 XTreePro Gold …… 128
8.2.3 Laplink …… 129
8.2.4 McAfee,Norton 等查毒杀毒软件 …… 129
8.2.5 AnaDisk/Viewdisk …… 129
8.2.6 类磁盘驱动程序 …… 129
8.2.7 Fried 和 Mares 应用程序 …… 129
8.2.8 PC-Tools …… 130
8.2.9 Lantastic …… 130
8.2.10 disk copy fast …… 130
8.2.11 压缩程序 …… 130
8.2.12 启动盘 …… 131

第9章 计算机证据 …… 135
9.1 计算机证据类型 …… 135
9.1.1 书证 …… 135
9.1.2 计算机部件 …… 135
9.1.3 主机、键盘和显示器 …… 135
9.1.4 磁盘 …… 136
9.1.5 磁带存储单元和媒介 …… 136
9.1.6 主板及元件 …… 136
9.1.7 调制解调器 …… 136
9.1.8 打印机和其他硬拷贝硬件设施 …… 136
9.1.9 PCMCIA 卡 …… 137
9.1.10 软件及使用手册 …… 137
9.2 发现计算机相关证据 …… 137

9.3 查找计算机证据 …… 138
9.4 检查证据 …… 138
9.5 收集证据 …… 138
9.5.1 大型计算机 …… 139
9.5.2 小型计算机 …… 139
9.5.3 专用计算机 …… 139
9.5.4 UNIX 工作站 …… 139
9.5.5 黑客系统 …… 140
9.6 证据保存 …… 140
9.7 警告及注意事项 …… 141
9.8 证据评估和分析 …… 143
9.8.1 证据表格 …… 143
9.8.2 证据分析工具 …… 144
9.8.3 证据分析 …… 146

第 10 章 勘查计算机及软盘 …… 152
10.1 一般步骤 …… 152
10.1.1 制作案件进展工作单 …… 152
10.1.2 评估计算机状况 …… 152
10.1.3 给计算机拍照 …… 152
10.1.4 从软盘启动计算机 …… 153
10.1.5 标记所有的线缆和硬件 …… 153
10.1.6 准备把计算机运走 …… 153
10.1.7 获取软盘和其他可移动介质 …… 154
10.2 注意事项 …… 154
10.2.1 小心搜索 …… 154
10.2.2 小心地把这些东西放到货车上 …… 154
10.2.3 磁性设备 …… 154
10.3 勘查软盘 …… 154

第 11 章 勘查网络的基础知识 …… 157
11.1 网络利弊 …… 157
11.2 网络的组成 …… 158
11.3 网络类型 …… 160
11.4 网络的物理连接 …… 161

11.5 网络操作系统…… 163

第 12 章 勘查电子公告牌 …… 166
12.1 从哪里开始…… 167
12.2 开始勘查…… 172
12.2.1 如何避免陷阱、圈套和错误 …… 172
12.2.2 工具及方法…… 174
12.3 鉴别嫌疑人…… 177
12.3.1 使用监视…… 177
12.3.2 通常的信息来源…… 177
12.3.3 在逮捕和搜查期间鉴别嫌疑人…… 178
12.4 需要注意的方面…… 178
12.5 调查人员易暴露的方面…… 179
12.6 建议保护调查人员的步骤…… 179

第 13 章 计算机犯罪勘查取证系统技术实现 …… 180
13.1 国内外研究现状与趋势…… 180
13.2 关键技术…… 183
13.3 系统模型的建立及框架结构和功能定义…… 183
13.3.1 勘查取证系统模型…… 184
13.3.2 勘查取证系统框架结构…… 186
13.3.3 勘查取证系统功能定义…… 187
13.4 系统结构设计…… 189
13.4.1 系统流程…… 189
13.4.2 软件体系结构…… 190
13.4.3 软件结构…… 190
13.5 典型算法设计…… 199
13.5.1 网络拓扑搜索基础…… 199
13.5.2 网络拓扑搜索算法…… 202
13.5.3 构造网络拓扑图…… 206
13.5.4 评价网络拓扑逻辑…… 208
13.5.5 在监听管理中使用的几种多模式匹配算法…… 211
13.6 安全保密设计…… 212
13.7 运行结果分析…… 213

附录 A 计算机运行环境勘查取证系统数据结构 …… 219
A1 数据结构描述 …… 219
A1.1 通用的定义 …… 219
A1.2 基本数据结构 …… 219
A2 数据库设计列表 …… 222

附录 B 系统出错处理设计 …… 226

附录 C 通用文件后缀 …… 227

参考文献 …… 228

上　篇

网络安全技术基础

第1章

网络安全概述

1.1 开放的网络环境及其安全问题

1.1.1 开放系统的基本概念

开放系统是计算机软硬件及网络技术发展的必然产物，是人们在当前软硬件环境下对计算环境的扩充和延伸。其产生的主要原因是计算环境的发展和协同计算的要求。计算环境的发展为它的产生提供了可能性，而协同计算的要求则是说明了它产生的必要性和迫切性。

所谓开放系统，是指计算机和计算机通信环境根据行业标准的接口所建立起来的计算机系统。在这样一个开放性系统中，不同厂商的计算机系统和软件都能互相交换使用，并能结合在一个集成式的操作环境里。要达到这样的目标，惟有依赖于标准的接口，使计算机系统具有可移植性、互操作性和可伸展性，从而可将操作系统或应用软件放在不同厂商的各种型号的计算机上使用，并且可以相互交换信息。

计算机的可移植性和互操作性主要有以下基本特点：

(1) 保障系统原有投资，便于更换计算机硬件或软件厂家，节省了培训和维护费用；便于扩充系统，随时可从市场上采购所需的软、硬件；可充分利用已有的应用软件和快速集成新技术，便于集成不同销售商的产品。

(2) 促进软硬件技术公开和标准化，促进供应商的竞争并不断降低软硬件价格。

(3) 便于对不同厂商的计算机系统进行集成，不断利用各厂家的新技术来加强系统功能，使系统具有更强的处理能力。

1.1.2 开放系统的特征

开放系统是以被广泛采用的各类标准(事实上的标准、工业标准、国家标准、国

际标准)、可以共享的技术标准以及有完整定义的开放标准为基础的。目前,虽然还没有一致公认的确切定义,但可以肯定地说,相对于封闭的专用系统,它具备以下特征:

(1) 符合各类标准(事实上的标准、工业标准、国家标准及国际标准)。根据标准化的程度确定其开放的程度。

(2) 技术公开。根据技术公开的程度,可将系统分成私有的、集团控制的和完全公开的。提供源代码是技术公开的重要方式。

(3) 可移植性(portability)。同一软件可以在不同计算机上运行,并且同一软件在不同计算机上进行移植时不需要做任何修改。可移植性要求不同计算机环境提供软件运行的界面是相同的,相同的界面能把硬件平台及操作系统的不同之处屏蔽起来。

(4) 兼容性(compatibility)。应用程序不加改动就可以在任何类型的计算机上运行,包括源代码和目标代码级兼容。

(5) 互操作性(interoperation)。互操作性是指不同系统间可以方便地相互连接,或者指不同计算机以及不同应用程序能在一个网络中交换信息、协同工作。每个用户作为网络的一个节点,都能够存取网络上的数据、调用应用程序,从而充分共享系统的资源。

(6) 可伸展性(extendability)。可在不同规模、不同配置的硬件环境下运行,在不同档次的计算机上运行应用程序,其性能与硬件平台的性能成正比。若在现有的计算机系统中多加几个处理器,或把同一程序移到功能更强的计算机上运行时,应用程序的性能呈线性增长。这意味着应用程序能充分地调动硬件平台的所有处理器资源及其系统功能,从而便于扩充系统规模和运行环境。

1.1.3　OSI 参考模型

OSI 参考模型如图 1-1 所示(省略了物理介质)。该模型基于国际标准化组织(ISO)的建议,是在每层使用的协议逐步标准化的基础上发展起来的(Day and Zimmermann,1983)。这一模型被称作 ISO 的 OSI 开放系统互联参考模型(Open Systems Interconnection reference model),因为它是关于如何把开放式系统(即为了与其他系统通信而相互开放的系统)连接起来的,所以常简称它为 OSI 模型。

OSI 模型有 7 层,其分层原则如下:

- 根据不同层次的抽象分层。
- 每层应当实现一个定义明确的功能。
- 每层功能的选择应该有助于制定网络协议的国际标准。

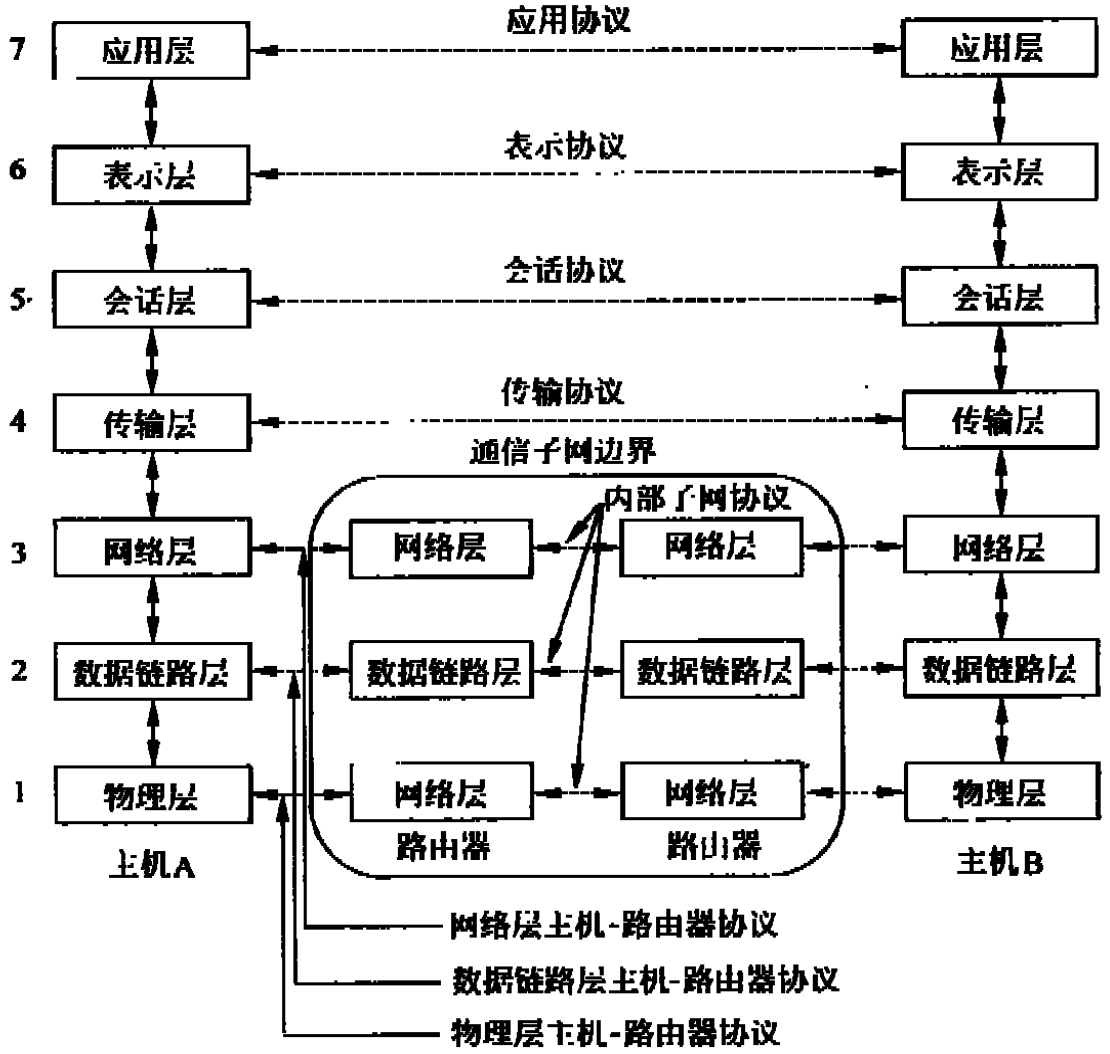

图 1-1 OSI 参考模型

- 各层边界的选择应尽量减少跨过接口的通信量。
- 层数应足够多，以避免不同的功能混杂在同一层中，但也不能太多，否则体系结构会过于庞大。

下面将从最下层开始，依次讨论 OSI 参考模型的各层。请注意 OSI 模型本身不是网络体系结构的全部内容，这是因为它并未确切地描述用于各层的协议和服务，它仅仅告诉我们每一层应该做什么。ISO 已经为各层制定的标准并不是参考模型的一部分，而是作为独立的国际标准公布的。

物理层

物理层(physical layer)涉及到通信在信道上传输的原始比特流。设计上必须保证一方发出二进制“1”时，另一方收到的也是“1”而不是“0”。本层的核心问题是用多少伏电压表示“1”，多少伏电压表示“0”；一个比特持续多少微秒；传输是否在两个方向上同时进行；最初的连接如何建立和完成通信后连接如何终止；网络接插件的针数以及各针的用途。本层的设计主要是处理机械的、电气的和过程的接口，以及物理层下的物理传输介质等问题。

数据链路层

数据链路层(data link layer)的主要任务是加强物理层传输原始比特的功能，使之对网络层表现为一条无错线路。发送方把输入数据分装在数据帧(data frame)里(典型的帧为几百字节或几千字节)，按顺序传送各帧，并处理接收方回送的确认帧(acknowledgement frame)。因为物理层仅仅接收和传送比特流，并不关心它的意义和结构，所以只能依赖各链路层来产生和识别帧边界。可以通过在帧的前面和后面附加上特殊的二进制编码模式来达到这一目的。如果在数据中偶然出现这些二进制编码，则必须采取特殊的措施(如编码方法)以避免混淆。

传输线路上突发的噪声干扰可能把帧完全破坏掉。在这种情况下，发送方机器上的数据链路软件必须重传该帧。然而，相同帧的多次重传也可能使接收方收到重复帧，比如接收方给发送方的确认丢失以后，就可能收到重复帧。数据链路层要解决由于帧的破坏、丢失和重复而出现的问题。数据链路层可能向网络层提供几类不同的服务，每一类都有不同的服务质量和价格。

数据链路层要解决的另一个问题(在大多数层上也存在)是防止高速的发送方的数据把低速的接收方"淹没"。因此需要有某种流量调节机制，使发送方知道当前接收方还有多少缓存空间。通常流量调节和出错处理同时完成。

如果线路能用于双向传输数据，数据链路层软件还必须解决新的麻烦，即从A到B数据帧的确认帧将同从B到A的数据帧竞争线路的使用权。借道(piggybacking)就是用来解决此类问题的一种巧妙方法。

广播式网络在数据链路层还要处理新的问题，即如何控制对共享信道的访问。数据链路层的一个特殊的子层——介质访问子层，就是专门处理这个问题的。

网络层

网络层(network layer)关系到子网的运行控制，其中一个关键问题是确定分组从源端到目的端如何选择路由。路由既可以选用网络中固定的静态路由表(几乎保持不变)，也可以在每一次会话开始时决定(例如通过终端对话决定)，还可以根据当前网络的负载状况，高度灵活地为每一个分组决定路由。如果在子网中同时出现过多的分组，它们将相互阻塞通路，形成瓶颈。此类拥塞控制也属于网络层的范围。

因为拥有子网的人总是希望他们提供的子网服务能得到报酬，所以网络层常常设有记账功能。最低限度，软件必须对每一个顾客究竟发送了多少分组、多少字符或多少比特进行记数，以便于生成账单。当分组跨越国界时，由于双方税率可能不同，记账则更加复杂。

当分组不得不跨越一个网络到达目的地时，新的问题又会产生。第二个网络

的寻址方式可能和第一个网络完全不同；第二个网络可能由于分组太长而无法接收；两个网络使用的协议也可能不同等。网络层必须解决这些问题，以便异种网络能够互联。

在广播网络中，选择路由问题很简单，因此网络层不起作用。

传输层

传输层(transport layer)的基本功能是从会话层接收数据，并且在必要时把它分成较小的单元，传递给网络层，并确保到达对方的各段信息正确无误，而且，这些任务都必须高效率地完成。从某种意义上讲，传输层使会话层不受硬件技术变化的影响。

通常，会话层每请求建立一个传输连接，传输层就为其创建一个独立的网络连接。如果传输连接需要较高的信息吞吐量，传输层也可以为之创建多个网络连接，让数据在这些网络连接上分流，以提高吞吐量。另一方面，如果创建或维持一个网络连接不合算，传输层可以将几个传输连接复用到一个网络连接上，以降低费用。在任何情况下，都要求传输层能使多路复用对会话层透明。

传输层也要决定向会话层，向最终网络用户提供什么样的服务。最流行的传输连接是一条无错的、按发送顺序传输报文或字节的点到点的信道。但是，还有的传输服务是不能保证传输次序的独立报文传输和多目标报文广播。采用哪种服务是在建立连接时确定的。

传输层是真正的从源到目标"端到端"的层。也就是说，源端机上的某程序，利用报文头和控制报文与目标机上的类似程序进行对话。在传输层以下的各层中，协议是每台机器和它直接相邻的机器间的协议，而不是最终的源端机与目标机之间的协议，在它们中间可能还有多个路由器。图 1-1 说明了这种区别，1～3 层是链接起来的，4～7 层是端到端的。

很多主机有多道程序在运行，这意味着这些主机有多条连接进出，因此需要有某种方式来区别报文属于哪条连接。可以使用传输层的报文头识别这些连接的信息。

除了将几个报文流多路复用到一条通道上，传输层还必须解决跨网络连接的建立和拆除。这需要某种命名机制，使机器内的进程知道与谁建立会话连接。另外，还需要一种机制以调节通信量，使高速主机不会发生过快地向低速主机传输数据的现象，这样的机制称为流量控制(flow control)，它在传输层(同样在其他层)中扮演着关键角色。主机之间的流量控制和路由器之间的流量控制不同。

会话层

会话层(session layer)允许不同机器上的用户建立会话(session)关系。会话

层允许进行类似传输层的普通数据的传输，并提供了对某些应用有用的增强服务会话，也可被用于远程登录到分时系统或在两台机器间传递文件。

会话层服务之一是管理对话。会话层允许信息同时双向传输，或任一时刻只能单向传输。若属于后者，则类似于单线铁路，会话层将记录此时该轮到哪一方了。

一种与会话有关的服务是令牌管理(token management)。有些协议保证双方不能同时进行同样的操作，这一点很重要。为了管理这些活动，会话层提供了令牌。令牌可以在会话双方之间交换，只有持有令牌的一方可以执行某种关键操作。

另一种会话服务是同步(synchronization)。如果网络平均每小时出现一次大故障，而两台计算机之间要进行长达两个小时的文件传输时该怎么办呢？每一次传输中途失败后，都不得不重新传输这个文件。而当网络再次出现故障时，又可能半途而废。为了解决这个问题，会话层提供了一种方法，即在数据流中插入检查点。每次网络崩溃后，仅需要重传最后一个检查点以后的数据。

表示层

表示层(presentation layer)完成某些特定的功能，由于这些功能经常被请求使用，因此人们希望找到通用的解决办法，而不是让每个用户来实现。值得一提的是，表示层以下的各层只关心可靠地传输比特流，而表示层关心的是所传输的信息的语法和语义。

表示层服务的一个典型例子是用一种大家一致同意的标准方法对数据编码。大多数用户程序之间并不是交换随机的比特流，而是诸如人名、日期、货币数据和发票之类的信息。这些对象是用字符串、整型、浮点数的形式，以及由几种简单类型组成的数据结构来表示的。不同的机器有不同的代码来表示字符串(如ASCII和Unicode)、整型(如二进制反码和二进制补码)等。为了让采用不同表示法的计算机之间能进行通信，通信中使用的数据结构可以用抽象的方式来定义，并且使用标准的编码方式。表示层管理这些抽象数据结构，并且在计算机内部表示法和网络的标准表示法之间进行转换。

应用层

应用层(application layer)包含人们普遍需要的大量协议。例如，世界上有成百种不兼容的终端型号。如果希望一个全屏幕编辑程序能工作在网络中许多不同的终端类型上，每个终端都有不同的屏幕格式、插入和删除文本的换码序列、光标移动等，其困难可想而知。

解决这一问题的方法之一是定义一个抽象的网络虚拟终端(network virtual terminal)，编辑程序和其他所有程序都面向该虚拟终端。对每一种终端类型，都

编写驱动软件来把网络虚拟终端映射到实际的终端。例如，当把虚拟终端的光标移到屏幕左上角时，该软件必须发出适当的命令使真正的终端的光标移动到同一位置。所有虚拟终端软件都位于应用层。

应用层的另一个功能是文件传输。不同的文件系统有不同的文件命名原则，文本行有不同的表示方式。不同的系统之间传输文件所需处理的各种不兼容问题，也同样属于应用层的工作。此外还有电子邮件、远程作业输入、名录查询和其他各种通用和专用的功能。

1.2 TCP/IP

TCP/IP 是网际互联的一个协议簇，形式上是 Transmission Control Protocol/Internet Protocol(传输控制协议/网际协议)的缩写，但 TCP/IP 并不意味着只是两个协议，而是强调一个与网际互联有关的协议系列。

TCP/IP 协议簇包括诸如网际协议(IP)、地址解析协议(ARP)、互联网控制信息协议(ICMP)、用户数据报协议(UDP)、传输控制协议(TCP)、路由信息协议(RIP)、Telnet、简单邮件传输协议(SMTP)、域名系统(DNS)等协议以及许多其他协议。

1.2.1 TCP/IP 参考模型

TCP/IP 参考模型是因特网使用的参考模型。从因特网的发展来看，它的雏形是由美国国防部(U. S. Department of Defense)赞助研究的 ARPANET 网络，它通过租用的电话线连接了数百所大学和政府部门。当卫星和无线网络出现以后，已有的协议在和它们互联时出现了问题，所以需要一种新的参考体系结构。能无缝隙地连接多个网络的能力是其一开始就确定的主要设计目标。ARPANET 网设计的另一个目标是只要源端和目的端机器都在工作，连接就能保持住，即使某些中间机器或传输线路突然失去控制。而且，整个体系结构必须相当灵活，因此对各种各样的信息传输，包括从文件传输到实时声音传输的需求均能被满足。这个体系结构在它的两个主要协议出现以后，被称为 TCP/IP 参考模型(TCP/IP reference model)。

TCP/IP 参考模型分为以下四层。

物理链路层

物理链路层通常包括操作系统中设备驱动程序和计算机中对应的网络接口卡，它们一起处理与电缆(或其他传输媒体)的物理接口细节。TCP/IP 参考模型没有真正描述这一部分，只是指出主机必须使用某种协议与网络连接，以便能在其

上传递 IP 分组。这个协议未被定义，并且随主机和网络的不同而不同。

互联网层

互联网层提供无连接服务的数据传送机制，它不能保证传输的可靠性，只负责把分组发往任何网络并使分组独立地传向目标(可能经由不同的网络)。这些分组到达的顺序和发送的顺序可能不同，因此如果需要按顺序发送及接收时，高层必须对分组排序。必须注意到，虽然因特网中确实存在互联网层，但是这里使用“互联网”是基于一般意义的。

这里不妨把它和邮政系统作个对比。某个国家的一个人把一些国际邮件投入邮箱，一般情况下，这些邮件大都会被投递到正确的地址。这些邮件可能会经过几个国际邮件通道，但这对用户是透明的。而且每个国家(每个网络)都有自己的邮戳，要求的信封大小也不同，而用户是不知道投递规则的。

互联网层定义正式的分组格式和协议，即 IP(Internet Protocol)协议。互联网层的功能就是把 IP 分组发送到应该去的地方。分组路由和避免阻塞是其主要的设计问题。由于这些原因，我们有理由说 TCP/IP 互联网层和 OSI 网络层在功能上非常相似。图 1-2 显示了它们的对应关系。

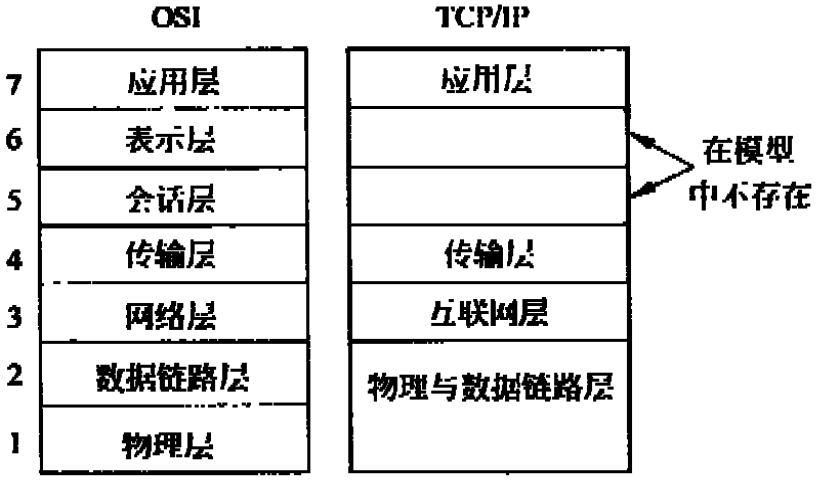

图 1-2　TCP/IP 参考模型与 OSI 模型的对应关系

传输层

在 TCP/IP 模型中，位于互联网层之上的那一层，现在通常被称为传输层(transport layer)。它的功能是使源端和目标端主机上的对等实体可以进行会话，这一点和 OSI 的传输层相同。

这里定义了两个端到端的协议。第一个是传输控制协议 TCP(Transmission Control Protocol)。它是一个面向连接的协议，允许从一台机器发出的字节流无差错地发往互联网上的其他机器。它把输入的字节流分成报文段并传给互联网

层。在接收端，TCP 接收进程把收到的报文再组装成输出流。TCP 还要处理流量控制，以避免快速发送方向低速接收方发送过多报文而使接收方无法处理。

第二个协议是用户数据报协议 UDP(User Datagram Protocol)。它是一个不可靠的、无连接协议，用于不需要 TCP 的排序和流量控制能力而是自己完成这些功能的应用程序。它也被广泛地应用于只有一次的、客户-服务器模式的请求-应答查询，以及快速递交比准确递交更重要的应用程序，如传输语音或影像。IP，TCP 和 UDP 的关系如图 1-3 所示。自这个模型出现以来，IP 已经在其他很多网络上实现了。

应用层

TCP/IP 模型没有会话层和表示层。来自 OSI 模型的经验已经证明，它们对大多数应用程序都没有用处。

传输层上面是应用层(application layer)，它包含所有的高层协议。最早引入的是虚拟终端协议(Telnet)、文件传输协议(FTP)和简单邮件传输协议(SMTP)，如图 1-3 所示。虚拟终端协议允许一台机器上的用户登录到远程机器上并且进行工作；文件传输协议提供了有效地把数据从一台机器转移到另一台机器的方法；简单邮件传输协议最初仅是一种文件传输，但是后来为它提出了专门的协议。这些年来又增加了不少的协议，例如域名服务 DNS(Domain Name Server)，用于把主机名映射到网络地址；NNTP 协议，用于传递新闻文章；HTTP 协议，用于在万维网(WWW)上获取主页等。

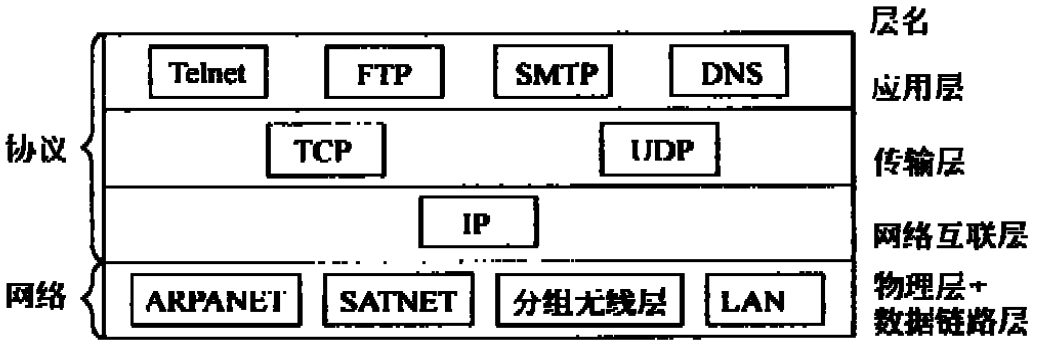

图 1-3 TCP/IP 模型中的协议与网络

1.2.2 TCP/IP 的安全问题

基于 TCP/IP 的 Internet 是在可信任网络环境中开发出来的成果，体现在 TCP/IP 协议上的总体构想和设计本身基本未考虑安全问题。在一个无网络边界的互不信任的网络环境中认为是安全脆弱性或安全漏洞的问题，在可信任的环境中并不存在，原因是 TCP/IP 协议最初设计的应用环境是美国国防系统的内部网

络，这一网络环境是互相信任的，当其推广到全社会的应用环境之后，信任问题就产生了。因此，Internet 充满了安全隐患就不难理解了。概括起来，Internet 网络体系存在着如下几种致命的安全隐患。

1. 缺乏对用户身份的鉴别

TCP/IP 协议的机制性安全隐患之一是缺乏对通信双方真实身份的认证机制。由于 TCP/IP 协议使用 IP 地址作为网络节点的惟一标识，而 IP 地址的使用和管理存在很多问题，因而可导致下列安全隐患：

(1) IP 地址是由 InterNIC(因特网网络信息中心)分发的，其数据包的源地址很容易被发现，且 IP 地址隐含了所使用的子网掩码，攻击者据此可以画出目标网络的轮廓。因此网络拓扑是暴露的。

(2) IP 地址很容易伪造和更改，且 TCP/IP 协议没有针对 IP 包中源地址真实性的认证机制和保密机制。因此网上任一主机都可以产生一个带有任意源 IP 地址的 IP 包，从而假冒另一个主机进行地址欺骗。

2. 缺乏对路由协议的安全认证

TCP/IP 在 IP 层上缺乏对路由协议的安全认证机制，因此对路由信息缺乏认证与保护。

3. TCP/UDP 的缺陷

TCP/IP 协议规定 TCP，UDP 是基于 IP 协议上的传输协议，TCP 分段和 UDP 数据包是封装在 IP 包中在网上传输的，除可能面临 IP 层所遇到的安全威胁外，还存在 TCP，UDP 实现中的安全隐患。

(1) 建立一个完整的 TCP 连接需要经历“三次握手”过程。在客户-服务器模式的“三次握手”过程中，假如客户的 IP 地址是假的，是不可达的，那么 TCP 永远不能完成该次连接所需的“三次握手”，使 TCP 连接处于“半开”状态。攻击者利用这一弱点可实施如 TCP SYN flooding 攻击的“拒绝服务”攻击。

(2) TCP 提供可靠连接是通过初始序列号和认证机制来实现的。一个合法的 TCP 连接都有一个客户-服务器双方共享的惟一序列号作为标识和认证。初始序列号一般由随机数发生器产生，但问题出在很多操作系统(如 UNIX)在实施 TCP 连接初始序列号的方法中，所产生的序列号并不是真正随机的，而是一个具有一定规律可猜测或计算的数字。对攻击者来说，猜出了初始序列号并掌握了目标 IP 地址之后，就可以对目标实施 IP spoofing 攻击，而 IP spoofing 攻击很难检测，因此此类攻击危害极大。

(3) 由于 UDP 是一个无连接控制协议，极易受 IP 源路由和拒绝服务型攻击。

在 TCP/IP 协议层结构中，应用层位于最顶部，因此下层的安全缺陷必然导致应用层的安全出现漏洞甚至崩溃。而各种应用层服务协议(如 Finger，FTP，Tel-

net,E-mail,DNS,SNMP 等)本身也存在许多安全隐患,这些隐患涉及到认证、访问控制、完整性和保密性等多个方面,极易受到针对基于 TCP/IP 应用服务协议和程序方面安全缺陷的攻击并造成损害。

1.3 网络信息安全

随着计算机及网络技术的不断发展,信息网络以其方便、快捷、灵活的特性给我们的工作、学习和生活带来了很大的方便,以至于人们越来越依赖它。但是,科学家最初研究并发展信息网络时,考虑更多的是如何来实现它的功能以及如何来提高它的性能,而很少考虑它的安全性因素。这正如人们最初制造并生产汽车的时候,考虑更多的是如何让汽车跑起来,而并未考虑怎样避免出车祸以及出了车祸之后如何更有效地减少人员伤亡和财产损失一样。今天的信息网络赖以存在的各种协议(如 TCP/IP 协议)、操作系统(如 UNIX,Windows 等)等都存在着这样或那样的安全漏洞。

1.3.1 网络信息安全保护的对象

在信息技术中,网络安全是急需解决的最重要的问题之一。安全问题的解决涉及很宽广的技术领域,而这些技术的广泛应用直到今天才成为可能。因为在现实中存在着各种各样的网络入侵、攻击的方法,人们不得不考虑采用复杂的防护措施的成本。由于通信技术的发展有下面三种主要趋势,人们必须综合考虑安全与成本的平衡关系,而将通信安全方面的考虑提高到适当的位置上。

(1) 系统互联与网络互联数量的日益增长,使任何系统都潜在地存在着已知或未知用户对网络进行非法访问的可能性。

(2) 人们越来越多地使用计算机网络来传送安全敏感的信息。例如,人们用计算机网络进行电子资金传递(EFT)、商业数据交换、政府秘密信息传递以及产权信息的交流等。

(3) 对攻击者来说,可以得到的技术越来越先进,并且这些技术的成本在不断地下降,从而使密码分析技术的工程实现变得越来越容易。

网络安全的根本在于保护网络中的信息免受各种攻击。因此,有必要对信息业务及其价值、机密信息、产权及敏感信息分别加以讨论。

1. 信息业务及其价值

与传统的邮政业务不同,信息传输、信息协同以及规划是通过电子和光子来完成的。现在的信息系统可以让人们实现面对面的电视会议和电话通信。然而,通过这些信息系统的信息有可能是十分敏感的,因为它们可能涉及产权信息,或者与

企业之间的竞争密切相关，或者是政府或企业的机密信息。目前，许多机构已明确规定，对网络上所传输的所有信息必须进行加密保护。从这个意义上来说，根据信息业务及其价值，应该采取相应的安全标准和策略，实施数据保护。

2. 机密信息

所谓机密信息，是指国家对涉及政治、经济、军事、外交等领域的需要而严加控制的一类信息。对那些被认为是敏感的但非机密的信息，也需要通过法律手段来加以保护以防止信息泄露或恶意的修改。事实上，敏感而非机密的政府信息也是不能通过未加保护的媒体进行传送的，而应该在开始发送之前或发送过程中进行加密保护。当然，这些保护措施的实施是要付出代价的。除此之外，在系统的方案设计、系统的管理和系统的保养方面还需要花费额外的时间和精力。令人感到忧虑的是，一些采用极强防护措施的部门信息，也面临着越来越严重的安全挑战。因为今天的信息系统不再是一个孤立的、完全与其他社会机构和部门隔离的系统，互联网络已经将无数个独立的系统连接到一起。在这种情况下，安全威胁对系统安全来说也呈现出许多新的形式和特点。

3. 产权及敏感信息

正像政府部门一样，商业部门也在信息处理策略方面发生着巨大的变化。在过去的一段时期里，人们通常将信息处理设备单独地放置在一个“黑屋”里，只有负责数据处理的工作人员才允许接触及使用计算机系统。随着信息处理方式的演化，出现了部门化的处理。在某些机构内部，可能有许多这样的“黑屋”。这些“黑屋”的分布，确定了企业内部各个机构之间的分界线。然而，即使信息处理的方式正向部门化方向发展，还仍然需要专门的工作人员来操作和使用企业的信息处理设备。将所有的计算机及其他信息设备放在“黑屋”中的优点之一是能够以相对简单的方式提供有效的安全性。这种安全性基本上是通过物理上的诸多防护措施来获得的。这些措施包括加强门锁管理，将所有的信息处理权赋予数据处理人员，并保证所有的数据处理人员在被雇佣之前是经过严格审查的。

今天，信息处理方式已经彻底地发生了改变。在企业或社会机构中，不再存在“黑屋”，这些“黑屋”的大门已经敞开，而且终端的信息处理能力得到了很大的提高。终端用户可以通过放置在桌面上的设备来对系统进行访问。各类软件工具的出现、快速的技术进步和完善，使系统能够很容易地相互连接到一起，极大方便了信息的互换和共享。但所有这些都给产权保护和敏感信息的保密工作带来了极大的困难和挑战。

1.3.2 信息安全的基本目标

确保信息系统在获取、存储、处理、集散和传输过程中保持信息完整、真实、可

用、不可否认和不被泄漏的特性是信息安全的最终目标。为此，需要在信息系统规划设计、实施、管理和操作使用的各个环节中，根据安全风险分布和程度，分别在OSI七层模型或TCP/IP四层模型的某一层或某几层上采用相应的互为补充的安全机制和安全服务措施，实现信息安全。

为表征信息系统的信息安全，一般采用机密性、完整性、可用性、可控制性和可审查性等项指标。其中保密性、完整性和可用性是针对信息内容的三项安全指标，可控制性和可审查性则是针对信息使用者的安全指标。

- 机密性(confidentiality)——信息内容对非授权使用者不可理解。
- 完整性(integrity)——信息内容在存储、处理、集散和传输过程中不被修改、删除、破坏或丢失。
- 可用性(availability)——合法用户能够访问并按权限使用信息资源。
- 可控制性(controllability)——对信息获取者的权限分割(授权)管理与信息交换双方对已发生操作进行确认的控制能力。
- 可审查性(accountability)——对系统内所发生的与安全有关的事件和操作进行记录和必要响应。

1.3.3 信息安全的基本内容

1. 实体安全

实体安全是指参与网络信息系统构成的计算机、存储体、网络设备、通信设备、安全设备、物理保障和环境以及应用软件的物理安全、逻辑安全和系统安全。

2. 连接安全

连接安全是指需要保护的本地和远程子网及其资源在与互联网络或其他网络处于Internet连接和intranet/extranet连接状态时的安全。这种安全体现为成功的TCP连接以及不因安全事故而中断连接或不与假冒站点发生连接。

3. 传输安全

传输安全是指信息在存取、转存、集散和通过本地网、公共网进行传输过程中的安全，主要体现为信息在传输中保持完整、真实和不被泄漏。

4. 应用安全

应用安全是指通过网络信息系统处理文档、作业、交易过程的安全，其中包括人机交互的鉴别、认证及操作确认的管理安全。

5. 用户安全

用户安全指对使用计算机和网络资源完成本职工作所需的系统准入和使用权

限的授权与管理。这类安全常常与用户和管理人员共同相关，有些场合甚至还与开发厂商有关。

1.3.4 信息安全的基础保障

为确保网络信息系统的安全，必须保证网络基础设施、安全设备、物理保障、运行环境、操作系统、应用平台等基础性安全符合和达到相应的标准要求，这对于规划、设计、实施安全方案以及设备的选型、采购都具有重要的现实意义。

1. 物理安全

(1) 网络信息基础设施（含安全设备）的机械与电气安全。

(2) 信息系统场地、物理保障和环境安全。

(3) 网络信息设备(含安全设备)的 EMPI 和 EMI 的辐射控制和防护符合与本系统保密等级相应的安全要求。

2. 逻辑安全

(1) 网络信息系统的安全规划(含子网划分、信息分类和用户群分类等)与安全设备的配置满足安全需求，具有防范大多数攻击和适应安全风险变化的抵御能力。

(2) 网络信息安全系统具有对恶意攻击和高技术犯罪的监视、跟踪和响应能力。其中的响应能力可理解为在监视、跟踪的同时发出报警，并及时调整安全策略直至在认为紧急情况下采取紧急安全措施(例如中断某些连接和暂时关闭网络信息系统)。

(3) 网络信息系统的安全策略应是完整、系统的，具有动态自适应能力。

(4) 网络信息安全设备(例如加密机、防火墙、鉴别服务器等)具有完善的自我保护措施和对被保护网络的保护能力。其中的自我保护措施应包括自我系统的不可进入以及在紧急情况下的紧急措施(例如加密设备中密钥的销毁机制)。

3. 系统安全

(1) 系统安全是指网络信息安全系统中各个安全元素运行的操作系统(OS)安全。操作系统安全可参照“可信计算机系统评估准则”的安全等级来加以评估。

(2) 应用平台(含数据库管理系统)安全。一般的应用平台软件都有相当程度的安全措施，但各个厂商采用的方法和措施并不相同，其中某些安全措施(例如未经国家批准的密码算法)是不可用的。另一点值得注意的是，安全措施的选择和配置是否得当十分重要。

(3) 软件功能模块最小化、最简化原则。

(4) 符合国家法律、法规并最大限度体现安全管理意志的安全策略。

1.3.5 网络安全服务

在网络通信中，主要的安全防护措施称作安全服务。有五种通用的安全服务，即鉴别服务、访问控制服务、机密性服务、数据完整性服务和不可否认服务。

为某一安全区域所制定的安全策略决定着在该区域或者在与其他区域进行通信时，应采用哪些安全服务。它也决定着在什么条件下可以使用某种安全服务，以及对此服务的任意一个变量参数施加了什么限制。

以下对五种安全服务进行详细分析。

1. 鉴别服务

鉴别服务提供了关于某个人或某个事物身份的保证。这意味着当某人(或某事)声称具有一个特别的身份(如某个特定的用户名称)时，鉴别服务将提供某种方法来证实这一声明是正确的。口令是一种提供鉴别的熟知方法。

鉴别是一种最重要的安全服务，因为在某种程度上所有其他安全服务均依赖于它。鉴别是对付假冒攻击的有效方法，此攻击能够直接导致破坏任一基本安全目标。

鉴别用于一个特殊的通信过程，即在此过程中需要提交人或物的身份。鉴别又可分为以下两种情况：

(1) 身份是由参与某次通信连接或会话的远端的一方提交的。这种情况下的鉴别服务被称作实体鉴别。

(2) 身份是由声称它是某个数据项的发送者的那个人或物所提交的，此身份连同数据项一起发送给接收者。这种情况下的鉴别服务被称作数据源鉴别。

注意：数据源鉴别可以用来鉴别某一数据项的真正的起源，而不管当前的通信活动是否涉及此数据源了，例如：一个数据项可能已经经过了许多系统转发，而这些系统的身份可能已被鉴别，也有可能尚未得到鉴别。

在达到基本的安全目标方面，两种类型的鉴别服务都具有重要的作用。数据源鉴别是保证部分完整性的目标的直接方法，即保证知道某个数据项的真正的起源。而实体鉴别则采用以下各种不同方式，以便达到安全目标。

① 作为访问控制服务的一种必要支持，访问控制服务的执行依赖于确知的身份(访问控制服务直接或间接地对达到保密性、完整性、可用性以及合法使用目标提供支持)。

② 作为提供数据源鉴别的一种可能方法(当它与数据完整性机制联合起来使用时)。

③ 作为对责任原则的一种直接支持，即在审计跟踪过程中做记录时，提供与某一活动相联系的确知身份。

实体鉴别的一个重要的特例是人员鉴别，即对处于网络结点上的某个人进行鉴别。出于两种原因，这需要特别地加以重视。第一个原因是在某个终结点上，不同的人员之间容易互相替代；第二个原因是在区分个别人方面可以采用一些特别的技术。

2. 访问控制服务

访问控制服务的目标是防止对任何资源（如计算资源、通信资源或信息资源）进行非授权的访问。所谓非授权访问包括未经授权的使用、泄露、修改、销毁以及颁发指令等。访问控制直接或间接支持保密性、完整性、可用性以及合法使用的安全目标，它对保密性、完整性和合法使用所起的作用是十分明显的。它对可用性所起的作用，取决于对以下几个方面进行有效的控制：

（1）谁能够颁发会影响网络可用性的网络管理指令。

（2）谁能够滥用资源以达到占用资源的目的。

（3）谁能够获得可以用于服务拒绝攻击的信息。

访问控制是实施授权的一种方法。它既是通信安全的问题，又是计算机（操作系统）安全的问题。然而，由于必须在系统之间传输访问控制信息，因此它对通信协议具有很高的要求。

访问控制的一般模型假定了一些主动的实体，称为发起者或主体。它们试图访问一些被动的资源，称作目标或客体。尽管“主体/客体”的术语在文献中得到了广泛的应用，但是由于在现代的计算机和通信技术中这一术语的滥用从而造成其意义的模糊不清，因此在本书中采用“发起者/目标”这个术语。

授权决策控制着哪些发起者在何种条件下，为了什么目的，可以访问哪些目标。这些决策以某一访问控制策略的形式反映出来。访问请求通过某个访问控制机制而得到过滤。

一个访问控制机制模型包括两个组成部分　实施功能和决策功能。OSI 的访问控制模型（ISO/IEC10181-3 标准）使用了这些概念，如图 1 4 所示。实际上，这两个组成部分的物理构成可能差别很大。通常，某些构成是将两个组成部分放在一起的。然而，在这些组成部分之间常常要传输访问控制信息，访问控制服务为这一通信提供了保证。

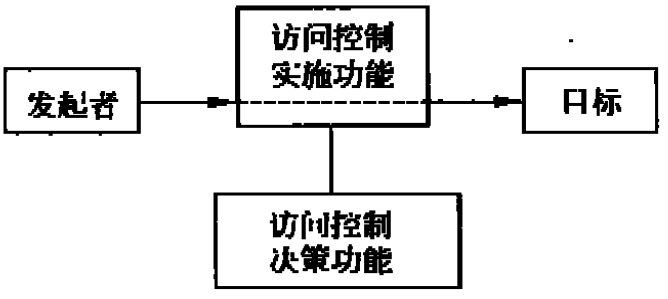

图 1-4　访问控制模型的基本组成

访问控制的另一个作用是保护敏感信息不经过有风险的环境传送。这涉及到对网络的业务流或消息实施路由的控制。访问控制服务的深入讨论依赖于两个因

素：访问控制策略的类型和各组成部分的物理构成。

3. 机密性服务

机密性服务就是保护信息不泄露或不暴露给那些未授权掌握这一信息的实体（例如人或组织）。在这里，我们要强调“信息”和“数据”的差别。信息是有意义的，而数据项只是一个比特串，用于存储和传输一条信息的编码表示。因此，在存储和通信中的某一数据项构成了某种形式的信息通道。然而，在计算机通信环境中，这不是惟一的信息通道。其他信息通道包括：

（1）观察某一数据项的存在与否（不管它的内容）。

（2）观察某一数据项的大小。

（3）观察某一数据项特性（如数据项内容、存在、大小等）的动态变化。

要达到保密的目标，必须防止信息经过这些信息通道被泄露出去。在计算机通信安全中，要区分两种类型的机密性服务：数据机密性服务使得攻击者想要从某个数据项中推出敏感信息是十分困难的，而业务流机密性服务使得攻击者想要通过观察网络的业务流来获得敏感信息也是十分困难的。

4. 数据完整性服务

数据完整性服务（或简称为完整性服务），是对下面的安全威胁所采取的一类防护措施，这种威胁就是以某种违反安全策略的方式，改变数据的价值和存在。改变数据的价值是指对数据进行修改和重新排序，而改变数据的存在则意味着新增或删除它。

依赖于应用环境，以上任何一种威胁都有可能导致严重的后果。

与机密性服务一样，数据完整性服务的一个重要特性是它的具体分类，即对什么样的数据采用什么样的完整性服务。有三种重要的类型：第一，连接完整性服务，它是对某个连接上传输的所有数据进行完整性检验；第二，无连接完整性服务，它是对构成一个无连接数据项的所有数据继续完整性检验；第三，区域完整性服务，它仅对某个数据单元中所指定的区域进行完整性检验。

所有数据完整性服务都能够对付新增或修改数据的企图，但不一定都能够对付复制和删除数据。复制是由重放攻击所造成的。无连接和区域完整性服务主要是为了检验对部分数据的修改，也许不能检测到重放攻击。连接完整性服务要求能够防止在某一连接内重放数据，但它仍然存在着脆弱之处，因为某个侵入者可能重放一个完整的连接。检测对某些数据的删除至少与检测重放攻击一样难，因此在说明任意一种数据完整性服务时要特别注意。

一个连接完整性服务也许会提供“恢复”的选择，这种情况下，当在某个连接内检测到完整性破坏的时候，该服务将试图“恢复”数据。例如，通信将返回到某一检测点并重新开始。

5. 不可否认服务

不可否认服务与其他安全服务有着本质上的区别。它的主要目的是保护通信用户免遭来自于系统其他合法用户的威胁，而不是来自于未知攻击者的威胁。“否认”最早被定义成一种威胁，它是指参与某次通信交换的一方事后虚伪地否认曾经发生过本次交换和/或交换过的内容。不可否认是用来对付此种威胁的。

术语“不可否认”本身不十分贴切。事实上，这种服务不能消除服务否认。也就是说，它并不能防止一方否认另一方对某件已发生的事情所作出的声明。它所能够做的只是提供无可辩驳的证据，以支持快速解决这种纠纷。

不可否认服务的出发点并不是仅仅因为在通信各方之间存在着相互欺骗的可能性。它也反映了一个现实，即没有任何一个系统是完备的。

首先考虑在有纸商业活动中出现的某些问题。纸张文件(例如合同、报价单、投标书、订单、货运清单、支票等)在商业活动中发挥着巨大的作用。然而，在对它们进行处理的过程中会发生许多问题，例如

(1) 邮递过程中的文件丢失。

(2) 收信者在对收到的文件作出处理之前丢失。

(3) 文件是由某个没有得到足够授权的人产生的。

(4) 在某一机构内部或在机构间的文件传递过程中被收买。

(5) 文件在某一机构内部或在机构之间传递时被欺骗性地修改。

(6) 伪造文件。

(7) 有关某个文件有争议的签署日期。

为了系统地处理以上所出现的问题，采用了许多不同的机制，诸如签名、匿签名、公证签名、收据、邮戳以及挂号邮件等。

在进行电子化商业活动时，情况与此类似。在某些方面，电子作业所出现的问题比纸张更难以解决，因为在处理文件时，常常涉及更多的人。然而，在某些方面，电子作业所出现的问题反而更容易解决。这是由于采用了较为复杂的技术——数字签名的结果。

原则上讲，不可否认服务适用于任何一种能够影响两方或更多方的事件。通常，这些纠纷涉及某一特定的事件是否发生了，是什么时候发生的，有哪几方参与了这一事件，以及与此事件有关的信息是什么。如果只考虑数据网络环境，服务否认分为两种不同的情况。

(1) 源点否认。这是一种关于“某特定的一方是否产生了某一特定的数据项”的纠纷和/或关于产生时间的纠纷。

(2) 递送否认。这是一种关于“某一特定的数据项是否被递送给某特定一方”的纠纷和/或关于递送时间的纠纷。

这两种服务否认情况导致了两种不同的不可否认服务。

1.4 安全威胁

所谓安全威胁，是指某个人、物、事件或概念对某一资源的机密性、完整性、可用性或合法使用所造成的危险。某种攻击就是某种威胁的具体实现。

安全威胁有时可以被分为故意的(如黑客渗透)和偶然的(如信息被发往错误的地址)。故意的威胁又可以进一步分为被动的和主动的。被动威胁包括只对信息进行监听(如搭线窃听)，而不对其进行修改。主动威胁包括对信息进行故意的修改(如改动某次金融会话过程中货币的数量)。总的来说，被动攻击比主动攻击更容易以更少的花费付诸工程实现。

目前还没有统一的方法来对各种威胁加以区别和进行分类，也难以搞清各种威胁之间的相互联系。不同威胁的存在及其重要性是随环境的变化而变化的。下面对主要的可实现的威胁进行分类。

1.4.1 黑客及恶意攻击者的攻击

利用 TCP/IP 协议的安全脆弱性，网络黑客以及恶意攻击者可从多方面对网络信息系统实施入侵、攻击。

(1) 伪造和更改源 IP 地址，从外部假冒内部某一主机非法访问内部网络信息资源或与之进行交易。

(2) 利用 IP 协议的源路由选项旁通访问控制机制实现违反安全策略的通信与访问。

(3) 利用 TCP 连接必须经“三次握手”机制才能完成的特点，向目标主机发送伪造的来自不可达主机的 TCP SYN 连接请求包，以此淹没目标主机。

(4) 利用 TCP/IP 协议使用可猜测或可计算伪随机初始序列号的弱点，实现对攻击目标的连接，如这种攻击与路由攻击结合起来可导致整个信息系统的运行混乱和安全崩溃。

(5) 利用 TCP/IP 协议在动态更新路由消息时缺乏对路由消息进行鉴别的弱点，将伪造的路由消息发布给攻击目标，引起路由混乱导致路由机制被破坏。

(6) 利用 TCP/IP 协议的安全脆弱性实施如 E-mail bombing，TCP SYN flooding 和 ICMP echo floods 等类攻击，导致不能实施正常的网络服务直至信息系统瘫痪。

(7) 利用 IP 隧道技术将恶意代码和病毒软件等埋藏在隧道中加以传输、实施特洛伊木马攻击。

(8) 利用 ICMP 的 ping 命令获得关于网络配置和可达性信息，为进一步的攻击收集情报。

(9) 利用 ICMP 目的不可达消息实现点对点应用的拒绝服务攻击。

(10) 利用一些操作系统不能处理相同源、目的 IP 地址的 IP 数据包的缺陷，伪造具有相同源、目的地址的 IP 包攻击目标主机，导致目标主机锁定其 TCP/IP 协议栈甚至系统崩溃。

(11) 使用 IP spoofing 方法向 UDP 的 chain 和 echo 服务端口发送大量伪造的源 IP 地址数据包，导致端口淹没，拒绝正常网络服务。

1.4.2 对网络系统的攻击

利用网络协议数据流在网上进行明文传输的弱点，攻击者可使用 sniffer，snoop 等网络监控程序或网络分析仪，截获在网上传输的含有会话内容、用户口令和用户账号等数据包，为日后的攻击准备详细、准确的资料。而 TCP/IP 协议本身恰恰不能阻止网上客户利用这一方法来捕获数据包。

1.4.3 利用扫描工具发现安全弱点并制定攻击策略

一些网络(安全)扫描工具软件，如 NSS，Strobe，SATAN，Jakal 等，能够快速地对 TCP 端口、应用程序、主机、子网、服务器(群)等进行扫描，并发现其中的安全缺陷。这些工具软件的正面应用是安全管理员用于检测系统的安全脆弱性和漏洞，其负面应用则是黑客甚至恶意犯罪人用于对信息系统进行攻击而搜集网络信息系统情报。

1.4.4 利用明文传输和电磁泄漏直接获取所需信息资源

这类攻击采用搭线窃听和辐射侦听等物理方法，并使用相应的分析仪器，这种犯罪行为往往可在被侵害者并不知情的情况下实现攻击。很显然，这对于在网上明文传输敏感和机密信息是非常危险的事情。

1.4.5 来自内部的恶意攻击以及内外勾结进行的网络攻击

这一类攻击的特点是与内部工作人员和管理不严密有关，而且攻击的成功率高，破坏力强。这类攻击除利用上述安全弱点和漏洞外，攻击者通常已掌握了网络信息系统的某些资源使用权、支配权并具有某种程度的可信任度。因而这种攻击同时利用了技术和管理上的弱点和漏洞。

1.4.6 病毒

所谓病毒，是指一段执行的程序代码，通过对其他程序进行修改，可以“感染”

这些程序使它们成为含有该病毒程序的一个拷贝。一种病毒通常且有两种功能：一种是对其他程序产生“感染”；另一种或者是引发损坏功能，或者是一种植入攻击的能力。

病毒是软件、计算机和网络系统的最大威胁。网络化特别是 Internet 的发展，大大地加速了病毒的传播。迄今为止，仅仅 DOS 系统的病毒就达 7000 多种，而且几乎每天都有新的计算机病毒出现。这些病毒的潜在破坏力极大，不仅已成为一种新的恐怖手段，而且正在演变成为军事电子战中的一种新式进攻性武器。

尽管在“开放”环境中要完全消除病毒几乎是不可能的，但是它们的传播可以通过杀毒软件和媒体管理等手段而得到有效的控制。早期的杀毒软件多采用特征值扫描法，从程序中提取特征值识别，而后加以清除。这类软件安装简单、成本较低，但随着病毒种类的增加，难以及时更新，且无法克服漏报和误报，更难以对付新型的变形性病毒。面对病毒猖獗的新趋势，需要建立更有效的病毒防范技术措施。这些新的技术措施能从病毒传染的可能途径入手，不受病毒种类和变形的限制，能够防、杀结合，甚至能够安全运行受病毒感染的程序，保证系统的高效、正常运行。

在网络环境下，如何联防和共享抗病毒资源的技术研究也是一个重要的研究课题。

第2章

网络安全标准、需求定义及配置

曾有人描绘什么是安全，那就是将有价值的东西锁进保管室，而保管室由钢层、坚硬的混凝土和敏感的报警系统组成，并且有荷枪实弹的守卫。但为了安全的目的而把计算机锁起来，则不能访问网络资源，也不可能满足信息时代对信息的需求。

2.1 安全标准

网络安全已引起越来越多的国家、政府及特殊部门的重视，它们都纷纷根据本国的国情或行业的特点制定相关的安全标准。以下简要介绍美国和我国的一些安全标准。

2.1.1 可信任计算机标准评估准则

根据美国国防部开发的计算机安全标准，即可信任计算机标准评估准则(trusted computer standards evaluation criteria)——橘皮书(Orange Book)的内容，一些级别被用于保护硬件、软件和存储的信息免受攻击。这些级别均描述了不同类型的物理安全、用户身份验证、操作系统软件的可信任性和用户应用程序。这些标准也限制了什么类型的系统可以连接到用户的系统。

橘皮书成为美国国防部的标准以来，一直是评估多用户主机和小型操作系统的主要方法。其他系统，如数据库和网络，也一直是通过橘皮书的解释来进行评估的。

橘皮书将计算机安全等级划分为 D1 级、C1 级、C2 级、B1 级、B2 级、B3 级及 A 级。其中 D1 级的安全级别最低，A 级的安全级别最高。

2.1.2 我国的计算机信息安全标准

我国信息安全权威机构根据我国的计算机发展水平及国情，制定了一系列符合中国国情的信息安全技术标准[1]。

1. 计算机信息系统安全保护等级划分标准

该标准(1999 年 9 月 13 日发布)规定了计算机系统安全保护能力的五个等级,即

第一级:用户自主保护级;

第二级:系统审计保护级;

第三级:安全标记保护级;

第四级:结构化保护级;

第五极:访问验证级。

该标准适用计算机信息系统安全保护技术能力等级的划分。计算机信息系统安全保护能力随着安全保护等级的增高,逐渐增强。

2. 计算机信息系统安全专用产品分类原则

该标准规定了计算机信息系统安全专用产品分类原则。适用于保护计算机信息系统安全专用产品,涉及实体安全、运行安全和信息安全三个方面。

为了保证分类体系的科学性,需遵循如下原则:

- 适度的前瞻性
- 标准的可操作性
- 分类体系的完整性
- 与传统的兼容性
- 按产品功能分类

2.2 intranet 安全性

intranet 是专用网络,与 Web 的结构相对应。它使用了 TCP/IP 协议簇,这一协议簇使得不同的计算机系统或网络通过公用通信基础设施在一个组织内互相通信。它改善了组织内部的通信,组织内部的用户在 PC 机上使用 Web 浏览器就可访问数据库、电子邮件等服务器,服务器可以位于组织内部网络的任何地点。一般来说,这些 intranet 也连接 Internet,因此组织用户也可以访问由 Internet 提供的大量信息。

intranet 的安全性可概括如下:拒绝未经授权的物理的或电子的闯入、操作或袭击,并保证 intranet 和所传信息端到端的完整性。它要能抗拒各种类型的破坏,包括电子袭击、物理袭击、人为错误和自然灾害等。

当政府、专门机构和一般公众日益依赖信息服务时,提供和传送信息服务的 intranet 的可靠性和安全性也日益重要。这些 intranet 必须能抗拒天灾而不失效,在各种威胁和不利条件下也不会丧失服务能力。

2.2.1　intranet 安全的趋势及问题

随着信息产业技术的迅猛发展，以及个人计算机产品数量的增长，特殊的 IT 系统及用于分布处理和应用任务的其他计算设备也快速发展。

基于分布处理的特点，intranet 更多地依赖于通信线路、通信服务。由于使用了通信设备，使计算机和用户指定的应用程序综合成一体，充分利用了分布式计算机资源，提高了效率。

计算机系统存储和处理了大部分保密的或专有的数据。这些信息通过专用或公用通信线路或组织的 intranet 网提供远程访问使用。先进的计算机技术构建了复杂的 IT 环境，很多用户可远程访问可用的系统。同时，那里有很多不同的应用程序、作业、过程正在执行。

一般情况下，用户关心的是计算机系统是否方便使用。换言之，用户不可能详细地了解其内部运行规则，因为很多软件产品对用户来说是“黑匣子”。这样，在运行任何系统(PC 除外)时，都包括了很多部件的内部相互作用、控制数据和控制的思路，这些都很难跟踪分析或修改。

研究一下全国的 intranet 安全问题，使用专用或公用类型通信线路的情况很多。如果使用公用通信线路，数据的传输完全经由供应商的媒体。此时，若使用分组交换，在 intranet 上各信息块经过不同的通路。这是先进的方式，然而，OSI 机构一般认为这种方式是最脆弱的计算机系统。

intranet 的安全主要是各种操作问题，包括可能对系统造成破坏的所有威胁。这些问题有

(1) 由于意外动作和操作的威胁，破坏了操作系统的正常状态，这可能被认为是工作程序或是错误。

(2) 由于有意的非法动作或操作，修改、破坏或暴露计算机资源。

2.2.2　设计和实现 intranet 的安全策略

多数组织内部通过 intranet 相连，信息从主机自由地流向小型机，从 intranet 服务器流向 PC 工作站。当前各种 intranet 环境都在努力提高效率，使得信息交流更容易。也就是说，intranet 在帮助人们工作起来更快、更好。

但是，应当注意的是，虽然 intranet 能在企业范围提高效率，但有时也会给用户带来麻烦，如软件有时工作，有时不工作。intranet 很庞大，但也很脆弱。intranet 是巨大的信息宝库，这些数据会遭到盗窃或引来不速之客。整个组织都应安全可靠，必须牢记一个新的商业准则：intranet 的安全性是一个网络化单位的命根子[2]。

2.2.3 intranet 安全标准

每一个组织(如商业公司、会计事务所或政策机构)都要处理一些分布计算。在这种情况下,安全管理人员要在整个 intranet 上使用类似主机的安全标准或 intranet 安全标准,包括现有系统和正在设计的系统。

如果措施得当,可以设计一个经济合理的 intranet 安全方案。该方案可给 IT 经理或安全管理员提供防止泄露的围墙和控制,这是任何成功企业的关键环节。正确实行的安全措施可以更容易地管理那些自由的计算机。特别是 PC 工作站,这种 PC 工作站很容易使用任何计算机环境下的各种插卡。

主机硬件供应商早已注意到信息安全的重要性,因此提供了内置安全机制——由安全核心提供访问控制。在这些机制上,主机软件开发商提供外部应用安全。这样,安全管理员更易于控制,并为工作带来方便,如审核工作。

标准化是控制 PC 的方法之一。主机是单一的信息源,其数据的检索和存储都在专用文件中,信息定位和更新都很容易。在有多台 PC 时,情况正好相反。每一 PC 文件的命名规范和目录树结构可以是 PC 用户所独有。相同的信息可以存储于数个不同的 PC,并在完全不同的硬盘位置上。用户拥有自主权,但增加了信息定位和更新的难度。

安全软件的开发者在设计未来系统或开发现有系统时,有如下 4 个步骤(或准则)可以保证一个安全和可管理的计算环境(但不是绝对的)。

第一步:使自己周围安全。

这是很明显的一步。要从内部保护好大楼和机器,在员工中增强办公楼的安全意识。

第二步:制定一个风险评估和进入保密点的规定。

一些组织对 PC 进行风险评估以确定哪些机器是薄弱环节。这些信息是有价值的,但其结论经常是所有 PC 都有弱点,都需要保护。一台 PC 今天没有保密信息,但明天可能就会有。任何与 intranet 或主机相连的机器都可能访问敏感的信息。特别要注意的是:笔记本电脑是最脆弱的。笔记本电脑是公共场所被盗的对象,它经常含有保密的客户信息。即使不能完全防止被盗,但至少应防止泄露被盗计算机上的数据。

第三步:综合安全和跨多平台的连接性。

在软件和硬件方面,相容性是个大问题。为了实现真正的综合连接,需要既易操作又可控制的跨平台注册过程。多数情况是多平台环境需要多口令。某些组织需要多达十余个 ID 和口令组合,才能访问工作站、intranet 和主机。如此麻烦地使用口令,就蕴涵着潜在的安全风险。

这一难题的理想解决方案是一次注册的方法,即只要使用 ID 和口令注册一

次，就可访问任何平台，而不限于特定的 intranet。否则，如果用户必须记忆十余组口令，可能会用笔记下口令，并放在较显眼的地方以便查看。

一个真正有效的 PC 安全程序可看作六层金字塔，如图 2-1 所示。第一步是组织的政策和步骤。最后一步是审核 intranet 的访问和活动。各层都很重要，但用户认证和权限控制是关键，如果未经授权的用户能够伪装成授权用户并得以访问 intranet 或敏感数据，那么其他安全控制都将无用。

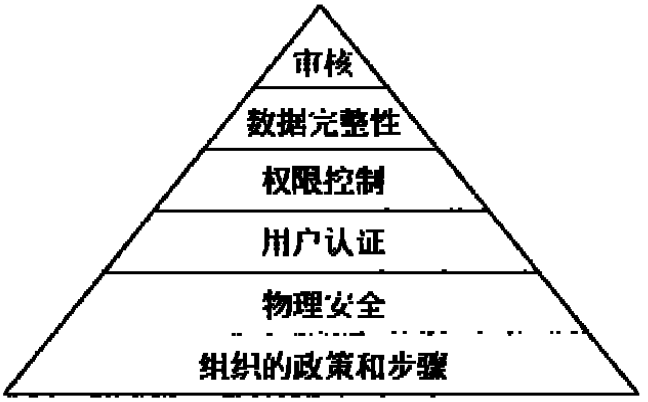

图 2-1　有效的 PC 安全方案

第四步：提供集中管理和审计控制。

由于在组织内部经常要添加或删除某些用户、修改安全标准、更新软件等，安全维护工作永无止境。对安全进行集中式管理已成为安全管理的基本方法。集中管理的优点是修改可以一次完成，能够及时管理组织范围内的所有工作站。这种方法的关键是基于 intranet 环境，很多工作站连接到一个服务器，通过服务器实行集中管理。

2.3　局部安全问题

除了其他组织开发的安全产品或规则之外，必须能够解决那些局部的，或仅限于某个组织或组织内部某个部门的安全问题，包括采取什么安全策略和如何进行口令控制。

2.3.1　安全策略

开发反映某个站点安全性的策略时，有两个不同的观点。这两个主要的观点形成了所有其他与安全有关的策略的基础，并且控制着实现它们的过程。

“没有明确允许的就是禁止的”，这是研究安全问题的第一个观点。这意味着某个组织提供了一个明确的和记录在案的服务集合，所有其他的都在禁止之列。例如，如果决定允许匿名 FTP 传输到一台特殊的机器或从其传输出来，但是拒绝 telnet 服务，就明确地用文档说明支持 FTP，拒绝 telnet。

另外一种观点是“没有明确禁止的就是允许的”，这意味着，除非明确指出一种服务不可用，否则所有服务都是可用的。例如，如果没有明确说明禁止对一台给定主机的 telnet 会话，那么它就是允许的(但是，通过不允许对该 TCP/IP 端口的连

接，仍然可以禁止该服务）。

不管遵循哪种观点，定义一种安全策略的出发点是：在一个组织的安全可能受到损害的情况下，必须决定应当采取什么行动。这种策略也描述了哪些行动是可以的，哪些不是。

2.3.2 口令控制

UNIX 操作系统防卫非授权访问系统的第一道防线是/etc/password 文件。但它经常是最薄弱的环节。

口令文件的许可权限是只读的，这意味着无人能够编辑该文件。类似地，影像口令文件和 TCB 中的文件一般也是只读的。

这些文件中的口令信息可通过 password 命令来修改。password 命令的许可权限包括 SUID(set user ID)位，使用户像程序的拥有者一样执行该程序。由于 SUID 位的应用，即使用户无权编辑该文件，也能够改变口令。

1. 影像口令文件

不包含来自 Secure Ware 的高级安全选择的 UNIX 版本可支持影像口令文件。当在口令域中看到字符 x 时，用户实际的口令就存储在影像口令文件/etc/shadow 中。与/etc/password 文件不同，影像口令只有通过根才是可读的，例如：

```
# ls-l/etc/shadow
-r———    1root   auth   861 Oct24 11:46 /ect/shadow
#
```

文件/etc/shadow 是命令 pwconv 在 SCO 和 SVR4 系统上创建的。只有超级用户才能够创建影像口令文件。SCO 系统中/etc/password 中的信息和被保护的口令数据库用于创建影像口令文件。在 SVR4 系统中，使用/etc/password 中的信息。

使用影像口令文件的主要优点是，它将加密口令放在一个普通用户无法访问的文件中，因而减少了破坏者窃取加密口令信息的机会。

2. 拨号口令文件

直接在 UNIX 系统上支持拨号访问的问题是有争议的。许多人仍然这么做，但一般来说它会引起某些问题。允许破坏者“侵入”系统可能会导致系统的损害。许多 UNIX 系统提供了匿名 UUCP 访问，这会导致口令文件的丢失，而对组织不利。

在 UNIX 系统上提供拨号访问的另一种方法是，通过一台支持身份验证的终端服务器来提供访问。在这种方式下，用户在允许网络访问之前，必须由终端服务

器证实为合法。因为没有口令文件可从终端服务器上获取，所以攻击终端服务器的任务变得更加困难。

在必须提供拨号访问 UNIX 服务器的情况下，可以采取一些措施来更好地保护自己免受非授权网络访问之害。

遗憾的是，并不是所有 UNIX 版本都具有在串行端口线路上安装附加口令的能力，但在基于 SCO 的系统中可以很容易实现。对这些串行线路的拨号口令保护是通过/etc/dialups 和/etc/d_passwd 两个文件来控制的。

3. 组文件

文件/etc/group 用来控制访问那些不是用户所拥有的文件。许可权限的工作步骤是这样的：如果不是文件的拥有者，那么就检查用户所属的组，查看用户是否是拥有该文件的组的成员。组员列表存储在/etc/group 中。

组文件是不使用口令的，也没有容易的机制在文件中设置口令。如果用户试图切换到不是成员的组，就会被提示输入口令。

4. 口令生命期和控制

许多 UNIX 版本都提供了口令生命期(password aging)，该机制控制用户在加密口令后何时可以通过在口令文件中插入一个值来修改他们的口令。该值定义了用户修改口令之前必须经过的最小时间间隔和口令有效期满之前可以经历的最大时间间隔。

上述描述用数轴来表示将会更加清楚，如图 2-2 所示。

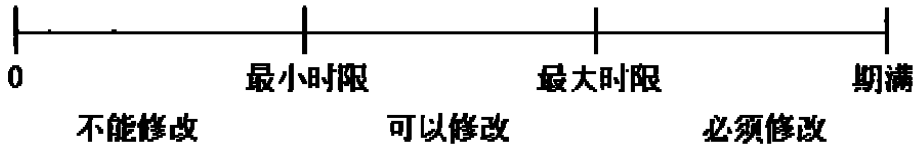

图 2-2　口令生命周期

口令生命期控制信息与加密口令存储在一起，以一系列可打印字符的形式出现。控制包含在口令之后，用逗号分开。通常，逗号后面的字符表示下述信息：

- 口令有效的最大生命周期数。
- 用户可以再次改变其口令之前必须经过的最小生命周期数。
- 口令最近改变的时间。

表 2-1 定义了口令生命周期的值。

表 2-1　口令生命周期值

字　符	0	2	4	6	8	/	1	3	5	7	9
口令生命周期值(单位：周)	2	4	6	8	10	1	3	5	7	9	11

2.4 安全需求定义

没有任何两个网络的安全需求是相同的。例如，一个银行要比服装零售店更关心网络入侵。随着安全等级的不同，相应的安全类型也不同，如在一个大学的计算实验室，管理员关心的是资源不被攻击和不被锁定为攻击目标。

要花多大的精力在网络安全上，需要知道网络中数据的价值、所在组织的公开程度或知名度，以及服务丢失会导致多大的损失。用户也应该考虑到采取的安全措施能使网络抵御多大的破坏。

类似的组织有类似的安全需求，读者可以用下面列出的组织类型来对比具体的网络安全需求。

2.4.1 家庭办公室

家庭办公室是最简单的连接因特网的网络。通常，家庭办公室在一个小局域网上以对等方式连接两至三台计算机。这些网络中每个计算机都有一个可以拨号到因特网的调制解调器，还有一台用户随时需要连接因特网时用来拨号到因特网的计算机。有时拨号到因特网的设备是一个很便宜的网络集线器和路由器设备。

典型的家庭办公室并没有财力去购买一台计算机专门用作网络防火墙。他们是依靠因特网服务供应商(ISP)来保证不受黑客攻击的。但是这并非非常有效的办法，因为各个 ISP 的能力和工作负载都各不相同。ISP 决不会为用户的具体需要定制安全——他们只提供“以点带面”的解决方案。这必然是松散的，因为不知道他们的客户如何使用因特网。

防火墙对家庭用户来讲是非常昂贵的。小型的没有防火墙的网络可以(也应该)安装当前操作系统的补丁程序来保护计算机不受 TCP/IP 攻击，如死亡之 ping、波段外攻击(out of band)。应该对那些连接到因特网的计算机关闭文件共享(另外，对于更高级的操作系统，如 Windows NT 和 UNIX，那些服务应与连接到因特网的网络路由器和调制解调器断开)。任何无用的服务都应该关闭，这样网络入侵者就不能利用它们了。

家庭办公室不被经常攻击的原因是因为它们的网络连接是间断性的。大多数黑客都使用随机扫描来锁定目标，这样那些大部分时间都不连接到因特网的计算机也就不会成为好的目标。对家庭办公室网络最大的威胁来自那些知道这些网络和出于特殊原因要攻击它的那些人。他们往往是心怀怨恨的雇员或前雇员、业务竞争对手或那些别有企图的人。

2.4.2 小商业公司

小商业公司网络一般带有十几台计算机，通常有一个专用计算机用作文件和打印服务，在大多数情况下都有一个专门到因特网的连接。这些小商业公司基本上没有防火墙，不过它们都应该有。由于网络入侵可能导致的数据丢失会造成公司生产效率下降，这种情况下，购买防火墙是值得的。

但是，在小的商业公司中并不需要在安全上做更多的工作，基本上没有小的商业公司花力气为它们的网络安全做任何小的防护，因为成本/效益分析表明通常一般的安全也就足够了。例如，考虑一个加热和空调公司，它虽然有连接到因特网的小网络，但是公司的计算机几乎没有什么有价值的东西值得随机的黑客和竞争对手充当商业间谍。网络的用户也希望对他们访问因特网的限制尽可能的少，这样就更难判定合适的安全策略了。

提示：小商业公司的网络管理员应该考虑到网络安全，但是合适的防火墙策略是默认使用的，并在防火墙上明确拒绝那些认为是危险的包、协议和服务。

2.4.3 专业公司

像小商业公司一样，小的保密行业，如法律公司、财务公司、精神病治疗行业或专家门诊，可能有带有间断的或永久的因特网连接的由七八台计算机组成的一个小局域网。这些小的保密行业要比典型的小商业公司更需要安全，因为这些行业的计算机中包含一些保密的信息，这些信息会引来因特网上网入侵者的特定攻击。

提示：因为这些信息的敏感性和这一类网络对黑客的吸引力，小的保密行业的网络管理员应该使用警惕级的(caution)安全(除非规则特别地指定允许，默认状态下要拒绝包、协议和服务)或严格级的(strictness)安全(根本不对IP数据包进行路由，并只允许代理的网络通信通过防火墙)。

2.4.4 制造商

对一般的黑客来讲，一个带有几十到上百台计算机的大网络更容易吸引他们，尤其是如果网络有昂贵的网络设备和连接到其他大型网络的VPN(虚拟专用网络)连接时。这种类型的网络是中到大型公司使用的网络。而正是大公司网络特定的大小和复杂度使它们更容易受到黑客的攻击。

大公司网络也容易成为工业间谍特定的攻击或反竞争组织的拒绝服务攻击的目标。因为这些公司比那些小一些的公司有更多雇员(和前雇员)，这些公司也更可能受到内部人员(或前雇员)的攻击。

公共知名度较高的公司(如Sony，Microsoft，Pepsi或Disney等)与那些知名

度较低的公司相比，会有更多的黑客为得到吹嘘的资本而试图入侵到它们的网络中。

提示：大公司的网络管理员需要特别注意使他们的网络免受攻击，因为大型网络被攻击带来的损失要比那些小网络大得多。这些类型的网络最适合使用警惕级的(caution)安全(默认状态下不使用路由功能)或严格级的(strictness)安全(根本就不使用路由功能)。

2.4.5 政府机关

政府机关使用的网络具有许多公司网络的特点(通常也是大的、有多种功能的硬件设备、并提供到其他网络的连接)，并且由于它们的政治特点，政府机关网络也是某些人感兴趣的目标。一些机关如民政部门基本上不会受到攻击。但是另一方面，FBI(联邦调查局)却一直受到那些他们要捕捉的黑客的长期攻击。通常，组织的知名度越高，就越容易引起黑客的攻击。

提示：根据组织的知名度和敏感性，政府机关的网络管理员应该使用严格级的(strictness)安全(不使用路由功能)和超常级的(transcendency)安全(防备任何最小形式的因特网威胁，而不考虑对自己网络的约束)。特别注意的是，要保证Web站点的安全，以防黑客可以轻易地给用户带来麻烦和散布他们自己的言论。

2.4.6 大学

大学网络管理员遇到的问题令人头疼，既要保护网络不受外部攻击，也要保护网络不受内部攻击。新学生的定期涌入保证了“黑客”成员的连续性，他们总是不断变化网络攻击手段。虽然学生必须要有计算机和访问因特网的路径，但是学校的行政机构也需要一个安全的网络环境。

大多数学校通过使用两个(或更多)分离的网络来解决这个问题，每个网络有不同的安全策略并严格控制网络之间的访问权限。对学生网络的公共访问有一个非常严格的策略，并且会受到对病毒、特洛伊木马、改动系统设置等的检查。

大学网络的管理员通常使用警惕级的(caution)安全(默认状态下不使用路由功能)或严格级的(strictness)安全(只使用代理，不使用路由功能)来管理学校行政机构的网络。网络管理员也用相当开放的措施管理学生网络，在特别注意保持网络分离的同时，对学生网络状态的管理不是很严格。

2.4.7 因特网服务供应商

ISP(因特网服务供应商)网络管理员面对的问题同大学网络管理员面对的问题类似。ISP网络管理员必须防止来自因特网和内部黑客的攻击，保证用户之间

不进行相互攻击的同时，也要保护他们不受外部攻击。另外，客户们也希望有对因特网的完全的访问权限——希望由自己来决定使用哪些协议和服务。

提示：大多数 ISP 在警惕级的(caution)安全和严格级的(strictness)安全配置中使用防火墙来保护他们的网络服务器(DNS 服务器、邮件服务器等)，同时在一个更开放的配置(使用默认权限)中使用包过滤器来阻断那些最明显的因特网攻击(死亡之 ping、源路由攻击、假冒的 IP 和 ICMP 包等)，不让它们到达他们的客户。对于客户的请求，许多 ISP 将针对每个客户对客户连接使用更严格的安全策略。

2.4.8 在线商务公司

对于大多数的公司来讲，因特网连接都是一个很方便的工具。而对于在线商务公司来讲，可靠的连接操作和在其上运行的服务更是公司的生命线。例如过去通过因特网得到书籍订单的书店可以承受他们的 Web 站点偶尔断开，但是现在在因特网上传输所有业务的网上书店却不能忍受。

另外，为了防止拒绝服务攻击，在线商务网络的管理员必须警惕更直接的威胁——客户信息的盗用者，包括金融事务数据(如信用卡号)。客户希望他们为在线商务公司提供的数据应该保密，如果泄露了这些数据将会产生严重的安全问题，若是发现公司忽视了它的安全防护，还会产生法律纠纷。

提示：因为服务拒绝和数据窃贼攻击会导致严重的后果，一个聪明的在线商务公司的网络管理员会为公司的因特网服务器使用严格级的(strictness)防火墙安全策略(只使用代理，不使用路由功能)。如果行政管理人员因业务活动需要而能自由地访问因特网，这些业务活动又不是关键业务，管理员可能会为分离的行政管理网络建立许可权限更宽的策略(警惕级和关注级)。

2.4.9 金融机构

通常，如果有商业价值的东西在网络上流动，管理员就要特别注意谁可以访问网络和他们访问的目的。价值越大，对访问权限的限制也就越严。因此，银行和信用机构从来不允许从因特网直接访问他们的金融网络(那些直接将钱从一个账号转到另一个账号的网络)，也不允许从因特网访问他们执行办公任务的内部网络。

金融机构的增长趋势使得客户可以通过因特网使用 Web 浏览器执行在线的储蓄。当然，这意味着某些类型的 Web 服务器必须既连接到因特网也要连接到受保护的金融计算机上。如果一个人为一个金融机构工作，就应该保证使用所有可以使用的方法来确保 Web 服务器的安全并保护客户的账户信息。

提示：那些允许以专用方式访问因特网的银行系统应该使用严格级的(strictness)安全(只使用代理进行访问)或超常级的(transcendency)安全(用专用的网络

软件仔细定制的)策略来保护它们的计算机。

2.4.10 医院

医院网络与上面所有类型的网络都不同,如果计算机停止工作可能会使病人失去生命。因为这个原因,连接医用设备的医院网络一般不会以任何形式连接到因特网上。然而,在研究试验室的网络通常是与因特网紧密的或不大受限制的连接,因为科学家在容易交换信息的开放信息环境中能够更好地工作。

提示:像银行和大学的网络一样,医院的网络管理员也将网络分成几个独立的网段。性命攸关的设备干脆就不连接到因特网上。对行政网络采用严格级的(strictness)安全(毕竟他们还要使用电子邮件)策略,而研究局域网通常使用警惕级的(caution)和关注级的(concern)安全策略。

2.4.11 军事部门

军方网络与医院网络一样,当安全遭到破坏时会作出快速反应。黑客或间谍机构通常有特殊的军事目标,或者对这些目标别有企图。但是也不是所有的军方网络都有相同的安全需求——管理购货、存储和分发机器工具合同的民用承包人就同海军战争学校的科研网络有着不同的安全需要,而这两种网络又与情报机关网络没法比,它是安全专家努力构造的实时战斗信息系统,这个信息系统可由士兵在战时使用。

提示:军方网络的管理员必须使局域网的防火墙策略与在其上执行的网络类型相匹配。大多数网络都至少有警惕级的(strictness)安全(只使用代理,不使用路由功能)策略,而重要的信息系统将完全同因特网分开。

2.4.12 情报机关

一些组织在保护他们网络时有双重目的,就是在保护自己网络的同时要发现破坏别人网络防火墙的方法。应该相信,这些组织的专家都有档案和利用任何一个操作系统的程序错误或协议的缺点进行攻击的计划。但是知道安全漏洞和填补安全漏洞是两个不同的问题,而且有时候黑客的攻击可能难以预测。

提示:这种类型网络的管理员使用的安全策略要比严格级的(strictness)安全策略还要高级——如果这些安全专家使用任何一种商业防火墙软件保护他们的网络,那都是不可思议的。真正的安全专家只信任他们自己使用的经编译检查没有后门和缺陷的防火墙。

2.5 配置规则

一旦判断出适合自己网络(或者多个网络)的安全级别,就可以设置防止黑客攻击的防火墙规则或其他网络安全产品规则了。任何一个防火墙都允许用户建立一套规则来指定允许哪些通信可以和哪些不能通过防火墙,当然还有建立和操作的相关规则。

可将安全划分为五个级别,这些级别能和多数的组织很好地匹配。如果能将用户自己的组织和下面的安全级别匹配上,就可以使用下面列出的规则作为防火墙安全策略的出发点。这些级别分别是

- 注意级(awareness)
- 关注级(concern)
- 警惕级(caution)
- 严格级(strictness)
- 超常级(transcendency)

对于每一个安全级别,下文将描述网络管理员为实现网络中这个安全级别所采用的规则、限制和过程。

2.5.1 注意级(awareness)

无论保护网络内容所需的是何种安全级别或网络所服务的是哪种类型的组织,有些事情是任何一个安全网络管理员都应该做的。安全网络管理员的行为和处理方法将弥补安全漏洞,并且不会对因特网的访问能力有任何负面的影响。管理员应该注意的是

- 在网络的服务器和客户机上安装最新的操作系统补丁程序。
- 不要将网络用户账号放在因特网服务计算机上,如 Web 服务器、FTP 服务器和防火墙等,并且对这些不同的机器使用不同的管理员账户和管理员口令。
- 定期扫描系统用户账号中的未授权网络服务用户账号的增加和修改。
- 不使用对网络和因特网服务器不必要的服务。
- 在服务器上使用病毒扫描。
- 定期执行备份。

2.5.2 关注级(concern)

关注网络安全的网络管理员至少要安装一个包过滤器并采取注意级的安全措

施。包过滤器虽然不能防止利用服务协议缺点而进行的集中式的网络攻击，但它能防止最简单的拒绝服务攻击——那些基于畸形或恶意配置的 ICMP 或 IP 包。

最简单配置下的包过滤器默认状态下允许包通过，除非规则指定过滤器让它们放弃这些包。代理服务器可以用来加强网络服务（例如缓存 HTML 页），但它并没有提供额外的安全，因为网络客户可以很容易地绕过它们。包过滤器可以把有问题的外部网络地址和子网放在外面，也可以拒绝外部对特定内部计算机（如文件和数据库服务器）的访问。

包规则控制几种不同类型的包通过过滤器或防火墙的流动。这些包规则分别为：

1. ICMP 规则

ICMP 控制 IP 包通过因特网的流动，因此 IP 是正确操作因特网的基础。但是 ICMP 包可被伪造来诱骗用户的计算机重定向它们的传输、停止所有传输甚至崩溃。

注意，虽然假定关注级的（不是警惕级的）管理员允许包默认通过防火墙，但规则对默认许可和默认拒绝配置都起作用。规则是（或应该是）按顺序从前至后执行的。规则简单描述如下：

（1）允许源抑制　当网络饱和时，希望外部主机能够告知内部的客户计算机。

（2）允许回应请求（echo request）出站　希望客户机可用 ping 外部主机来验证连通性。

（3）允许回应应答（echo reply）入站　希望客户机能听到被 ping 主机的应答信号。

（4）允许目标不可达（destination unreachable）入站　这些包通知客户机外部资源是不可用的。

（5）允许服务不可用（service unavailable）入站　这些包通知客户机外部资源是不可用的。

（6）允许 TTL 超出（TTL exceeded）入站　这些包通知客户机外部资源太远。

（7）允许参数问题　这些包通知客户机它们没有发送正确格式化的包。

（8）放弃重定向入站　用户不希望在没有自己监督的情况下，外部代理可以弄乱内部计算机的路由表。

（9）放弃回应请求入站　回应请求（ping）包可以被用来搜集网络上要攻击的计算机的信息。畸形的 ping 通常也能以请求的形式对计算机进行破坏。

（10）放弃回应应答出站　为什么要让黑客能很容易地发现要攻击的计算机呢？

（11）放弃目标不可达出站　像用户保护内部主机标识那样保护内部网络的标识。

(12) 放弃服务不可用出站　向网络攻击者们宣布在自己的网络中有哪些可用的服务是不明智的。

(13) 放弃 TTL 超出出站　通过尝试不同的 TTL 值，黑客可以判断出用户网络内部的网段的数量或者局域网的边界数量。

(14) 放弃所有其他的 ICMP 包　只是为了安全。用户指定允许使用的 ICMP 包应该是足够的。

2. IP 规则

不管 IP 包包含的是 TCP 还是 UDP 传输，有一些规则对所有的 IP 包都是适用的。这些规则管理着出入用户网络的 IP 传输的一般流动。如果用户希望禁止某个计算机或者是网络访问自己的网络，就可以在这里设置一个规则。下面对这些规则作出具体说明。

(1) 放弃所有源路由的包　没有人再在一个被破坏的连接周围重定向包，他们要做的只是修理被破坏的设备。一个源路由包的出现是一个网络入侵行为的危险信号。

(2) 放弃所有从外部端口到达的却表示为是从内部网络发出的包　如果包声明它是从用户网络内部发出的，它只能从内部端口发出。

(3) 放弃所有从内部端口到达的却表示为是从外部网络发出的包　这个行为表明有些可疑的事情正在进行，最安全的办法就是放弃这些包并将其记录到日志中。

(4) 放弃入站到那些外部不可访问的服务(如文件服务器)的包　在用户网络之外的人没有到用户局域网文件服务器的业务连接，除非他们是通过用户特别为他们设置的加密通道来连接的。

(5) 放弃 RIP，OSFP 和其他路由器信息交换协议　用户不需要外部代理重新配置自己的路由器。

(6) 放弃从特定主机发出的包　在这里用户可以设置规则禁止那些打扰自己的主机和网络连接到自己的网络。

3. UDP 规则

一旦用户为一般的 IP 传输设置了规则，就希望进一步指定一些 UDP 规则来阻断很大的安全漏洞，如 X-Windows。

提示：默认情况下，关注级(而非警惕级)的安全管理员允许包通过防火墙，除非有一个指定的规则要拒绝这种类型的包。

每一个规则都指定拒绝一个端口或是一个端口范围(一些防火墙需要用户为每一个指定为不允许使用的端口重复此规则)。下面对这些规则进行说明。

(1) 放弃使用 21 以下端口的包　在端口 21 以下没有一般因特网用户认为有

用的任何服务。

(2) 放弃 X-Windows(使用端口 6000～6003 的包) 用户不会希望黑客获得自己鼠标和键盘的控制。

(3) 放弃 SNMP(使用端口 161 和 162 的包) 用户不会希望网络入侵者利用这个协议重新配置自己的集成器和路由器。

4. TCP 规则

建立 TCP 规则与建立 UDP 规则只有一个区别 用户可以使用包的 ACK 位终止任何方向上建立连接。对特定的端口用清空(C)ACK 位阻断包入站,只允许启动出站连接,但允许这个连接的后续数据传输进行——它们都有 ACK 位设置(S)。一些 TCP 端口同上面列出的 UDP 端口相同,有些协议既对 UDP 操作也对 TCP 操作。下面对这些规则进行说明。

(1) 放弃使用 21 以下端口的包 在端口 21 以下没有一般因特网用户认为有用的任何服务。

(2) 放弃 X Windows(使用端口 6000～6003 的包) 用户不会希望黑客获得自己鼠标和键盘的控制。

(3) 放弃 SNMP(使用端口 161 和 162 的包) 用户不会希望网络入侵者利用这个协议重新配置自己的集成器和路由器。

(4) 不允许 telnet 连接进入(目标端口为 23,源端口大于 1023 的进入包) Telnet 是一个不安全的协议,因为一旦建立了一个 telnet 对话,用户名和口令交换就是不加密的,数据通道也是不加密的。

(5) 指定允许使用端口号为 1023 以上的任何内部服务 使用这个方法,用户可以在下一个规则中终止后门软件,如 Back Orifice,它们可以为用户计算机的远程未授权控制打开内部端口。

(6) 放弃 SYN 包(从外部到内部,端口号大于 1023) 大多数合法的服务都配置为在 1023 端口以下,所以这个规则终止了到那些大于 1023 的端口上的连接请求。规则(5)和其他相似的规则(在这个规则之前必须就位)可特别允许任何例外的连接。

(7) 不允许进来的 FTP 数据连接,这样就只允许被动的 FTP 了。

(8) 除了电子邮件服务器,不允许来自外部的 SMTP 连接(端口为 25)。

(9) 为其他服务(如 HTTP)建立服务目标规则。

2.5.3 警惕级(caution)

大多数网络管理员会觉得上面的规则不是很充分,因为一些有时间和能力的专业的黑客有办法绕过上面的规则。谨慎的网络管理员将在默认情况下执行更保

守的跟踪并阻断所有的传输，只允许那些在仔细分析后认为安全的传输进行。这种方法需要花更多时间和精力来正确配置，但结果是会产生更安全的防火墙。

警惕级采用的配置规则包括

1. 网络地址转换

实际上，谨慎的管理员喜欢的是一个网络地址转换(network address translation，NAT)功能，这个功能的作用是可以对外部世界只公开一小部分(甚至是一个)IP 地址，而在它后面隐藏着数十个、数百个，甚至数千个计算机。对在局域网上的计算机而言，直接连接到因特网和在隐藏 NAT 的局域网上存在没有什么区别。防火墙跟踪连接，并重新写包的源、目标地址以及端口值。

2. 分段

一个谨慎的网络管理员不会允许已分段的包进入网络。直到最近，分段包还一直被认为是安全的，因为人们认为只是分段包的第一个段需要检查，并且如果必要就会将其放弃。任何后继的包都将被目标计算机放弃，因为它们缺乏初始包的报头信息。

由于在一般的 TCP/IP 协议的实现产品(包括 Windows NT)中发现了一个程序错误，情况就不同了。这个程序错误(后来被修复了)忽视不正确的分段偏移值，这样将允许第二个(或后面的)分段占据第一个分段的内存位置，大多数谨慎的网络管理员选择在防火墙重新装配分段的包或者放弃它们，因为分段功能已经很过时了。

3. ICMP，TCP 和 UDP

当谨慎的管理员默认拒绝所有包时，前一小节列出的一些包规则就变得冗余了。用户可能希望它留在自己的规则中，这样就可以把默认拒绝切换成默认接受，并当检查网络连通性时，再把它们设置回去。

在这里没有列出的一个规则(因为默认是拒绝的)是：用户根本就不应允许 telnet 连接(到 23 端口的连接)通过自己的防火墙，而是使用 Secure SHELL (SSH)，因为它为远程终端提供了更安全的连接。另外，在这里没有明确地列出阻断对 1023 以上端口访问的规则，因为一般被访问的服务都在 1023 以下的端口上。

下面对这些规则进行说明。

(1) 允许从用户的电子邮件服务器出去的 SMTP 连接(端口为 25)。

(2) 允许从用户的新闻服务器向外部新闻服务器发送 NNTP(源端口为 119，目标端口大于 1023)。

(3) 允许从外部新闻服务器向用户的新闻服务器发送 NNTP(源端口为 119，目标端口大于 1023)。

(4) 允许客户机建立 HTTP 连接(源端口大于 1024，目标端口为 80)。

(5) 允许在已经建立的 HTTP 连接中从因特网 80 端口返回到用户局域网中

的客户端口(大于 1023)的数据传输。

(6) 为希望内部客户可以连接到的其他因特网服务重复规则(4)和(5)。

4. 服务规则(代理功能)

一般的规则:不允许来自因特网的代理请求,即通过过滤出带有清空的 ACK 位的包,且此包是从外部接口连接到用户的代理的。这就防止了黑客连接到用户的代理服务器和使用代理服务器隐藏他的连接。

代理 DNS 使用一个 DNS 服务器或一个代理服务器,此服务器透明地支持 DNS 代理,但不允许域转移。例如用户不会希望任何网络外的人重新配置自己网络的名字。

通过让用户的电子邮件服务器向磁盘写电子邮件信息,并让其他的电子邮件服务器在网络内部处理和转发这些邮件来代理 SMTP 邮件服务。这就防止了任何一个简单的进程遭到攻击,这个进程可能始终允许连接通过机器。这也保证了任何恶意的电子邮件或者将会破坏入站的进程被丢弃,或者在不被破坏的情况下通过转发过程完全重新产生。这也防止了用户网络中的电子邮件服务器出现缓冲区溢出的情况。

通过在用户的停火区建立一个 NNTP 服务器来代理 NTTP。入站的 NTTP 只能被转发到服务器上,而内部新闻读者也只能读服务器上的新闻。这就防止了特洛伊木马或其他的非 NTTP 传输利用包过滤器上打开的 NNTP 端口。

在防火墙中使用专门的 FTP 代理应用程序来代理 FTP。状态防火墙上的 FTP 服务过滤器在被指定为 FTP 协议服务时也可以使用。

通过一个安全的 HTTP 代理来代理 HTTP。用户的 HTTP 代理将有能力检查病毒和去除可执行的内容。

不要在外部边界网关处理 POP 访问。用户的 SMTP 服务器应在自己的 DMZ 内部。对于远程用户,强迫他们为其电子邮件访问建立加密的通道。这就防止了电子邮件在因特网上使用免费网关服务中的一个,用户就可以使用 Web 浏览器来检查他们的专用电子邮件了。

不要提供 telnet 代理,因为 telnet 可以通过用户的网关进行公开访问,这样太不安全。

2.5.4 严格级(strictness)

严格级控制的基本策略是完全不允许使用在公共和专用网络之间的网络层路由功能。严格的策略只使用应用层代理(并且不是许多)来提供最有用的因特网服务。状态包过滤器应被用来保护堡垒主机上的应用级代理,堡垒主机不应执行包路由功能。

这个堡垒主机可以执行网络地址转换来使自己对内部主机是“不可见的”，这样客户应用程序就不必被明确地设置为使用代理了。在这种模式中，代理主机对内部主机像一个路由器，它接收所有传输，似乎它要将这些传输直接转发到公共网络一样。这种模式使很难代理的协议（如 FTP 和 H.323）也变得简单了。

严格级采用的配置规则包括

- 包规则（过滤功能）

在堡垒主机的外部公共接口和内部私有接口之间不存在任何路由。在以上部分描述的 ICMP 和 IP 规则也应用来保护堡垒主机不受服务拒绝攻击。

- 服务规则（代理功能）

严格安全后最基本的策略是只代理最有用的协议——HTTP 和 SMTP。这两个协议都非常容易控制和跟踪，允许利用因特网上的大多数功能。用户受到攻击的威胁同用户在堡垒主机中定义的情况的数量成线性比例。这样的策略就是最实用的。

使用 DNS 服务器代理 DNS，但不允许域转移，因为用户不会希望任何网络外的人重新配置自己网络的名字。用户要确保 DNS 代理不会公布内部主机的名字。

通过一个安全的 HTTP 代理，如 NAI 的 Gauntlet 来代理 HTTP，去掉任何可以执行的内容，包括 EXE，ActiveX 和 Java 等小程序。

通过让用户的电子邮件服务器将电子邮件信息写到一个磁盘上，而其他的邮件进程在网络内部处理和转发这些邮件来代理 SMTP 邮件服务。配置用户的电子邮件服务去除所有可执行的附件并在 ZIP 压缩文件和办公文档中检查病毒。惟一允许通过防火墙传输可执行内容的办法就是使用压缩格式或使用非可执行格式，如 BIN-HEX。

2.5.5　超常级（transcendency）

超常级安装的策略是，或者不连接到因特网上，或者将一个单独的“只连接到因特网”的网络连接到因特网。美国政府使用这两种方法来保护他们的机密网络不受到来自因特网上的攻击，它们是完全在物理上断开连接的，另外还有一组“一次性的”机器可以为那些在因特网上工作的人员使用。用户应在标准的状态检查包过滤器后面使用一组专用因特网机器。

- 包规则（过滤功能）

在公共网络的专用网络之间不允许使用直接路由功能。

- 服务规则（代理功能）

在公共网络和专用网络中不允许使用代理功能。

第3章

信息安全产品分类

随着信息系统和安全技术的发展，信息安全产品的功能和种类也在不断加强和丰富，适应范围也越来越广。根据产品应用的目的，可将信息安全产品划分为两大类——安全防御类和安全管理类。

3.1 安全防御类

安全防御类产品的主要用途是通过对信息系统和资源的安全控制，来防止非法用户进入系统、越权使用信息资源以及窃听机要/敏感信息。下面对这类产品分别进行介绍。

3.1.1 鉴别和认证产品

鉴别是确保所有安全应用和服务的基础。鉴别是手段，认证是目的。认证就是将特定实体从任意实体的集合中识别出来的行为，而鉴别则是为认证提供充分保证的手段。例如目前在网络中广泛运行的 Kerberos 和 RADIUS 协议，就是鉴别与认证技术的典型应用。鉴别和认证产品主要包括

- 卡片类手持身份认证产品和服务器、基于网络的身份认证及一次性系统登录产品等；
- 用于数字证书发行和管理的证书授权机构 CA。

3.1.2 访问控制产品

访问控制的目的是防止对网络信息资源的非授权访问和操作。访问控制的技术原理有硬件物理隔离(例如防火墙)；面向连接的中继；面向网络层的控制(例如 IP 包过滤)；协议层状态检查；面向应用的转发与代理；通过中继设备对实体标识进行变换(例如 NAT)及基于授权等级分割的权限控制等。

一台安全设备中往往集成了多种访问控制技术，同时兼有物理隔离和逻辑隔离技术，这里所指的逻辑隔离是基于算法或访问控制表(ACL)的中继或转发

控制。

访问控制技术广泛应用于防火墙设备、代理服务器、鉴别与认证服务器及授权服务器中。访问控制作为一种安全机制在安全访问和服务可用性等安全服务中使用。访问控制产品主要包括

- 防火墙
- 操作系统加固模块
- 网页/内容过滤模块
- 数据库隔离模块等。

3.1.3 加密产品

加密就是按特殊方式对信息进行编码，使其不能被未经许可的访问识别的过程，其逆过程为解密。利用加密技术可以对信息进行机密性保护，防止非授权人员解析信息/数据内容。加密技术可运用于链路层、网络层、传输层和应用层。加密产品主要包括

- 链路密码机
- IP 协议密码机
- 邮件/文件加密产品
- 交易/处理过程加密系统等

3.2 安全管理类

应该认识到，安全是相对和动态的。单靠配置安全设备和系统不能完全解决安全问题。一种完善的安全体系不仅包括安全防护系统本身，而且还应具有主动性的监视、审计能力，通过不断地检查系统安全漏洞和安全威胁，及时弥补和完善系统安全策略。这类产品主要包括以下几种。

3.2.1 入侵检测产品

入侵检测产品采用的入侵检测技术是一种试图识别并隔离“入侵”计算机系统的安全技术，是安全系统的重要组件，它帮助计算机系统预防和处理攻击，并对攻击者的行为进行审计，进一步还可制止将要到来的攻击。为此，入侵检测系统收集系统和网络资源的各种信息，然后分析这些信息是否有安全问题迹象。某些情况下，入侵检测系统允许用户指明对违规事件作出实时响应。

入侵检测系统是防火墙的合理补充，帮助系统对付网络攻击，扩展了系统管理员的安全管理能力(包括安全审计、监视、对攻击进行识别和响应等)，提高了信息

安全基础结构的完整性。入侵检测被认为是防火墙之后的第二道安全闸门，在不影响网络性能的情况下能对网络进行监测，从而提供对内部攻击、外部攻击和误操作的实时保护。

入侵检测技术可以分为5种。

第1种是基于应用的监控技术，其主要特征是使用应用层监控传感器在应用层收集信息。随着电子商务的流行，由于这种技术可以更准确地监控用户某一应用的行为，所以这种技术也越来越受到注意。其缺点在于应用层的脆弱性可能削弱基于应用的监视和检测方法的完整性。

第2种是基于主机的监控技术，其主要特征是使用主机传感器采集本系统的信息。这种技术可以用于监控分布式、加密、交换的环境中，把特定的问题同特定的用户联系起来。其缺点在于主机传感器要和特定的平台相关联，对网络行为也察觉不到，同时加大了系统的负担。

第3种是基于目标的监控技术，其主要特征是针对专有系统属性、文件属性、敏感数据、攻击进程结果等进行监控。这种技术不依据历史数据，系统负担小，可以准确地确定受攻击的部位，受到攻击的系统容易恢复。其缺点在于实时性较差，对目标的校验和依赖较大。

第4种是基于网络的监控技术，其主要特征是网络监控传感器采集包监听器收集的信息。该技术不需要任何特殊的审计和登录机制，只要配置网络接口就可以了，不会影响其他数据源。其缺点在于如果数据流进行了加密就不能审查其内容，对主机上执行的命令也感觉不到。此外，该技术对高速网络不是特别有效。

第5种是综合以上4种方法进行监控，可以提高检测性能。但这样就会产生非常复杂的安全方案，会严重影响网络的效率，而且目前还没有一个统一的业界标准。

在使用入侵检测技术时，应该注意以下技术特点的应用，要根据具体情况进行选择。

(1) 信息收集分析的时间　可分为固定时间间隔和实时收集分析两种。

采用固定时间间隔方法，通过操作系统审计机制和其他基于主机的登录信息，入侵检测系统在固定的时间段内收集和分析这些信息。这种适用于对安全性能要求较低的系统，对系统开销影响较小。但这种技术的缺点是显而易见的，即在时间间隔内将失去对网络的保护。

采用实时收集分析技术可以实时地抑制攻击，使系统管理员及时了解并阻止攻击，系统管理员也可以记录入侵的信息，但缺点是加大了系统的开销。

(2) 对采集的信息进行分析的方法　可分为签名分析、统计分析和完整性分析。

签名分析就是将收集到的信息与已知的网络入侵和系统误用模式数据库进行

比较，从而发现违背安全策略的行为。该过程可以很简单（如通过字符串匹配以寻找一个简单的条目或指令），也可以很复杂（如利用正规的数学表达式来表示安全状态的变化）。一般来讲，一种进攻模式可以用一个过程（如执行一条指令）或一个输出（如获得权限）来表示。该方法的一大优点是只需收集相关的数据集合，能显著减少系统的负担，且技术已相当成熟。它与检测病毒的防火墙采用的方法一样，检测准确率和效率都相当高。但是，该方法存在的弱点是需要不断的升级以对付不断出现的攻击手法，它不能检测到从未出现过的攻击手段。

统计分析方法首先给系统对象（如用户、文件、目录和设备等）创建一个统计描述，统计正常使用时的一些测量属性（如访问次数、操作失败次数和延时等）。测量属性的平均值将被用来与网络、系统的行为进行比较，任何观测值在正常值范围之外时，就认为有入侵发生。例如，统计分析可能识别一个不正常行为，因为它发现一个在晚 8:00 至早 6:00 不登录的账户却在凌晨 2:00 试图登录。其优点是可检测到未知的入侵和更为复杂的入侵，缺点是误报、漏报率高，且不能适应用户正常行为的突然改变。具体的统计分析方法可基于专家系统、基于模型推理和基于神经网络，目前正处于热点研究和迅速发展之中。

完整性分析主要关注某个文件或对象是否被更改，这经常包括文件和目录的内容及属性，它在发现被更改的、被特洛伊木马化的应用程序方面特别有效。完整性分析利用强有力的加密机制，称为消息摘要算法（例如 MD5），它能识别哪怕是微小的变化。其优点是不管签名分析方法和统计分析方法能否发现入侵，只要是成功的攻击导致了文件或其他对象的任何改变，它都能够发现。缺点是一般以批处理方式实现，不适用于实时响应。尽管如此，完整性检测方法应该还是网络安全产品的必要手段之一。例如，可以在每一天的某个特定时间内开启完整性分析模块，对网络系统进行全面扫描检查。

（3）入侵检测系统对攻击和误用的反应　有些基于网络的检测系统可以针对检测到的问题做出反应，这个特点使得网络管理员对付诸如拒绝服务之类的攻击变得非常容易。这些反应主要有改变环境、效用检验及实时通知等。当系统检测到攻击时，一个典型的反应就是改变系统的环境，通常包括关闭连接、重新设置系统。由于改变了系统的环境，就可以通过设置代理和审计机制获得更多的信息，从而能跟踪入侵。

3.2.2 安全性扫描产品

安全性扫描，也叫脆弱性评估，它从广泛的角度进行严格的系统检查，以便发现系统与网络的薄弱环节以及策略管理的漏洞，并且提出一种可行的方法去评估网络系统的安全设置。漏洞扫描系统可以扫描系统中每一种网络设备的安全漏洞，快速发现网络的某些弱连接部分，识别易受攻击的服务，并且会提示适当的解

决措施。漏洞扫描产品使入侵检测系统更加完备，如允许系统管理员在攻击者使用漏洞前就可以发现并关闭它们来主动地保护系统。

漏洞扫描技术可分为以下5种。

第1种是基于应用的探测技术，它使用被动的、非破坏的方法来检查应用包中的设置和配置，以发现安全漏洞。

第2种是基于主机的探测技术，它采用被动的、非破坏的方法对系统进行探测。通常，它涉及到系统内核、文件属性和操作系统的补丁等问题。这种技术还包括口令分析、破译口令文件、利用已知攻击方法迅速找出弱的(空的)或其他易猜的口令等。因此这种技术可以非常准确地定位系统所存在的问题，发现系统漏洞，它的缺点是与平台相关；升级复杂。

第3种是基于目标的探测技术，它采用被动的、非破坏的方法检查系统属性和文件属性，如数据库、注册号等。通过消息摘要算法，对重要的文件进行校验和运算。其基本原理是利用散列函数消息加密算法，如果函数的输入有一点变化，其输出就会发生很大的变化，这样文件和数据流的细微变化都会被感知到。这些算法加密强度极大，不容易受到攻击，并且其实现是运行在一个闭环上，不断地处理文件和目标的属性，然后产生校验和，把这些校验和同原来的校验和相比较，一旦发现改变就通知管理员。

第4种是基于网络的探测技术，采用主动的、非破坏的方法来检验系统是否有可能受到攻击。它利用了一系列的脚本对系统进行攻击，然后对结果进行分析，网络探测技术常被用来进行穿透实验和安全审计。这种技术可以发现一系列的平台漏洞，也容易安装。

第5种是综合的探测技术，它集中了以上4种技术的优点，极大地增强了漏洞识别的精度。

漏洞扫描技术的技术特点表现在如下几个方面。

(1) 探测分析的位置　在漏洞探测中，收集数据是第一步，数据分析是第二步。在大型网络中，通常采用控制台和代理结合的结构，这种结构特别适用于异构型网络，容易探测不同的平台。并且，在不同威胁程度的环境下，可以有不同的探测标准。

(2) 报表与安装　漏洞扫描系统生成的报表是理解系统安全状况的关键，它记录了系统的安全特征，针对发现的漏洞提出需要采取的措施。整个漏洞扫描系统还应该提供友好的界面、灵活的配置特性，且安全漏洞数据库可以不断更新补充。

(3) 探测后的解决方案　一旦探测完毕，如果发现了漏洞，系统可有多种反应机制。预警机制可以让系统发送消息、电子邮件、呼叫等来报告发现的漏洞。报表机制则生成综合报表列出所有的漏洞。根据这些报告可以进行针对性的补救措

施。同入侵检测系统一样，漏洞扫描系统有许多管理功能，通过一系列的报表可让系统管理员对这些结果作进一步分析。

(4) 探测系统本身的完整性 同样，在这里有许多设计、安装、维护探测系统要考虑的安全问题。安全数据库必须安全，否则会成为黑客的工具，因此，加密就显得特别重要。由于新的攻击方法不断出现，所以要提供给用户一个更新系统的方法。更新的过程也必须加密，否则将产生新的危险。实际上，漏洞扫描系统本身就是一种攻击，如果被黑客利用就会产生难以想像的后果，因此必须采用保密措施，使其不被黑客利用。

3.2.3 信息审计系统

信息审计系统采用先进的状态检查技术，以透明方式实时对进出内部网络的电子邮件和传输文件等进行数据备份，并可根据用户需求对通信内容进行审计，从而为防止内部网络敏感信息的泄漏、外部不良信息的侵入和外部的非法攻击提供有效的技术手段。

信息审计系统的主要功能有

- 数据采集、还原处理及备份功能
- 自动中标检查
- 日志管理与审计

3.2.4 防病毒产品

防病毒机制是系统安全性的一个十分重要的方面，它是系统安全的重要保证。在技术上可以在服务器中安装服务器端的网络防病毒软件，在用户单机上安装单机或网络版防病毒软件。现在，网络传输的文件是头号病毒感染源。隐藏在普通共享文档中的宏病毒很容易通过 Internet 被不经意地传至毫无戒备的用户，一旦这些病毒文档通过 Internet 网关，它们就可以迅速蔓延至整个公司。因此，有必要在网关截止此类病毒，保证在病毒有机会复制并造成大范围 PC 机破坏之前将其阻止。

第4章

防火墙技术

4.1 防火墙基本知识

不能控制访问的网络不能保证存储数据的安全和保密，也不能防止黑客盗用网络资源。

因特网提供的通信效率使直接连接到因特网的专用网络大量增加。直接与因特网连接很容易使黑客盗用专用网络资源。在 Internet 出现以前，黑客广泛使用的是从家里连接到专用网络的办法，这只有用调制解调器直接拨号和使用公共电话网来实现。

当将专用网络连接到因特网时，实际上是将用户的网络直接连接到每个直接连在因特网的网络上。在那里没有固定的中央安全控制点。

防火墙(firewall)被用来在专用网络的边界上建立安全的检查点。通过在因特网和专用网络之间提供路由功能，防火墙检查这两个网络的所有通信，防火墙根据这些通信是否匹配已配置好的策略规则来决定通过或是断开通信连接。如果防火墙配置正确并且没有严重的可被利用的错误，用户的网络将会远离风险。

防火墙通过检测在内部网(即前面提到的专用网)和外部网(如因特网)之间的请求，然后允许或是拒绝每个连接请求，使因特网连接尽量安全。边界安全的概念是非常重要的，如果没有它，网络中的每个主机都将不得不自己实现防火墙的功能；有了这个概念，就没有必要花费宝贵的计算资源，没必要增加连接、身份认证所需的时间，没必要在本地的高速网中加密数据。防火墙使用户可以集中管理那些为上述任务而优化并专门从事上述任务的机器上的所有外部安全服务。

也是由于防火墙的本质，防火墙在内部网和外部网之间形成了瓶颈，因为所有外部网和内部网之间的通信都必须通过一个单一的控制点。由于外部租用线的连接速度比现代的计算机速度相对较慢，所以由防火墙引起的等待时间就相当明显。

一般来说，防火墙包括几个不同的组成部分(见图 4-1)。过滤器(filter，有时也称为屏蔽)用于阻断一定类型的通信传输。网关是一台或一组机器，它提供中继服务，以补偿过滤器的影响。驻有网关的网络常被叫做非军事区(DeMilitarized

Zone,DMZ)。DMZ中的网关有时还由一个内部网关(internal gataway)协助工作。一般情况下,两个网关通过内部过滤器到内部的连接比外部网关到其他内部主机的连接更为开放。就网络通信而言,两个过滤器或网关本身,都是可以省去的,详细情况随防火墙的变化而变化。一般说来,外部过滤器可用来保护网关免受攻击,而内部过滤器用来承担一个网关遭到破坏后所带来的后果,两个过滤器均可保护内部网络,使之免受攻击。一个暴露的网关机器通常被称为堡垒机(bastion host)。

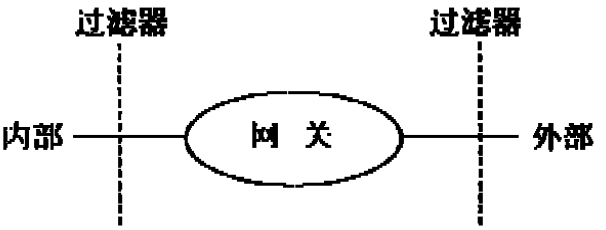

图4-1 防火墙示意图

4.2 防火墙的常见配置

4.2.1 屏蔽过滤路由器

这是最基本的模式,通过路由器将内部网络和Internet连接起来。所有访问内部网络的IP包在达到它们的目标主机前均被过滤路由器屏蔽,过滤器对进出的访问进行控制。不过,这种模式的防火墙不能对应用层的数据进行处理,因为它完全是网络层的过滤。

4.2.2 堡垒主机

所有访问WWW站点或者内部网络主机的IP包在未经堡垒主机鉴别之前,不得访问WWW服务器或进入内部网络。这种主机往往是一台PC机,置于Internet和被保护的网络之间。访问控制既可以基于用户,也可以针对应用层的信息。不过为了安全,对用户级进行控制并不一定行得通,因为会有大量的来自各地的用户,他们可能以许多方式访问站点,这样花费会非常大。

4.2.3 双宿主网关

这种模式集堡垒主机和屏蔽过滤机制于一身,其优点是可以保护WWW服务器,并允许用户访问服务器提供的一些重要服务。

4.2.4 IP过滤

这是防火墙的基础之一,虽然高效,但不可靠,它保护内部网络和WWW服务器的安全性。在防火墙中包过滤依然是提高内部网络安全性的有效方式。

4.2.5 代理

代理(proxy)程序用于防火墙环境中，以使内部受保护的网络可以继续访问外部网络。目前有多种代理，大多数运行在防火墙系统中，在内部及外部网络之间传递请求。

代理程序的作用有

- 当防火墙失去一部分访问控制功能以后，可利用代理实现访问控制。
- 通过禁止某些 HTTP 方法的使用，来限制 HTTP 协议软件可能带来的危险。
- 它可以使客户机和服务器访问预先安排的服务器或主机。比如，可以控制哪些站点能够允许用户访问，哪些主机不能与指定的 WWW 服务器相连。
- 可以对数据包中携带的各种信息进行检查，以保护系统安全。比如过滤可疑的 URL。
- 可对从服务器到客户机之间传送的信息进行扫描，过滤掉那些对服务器而言危险的或陌生的数据和程序。
- 可以提供详细的注册及审计功能，这大大提高了网络的安全性，也为改进现有软件的安全性能提供了可能性。

4.3 防火墙技术

本节将对现在常用的几种防火墙技术进行详细阐述[3,4]。

4.3.1 包过滤

包过滤器是最早出现的防火墙技术。最初进行 TCP/IP 安全的尝试是基于这样一种想法：一个路由器能很容易地检查 TCP/IP 包的头，并简单地放弃那些与用户所设置的规则相冲突的包。

包过滤器存在一些问题使它不能完全保证一个内部网络的整体安全。目前，常将包过滤与代理服务器和网络地址转换合并在一起来解决网络安全问题。

有两种基本类型的包过滤功能，分别为

- 标准的，或称为无状态的包过滤功能；
- 有状态检查的包过滤器。

这一章讨论“纯”包过滤功能，它指的是没有与代理服务器和网络地址转换合并在一起的包过滤功能，而代理服务器和网络地址转换将在后面两节讲述。因为现在许多地方还在使用纯包过滤器，所以这部分的讨论很有必要。

1. 无状态包过滤器

包过滤器是指那些边界路由器，它们根据每个数据包包头信息来决定是否要将包继续传递，不传递的则丢弃，从而增加安全性。理论上，包过滤器可以被配置为根据协议报头的任何部分进行判断，但是大多数的过滤器被配置为只过滤最有用的数据域，这些域包括

- 协议类型
- IP 地址
- TCP/UDP 端口
- 分段号
- 源路由信息

下面详细介绍如何使用这些域进行包过滤。

(1) 协议过滤功能

协议过滤功能根据 IP 协议域的内容过滤包。协议域可以用来区别不同的服务类型，如 UDP，TCP，ICMP，IGMP 等。

例如，如果用户有一个单一目的的服务器，它只为基于 TCP 的服务，如 HTTP 服务，用户就可以过滤掉所有 UDP 服务。但是，协议域太普通了(只可以在一般协议上进行过滤)，所以大多数的服务器和路由器都将它们开着。

(2) IP 地址过滤功能

IP 地址过滤功能可以让用户根据 IP 地址限制指定主机和网络之间的连接。大多数过滤器既可以允许用户拒绝所有主机和网络的访问(除在一个列表中指定的主机和网络外)，也可以允许用户接受所有主机和网络的访问(除在一个列表中指定的主机和网络外)。

指定某些拒绝访问的主机几乎是没有价值的，因为用户不得不跟踪每一个曾经攻击过自己网络的黑客，并且要假设这些黑客不能从其他 IP 地址上获得信息，但通常他们会获得。依靠指定拒绝的方法不是一个很好的安全策略。

然而，指定某些接受访问的主机地址的方法提供了特别强的安全保证，这是无状态包过滤器所能提供的最好的安全形式。通过拒绝没有在一个已知 IP 地址列表中指定的主机和网络外的所有主机和网络的访问，可以保证用户的路由器只能由用户知道的机器或网络的 IP 地址得到。这个列表可以是组织内的其他网络、客户的网络或那些在家里的用户的网络。通过拒绝其他所有 IP 地址的访问，几乎可以使黑客不能攻击到用户的网络。要闯入网络，黑客必须首先进入可以接受访问的 IP 地址列表。

黑客可能使用源路由(下一节中详细解释)方法“假冒”一个 IP 地址。源路由允许黑客将一个许可的地址放到一个包里，并通过指定哪个响应要路由到他的计算机的方法捕获返回的内容。因为这个原因，包过滤器通常被配置为放弃源路由包。

好的包过滤器允许用户根据每一个协议来指定主机，这样，用户就可以为HTTP服务允许所有的主机访问TCP的80端口，而只有内部网络的主机才能访问TCP的23端口(Telnet)。许多简单的过滤器不允许为每个协议指定列表，这样就只能指定一个简单的、为所有协议许可的主机列表了。

另外非常重要的一点是，过滤器只根据IP地址域的内容限制那些地址，而地址域可能与实际的源主机不同。黑客要伪造包的IP地址域很容易，如果他们知道一个过滤器可以通过的地址，当然他们也就可以让包通过过滤器。在包不能往返的情况下，如在服务拒绝攻击中或在协议的返回地址包含在包的有效负荷和包的报头中的情况下(如在FTP中)，这种办法很有效。

(3) TCP/IP端口

TCP或UDP端口信息是过滤器最常使用的信息，因为这个数据域大多数情况下是指定这个包的作用。因为TCP或UDP端口号通常表明高层协议，所以端口路由通常指的是协议路由。图4-2表明了一个无状态包过滤器是如何根据TCP或UDP端口号而区别对待的。

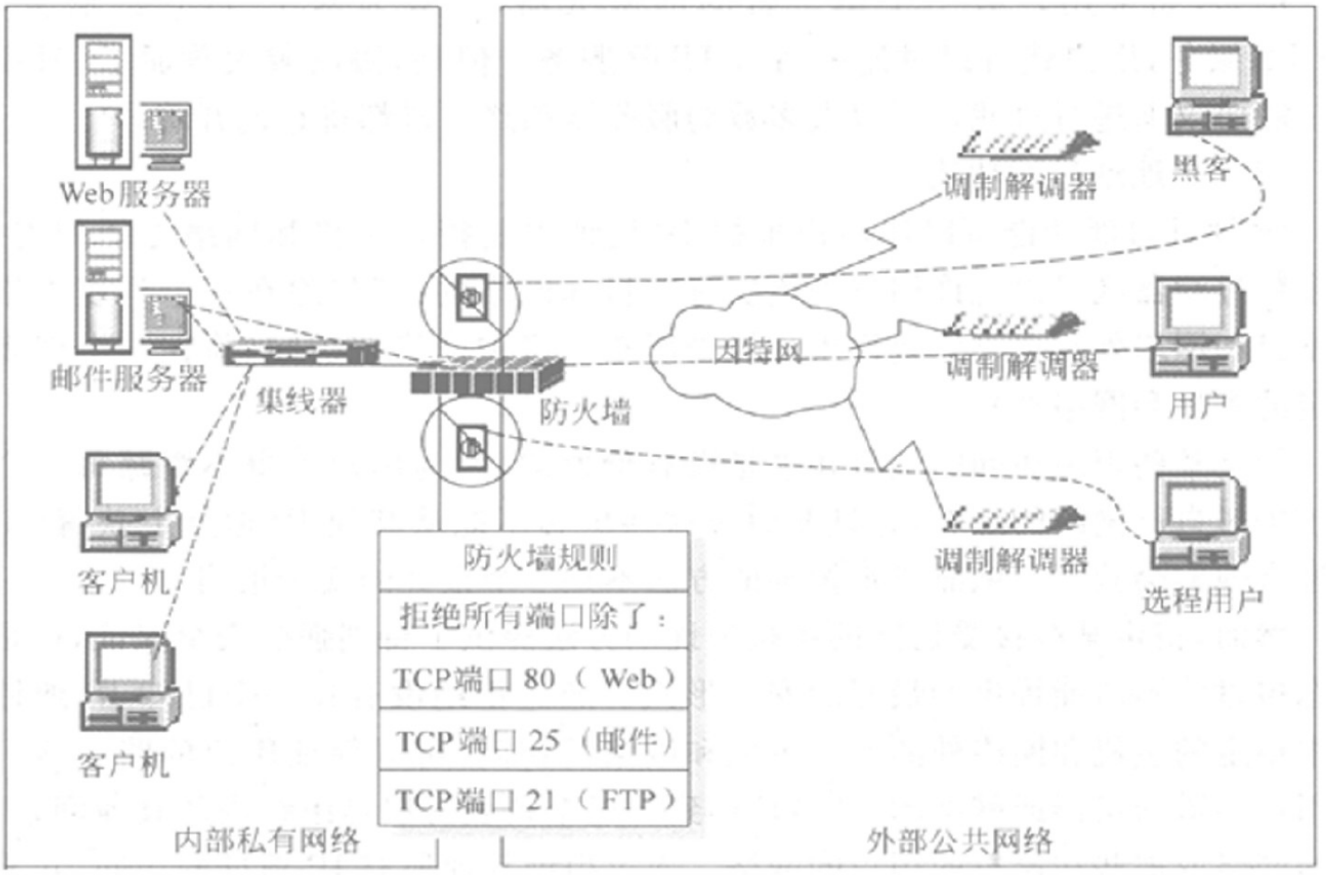

图4-2 包过滤器的过滤原理

可以根据TCP或UDP端口域进行过滤的一般协议包括：

Daytime	DNS	NetBIOS Session	Echo
HTTP	IMAP	Quote	Gopher

NFS	FTP	POP	Whois
Telnet	SNMP	RSH	SMTP
NNTP			

通过使用 IP 地址，大多数的包过滤器允许接受所有协议(除一个拒绝列表外)，也允许拒绝所有协议(除一个接受列表外)。这种拒绝除了一个接受列表外的所有协议的方法更安全些。与 IP 地址过滤不同的是，只拒绝某些指定的端口还是有用的，因为大多数的黑客行为只针对几个特殊的协议。要拒绝的最重要的协议分别是

- Telnet　如果让一个主机的这个端口打开，会使黑客打开一个带有大量可访问资源的命令行提示。
- NetBIOS 会话　如果让 Windows 或 SMB 服务器的这个端口对因特网打开，会使黑客连上文件服务器，就好像他们也是本地客户一样。
- POP　应该为那些需要检查邮件的远程客户建立一个 VPN 连接，因为 POP 是使用明文口令进行访问的，而这样可以使网络外的黑客得到用户的口令。
- NFS　同 Windows 客户不要使 NetBIOS 打开的原因一样，UNIX 用户也不要使 NFS 端口打开。
- X Windows　运行 X 客户软件(X 环境中的"客户"和"服务器"与它们一般情况下的意思正好相反)将使服务器很容易受到攻击。

因为为黑客提供了高级的控制功能，这些端口特别容易受到攻击。其他端口(如 DNS)可以被用来破坏某些特殊的信息，但是不能直接用它们来控制机器，因此对黑客来讲它们的价值也就不是很大。

其他应该拒绝的端口包括任何一种可以进行远程访问控制的软件，如 VNC 或 PcAnywhere 软件。

(4) 基于其他信息的过滤功能

除了标准的数据域外，可以用报头中包含的其他信息来判断是否让一个包通过。

源路由和分段是 IP 协议支持的两个技术，它们虽然早已经过时了，但经常被黑客利用。大多数包过滤器可以简单地放弃那些源路由或分段的包。

源路由是指在 IP 连接中的两个主机间的一个包必须采用设置的路径进行路由的过程。源路由最初被用在网络调试和测试上，但是现在被黑客频繁地使用，因为黑客可以在源地址域中设置任何地址，并且通过在源路由路径中指定他的机器来保证包可以返回到他的机器。

现存的两种源路由的类型分别为

- 松源路由　只指定包必须通过的一个或多个主机，而不指定一个完整的路由路径列表。
- 紧源路由　指定包返回源必须通过的路由路径。

在这两种类型中，黑客最常使用松源路由，因为黑客可以简单地将他的机器地址插入 IP 地址，并保证无论如何包都会返回到他的机器上。

除非在网络中专门指定使用源路由，否则把自己的过滤器配置为放弃任何源路由包。没有任何协议或者 ISP 服务商需要使用源路由。

分段是为了支持那些与一些早的网络帧尺寸不匹配的大的 IP 包，使它们能够通过源路由器而开发的。分段赋予在两个主机间的路由路径上的任何路由器一种能力，使它们可以将入站 IP 包分成许多小的片段，并将这些小的包发向那些限制包尺寸的网络。接收系统只是简单地等待所有分段的到来，然后再将它们重新组合成原始的格式。

分段带来的问题源于这样的事实：大多数有用的过滤器数据，如 TCP 或 UDP 端口号，只在 IP 包的开始部分提供，也就是只在分段号为 0 的包中。分段号为 1 或更高的包并不能根据端口信息进行过滤，因为它们不包含任何端口信息。因此最早的过滤器简单地让所有后继包通过，假设第 0 个包被放弃了，后继的包也就没有价值了。

但是事实通常不是这样的。许多在内部主机上运行的有错误的 TCP/IP 版本，可能无论如何都会将包重新组合，如果第一个包到第 n 个包都包含一个有效的 TCP 包，这些包将会被继续使用。这就意味着黑客可以将他的 IP 分段号从 1 开始，并完全有效地通过防火墙。

(5) 无状态包过滤器的问题

有两个问题使无状态包过滤器不能保证有效的安全性。

- 它们不检查包的有效负载。
- 它们不维持连接状态。

以下这些问题使包过滤器不能独自完成保护网络安全的任务。

① 非服务指定的安全

包过滤只根据报头信息决定通过还是放弃包——它们并不检查包的内容是否有危险或数据是否错误。因为这个原因，包过滤器自身不能构成有效的安全体系。

例如，流回用户网络的 HTTP 内容可能包含嵌套在 Active X 控件中的特洛伊木马。包过滤器并不能判断出这种情况，所以它简单地让这个包进入了用户的内部网络。或者用户可能允许通过 SMTP 的 25 端口访问自己的邮件服务器来接收邮件，但是过滤器不能判断出一个带有恶意内容的邮件通过了它，而这个恶意的邮件可能破坏邮件服务器。

服务指定的安全必须通过由代理服务器和真正的防火墙使用的服务指定过滤器才能实现。

② 非连接状态的安全

大多数的包过滤器是无状态的，也就是说，它们不维持使用中的连接的状态信

息，它们简单地根据包中包含的信息来决定通过还是放弃这个包。无状态包过滤器不能决定通过还是放弃分段，因为它们不维持分段服务端口的信息。无状态包过滤器也不能决定何时返回一个套接字连接来响应从内部网络建立的连接，所以它们必须被配置为通过那些在普通返回套接字范围内的所有 TCP 端口。因为这个原因，许多早期的包过滤器简单地让 1024 以上的所有 TCP 端口的数据包通过。

现在流行的端口过滤器和防火墙都使用状态信息来跟踪连接状态，因此更能正确地控制通过网络的包的路由过程。

如果不能使用代理服务器来消除在网络边界上的路由问题，就使用基于状态的包过滤器功能与网络地址转换功能相结合。

③ 操作系统的包过滤功能

现在的大多数操作系统，包括 UNIX 和 Windows NT，都把包过滤功能作为 TCP/IP 层次结构的一部分包含进来。这就意味着用户可以根据每个服务器的具体功能来为其配置它们独有的过滤规则。这被称为终端系统包过滤功能，因为是路由路径的终端计算机，也就是由包实际要被发送到的主机来执行过滤功能的。

一些中间系统，如包过滤功能路由器和防火墙，可以被配置为根据最终的地址来判断是让包通过还是放弃包，这样一来，似乎终端系统包过滤功能就没有必要了。但是没有边界系统可以保证用户的服务器不受内部攻击，或是通过利用拨号连接的方法，绕过边界安全的攻击。

通过直接在服务器上备份包过滤功能，就可以提供一个安全性极高的保证。在边界安全失败时或是攻击来自内部网络时，这个安全性是存在的。

应该使用操作系统的包过滤功能来保证只为那些公开的协议提供服务。基于主机的包过滤功能使用户可以保证每个服务器只根据自己的意图提供服务。

2. 状态检查包过滤

标准的包过滤器有许多缺点，而这些问题都源于这样的事实：简单的在通信中的包过滤器不能维持足够的信息来决定是否应该放弃这个包，因为它只是一个大的通信中的一小部分。状态检查包过滤器通过记住通过防火墙的所有通信的状态，并根据这些记录下来的状态信息来决定是否要放弃某个包，从而解决了这个问题。状态检查过滤整个通信流，而不仅仅是包。

状态检查包过滤器通过记录通过过滤网关的建立对话的信息来记住网络层和对话层的连接状态。然后过滤器就根据这些信息区分出哪些是有效连接请求，哪些是无效连接请求或黑客行为。

大多数无状态包过滤器简单地允许在 1024 以上的所有端口通过防火墙，因为这些端口被用来返回在防火墙内启动的套接字连接。这样很不安全，因为没有什么可以防止特洛伊木马在网络内部等待开启在 1024 以上的服务端口，所以无状态包过滤器不能防止这种类型的攻击。

相反地，除了那些设计允许的服务和已经在状态表中的连接外，状态检查包过滤器不允许其他任何服务通过防火墙。

当一个可信任的内部主机与一个不可信任的外部主机上的一个 TCP 套接字连接时，与连接同步(SYN)包一起传输的还有准备接收响应的套接字(IP 地址和端口)。当 SYN 包被路由通过状态检查包过滤器时，过滤器在它的状态表中建立一个包含目标套接字和响应套接字的条目，然后将包发送到不可信任网络上。当响应返回时，过滤器简单地在它的状态表中查找包的源套接字和目标套接字，如果查明它与希望的响应匹配，就让这个包通过。如果在状态表中没有这个条目，包就被放弃了，因为它不是内部网络请求的。图 4-3 表示无状态过滤器的建立阶段。

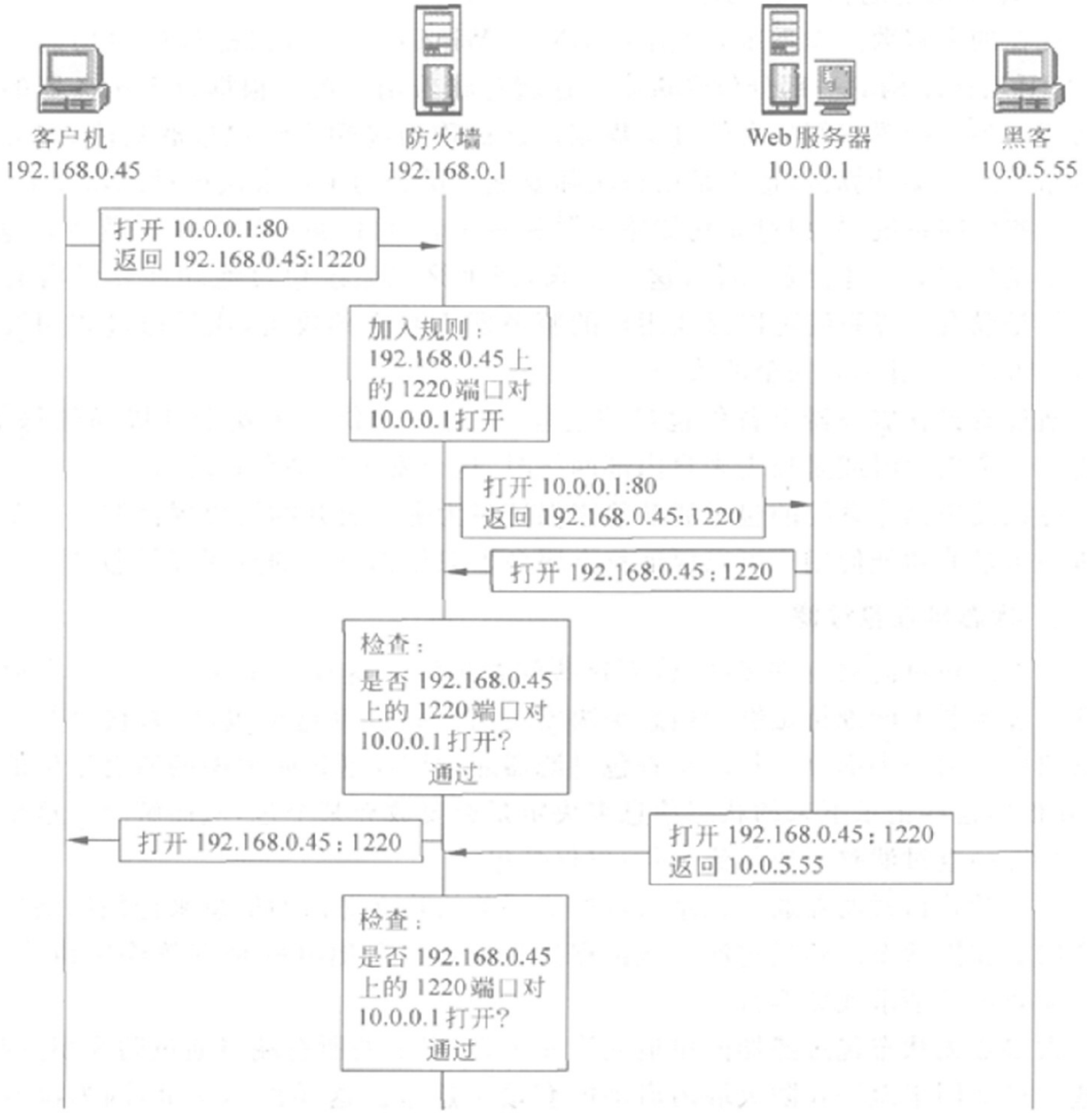

图 4-3 一个状态检查包过滤器允许返回的数据

当 TCP 关闭对话协商包被发送通过过滤器时，或者在一段延迟之后（这段延迟通常是几分钟），过滤器就将这个条目从状态中删除。这就保证了放弃的连接不会在状态表中留下“漏洞”。图 4-4 表示的是一个过滤器正在删除允许从连接中返回数据的条目。

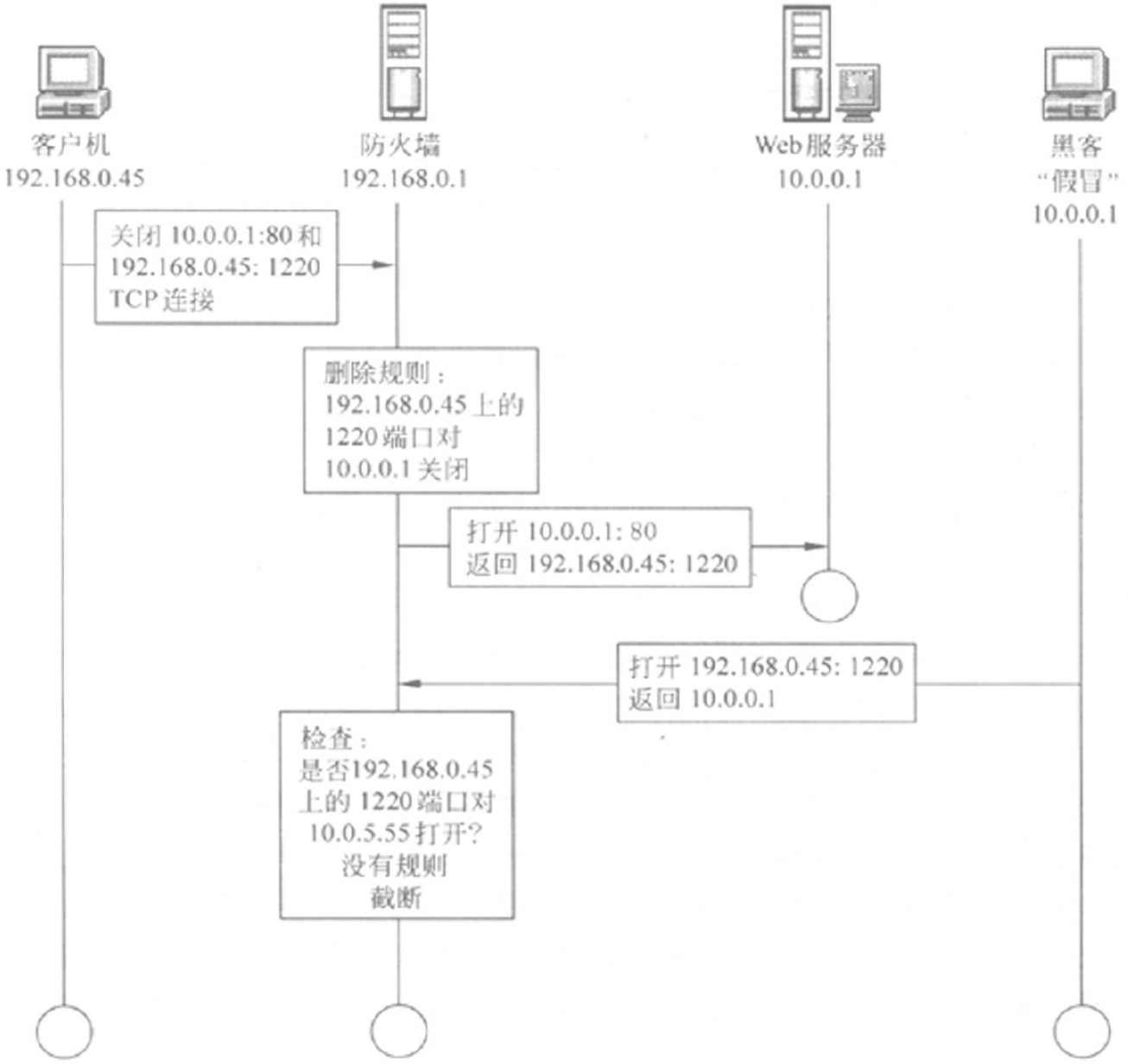

图 4-4　状态检查包过滤器的删除过程

状态检查包过滤器使用规则（通常也称为策略）进行编辑，这些规则改变过滤器的基本行为。策略通常包括一般被放弃的包的规则、从不被放弃的包的规则、允许外部与内部主机进行连接的服务的规则等。在一个多功能防火墙上，策略还控制着网络地址转换功能和代理功能，并一般将 IP 地址、网络和端口归纳为对象、域和服务。

因为状态检查包过滤器可以过滤所有无状态包过滤器能够过滤的相同信息，以及从防火墙那边启动连接的分段部分，和其他更复杂的信息，因此状态检查包过

滤器更安全些。

无状态包过滤器仍未能解决高层协议(如 HTTP 和 FTP)的内部协议分析问题,但是防火墙(如 Firewall-1)却为一般的协议(如 HTTP,FTP 和 SMTP)提供了"类似代理"的高层过滤服务。尽管这要比没有高层检查安全得多,但仍不能保证包像使用代理服务器那样工作,所以恶意的原始数据仍有机会通过过滤器到达内部网络。

3. 通过包过滤器进行的黑客行为

黑客使用许多众所周知的方法来绕过包过滤器进入网络内部。他们利用包过滤的安全问题如下:

- TCP 只能在第 0 个分段中被过滤。
- 许多包过滤器允许 1024 以上的端口通过。
- 特洛伊木马可以使用 NAT 使包过滤器失效。

这些攻击方法将在下面分别详细介绍。

(1) TCP 只能在第 0 个分段中被过滤

无状态包过滤器只根据它自己的方法对每个包进行检查,并不保留前一个包的信息,因此,当一个分段包要通过时,只在第 0 个分段中才有 TCP 报头信息。这就意味着尽管包过滤器放弃了第 0 个分段,它也不会放弃 0 之后的分段。

许多操作系统的 TCP/IP 结构实际上并不注意分段顺序,只是当这些操作系统接收到带有结束分段标志设置的包时,才简单地重新组装这个被分段了的包。如果这些分段了的包的 IP 缓冲数据可以形成一个有效的包,将把数据包送到操作系统处理。黑客正是利用了这一点,让数据通过包过滤器到网络中指定的计算机。通过传送那些分段号被设置为 1 的包,而实际上这个分段却包含整个 IP 包,过滤器将忽视这个 TCP 包中的有效负荷而让它通过并到达网络内部。被寻址到的终端系统看到这个最后的分段信息被设置之后,就把这个 TCP 包送到操作系统去处理。通过这种方式,黑客可以直接连接到网络内部的主机上,而似乎包过滤器根本就不存在。

解决这个问题的两个办法是:在内部主机中使用更好的 TCP/IP 层次结构;使用像防火墙一样的基于状态检查的包过滤器。Windows NT 的 Service Pack 3(服务器补充软件包版本 3)及以上版本为解决这个问题而加强了 TCP/IP 层次结构,但是早一些的 NT 版本没有这项功能。许多 UNIX 的实现产品也针对黑客的这种攻击相应地作了功能上的改进,但是仍有许多产品没有改进。用户可以在 Web 网上寻找需要的版本,来确定这种功能是不是对自己的操作系统有效。

(2) 阻断低端口的过滤器并不能捕获高端口的连接

无状态包过滤器和由 ISP 提供的包过滤服务通常都打开 1024 端口以上的端口,这样可以建立返回主机的套接字连接。这也意味着用 1024 以上的 TCP 端口

的任何协议都不受包过滤器保护。

用户的包过滤器应保证是基于状态检查的，除了那些允许的和由内部网络启动的连接外，阻断所有入站连接请求。

(3) 内部 NAT 可以使过滤功能失效

如果网络内部的用户在一台机器上(例如，在一台 Linux 计算机上)设置了一个网络地址转换程序，那么这台机器就可以用来执行端口和地址转换，它可以将一个在高的、未过滤端口(比如 8080)上的协议改变为一个过滤端口(80)上的协议，然后让改变后的协议到达内部服务器。内部代理服务器也有这个缺点，这就意味着可以对内部服务进行不受控制的访问。

特洛伊木马正是执行的这样一种协议转换功能，目的就是为了使黑客能直接访问内部网络。不留心的用户可能从用户的电子邮件地址得到一个电子邮件，并执行邮件附件中的一个安装程序，而这样做也就安装了特洛伊木马。黑客可以使用这个特洛伊木马的网络地址转换程序绕过用户的过滤器。

4. 包过滤功能的最佳运用

纯包过滤器会受到几个严重安全问题的威胁。可以使用下面推荐的方法来保证包过滤器的安全：

- 如果不能使用代理，至少使用一个无状态过滤器。
- 在默认状态下，让所有端口失效。
- 保证基本操作系统的安全。

下面对这些实现方法进行详细描述。

(1) 使用一个真正的防火墙

首先，使用一个强有力的防火墙是最重要的。建议使用正确的基于状态检查的包过滤功能的防火墙与服务指定、基于代理的过滤功能和网络地址转换的结合。

不要认为简单的包过滤器或操作系统的包过滤功能可以保证网络的安全，实际上纯包过滤器不足以保证一个网络的安全。

(2) 在默认状态下，让所有端口失效

在默认状态下，不要让其他协议都可以通过，而只阻断那些认为危险的协议。尽管这样做方便，却为特洛伊木马的攻击和不希望的用户模式服务(如 PcAnywhere)打开了方便之门。

在默认状态下，应该阻断所有端口，只让自己希望服务的端口和内部网络启动的连接返回通道通过。

(3) 保证基本操作系统的安全

确认基本操作系统是安全的这一点很重要。同所有的安全软件一样，包过滤器的安全也是基于其运行设备的安全。大多数包过滤器设备(路由器)都可以通过 Telnet 进行配置，这也就意味着黑客也可以通过 Telnet 进入包过滤器并重新配置

它，让它打开更多有用的端口。

4.3.2 代理

代理(proxy)程序用于防火墙环境中，以使内部受保护的网络可以继续访问外部网络。从工作原理的角度来划分，代理可分为应用级代理和电路级代理两类。目前有多种实际应用的代理程序，大多数运行在防火墙系统中，在内部网之间传递请求。

代理的主要作用有

- 当防火墙失去部分访问控制功能以后，可利用代理实现访问控制。
- 限制客户的服务请求。
- 限制某些应用的命令使用，从而限制应用协议软件可能带来的危险。
- 可以对数据包中携带的各种信息进行检查，以保护系统安全。
- 隔离内外网，并隐藏内部网络的主机地址，从而增强内部网络的安全性。

代理程序可以提供详细的注册及审计功能，这大大提高了网络的安全性，也为改进已有软件及系统的安全性能提供了可能。

1. 应用级代理

应用级代理与电路级代理的主要区别是实现方法上有所不同，但从工作过程来看却非常相似。本节所指的代理是应用级代理。

应用级代理通过侦听网络内部客户的服务请求，然后把这些请求发向外部网络，就好像代理服务就是原始的客户一样。当代理服务器从公共服务器那里接收到响应时，再将响应返回给客户，就好像它就是原始的公共服务器一样。图 4-5 详细地描述了这个过程。

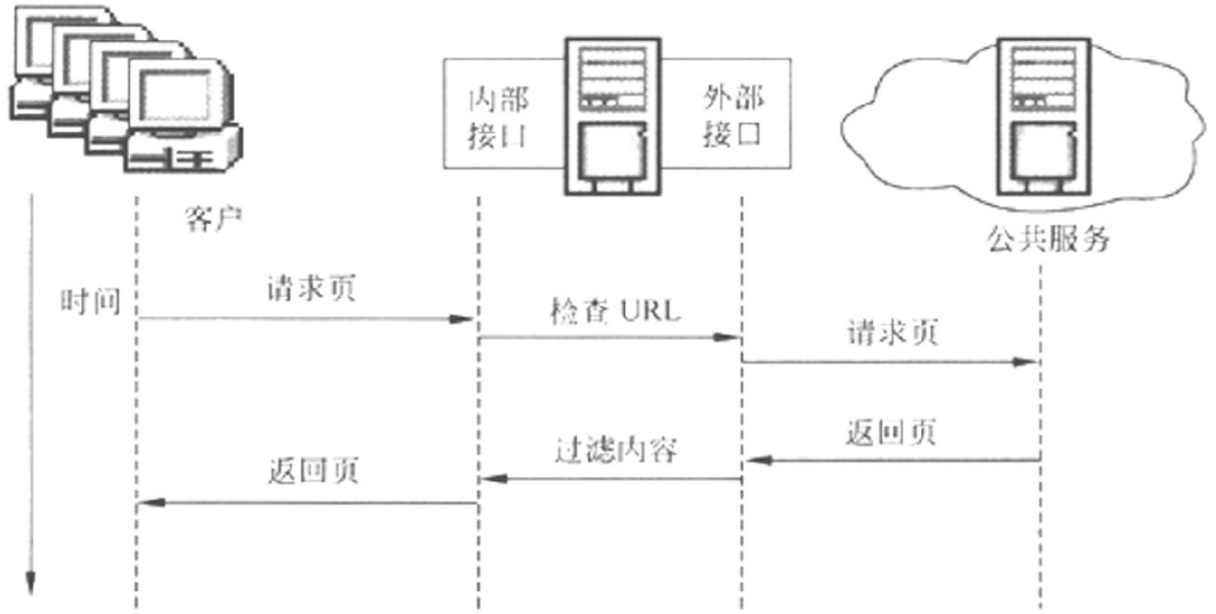

图 4-5 一个服务代理示意图

(1) 应用级代理的安全特点

请求重新生成的过程和代理位于内部和外部网络之间的这个事实,使应用级代理表现出许多安全特点:

- 代理隐藏了私有客户,而不让它们暴露给外界。
- 代理能阻断危险的 URL。
- 代理能在危险的内容传送给客户之前将它们过滤掉,如病毒和特洛伊木马。
- 代理能检查返回内容的一致性。
- 代理能消除在网络之间的传输层进行的路由。
- 代理提供了单点的访问、控制和日志记录功能。

每个安全特点将在下面详细论述。

① 代理服务器的主要安全功能就是隐藏客户。同网络地址转换一样,从因特网上看代理服务器可以使整个网络看上去像一台机器,因为只有一台机器向因特网发送请求。

代理服务器防止外部主机对内部机器上服务的连接。在代理服务器的情况下,不存在到客户的路由表,因为在内网与外网之间不存在传输层的路由功能。

代理完全重新产生服务级请求而不是简单地改变和重新计算地址报头。例如,当 Web 客户通过代理服务器发出了一个请求时,代理服务器接收这个请求,就好像代理服务器就是外部网络上的目标 Web 服务器一样。然后代理服务器重新产生对外部网络的请求,就好像它是典型的 Web 服务器一样。当代理服务器从外部 Web 服务器上接收到响应时,再把这个响应传送给内部客户。只有 HTTP 才能通过代理服务器,而 TCP 和 IP 不能。TCP/IP(和其他低级协议)由代理重新产生——它们并不通过代理进行路由,除非代理被错误地配置。

隐藏客户的另一个方面是隐藏复合连接,即一个代理服务器可被用来共享一个因特网连接和在整个网络的 IP 地址。因为这个原因,轻型的代理服务器,如 WinGate,在家庭和小办公室环境中非常流行,在那里只有一个拨号和专用连接可以使用。

② 阻断 URL 可以使网络管理员根据其 URL 禁止某些 Web 站点的内容通过代理。这样做理论上可以不让用户的雇员访问那些用户不希望他们访问的站点。这个功能很容易完成。在代理重新产生请求以前,代理简单地根据一个拒绝 Web 页的列表检查每个对 Web 页的请求(或其他服务 URL)。如果这个 URL 被阻断了,代理将不发送请求或返回到这个页。

对于管理员来说阻断 URL 的另一个主要问题是不断更新 URL 数据库,保持阻断一些站点及其变化。有问题的站点如黑客工具库、色情站点或游戏站点等,它

们的生存期非常短——它们弹出和消失得一样快。大多数喜欢这些活动的人都会使用搜索引擎或 Usenet 新闻列表，来跟踪那些他们喜欢的站点的移动位置。用户不可能使阻断的 URL 数据库总保持领先于这些活动。

③ 因为应用代理重新传送所有协议的有效数据是协议专用的，代理服务器就可以用来在有效数据部分中寻找可疑内容。这意味着如果用户认为 ActiveX 控件、Java applet，甚至是大的图像有安全问题的话，可以配置 HTTP 代理服务来剔除它们；如果用户认为可执行的邮件附件和压缩文件有问题的话，可以使用 STMP 代理服务来剔除它们。

内容过滤器也可以用来检查 Web 页中特定字或词的出现，如用户的竞争对手的商标或一些流行的新闻词汇。

应该过滤掉 Web 站点中的 ActiveX 控件、电子邮件中的 Java applet 和可执行文件，因为它们可以被用来在用户的网络中安装特洛伊木马。如果有人需要传输可执行文件，可以让他们用 Zip，BinHex 或其他的编码器将内容转换成文本格式进行传输。虽然这样做还要解码，但是可以防止病毒或特洛伊木马偶然进入用户的网络。

④ 一致性检查指的是，检查协议的内容来保证这个协议内容是有意义的。一致性检查经常被用来确保特定的恶意攻击不会被用来发现网络上的安全漏洞。

例如，早期版本的 UNIX 的 sendmail SMTP 进程就是一个很不好的容易受各种缓冲区溢出问题影响的程序。当电子邮件信息的内容比其声明的要大时，缓冲器溢出的情况会发生。sendmail 将为这个信息声明内容留出它所声明容量的内存缓冲区，然后扫描信息，直到遇到文件结束标志。如果在声明结束点和实际文件的结束点之间的区域中包含可执行代码，黑客就可以获得进入电子邮件服务器的根用户访问权限。

还有缓冲区溢出问题出现在长于 256 个字符的 URL 中。早期的 Web 浏览器就有这个问题，因为 URL 中第 256 个字符后的字符可能包含可执行的代码，而这些代码可以由浏览器软件执行。

与代理软件综合在一起的一致性检查能够保证在代理上消除这类问题，这样它们就不会影响内部机器了。然而，要检查的问题通常是在黑客利用它们之前是没有人知道的，所以大多数的一致性检查都是在发现有被利用的弱点后才有效。

传输层包不需要路由，因为请求安全是被重新产生的。这就消除了传输层的弱点，如源路由、分段和不同的服务拒绝攻击。通过消除路由功能，可以确保那些没有建立代理服务的协议不会被发送到公共网络上。

阻断路由功能可能是代理服务器中最重要的优点。因为没有 TCP/IP 包可以真正在内部网络和外部网络之间传输，并且可以防止大多数的服务拒绝和利用软件弱点的攻击。然而，阻断路由功能通常使用得并不充分。因为有许多协议存在，

但却没有好的相应的应用代理服务，管理员通常要启用这个代理服务器的路由功能，而这样完全消除了断开连接而获得的安全性。如果可以，就允许低层网络包通过用户的代理服务器。

代理的最后一个安全优点是它所能提供的记录日志和警告实用工具。代理保证所有内容都通过单一的点，这个点就成为用户检查网络数据的检查点。大多数代理软件都能记录用户对代理的使用情况，并可被配置为维护他们访问站点的一个日志文件。如果发现用户的 Web 浏览对话中有一些非法或不道德的语言，就可以重新建立用户的 Web 浏览对话。

一些代理提供的警告实用工具可以警告用户正在遭受攻击(即使一个服务器的代理实用工具一般不会遭受攻击)。这些实用工具可以警告用户来自外部接口上的代理连接请求，而这些外部接口是黑客经常利用来建立连接的。

(2) 代理的执行方面

除了上面提到的安全方面以外，代理服务器也有性能方面的重要特点，分别为

- 代理可以缓存频繁访问的数据，这样通过消除对较慢的外部网络的冗余访问来提高执行性能。
- 代理可以平衡内部许多服务器的负载。

最初开发代理的目的就是改进性能，而并不是作为安全设备。在 Web 刚出现的时候，只有几万个站点，大多数都是科学站点，并且也不常变化。因为广域网连接到因特网比较慢。代理可被用来缓存本地 Web 的大部分内容，这样因特网用户就可以简单地从本地代理服务器那里进行浏览了。因为内容变化的并不快，所以这样做是合理的。

使用缓存功能只是当大量用户频繁访问同一个 Web 时才是合理的。现在这种用法已经很少用了，因为代理服务器的缓存功能差不多已经过时了。

随着电子商务的流行，缓存又重新成为了一个重要的功能，因为许多人将通过频繁地访问几个站点来交互地完成他们的工作。考虑下面的例子，如一个旅行社使用 Expedia.com 和 Travelocity.com 来完成它的工作，许多业务员将一遍一遍地访问这两个站点，所以缓存这两个站点的主要站点元素、图形和 applet 就很有必要。

新一些的代理服务器可以用作“反向代理”，或者说是为内部客户提供到外部服务器的代理服务。这个功能是用来平衡跨越大量 Web 服务器的客户机负载的。许多功能强大的 Web 站点使用诸如 ISAPI 应用程序，active sever page(ASP)，Java applet 或 CGI 应用程序等复杂的应用程序。这些程序在服务器上执行，这样它们大大减少了服务器可以处理的用户请求数量。例如，运行 IIS 的一个 NT 服务器可以合理地处理 100 000 个标准的 HTML 页浏览者，也许只能处理这个服务器上的一个 ASP 页的 5 000 个浏览者。

这意味着大多数电子商务功能实际上不能在一个服务器上进行处理，这样，站点就必须并行地运行在许多计算机上。例如，微软的站点 www. microsoft. com 现在在 30 多个同样的 Web 服务器上运行。DNS 也提供了一个基本的负载分配机制，通过这个机制对子 DNS 域名的访问将提供大量 IP 地址中的一个，但这样做实际上并不能平衡负载。只是在许多静态的同等访问发生后，这个机制才实际上平衡了客户负载。

一个代理服务器可以用来响应一个 IP 地址，然后再把客户连接分成到它后面的许多站点服务器上的连接。这个代理服务器也可以使用由每个 Web 服务器提供的尺度来了解哪个服务器现在的可用能力最大。每个连接的客户都可以被分散到能最好地处理它的服务器上。因为与用于电子商务的 Web 页相比，代理实际上并不做多少工作，所以它可以比它后面的电子商务服务器处理更大量的指令和更多的客户连接。图 4-6 表示的是一个代理服务器平衡许多电子商务服务器的负载的示意图。

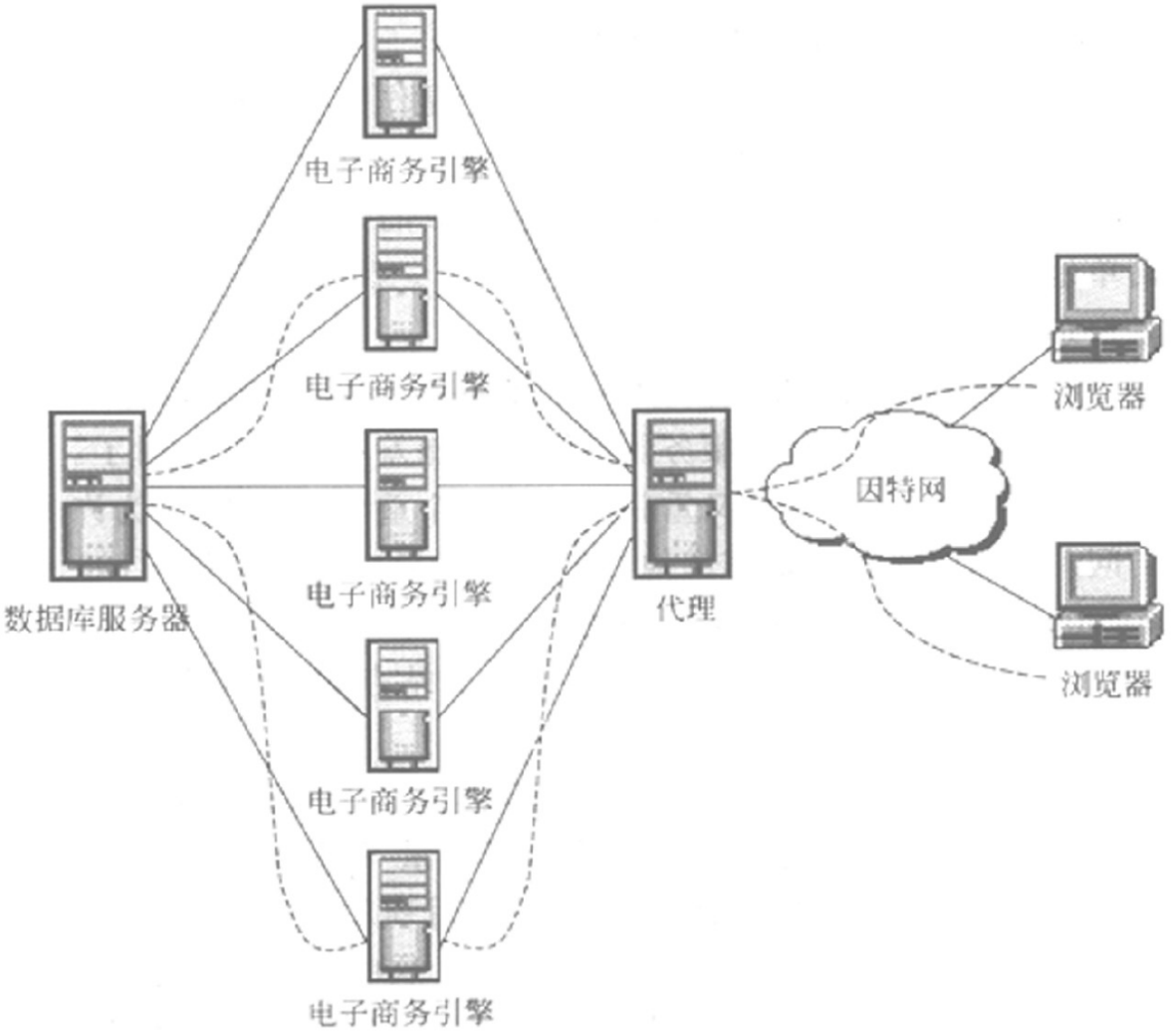

图 4-6 代理服务器的负载平衡功能

(3) 代理的安全责任

应用代理受下面一些安全责任的影响：

- 代理产生单点的错误。
- 客户软件必须能与代理一起工作。它们不能被配置为在网络上透明工作。
- 每个服务都必须有代理。
- 代理并不保护基本的操作系统。
- 默认的配置通常是性能上的优化而不是安全上的。

与任何单点控制相应的就是单点错误。如果黑客可以使代理不能工作，网络也就与因特网切断联系了。

代理、路由器和防火墙都在某种程度上受这个问题的影响。对于路由器，这个问题较容易解决，只要简单地多设置几个因特网的路由路径就可以了。防火墙比纯代理要安全得多，因为它们有低级的包过滤功能来消除这个由服务拒绝攻击带来的问题。然而，纯代理服务器并没有这方面的功能来保证它们不受到这些攻击，所以它们对于入侵和服务拒绝非常脆弱。

因为这些原因，用户的代理服务器必须有强有力的包过滤功能的服务和操作系统的包过滤机制来进行保护。包过滤器应该有过滤 ICMP，IP，TCP 和 UDP 的能力。

对于每个要使用的代理服务都必须存在可使用代理的客户机。例如，用户的 Web 浏览器必须支持到代理服务器的连接，这就须将浏览器的配置选项设置为所有请求通过那些代理服务来传送。如果客户软件不能被配置为使用代理，就不能使用代理服务，除非和真正的网络地址转换器连接在一起。这对于像 FTP 那样的服务，即其与操作系统一起发送的客户软件不支持连接到代理服务器来说，是主要的问题。不过，用户可以为这些服务购买代理客户程序。

带有地址转换功能防火墙的代理服务能绕过这些限制，因为它们可以改变入站和出站地址。这意味着客户不需要知道或不需要被配置为与代理一起工作，因为代理实际上是真正带有地址转换功能防火墙的一部分。

不同的应用代理服务需要支持不同服务的协议。网络地址转换是通用的，并且可以和任何协议(除了依靠嵌入了有效载荷的 IP 地址信息或需要为客户建立返回通道功能的协议外)一起工作。不能使用代理服务的协议不能通过代理进行连接，除了通过电路级的代理服务(如一般的 SOCKS 代理)，不过这样的服务都没有内容过滤的功能。

许多服务不能轻易地被代理，因为它们需要建立一个返回通道。只有那些维护预期返回套接字表的代理器才能代理像 H.323(网络电视电话会议需要使用的协议)那样的服务。

许多服务都是在没有有效的内容过滤器的情况下使用的。基于流的服务(如 RealAudio 或 RealVideo)很难进行内容过滤，因为内容一定是实时流动的，并且在

压缩流中的任何中断都将使剩余部分很难进行内容过滤。由于这样的内容不能被可靠地进行过滤，假如考虑到对安全的威胁就不要使用它们。

许多代理服务器软件包都有基本的默认配置，而这些基本的默认配置会导致严重的安全问题。例如，WinGate，是家庭和办公室最流行的代理服务器，是用来共享一个因特网连接的，而不是用来解决安全问题的，因为这个原因，软件的制造商使它对于那些不理解代理的人可以容易地设置，并且能通过默认配置使大多数的普通协议都能工作。

许多代理服务器都受到基本默认配置问题的困扰，因为它们通常是为那些缺乏计算机经验的用户设计的，并把性能和功能放到了比安全更重要的地位。大多数代理服务器都能被正确地配置，但是一旦用户完全安装完软件后，通常就忽视了这个软件。

(4) 代理的执行责任

代理服务器建立一个服务瓶颈。

同防火墙和路由器一样，如果网络用户数量增加时代理服务器没有正确地升级，一个连接到因特网的代理服务器就会造成一个瓶颈。尽管代理最初是通过执行它们的缓冲机制来提高执行性能的，但若使用代理服务器的客户比代理服务器能有效支持的用户数要多时，就要使每一个人都要等待这个慢机器。注意对代理瓶颈的不满意实际上是由因特网通道的缓慢引起的。如果用户只使用一个因特网连接，并且是 1T(1.5MB/s)或更慢的连接，任何计算机(实际上满足操作系统和代理服务器最小需求的)都能快到足以处理负载。代理瓶颈只发生在比 1.5MB/s 快的网络连接中或者是代理服务器有问题的情况下。

这个问题非常容易解决，即增加更多的代理服务器。与 Web 站点和其他公共服务器不同，在许多机器之间的一个代理服务器不需要有完全相同的配置。用户可以直接将任何数量的代理服务器连接到外部网络上，并基于随机或平均分配的原则，为每一个网络内的客户机指定一个服务器。例如，如果有 4 台正在运行的代理服务器，只需按顺序循环地将每一个客户机分配给代理服务器，4 个一轮。这样做可能会失去缓冲效果，因为不同代理上的一个客户访问的站点并不能由其他的代理访问。

用户也可以使用复杂的、高性能的软件和 TCP/IP 负载平衡功能来处理多个代理的连接。但是这样做却需要更多的开销，并且效果不一定显著。不过，虽然它的确提供了代理的冗余，但是当某个用户段分配的代理停机时，这个用户段上的用户就会丢失服务。

2. 电路级代理

电路级代理从工作的过程来看，与应用级代理的区别不大，它们都是由一个代理服务器为客户机与应用服务器建立连接，代理服务器在客户与应用服务器之间

中转数据。从应用服务器的角度来看，代理服务器是客户。

但从工作原理来看，或者从它们在 OSI 七层模型中工作的位置来看，两者有明显的不同。

应用级代理可以受理存储转发的流量以及某些交互流量，通过编程来弄清用户应用层的流量，并能在用户和应用协议层提供访问控制。对于每一个它所转接的应用程序，应用层代理使用一个特殊的目的代码。用户的代码程序必须针对每个应用而写，这是它的缺点，但从安全的角度来看，这也是一个优点。

电路级代理中，包括提高给用户应用层处理。电路级代理用来在两个通信的终点之间转接包，它只是简单地在两个终点之间来回拷贝字节，如图 4-7 电路层应用程序网关工作过程所示。

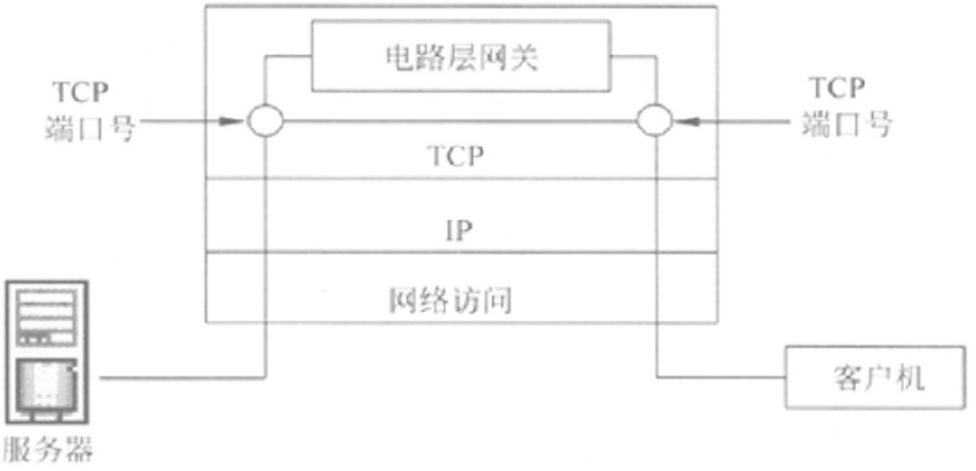

图 4-7　电路层应用程序网关

电路级代理是一种更加灵活的方法，它不需要为每个应用编写特定的代码，但可能需要安装特殊的客户机软件，用户可能需要一个可变的用户接口来相互协作。

(1) 电路级代理 SOCKS 的工作原理。

SOCKS 是一种典型的电路级代理协议，目前有两个版本的 SOCKS 协议，即版本 4 和版本 5，分别简称为“SOCKSv4”和“SOCKSv5”。

当客户想建立到应用服务器的连接时，应该连接到代理服务器。应用服务器的地址和端口号通过代理协议被传递到代理服务器，然后，代理服务器再连接到应用服务器。一旦应用服务器的连接被建立，代理服务器就会在客户与应用服务器之间中转数据。

SOCKS 服务器与 SOCKS 客户在 OSI 模型中的位置如图 4-8 所示。

(2) SOCKS 模型

由于 SOCKS 协议很简单，得到了广泛应用，世界著名的网络安全产品提供商都纷纷宣布对它的支持。

因为 SOCKS 服务器是以客户的身份展现给应用服务器，从而真正的客户被

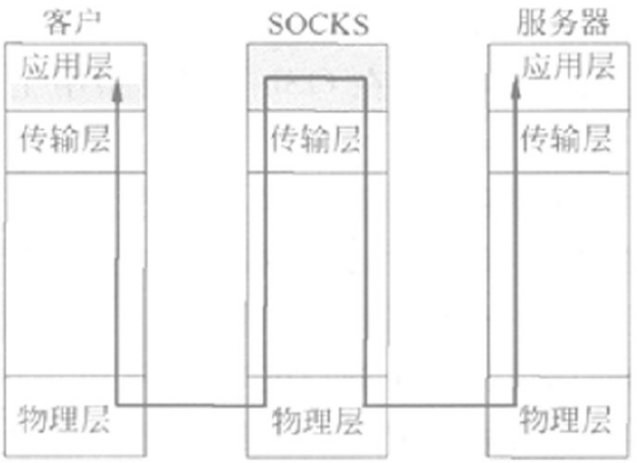

图 4-8 SOCKS 基本组件在 OSI 模型中的位置

隐藏，SOCKS 服务器为网络提供对外网络的单一访问接口。

SOCKSv4 协议执行三个功能，即连接请求、代理链路的建立和应用数据中转。SOCKSv5 协议则又增加了鉴别功能。图 4-9 显示了 SOCKSv5 的控制流模型，虚线框中的部分代表 SOCKSv4 的功能。

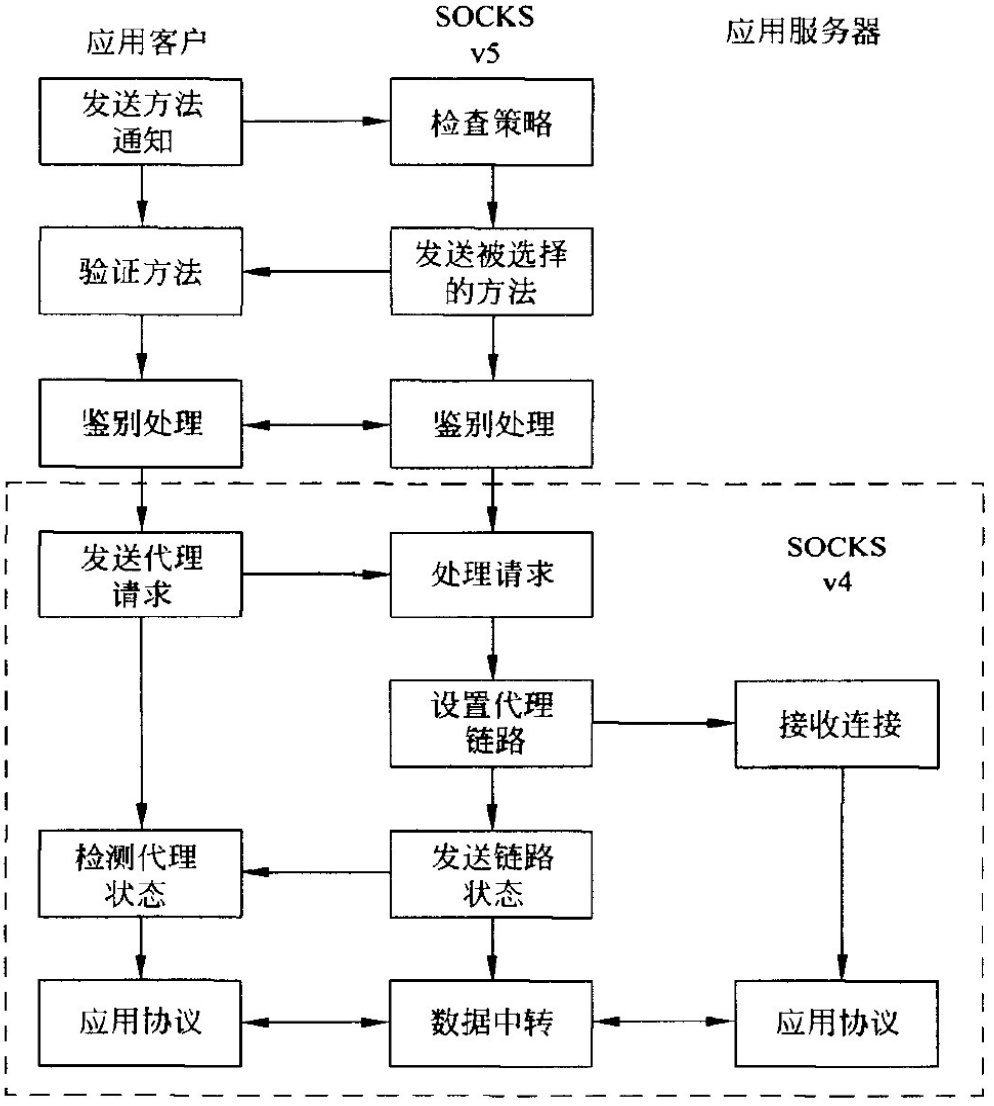

图 4-9 SOCKS 控制流程

当应用客户需要请求外部网络的应用服务器服务时，首先与 SOCKS 服务器建立连接，它向 SOCKS 服务器发出连接请求及相关的信息(如所支持的鉴别方法列表)；SOCKS 服务器接到信息后，就会检查安全配置策略，并返回服务器选择的安全鉴别方法；SOCKS 客户再对服务器所作的选择进行验证，SOCKS 客户及服务器分别根据选择的鉴别方法进行处理。SOCKS 客户向 SOCKS 服务器发送代理请求；SOCKS 服务器处理客户的请求，设置代理链路，建立与应用服务器的连接，并向 SOCKS 客户发送设置状态。而后，SOCKS 服务器可以在 SOCKS 客户与应用服务器之间中转数据。

(3) SOCKSv5 的特点

SOCKSv5 协议也称为被鉴别的防火墙穿越(authenticated firewall traversal，AFT)，是一个开放的在传输层执行网络代理的 Internet 标准。它解决了几个 SOCKSv4 没有解决或忽略了的问题。它的新特点是

- 强有力的鉴别
- 鉴别方法的协商
- 地址解析代理
- 支持 UDP 应用
- 信息的完整性和机密性

有两个与 SOCKSv5 相关的标准支持的两种鉴别方法，分别为

- Username/Password 鉴别(rfc 1929)
- GSS-API(generic security service application programming interface)鉴别(rfc 1961)。GSS-API 也支持信息的完整性和机密性。

下面详细介绍一下这些特点。

① 强有力的鉴别

SOCKSv5 增加了对强有力的鉴别的支持。

② 鉴别方法的协商

为了增加对鉴别方法的协商能力，SOCKSv5 增加了两个消息。应用客户发出第一个消息给 SOCKSv5 服务器，声明客户能支持的鉴别方法；SOCKSv5 服务器发出另一消息给客户，以宣布客户应支持的方法。

SOCKSv5 服务器基于在其上的安全政策配置来决定鉴别方法。如果客户申明的安全方法不满足安全要求，SOCKSv5 服务器就会关闭通信连接。

③ 地址解析代理

SOCKSv5 内部的地址解析代理简化 DNS 管理并实现 IP 地址的隐藏和转化。SOCKSv5 客户可传送域名而非解析后的地址到 SOCKSv5 服务器，而服务器为客户进行地址解析。

④ 支持 UDP 应用

SOCKSv5 支持 UDP 联系。UDP 联系创建一个虚拟的代理链路，用于传输基于 UDP 的应用数据。在 TCP 和基于 UDP 的代理链路之间主要有以下两个不同点。

- 对于 UDP 的代理链路是一对接收和发送数据的通信端点的地址。
- UDP 代理链路封装应用数据，包括数据报的目标地址。

⑤ 信息的完整性和机密性

当选定的 GSS-API 鉴别方法支持信息安全，SOCKSv5 客户可与 SOCKSv5 服务器进行协商，以检测完整性、机密性或完整性与机密性。

⑥ 以 GSS-API 为基础的代理(VPN)

用 GSS-API 检测信息的完整性与机密性，这种有效的方法可以用于建立穿越 Internet 的虚拟私有网络 VPN(virtual private networks)。SOCKS VPN 具有以下优点：

- 时间信号
- 基于用户的鉴别
- 在 Internet 中的加密通信隧道
- 透明地访问整个私有网络
- 网络访问的集中控制和审计
- 网络管理本地化
- VPN 环境掩饰

(4) SOCKS 的安全性质

SOCKS 是一个发展的工业标准，是基于特定流的电路级代理协议，它管理网络进出的信息，任何对话由代理发送，从而允许安全地、被控制地访问外部网络。SOCKSv5，这个最新的 SOCKS 版本，是一个 IETF 标准(RFC 1928)，它在 Internet 服务提供商中被普遍接受。

SOCKS 指定基于特定流(flow-specific)的代理功能。为了理解特定流代理的独特作用，我们将它与应用级代理和简单的包过滤进行比较。表 4-1 中作出了总结。

作为电路级代理，SOCKS 独特的贡献是为所有的应用在一种形式下提供一个强有力的安全机制，它容易配置和管理，并且不需要活动规则。SOCKSv4 提供 IP 隐藏和网络防火墙的穿越，而 SOCKSv5 支持更强大的安全机制。

包过滤阻塞非期望的通信，以至于其他网络设备(包括防火墙)也不能处理那些信息。包过滤对于静态的通信管理是有效的，但不能提供强有力的安全检查或动态的适应性，而 SOCKS 具备这些功能。

表 4-1 防火墙类型的比较

安全类型	优 点	不 足
包过滤	快速 容易实现 IP 包括所有信息 不改变客户端应用	不灵活 不隔绝 没有用户级鉴别 登录可行,但常不应用
电路级代理	几乎与过滤一样快 UDP 和 TCP 包括所有信息 用户级鉴别 特定会话安全 特定会话登录 隔绝	客户必须重新配置 无特定应用安全 无特定应用登录
应用级代理	特定应用安全 特定应用登录 用户级鉴别 隔绝	对硬件敏感 客户可能需要重新配置 有限的应用支持 典型地阻塞 UDP 多重鉴别
状态审查	丰富的状态信息 可扩的状态信息 能处理所有的应用	要求活动规则 难以管理和配置

SOCKS 也可以实现应用代理,它提供强有力的安全检查,但不处理所有应用。应用代理仍然有用,因为它们提供其他技术所不能比的安全级别。

SOCKS 比独特的应用代理更好是因为它支持任何会话,而不需为每个应用协议编写独特的代理。

状态审查也提供非常精密的安全功能,但也需要同样精密的配置、管理和活动规则。状态审查会因错误的配置留下安全漏洞。SOCKS 能用较简单的功能审查提供一个安全网络,它因错误配置而留下安全漏洞的可能性较小。

另外,目前除了 SOCKS 外,其他的地址转换技术都不允许私有网络中的客户动态地侦听进入连接。

包过滤、电路级代理、应用级代理和状态审查并不是相互排斥的,相反,它们是相互补充的。许多防火墙的供应商都将其中的两项或三项技术相结合,因为一个产品中提供多项技术,使得用户能在多种特性(例如速度、适应性、扩展的方便性、应用的安全、会话级安全等)之间进行权衡,也允许用户根据需要改变这些特性。

(5) SOCKSv5 的应用

要使用 SOCKSv5 服务,必须安装 SOCKS 服务器,并在 SOCKS 客户机上安

装 SOCKS 客户端程序。以下以 UNIX 操作系统为例，描述客户与服务器的配置方法。

在 SOCKS 环境下，除了在服务器与客户机上分别安装服务程序与客户库外，还要正确配置文件。在默认情况下，服务器的配置文件是/etc/socks5. conf，客户的配置文件是/etc/libsocks5. conf。

下面以双宿主 SOCKS 服务器为例说明 SOCKS 环境的配置情况。

双宿主 SOCKSv5 服务器的示意图如图 4-10 所示。

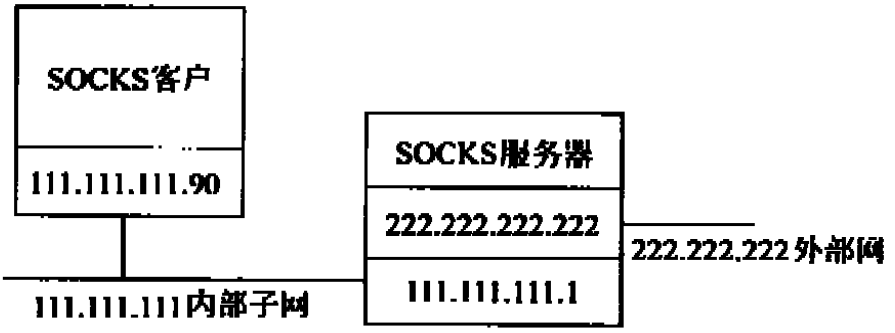

图 4-10 双宿主 SOCKSv5 服务环境示意图

事例 1：简单双宿主例子

• 基本策略

允许内部所有的客户访问外部网络

• 客户配置

```
noproxy     -     111.111.111.     -     -
socks5      -     -          -     111.111.111.1
```

• 服务器配置

```
auth        -     -     -     -
interface   111.111.111.          111.111.111.1
interface   -     -     222.222.222.222
permit      -     -     111.111.111.     -     -     -
```

此配置允许任何鉴别，在内部子网没有代理，并且允许内部子网的所有主机使用 SOCKS 服务。

• 路由表配置

多宿主 SOCKS 服务器的路由表应该

① 取消 IP 转发和源地址路由。

② 阻塞客户机与外部网络之间的通信。

事例 2：两条路通信例子

• 基本策略

允许所有内部客户访问外部子网，并允许从 friendly. external. com 到

111.111.111.90 的 telnet 请求。

• 客户配置

该配置同事例 1 的客户配置。

• 服务器配置

```
interface     111.111.111.     -     111.111.111.1
interface     -     -     222.222.222.222
permit     -     -     111.111.111.     -     -     -
permit     -     -     friendly.external.com     111.111.111.90     -     23
```

注意 一个恶意的外部主机能使用 IP 欺骗或 DNS 侵袭来模仿 friendly.external.com。

• 路由表配置

该配置同事例 1 的路由表配置。

4.3.3 网络地址转换

代理服务器最初的设计目的是使 World Wide Web(WWW)的速度更快。网络地址转换最初的设计目的是用来增加私有组织的可用地址空间和解决将现有的私有 TCP/IP 网络连接到因特网上的 IP 地址编号问题。这两个功能的安全特点与包过滤功能集成在一起,就构成了现在最有效的防火墙。

没有包过滤,代理服务器和网络地址转换都不能完全保证安全;同样,没有代理服务器和网络地址转换,包过滤器也不能提供完全的安全。这些服务必须合并成一个一致的安全功能才是有效的,用户应该使用那些有效利用这三个功能的防火墙来保证网络的安全。本章将对网络地址转换进行详细阐述。

Internet 的扩展速率成指数增长,正因为大量的信息和资源的增长,使得即使是最小的商店和家庭连接到 Internet 也是必要的。网络地址转换 NAT(network address translation)是连接多台计算机(或任何 IP 网络)到 Internet 的方法,它使得家庭和小公司可以方便并且高效地连接到 Internet。

推动 NAT 应用增长的因素主要包括

• 全球 IP 地址短缺

• 安全需要

• 容易并且灵活的网络管理

1. 什么是 NAT?

NAT(network address translation),也称作网络地址转换,指将一个网络内的 IP 地址转换为其他网络中不同的 IP 地址,这个网络被设计为内部网络,而其他的网络为外部网络。典型的情况是,本地的内部网络地址映射为一个或多个全球

IP 地址，全球 IP 地址不映射为本地的 IP 地址。这样有利于确保安全，因为每个外出或进入的请求必须通过一个转换进程，这样就有机会限制或鉴别该请求，或是将它与先前的请求进行匹配。如果组织需要，NAT 也可保存许多全球 IP 地址，并且使用一个 IP 地址与全球通信。一个典型的 NAT 应用如图 4-11 所示。

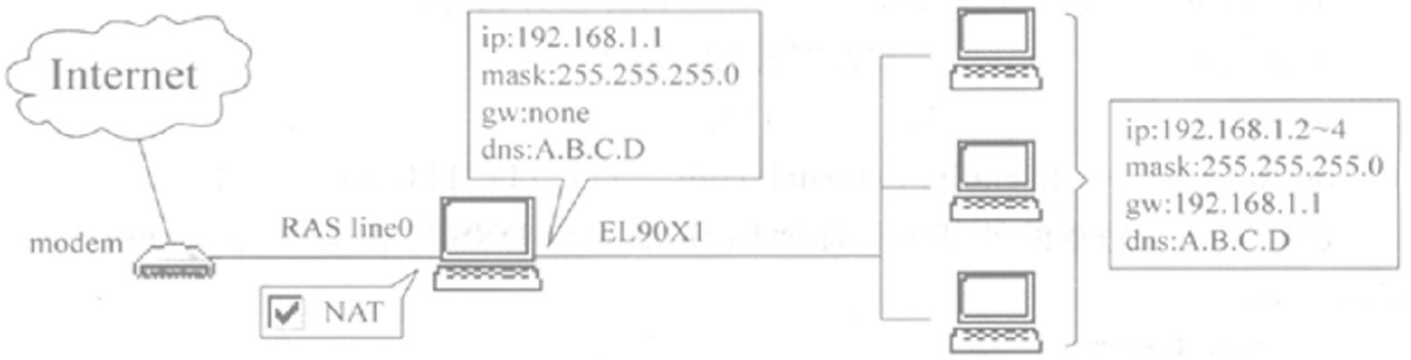

图 4-11 NAT 应用

在该 NAT 应用中，192.168.1.0 的主机使用网关(gw)192.168.1.1，通过该网关的 NAT 转换，在因特网上只能看到 RAS line0 线路的 IP 地址，故隐藏了内部网的结构及地址。

2. 安全考虑

随着 Internet 的扩展和应用的增加，安全问题已非常严峻。对于家庭用户来说，敏感的个人信息，例如电子邮件、信件或财务资料(如信用卡或支票编号)等信息可能被盗走；对于商业用户来说，信息被盗用的后果会非常惨重，如果生产计划、市场战略等公司机密信息被偷走，将导致严重的财产损失，甚至导致破产。

为了解决安全问题，市场出现了大量的防火墙产品，它们被放置于用户与 Internet 之间，在通信信息之间进行检查，使得非授权用户不能访问组织的文件或电子邮件服务等。但是对家庭和小商业用户来说，防火墙的使用比较昂贵，并且配置和维护困难。

NAT 自动提供防火墙式的保护，并不需要任何特殊配置，因为它一般只允许从内部网络所发起的连接。这意味着，一个内部网络客户可以连接到外部网络的 FTP 服务器，而外部网络的客户要连接到内部网络的 FTP 服务器必然发起连接请求，而 NAT 将不允许它的连接请求。为了使一些内部的服务器从外部访问成为可能，可通过入口映射，即映射某些众所周知的 TCP 端口(例如 FTP 服务的 21 端口)为特定的内部地址，这样就使得 FTP，Web 等服务在受控的方式下运行。

许多 TCP/IP 堆栈容易受到低层协议攻击的影响，如“SYN flood”或“ping of death”攻击，这些攻击不会危及计算机的安全，但会导致服务器崩溃，引发潜在的有破坏性的“拒绝服务”攻击。这样的攻击会引发异常网络事件的发生，这些事件会被用作进一步安全破坏的先驱或掩护。不使用主机协议堆栈而提供自身协议堆

栈的 NAT 能防止这样的攻击，原理图如图 4-12 所示。

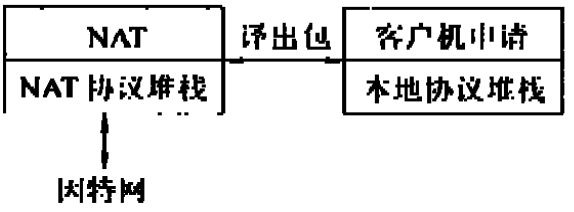

图 4-12　NAT 协议堆栈结构

3. 管理员的考虑

配置 IP 网络比本地局域网要难得多，每一台计算机都需要一个 IP 地址、子网掩码 DNS 地址、域名和一个默认路由器，要将这些信息输入到网络中的每一台计算机中。如果这些信息中某一小部分出现错误，那么网络连接就不能运行而且没有任何错误原因提示。在大型网络中，协调地配置地址和划分子网是一项很复杂的任务，所以需要一名专职网络管理员。

NAT 可以在以下几个方面帮助网络管理。

(1) 它能将一个大型网络划分成几个小的网络。这些小的网络只对外部展示一个 IP 地址，这就意味着可以增加或删除计算机、或改变它的地址却不会影响外部网络，如图 4-13 所示。用入口映射，甚至可以将服务(如 Web 服务器)移到不同的计算机上，而外部客户机却不需作任何改变。

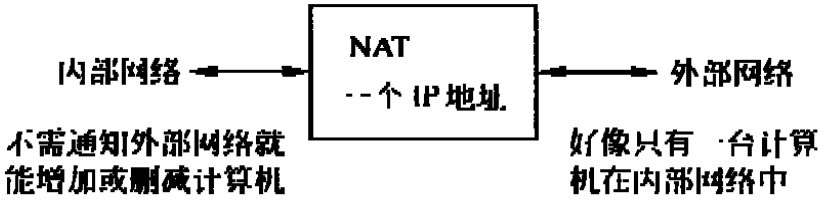

图 4-13　NAT 方便内部网络管理

(2) 一些现行的 NAT 网关包含动态主机配置协议(DHCP)服务。DHCP 允许自动配置客户计算机，当一台计算机接通后，它就开始搜索 DHCP 服务器并得到 TCP/IP 配置信息。网络配置的改变集中在服务器完成并影响到所有的客户机，管理员不必将变化应用到网络中的每一台计算机。例如，如果 DNS 服务器地址有变动，那么，所有的客户机在下次与 DHCP 服务器联系时将自动启用新的地址。

(3) 许多 NAT 网络提供限制访问因特网的方法。例如 vicomsoft internet gateway 有内置式 CyberPatrol 过滤器，这就禁止管理员访问可疑的目标资源。

(4) 另一个有用的特征是通信流量日志。因为来往于因特网中的所有流量都要通过 NAT 网关，所以它能将所有的通信记录在一个日志文档中，如记录由用户、站点或网络连接造成的通信崩溃等。

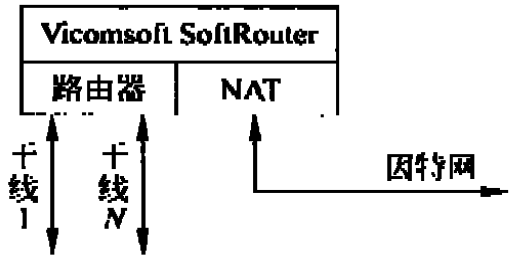

图 4-14　将内部网络划分成若干子网

(5) 因为 NAT 网关在 IP 层运行，所以大多数 NAT 网关有内置的内部网络路由选择能力。它们服务的内网可划分成几个独立的子网(用不同的干线或共享同一干线)，可进一步简化网络管理并允许更多的计算机连接到网络上，如图 4-14 所示。

总的来讲，NAT 网关有以下优点：

- 内部网络的防火墙保护，只有明确地用入口映射指定的服务器，才能从因特网上访问。
- 协议级保护。
- 自动的客户计算机配置控制。
- 包过滤和路由。

4. NAT 和代理的对比

在前文已对代理作了充分说明，这一节中所提到的代理表示 Web 代理。一个 Web 代理充当"half-way"Web 服务器：网络客户对代理提出请求，然后代理代表它们向适当的 Web 服务器提出请求。代理技术常被看成一种对单一因特网连接提供共享访问的方法。Web 代理的主要优点有

- 本地隐藏：代理可以将频繁访问的页面放在本地硬盘上；当这些页面被请求时，它能从本地文件中提供而不必从远程 Web 服务器上下载数据。执行隐藏任务的代理常叫做隐藏代理服务器。
- 网络带宽守恒：如果不止一个客户请求同一页面，那么代理能够只对一个远程服务器提出一个请求并将得到的数据分发给所有正在等待的客户。

这些优点只有在多个客户可能访问同一站点并分享相同数据的情况下才会表现得非常明显。

和 NAT 不同，Web 代理不是一个透明的操作，它必须明确地受到客户的支持。

由于早期采用 Web 代理，大多数浏览器(包括 IE 和 Netscape Communicator)都有内置式代理支持。但是，正常情况下，必须对每台客户机配置这种支持，否则无知的或恶意的用户可以改变它。Web 代理有以下缺点：

- 随着诸如视频和音频技术的广泛应用，Web 内容变得越来越具动态性了。大多数新数据格式是不能缓冲的，这就使代理失去了一个主要优点。
- 客户必须明确地设置使用 Web 代理，只要代理有变化(如代理移动到一个新的 IP 地址)，就必须重新设置每一个客户机。
- 代理服务器在 TCP 层之上运行并使用计算机的内置式协议堆栈。对来自客户的每一个 Web 请求，都要在客户和代理服务器之间建立一个 TCP 连接，在代理服务器和远程 Web 服务器之间建立另一个连接。这使得代理服务负载较重。事实上，因为 Web 页面变得越来越复杂，代理本身可能会变成网络的瓶颈。这与在包级别运行的 NAT 形成对照，它对每个连接的处理要少得多。

5. NAT 操作

NAT 的基本目的是对内部网络的通信流量进行多路复用并提交给因特网，

就像它来自只有一个 IP 地址的单一计算机。

TCP/IP 协议包括多路技术功能，所以任何计算机都可以保持同一台远程计算机的多重同时连接。这种多路技术功能是单地址 NAT 的关键。

为了实现对单一目的地的多个连接，客户计算机用独特的“端口号”标注所有的包。每一个 IP 包包括一个头，它包括源/目的地址和端口编号，格式如下：

源地址	源端口	目的地址	目的端口

这些数字的组合完全定义了一个单一的 TCP/IP 连接。地址指明了在两端的两台机器，两个端口号确保两台机器之间的每个连接都惟一地被识别。

每次单独的连接由客户的惟一源端口号发起，来自远程服务器的对本次连接的所有答复包都包括作为目的端口的相同编号，所以客户能按正确的连接接收包。例如，Web 浏览器能要求 Web 服务器同时提供几个图像，并且知道怎样将所有响应的部分一起正确返回。

一个流行的 NAT 网关必须改变每一个输出包的源地址，作为单一的公共地址。所以也要对源端口重新编号使其惟一，这样就能保持对每一个客户连接的追踪。NAT 网关使用端口映射表来记住它是怎样对每一个客户的输出包进行端口编号的，端口映射表说明了客户的真实的 IP 地址和源端口号，以及为了到达目的地网址和端口而被转换后的源端口号。因此，NAT 网关能反向地处理返回的包并将它们路由到正确的客户机。

当任何远程服务器响应某一 NAT 客户时，所有到达 NAT 网关的进入包都具有同样的目的地址，但目的端口号将是惟一地由 NAT 分配的源端口号，NAT 网关查询端口映射以确定所要到达的真正的客户地址和端口，并在包传递给本地客户前替换其地址和端口号。

这个过程完全是动态的。当从内网客户那里接收到一个包，NAT 就寻找端口映射表中是否有匹配的源地址和端口，如果没有找到，则创建一项新记录，并将这项新的端口映射分配给这个客户。以上过程表示如下：

- 非 NAT 端口接收包(即 NAT 服务器与内网相连的端口)；
- 在端口映射表中查找源地址及端口；
- 如果找到，则用映射表中原分配的端口替换源端口；
- 如果没有找到，则分配一个新的映射端口；
- 用 NAT 地址替换源地址，用映射端口替换源端口。

在 NAT 端口上接收的包经历一个相反的转换过程：

- NAT 端口接收包(即 NAT 服务器与外网相连的端口)；
- 在端口映射表中查找目的端口；

- 如果找到，则用映射表中的记录替换目的地址及端口；
- 如果没有找到，则说明包不是所需要的，应该丢弃。

每个客户有一个超时等待时间，当客户来的新的包被接收到，则它的等待时间被复位。如果超时，客户记录就从映射表中删除。这样可确保映射表保持在合理的大小。超时等待时间是可变的，考虑到在因特网上通信的不同情况，应该设置超时等待时间不低于 2 分钟。许多 NAT 设备能跟踪每个 TCP 客户的连接，一旦连接关闭，立即从映射表中删除相应记录。但这对 UDP 通信是行不通的，因为 UDP 是面向无连接的传输协议。

6. 转换模式

许多防火墙都支持不同类型的网络地址转换。NAT 防火墙有四个最基本的功能，按普及程度和可用性顺序，定义如下：

- 静态转换(static translation，也称为端口转发，port forwarding) 在这种模式中，一个指定的内部网络源(通常是一个服务器)有一个从不改变的固定的转换表。为使内部主机建立与外部主机的连接需要使用静态 NAT。
- 动态转换(dynamic translation，也称为自动模式、隐藏模式或 IP 伪装) 在这种模式中，为了隐藏内部主机的身份或扩展内部网络的地址空间，一个大的因特网客户群共享单一一个或一组小的因特网 IP 地址。
- 负载平衡转换(load blancing translation) 在这种模式中，一个 IP 地址和端口被转换为同等配置的多个服务器的一个集中地址，这样一个公共地址可以为许多服务器服务。
- 网络冗余转换(network redundancy translation) 在这种模式中，多个因特网连接被附加在一个 NAT 防火墙上，而这个防火墙根据负载和可用性对这些连接进行选择和使用。

注意 不是每个防火墙都支持以上所有类型的 NAT。在购买防火墙之前需仔细阅读防火墙的文档，确保它使用的 NAT 模式是所需要的。

下面分别介绍这四个功能：

(1) 动态转换

动态转换，也指 IP 伪装或隐藏模式，即通过用一个防火墙对外部的 IP 地址替换内部主机的 IP 地址的方法来保护内部主机。

实际上，动态网络地址转换也有两种方式。一种方式是单纯的网络地址转换，它只是对 IP 地址进行转换，不包括 TCP 端口号，如图 4 15 所示。在这种方式中，一旦内网主机产生对外网的连接请求，NAT 服务器(或路由器)选择一个当时未被占用的外部 IP 地址，然后进行转换。这种转换只有在同时请求与外网连接的数量等于或小于 NAT 服务器所拥有的外部 IP 地址时才能进行。

另一种方式中防火墙内部的单一主机是根据每个流过防火墙的连接中的端口

号来识别的，因此，这种方法也称为网络地址和端口转换(network address and port translation)。这种方式也是目前普遍采用的，以下的描述也是针对它进行的。

因为在内部客户建立通过防火墙的连接之前，这个转换项并不存在，外部计算机就没有办法寻址那台使用动态转换的 IP 地址保护的内部主机。并且由于大多数防火墙建立只对指定的主机和端口使用的转换，因此除了那些计算机外任何计算机都不可能攻击主机，因为根本没有到它的路由路径。

图 4-15　动态网络地址转换(不包括端口转换)

注意，NAT 只是防止外部主机连接到内部主机，而不对客户进行任何保护，这是很重要的。如果用户被引诱连接到一个恶意的外部主机上，或者如果连接到指定外部主机的一个计算机上安装了一个特洛伊木马，客户机就可能像没有防火墙一样很容易地被攻击。因此，只有 NAT 不足以保护用户的网络。

引诱一个客户连接到一个恶意站点上的方法很简单。例如，如果你的老板向你发了一个电子邮件说“查查这个站点，它与我们要做的非常接近”，你可能毫不怀疑就单击了这个邮件中的超级链接。就是这么简单，假冒电子邮件对于黑客来是说轻而易举的事。

另外，用户也应该慎重地考虑过滤掉从 HTTP 下载的和电子邮件附件中的可执行部分。

当端口改变时，有些协议不能正确执行它们的功能。这些协议不能通过动态转换的连接正确地工作。只有防火墙被设计为不包括某个指定的协议，所有依靠建立一个到源客户的反向连接能力的协议才会正确工作。

当使用动态转换时，必须建立一个 IP 地址以便将内部地址转换为这个地址。这就是出站连接中由外部可见的地址。大多数防火墙都允许使用防火墙自己的地址或者其他路由到防火墙和防火墙使用 ARP 进行应答的地址。

每一个 IP 地址支持的最大连接数理论上为 65 536(2^{16})个，因为用来复用客户连接的端口地址组合只有 16 位宽。大多数防火墙将其进一步限制为 50 000 个连

接，因为许多端口为其他的用途保留了。Linux 的默认 IP 伪装设置仅是使 4 096 个端口可以用作转换，但是这个可以很容易地进行改动。

无论如何，端口号都要很大并且不应引起任何问题，除非用户在工作的同时保持数百个因特网连接。如果用户的确发现端口用光了，就需要多个 IP 地址来隐藏内部主机。

(2) 静态转换

静态转换(也称为端口转发)是在如下情况中使用的：当防火墙的一个源要作为公共使用时，或者(罕见的情况)当用户使用某个必须用某个端口或 IP 地址操作的协议时。

例如，如果要将电子邮件服务器放在防火墙内部，可以为这个服务建立一个通过防火墙的静态路由路径。

假设用户的电子邮件服务器的 IP 地址是 192.168.1.3，用户的防火墙的外部 IP 地址为 130.102.1.1，可以静态地将套接字 130.102.1.1:25 映射到地址 192.168.1.3:25。这个静态连接可以使防火墙把任何到其 SMTP 端口的连接转换为到网络内部的电子邮件服务器连接。如图 4-16 所示。

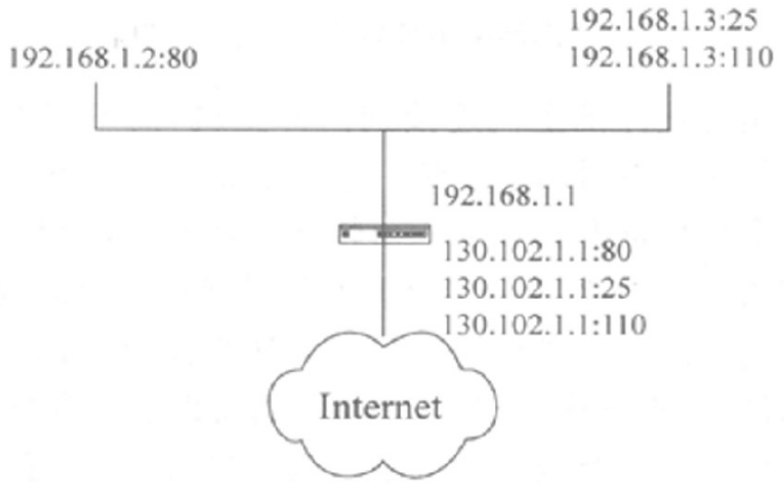

图 4-16 静态转换(端口转发)

静态转换可以用来在一个 IP 地址上建立许多不同的复杂服务。例如，可以有在 SMTP 和 POP 端口静态转换的电子邮件服务器、在 HTTP 端口上静态转换的 Web 服务器、在 NNTP 上的新闻服务器。因为转换可以指定任何 IP 地址，所以这些服务可以被分散在防火墙的许多计算机上。

(3) 负载平衡

一些使用静态 NAT 工具的防火墙支持 IP 负载平衡功能。基于循环或负载平衡原则，使用防火墙来为每个外部客户选择连接到哪个内部服务，这样就使一个非常受欢迎的 Web 站点上的负载分散到了许多不同的服务器上。这有点像动态转换的逆过程——防火墙为每个连接请求选择它应该到达的服务器。

要根据负载进行选择，必须有一些工具来将这些集中的服务器的负载水平传送给防火墙。由于没有这样的标准，防火墙必须自己实现一个专用的方法。因为这个原因，许多简单的防火墙假设每个连接产生相同的负载量，并在列表中将连接分配给下一个服务器。

IP 负载平衡功能只能同那些无状态协议或者是只在客户端维持状态的协议一起工作。对于 Web 站点，IP 负载平衡功能是完美的，因为在网页传输之间服务器不维护客户的任何信息，所以实际上一个指定客户是否每次加载网页时都使用同一个服务器并不重要。可是，考虑邮件的问题。如果防火墙为许多电子邮件服务器提供负载平衡功能，每个用户的电子邮件信息可能到达服务器中的任何一个，而这要根据防火墙为 SMTP 选择的服务器而定。当用户连接到一个电子邮件服务器时，防火墙再一次通过 POP 连接选择一个服务器，这样用户看到的信息恰好只是这个服务器接收到的信息——用户不会看到他收到的所有信息。

IP 负载平衡功能对那些处理量很大的电子商务站点非常重要，因为这些站点大量地使用 active server page、CGI 或 Perl 脚本、或者 Java serlet。这些技术都使 Web 服务器的计算负担很重，从而减少了这个服务器可以支持的用户的最大数量。图 4-17 表示了一个复杂的通过防火墙进行负载平衡的电子商务 Web 站点。

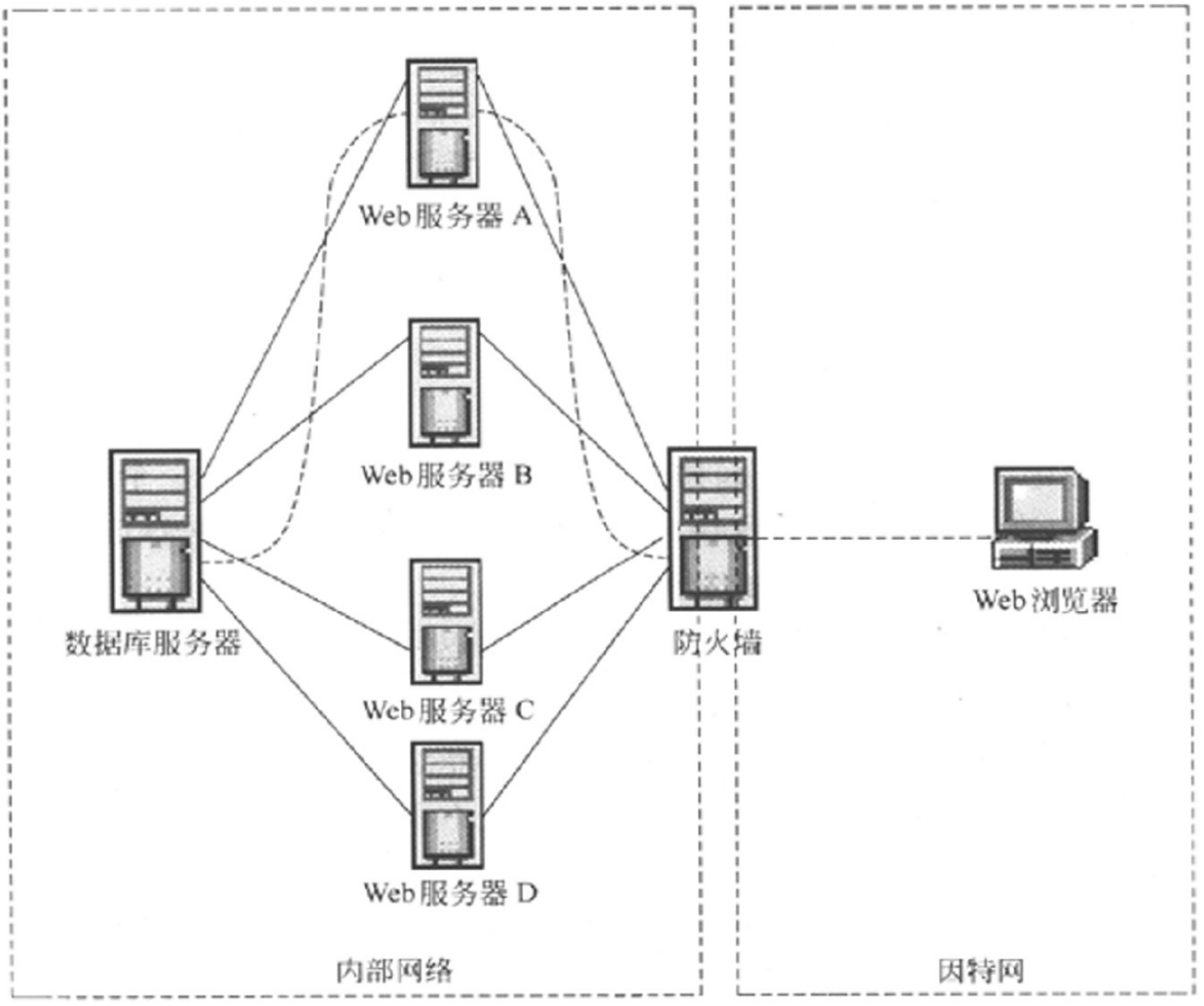

图 4-17　使用防火墙执行负载平衡

(4) 网络冗余

为了通过多个低开销的因特网连接平衡客户的负载,或是自动修复任何指定链接的错误,使用基于 NAT 的防火墙执行因特网网络冗余是可能的。

与动态转换一起使用的网络冗余同与静态转换一起使用的 IP 负载平衡工作方式非常相似。在网络冗余中,防火墙通过多个接口连接到多个 ISP,对于每个 ISP 都有一个公共的伪装地址。内部用户每次通过防火墙建立一个连接时,防火墙根据最小负载原则决定在哪个网络来建立这个转换的连接。用这种方式,防火墙能把内部客户的负载分散到多个网络上。

这样,任何网络中的错误都会被看成那个网络已满载了一样,防火墙干脆不让客户的路由路径通过这个网络。尽管基于对话的协议将不得不从客户主机上重新建立,而无状态的协议(如 HTTP)可以在客户毫不知情的情况下自动修复网络上的这个连接错误。网络冗余的工作原理如图 4-18 所示。注意,因为 IP 地址是被转换了的,防火墙使用哪个 ISP 连接到 Web 站点上并不重要。

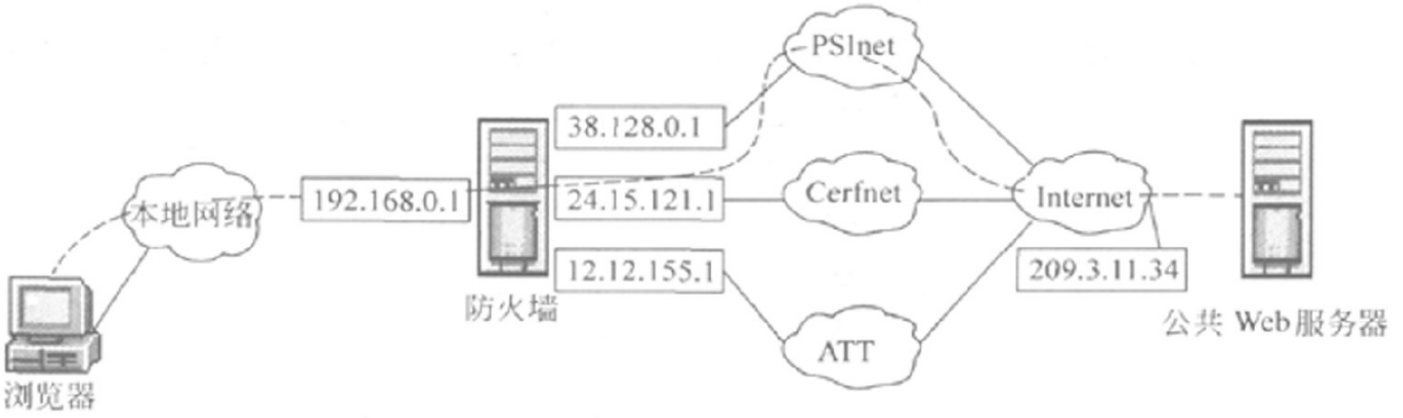

图 4-18 网络冗余

7. NAT 的问题

有几个协议不能同 NAT 一起使用,因为它们可能要求打开一个能够返回到客户端的通道、在更高级些的协议中内置 TCP/IP 地址信息、加密 TCP 报头信息、或者因为安全原因而使用原始的 IP 地址。

- 返回通道不能工作,因为没有单独的路由返回到内部主机。这种情况会在 H.323 电视会议协议中发生。
- 在 TCP 包中内置 TCP/IP 地址信息并依靠这些信息进行工作的软件不能工作,因为内部的 TCP/IP 地址信息将是不正确的。这种情况发生在 FTP 和其他一些协议中。
- 加密 TCP 报头信息的软件也不能同 NAT 一起正常工作,因为对于防火墙来讲,TCP 信息必须是可访问的。通过让防火墙在端点进行加密可以解决这些问题。这种情况发生在 PPTP 中。

- 为安全检查而依靠 TCP/IP 地址信息的软件也不能工作，因为 IP 地址已变化了。这种情况发生在 sqlnet2 中。

大多数先进的防火墙软件为这些协议检查出站连接，并建立转换表等待目标公共主机打开返回通道请求的响应。大多数防火墙不支持服务专用的 NAT，它们常常使用与 NAT 机制融合在一起的服务指定代理软件来执行这些功能。

在没有某种形式的高级代理功能和对基本 NAT 程序的补丁的情况下，NAT 不能同下列服务一起使用。

- H.323，CUSsMe 和 VDOlive　这些电视电话会议软件程序不能使用，因为它们要依靠建立到主机的返回通道的能力。一些防火墙可以在它们的转换表中建立专用项允许指定的主机建立返回通道。
- Xing　因为同样的原因不能使用。
- Rshell　因为同样的原因不能使用。
- IRC　因为同样的原因不能使用。
- PPTP　这个软件不能工作的原因是它依靠在它的流中的加密 IP 信息，但是其他非 TCP/IP 协议的软件可以在 PPTP 中用防火墙上的一个端点建立一个通道来解决这个问题。
- Sqlnet2　这个软件要求主机和客户机 IP 地址之间的数字差要相同，就如同两个 IP 地址都没有转换一样。这意味着这个软件几乎总是失败，除非将自己的网络设计为避开这个奇怪的约束。
- FTP　这个软件必须与 NAT 的建议标准 RFC1631 符合。FTP 在 TCP 包中的 ASCII 文本中内置了 IP 地址信息，这个地址的长度在通过地址转换后很可能改变。
- ICMP　这个软件有时要在 ICMP 报文中内置原始包的第一部分。这个第一部分可能会包含转换的地址。这个安全解决方案根本不会使 ICMP 传输通过防火墙。

8. 通过 NAT 进行攻击

如果网络地址转换使客户不可见，对客户的攻击就不可能了吗？回答是否定的。下面是 NAT 失败的原因。

- 静态转换不能保护内部客户。
- 如果客户建立了连接，那就存在返回的连接。
- 如果连接被中间人攻击阻断或受中间人攻击的影响，这个中间人就是终点。
- 如果防火墙的 NAT 实现产品有缺陷，就会受到攻击。

下面部分将进一步解释这些攻击。

(1) 静态转换=不安全

静态转换仅仅在一对一的基础上替换端口信息。这对静态转换的主机不提供任何保护,因为攻击行为可以像对任何有效连接请求一样被转换。

解决必须提供公共服务的静态转换的主机的安全问题的办法是减少攻击方向的数目为一个,然后使用(如果必要的话)应用程序代理软件或其他基于应用程序的安全方法来进一步保护主机。

例如,要保护防火墙内的一些电子邮件服务器,CheckPointer 的 firewall-1 软件有一个简单的 SMTP 存储和转发机制来消除令人讨厌的电子邮件缓冲区溢出问题。firewall-1 的电子邮件代理在它的 25 端口上接收所有电子邮件的入站并将每个信息写到硬盘。运行在另一个进程中的一个单独的服务读电子邮件的信息,并将它们传送到因特网的电子邮件服务器上。这个机制消除了恶意电子邮件信息产生缓冲区溢出的可能性。缓冲区溢出可能影响除了防火墙的任何东西,如果出现这种情况,它只是关闭电子邮件接收器,然后防火墙的内部一致性检查软件可以重新启动这个电子邮件接收服务器。

(2) 对内部主机的引诱

即使黑客不能达到网络内部,也不能阻止用户不到黑客那里去。伪造带有 Web 站点连接的电子邮件、带特洛伊木马的电子邮件或者带有引诱内容 Web 站点的电子邮件可以诱惑用户连接到一个目的是搜索网络信息的机器上。HTTP 是功能相当强大的协议,并且通过主要浏览器销售商的扩展,使它成为一个潜在的可被攻击利用资源。因为几乎任何内容都可以从 HTTP 连接中下载,一旦用户连接到黑客的机器就可能被轻易地攻击了。

同样,高级应用程序专用的代理成为解决办法。通过检查这些协议中最可能被利用的内容(如 HTTP),用户的防火墙可以检查可疑的内容,如 Java applet, Active 控件,可以下载的、可执行的、恶意的 URL,或者其他黑客用来执行攻击的工具。通过过滤掉这些内容,或者至少在这些内容出现时进行记录和警告,可以使用户避免被引诱的方法攻击。

(3) 状态表超时问题

一个客户连接到网络外部时,防火墙必须记住哪个内部主机连接到了哪个外部主机,这样防火墙才能将 TCP 连接的返回部分返回给源主机。如果没有这个功能,只能进行单向传输。

但是防火墙如何知道何时客户能完成连接呢?如果防火墙只依靠 TCP 信息,它可以检测出对话关闭的信息。但是许多协议没有一个明显的结束协定,在这种情况,要维护一般的协议是可能的。大多数防火墙的实现产品有一个超时值,这个超时值的变化范围很大,而防火墙的出版商从不告诉用户这个值是多大。

网络地址转换的功能可以被攻击的另一个方面正是因为如此。在超时发生之

前，通过防火墙到源内部主机的连接仍然存在。这个连接是可被黑客利用的潜在资源，尽管黑客不得不确切地知道使用的是哪个 IP 地址和哪个端口，并且为了通过防火墙黑客还必须知道原始的目标地址。只有在黑客一直偷听连接的情况下，黑客才能知道这些信息。

遭受这种攻击存在理论上的可能性，但要执行攻击需要许多信息。通常用户已经关闭了连接，而且在被打开的启动连接的高端口上很难侦听到用户的信息。因此，最有效的攻击就是向一个主机发送恶意的包来执行服务拒绝攻击。

第5章

密码技术基础

5.1 对称密码体制

对信息进行密码运算时，加密与解密使用相同密钥的密码体制，称为对称密码体制。在该体制中，记 E_k 为加密函数，D_k 为解密函数，密钥为 k；P 为明文空间，C 为密文空间；m 表示明文消息，c 表示密文消息。对称密码体制的特点可以表示如下：

$$D_k(E_k(m)) = m \quad \forall m \in P$$

$$E_k(D_k(c)) = c \quad \forall c \in C$$

利用对称密码体制，可以对传输或存储的信息进行机密性保护。为了对传输信息提供机密性服务，通信双方必须在数据通信之前协商一个双方共知的密钥（即共享密钥）。如何安全地使通信双方得到共享密钥（即密钥只被通信双方知道，第三方无从知晓密钥的值）将在密钥协商一节中描述，这里假定通信双方已安全地得到了一对共享密钥 k。此时，通信一方（称发送方）为了将明文信息 m 秘密地通过公网传送给另一方（称接收方），使用某对称加密算法 E_k 对 m 进行加密，得到密文 c 为

$$c = E_k(m)$$

发送方通过网络将 c 发送给接收方，在公网上可能存在各种攻击。当第三方截获到信息 c 时，由于他不知道 k 值，因此 c 对他来说是不可理解的，这就达到了秘密传送的目的。在接收方，接收者利用共享密钥 k 对 c 进行解密，复原明文信息 m，即

$$m = D_k(c) = D_k(E_k(m))$$

图 5-1 描述了采用对称密码体制提供加密保护的流程。

对于存储中的信息，信息的所有者利用对称加密算法 E 及密钥 k，将明文信息变化为密文 c 进行存储。由于密钥 k 是信息所有者私有的，因此第三方不能从密文中恢复明文信息 m，因而能达到对信息的机密性保护的目的。对存储信息的保护模型描述如图 5-2 所示。

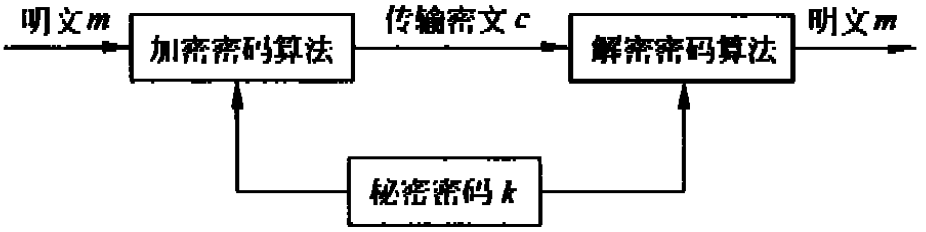

图 5-1 对称密钥保密体制模型

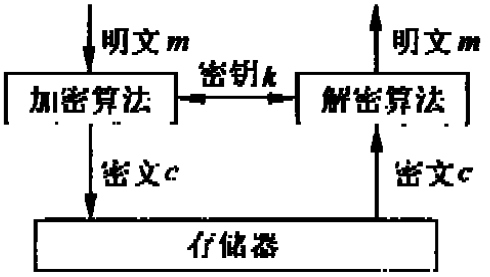

图 5-2 对存储信息的保护模型

对称密码体制的实例——DES

DES,即数据加密标准,由 IBM 公司开发,于 1975 年 3 月公布,1977 年 7 月被采纳为非密级加密标准。DES 是一种分组密码体制,即按分组方式工作的密码。

基本思想:将信息明文分解为 64 bit 的分块,对所有的分块采用相同的加密密钥。解密密钥与加密密钥相同。用长为 64 bit 的密钥对其进行 16 轮代换和换位加密,最后形成密文。

优点:在制造 DES 芯片时,易于实现标准化和通用化;随机特性好;线性复杂度高;易于实现等。

破译方法:有人用穷举法借助网络计算用了二十几个小时就攻破了 56 bit 的 DES。

5.2 非对称密码体制

对信息进行明/密变换时,使用不同密钥的密码体制称为非对称密码体制。在非对称密码体制中,每个用户都具有一对密钥,一个用于加密,一个用于解密。其中加密密钥可以在网络服务器、报刊等场合公开,而解密密钥则属用户的私有秘密,只有用户一人知道。这要求所有非对称密码体制具有如下特点:

(1) 由公开的加密密钥推导出私有解密密钥是实际上不可行的。所谓实际上不可行,即理论上是可以推导的,但却无法实际满足推导的要求,如计算机的处理速度、存储空间的大小,等等。或者说,推导者为推导解密密钥所花费的代价是无

法承受的或得不偿失的。

假设明文仍记为 m，加密密钥为 k_1，解密密钥为 k_2，E 和 D 表示相应的加密/解密算法，仍用 P 表示明文空间，C 表示密文空间。非对称密码体制的特点可表示为

$$D_{k2}(E_{k1}(m)) = m \quad \forall m \in P$$

$$E_{k1}(D_{k2}(c)) = c \quad \forall c \in C$$

(2) 利用非对称密码体制，可实现对传输或存储中的信息进行机密性保护。

在通信中，发送方 A 为了将明文 m 秘密地发送给接收方 B，需要从公开刊物或网络服务器等处查寻 B 的公开加密密钥 k_1（k_1 也可以通过其他途径得到，如由 B 直接通过网络告知 A）。在得到 k_1 后，A 利用加密算法将 m 变换为密文 c 并发送给 B：

$$c = E_{k1}(m)$$

在 c 的传输过程中，第三方因为不知道 B 的解密密钥 k_2，不能从 c 中恢复明文信息 m，因此可实现机密性保护。当接收到 c 后，B 利用解密算法 D 及密钥 k_2 进行解密：

$$m = D_{k2}(E_{k2}(m)) = D_{k2}(c)$$

对传输信息的保护模型可用图 5-3 表示。

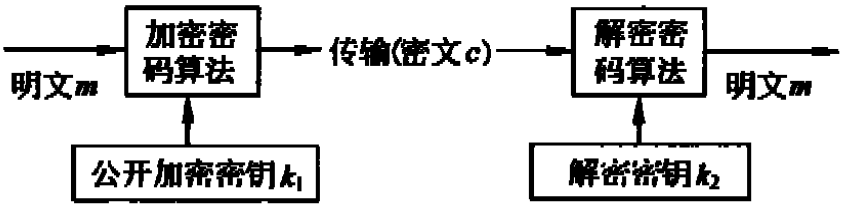

图 5-3 非对称密码体制对传输信息的保护模型

对于存储信息 m 的机密性保护，非对称密码体制有类似的工作原理：信息的拥有者使用自己的公钥 k_1 对明文 m 加密生成密文 c 并存储起来，其他人不知道存储者的解密密钥 k_2，因此无法从 c 中恢复出明文信息 m。只有知道 k_2 的用户才能对 c 进行恢复。对存储信息的保护模型如图 5-4 所示。

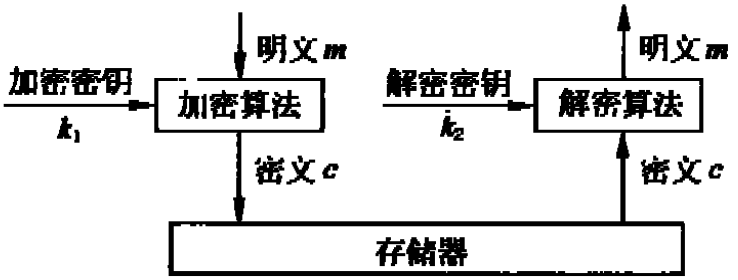

图 5-4 非对称密码体制对存储信息的保护模型

非对称密码体制也称公钥密码体制。与对称密码体制相比较，采用非对称密码体制的保密体系的密钥管理方便，而且保密性比较强，但实现速度比较慢，不适应于通信负荷较重的场合应用。

非对称密码体制的实例——RSA

RSA 密码体制是由 Rivest，Shamir 以及 Adleman 在 1977 年发明的，它的安全性是基于大整数因子分解的困难性。RSA 使用了 Z_n 中的计算，这里 n 是两个不同的素数 p 和 q 的乘积，记 $\phi(n)=(p-1)(q-1)$，即 n 的欧拉数。RSA 密码体制描述过程为：

设 $n=pq$，p，q 为两个大素数。取 $a,b\in Z_n$，满足 $ab\equiv 1(\mathrm{mod}\phi(n))$。对于 x，$y\in Z_n$，$E(x)=x^b \bmod n$，$D(y)=y^a \bmod n$。公开 n 和 b，而 p，q，a 是保密的。

在不知道 a 的情况下，想要从公开密钥 n 和 b 算出 a，只有分解大整数 n 的因子，但是大数分解是一个公认的十分困难的数学问题。比如用运算速度为 100 万次/s 的计算机分解 500 bit 的 n，计算机分解操作数是 1.3×10^{39}，分解时间是 4.2×10^{25} s！

很容易验证：$\forall x\in Z_n$，有 $D(E(x))=(x^b)^a \bmod n=x^{\phi(n)} \bmod n=x$，$\forall y\in Z_n$，有 $E(D(y))=(y^a)^b \bmod n=y^{\phi(n)} \bmod n=y$。RSA 之所以被认为是安全的，是因为对于 $n=pq$，如果不知 p 或 q 的值，则没有有效的方法分解 n。

5.3　散列算法（hash）

在第 5.1，5.2 两节集中讨论了利用公钥密码体制和对称密码体制为数据提供机密性服务的方法。然而，生活中有许多信息是可以公开的，但信息的发布者却要求信息必须是完整的。对某些重要的信息，既要求对数据保密，也要求数据真实可靠，不受到第三方的篡改。这涉及到数据安全的另一个重要方面　　完整性保护。

通常使用散列函数为信息提供完整性服务。散列函数是一种单向函数，它将任何长度的信息作为输入，进行一系列模乘、移位等运算，输出固定长度的散列结果（一般称之为信息摘要）。单向性是指由输入产生输出计算容易实现，但由输出的信息摘要计算出原有输入是计算上不可行的。由于信息摘要值比较短（一般为几十个字节），因此存在不同的输入产生相同的输出。一个好的散列函数要求具有强无碰撞特性，即要找出两个不同消息 x_1，x_2 具有相同的输出，即 $h(x_1)=h(x_2)$，是计算上不可行的。这里 h 代表散列函数。

下面看看散列函数如何为信息提供完整性保护：假定用户 A 希望给 B 发送一条消息 x，如果没有完整性保护，在网上完全有可能受到第三方的恶意修改，导致消息 x 失真。为了提供完整性保护，假设 A 与 B 共享了一个密钥 k。那么，A 和 B

可以约定一个散列方式，例如 A 和 B 约定对消息 x 作如下计算：

$$y = h(x \| k)$$

这里 h 为散列函数，“‖”表示两个串首尾相连。由此产生一个定长的摘要 y。A 发送给 B 的消息不是 x，而是 $x \| y$。现在第三方企图修改 x 为 x' 时，由于 x' 必须粘上摘要 $h(x' \| k)$ 才是合法的消息，而第三方却不知道 k，且 h 具有强无碰撞特性，因此不可能构造出 $h(x' \| k)$。这就意味着第三方不能修改 x，因为 B 通过计算 $h(x \| k)$，很容易验证 x 是否是真实的。图 5-5 表示散列函数的保护模型。

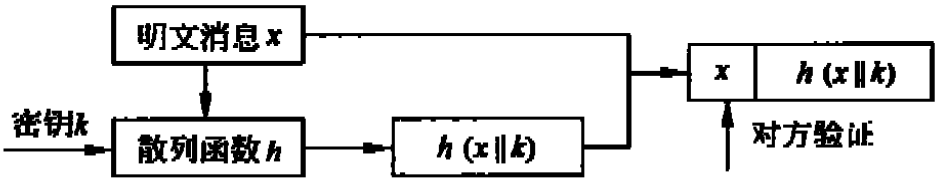

图 5-5 散列函数保护模型

注 实际应用中，未必一定是如 $h(x \| k)$ 的计算方式，明文与密钥的组合方式因不同的实现可以不同，如 HMAC 就给出了另一种散列方式。

散列函数实例——MD5

MD5 依据 1990 年 Rivest 提出的 MD4 改进而来。它接受任意长度的输入，利用 4 个寄存器，对数据进行 3 轮运算。每一轮运算都包括 16 轮子运算，并最终产生 16 字节的散列输出。

5.4 数字签名

说到签名，大家不会陌生。对文件的签名表示签名者将对文件内容负责。签名的真实性来源于手迹的难于模仿性。在电子商务时代，在网上的商务频繁，人们通过网络支付费用、买卖股票等。例如，A 通过网络发送一条消息，告诉银行从 A 的账户上给 B 支付 500 美元。银行如何知道这条消息是由 A 发送的？进而，如果事后 A 否认曾发送过这条消息，银行如何向公众证明 A 确实发送过这条消息？这就涉及信息安全中的另一项重要的服务——抗否认服务。

抗否认服务指的是人们通过为消息附上电子数字签名，使签名者对消息的内容负责，而不可以在事后加以否认。

数字签名是基于公钥密码体制的。为了对消息 m 进行数字签名，用户 A 必须具有密钥对 $<k_1, k_2>$。其中 k_1 为公开的加密密钥，k_2 为私有的解密密钥。A 通过如下运算对消息 m 进行签名：

$$\mathrm{Sig} = D_{k_2}(m)$$

A 将 $D_{k_2}(m)$ 作为消息 m 的签名与 m 组合，形成一条签名信息。在上面支付的例子中，银行通过查找 A 的公钥 k_1，对签名进行计算：

$$E_{k_1}(\mathrm{Sig}) = E_{k_1}(D_{k_2}(m)) = m$$

由此而知道消息确实来源于 A。第三方无从知晓 k_2，因为无法计算出 Sig。不难看出，事后 A 无法否认曾发送此消息的行为，因为除了 A 之外，任何人都不能从 m 计算出 Sig 来。由此实现抗否认服务。数字签名的工作流程如图 5-6 所示。

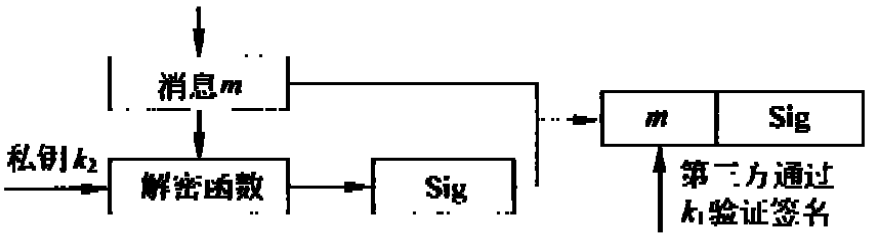

图 5-6 数字签名

注 在实际生活中的数字签名，由于使用了公钥密码体制，对一份长的文件解密计算是十分缓慢的。因此数字签名的步骤往往是先对文件进行散列，然后对散列输出进行签名。这样仍能提供抗否认服务，但却大大提高了签名和验证的速度。

数字签名的实例——DSS

DSS，即数字签名标准，是 ElGamal 签名方案的改进。它公布于 1994 年 5 月 19 日，并于 1994 年 12 月 1 日被美国采纳为数字签名标准。该签名方案基于 ElGamal 公钥密码体制。

5.5 数字证书

无论是利用公钥密码体制为通信提供机密性服务，还是进行数字签名，都涉及利用公钥的问题。考虑一种情况：假如 A 希望给 B 传送一份机密信息，A 要求 B 将 B 的公钥发送给 A；这时第三方 C 适时插入进来，将自己的公钥发送给 A，并同时声称自己就是 B；A 相信了 C，用 C 的公钥对信息进行加密并发送给 B，C 在途中截获到密文，利用私钥从中解密出明文信息 m。这样机密信息便被泄露了。A 泄露机密信息的根源在于 A 无法验证 B 是否具有公开加密密钥 k_1。数字证书可以解决这个问题。

数字证书在网络王国里对用户的作用，相当于现实生活中的个人身份证。比如警察问："你是谁？"，你答道："我是张三"。如果没有身份证这个概念，警察也许会相信你就是张三，因为你声称自己是张三。而有了身份证的出现，警察会说："请出示身份证。"，你出示身份证，警察对照相片和姓名后，证明你确实是张三，因为身份证能证明你是张三。在网络王国中，数字证书也能起到这个作用：用户 B 声称自

已具有公开加密密钥 k_1，A 可以要求 B 出示数字证书，以证明 B 的公钥确实是 k_1。

数字证书是由一个可信第三方签名的一张证明，它的生成流程通常如图 5-7 所示。

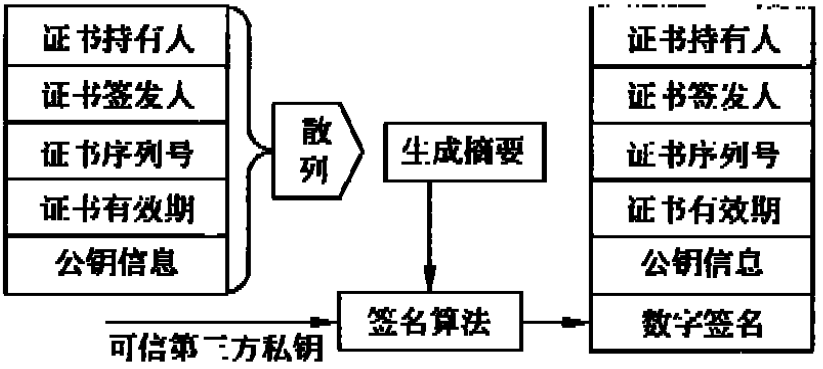

图 5-7 数字证书的生成

A 为了证明 B 确实具有公钥 k_1，要求 B 出示数字证书。A 首先利用可信第三方的公钥对证书的数字签名进行验证，以证明数字证书是有效的。然后从证书中验证用户 B 是否具有公钥 k_1。

现在再考虑前面的例子。如果用户 C 插入，并声称自己是用户 B，具有公钥 k_1（事实上 k_1 是 C 的公钥）。A 验证数字证书后，证明 B 的公钥并非 k_1，从而防止了机密信息的泄露。

读者很自然就会问：何谓可信第三方？它为什么可信？如果一个用户已申请一个证书作废，其他用户又如何知晓，等等。这一系列的问题就是 PKI（公钥基础设施）所应解决的问题。PKI 的职能包括为用户生成公钥、私钥，签发数字证书，公布有效数字证书，公布无效数字证书等。在 PKI 中，完成这些功能的主机称 CA，即证书权威机构。一个典型的 PKI 模型如图 5-8 所示。

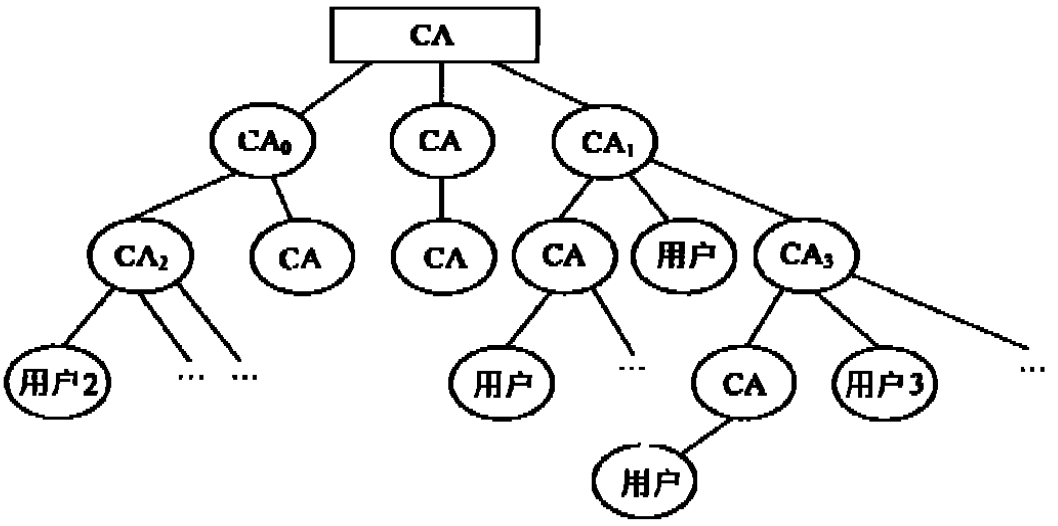

图 5-8 树状 PKI

在图 5-8 中，用户 2 由 CA_2 颁发了数字证书，用户 3 由 CA_3 颁发了数字证书。当用户 2 和用户 3 发生通信时，用户 3 为了验证用户 2 确实拥有公钥 k_1，必须对 CA_2 颁发的数字证书进行验证。因为证书是 CA_2 签发的，验证时要使用 CA_2 的公钥，用户为了相信 CA_2 具有声称的公钥，同理，需要对 CA_2 的数字证书进行验证，验证时使用 CA_0 的公钥，对 CA_0 给 CA_2 签发的证书进行验证……如此，形成了一条证书的信任链，$<CA_2, CA_0 \cdots>$，直到用户 3 觉得可信为止。处于树根的根 CA 是所有用户无条件相信的，它所拥有的证书称根证书，也称自签名证书。

每一个 PKI 中有专用服务器(例如每台 CA 都可能具有一个服务器)，用以公布已签发证书以及证书黑表(已作废证书)，用户在这里可以找到证书的使用状态信息。

并非所有的 PKI 都是树状，现实生活中的 PKI 多为交叉认证与树状认证的混合。有兴趣的读者可以参见其他的参考书。

5.6 密钥协商

前面曾假设通信双方在加密通信前得到一对共享密钥，这就是密钥协商应解决的问题。

所谓密钥协商，指按一定的通信规范及运算规范，使通信的双方得到一对共享密钥，而第三方却不能知晓协商密钥的内容。

密钥协商分为两种情况：密钥分配和密钥共识。

5.6.1 密钥分配

所谓密钥分配，指密钥由通信一方或一个第三方服务器生成，在一个加密密钥(可能是一个共享密钥，也可能是一个公开加密密钥)的保护下，发送给对方。对方利用共享密钥或对应的私钥，解密出相应的密钥。

密钥分配方案实例 Kerberos 方案

在 Kerberos 方案中，有一个可信的密钥服务器，记作 TA。它与每个用户都共享一个秘密密钥。当用户 U 希望与用户 V 进行通信时，U 向 TA 发出申请，并附上用户 V 的身份信息，TA 接收到申请后，生成一个密钥 k，并计算

$$m_1 = E_{k_U}(k, \mathrm{ID}(V), T, L) \quad \text{和}$$

$$m_2 = E_{k_V}(k, \mathrm{ID}(U), T, L)$$

其中，ku 为 TA 与 U 的共享密钥，kv 为 TA 与 V 的共享密钥。ID(U)，ID(V)分别为 U 和 V 的身份信息；T，L 分别为当时的时间和 k 的有效使用期。TA 将 m_1 和 m_2 发送给 U，U 收到 m_1，m_2 后，从 m_1 中解出 k，T，L，并计算

$$m_3 = E_k(\mathrm{ID}(U), T)$$

然后，将 m_2，m_3 发送给 V，V 从 m_3 中解密出 k，ID(U)，T，L。依据 k 从 m_3 中解密出 ID(U)，T，通过对比 ID(U)，T，判断两端的 k 是否一致。若一致，V 计算

$$m_4 = E_k(T+1)$$

并将 m_4 发送给 U，U 收到后，若解密结果为 $T+1$，则证明分配成功。

5.6.2 密钥共识

所谓密钥共识，是指通信双方各自向对方发送部分信息(可以是明文，也可以是密文)，在接收到来自对方的信息后，通信双方各自利用本地和收到的信息，合成共享密钥。密钥共识方案要求中间第三方在截取到通信双方的传输信息之后，无法合成共享密钥。

密钥共识方案实例 Diffie-Hellman 方案

这里简称 Diffie-Hellman 密钥共识方案为 D-H 密钥共识方案。

在 D-H 密钥共识方案中，公开大素数 p，以及 Z_p^* 上的本原 α 元。(所谓 α 为本原元，即 $\beta \in Z_p^*$，$\exists t$，使得 $\beta = \alpha^t \bmod p$。设 $t = \log_\alpha \beta$，称 t 是以 α 为底，β 的离散对数)。为了达成密钥共识，用户 U 随机选择 $a_u \in Z_p^*$，满足 $0 < a_u \leqslant p-2$，并计算

$$C_1 = \alpha^{a_u} \bmod p$$

将 C_1 发送给用户 V。同时随机选择 $a_v \in Z_p^*$，满足 $0 < a_v \leqslant p-2$，并计算

$$C_2 = \alpha^{a_v} \bmod p$$

将 C_2 发送给 U。在 U 端，当收到 C_2 时，U 计算

$$k = C_2^{a_u} \bmod p = \alpha^{a_v a_u} \bmod p$$

在 V 端，当收到 C_1 时，V 计算

$$k = C_1^{a_v} \bmod p = \alpha^{a_u a_v} \bmod p$$

于是达成了密钥共识。

D-H 方案的安全性基于离散对数问题难解。当第三方截获到 $\alpha^{a_u} \bmod p$ 和 $\alpha^{a_v} \bmod p$ 后，却无从计算 $\alpha^{a_u a_v} \bmod p$。即当已知 α，p 和 β 时，无从计算 t(其中 $\alpha^t \equiv \beta \bmod p$)。

在密钥协商过程中，应注意以下几个方面的问题。

- 生成的密钥应具有不可预测性。

- 应对生成的密钥进行质量检查，如 0，1 的比例检查和游程测试。
- 协商得到的密钥应受到保护，对密钥的访问应受到鉴别授权控制。
- 协商过程中应注意密钥的分层使用，防止密钥滥用。
- 应定期启动密钥协商模块，进行密钥刷新，防止密钥过度使用。
- 密钥协商方案应具有严密的保护体系，能防止重放、拒绝服务、链路劫持等攻击，并能提供身份保护服务。

下　篇

计算机犯罪勘查技术学

第6章

计算机犯罪勘查概述

计算机犯罪的外延和内涵均大于网络犯罪，但网络的飞速发展使得现今的计算机犯罪更多地体现为网络犯罪。在本书中将计算机犯罪与网络犯罪定义为同义词，虽然这从严格意义上讲并不科学，但却有助于作者叙述和读者理解本书。实际上，“计算机”、“网络”、“犯罪”等都不是新名词，“计算机犯罪”、“网络犯罪”听起来也不陌生，但是计算机及网络犯罪勘查却是个亟待研究的领域。个人及商用电脑的激增与高速的信息交换方式一起导致了计算机犯罪高潮的出现。尽管计算机犯罪已有多年的历史，但大多数执法机关都没有意识到或不愿接受计算机已成为罪犯作案的得力工具这一事实。大多数法律执行机构都缺乏具备计算机技术的专业侦查人员。

计算机的发展代表着科技的水平，在很大程度上，计算机也进入到刑事司法领域。年轻的官员可以在学校里学习计算机；上了年纪的人虽然没有专门学习，却可以通过培训或传授经验来对付“网络恐惧症”的折磨。法律资源几乎触及社会的每一个角落，而管理者们往往不愿处理那些需要更多法律资源的犯罪行为。我们所遇到的问题是：大多数计算机犯罪没有被报告。研究表明，美国约有1/4使用计算机的商务公司因为计算机犯罪损失惨重。其中的大多数案件未经报告是因为公司不相信司法部门的调查能力，再加上公司也不愿意因承认损失而使股东不满意。

由于媒介的普及和家庭、商用计算机的增多，计算机已成为众所周知的科技发展与犯罪的工具。刑事司法机关不再忽视此类犯罪，在美国，一般的当地培训机构、学院、成人学校都可提供针对法律执行者以及检察官的培训（包括从简单的DOS到编程）。美国的联邦司法培训中心及联邦调查局还可提供专门的侦查培训；位于渥太华的加拿大警官大学还设有关于计算机犯罪侦查的高级课程；中国在这方面相对而言起步较晚，但也已逐步意识到法律与计算机技术的结合在计算机及网络犯罪勘查中的重要性。据悉，我国已设置计算机及网络犯罪警察专门从事类技术犯罪的侦查和勘验工作。本书下篇部分为刑侦人员、律师、刑事学学生等一些具备计算机基础知识的学者提供通过调查计算机以获得证据的方法，同时也试图引导与侦查人员一起工作的计算机专业人士知晓侦查人员是如何从计算机获取

信息作为证据的。

计算机犯罪调查是耗资耗时，并且需要大量工具和技巧的艰巨任务。如何完成这个任务的答案相当简单，这正如一个人如何吃掉一头大象：一次吃一口，时间长了，就会吃完。本章对计算机犯罪、计算机犯罪现场勘查对策及重点等内容进行总体介绍，接下来将在每一章节详细阐述，综合各部分便成为一套完整的计算机犯罪调查及侦查体系。本书力图使读者通过本篇的学习，获得对计算机犯罪调查原理的基础性理解，直接从事调查的警务司法人员和计算机专家从中更将获益匪浅。

6.1 计算机犯罪的概念、范畴及类型

6.1.1 计算机犯罪的概念

所谓计算机犯罪[5]，就是犯罪分子利用计算机或网络的技术上或管理上的部分安全漏洞，通过计算机或网络对受害者的计算机或网络系统进行非授权的操作，从而造成受害者在经济、名誉以及心理等方面损失的犯罪行为。从广义上讲，任何运用计算机或网络作为作案工具、把计算机或网络作为作案对象的犯罪都是计算机犯罪。

以上可以视为计算机犯罪的概念。鉴于目前我国对信息网络系统犯罪的立法还不很完善，以上概念仅适用于本书范围内，不作为法律参考。本书后面部分将从范畴和类型两个方面来解释计算机及网络犯罪，以使读者有一个较全面的理性和感性认识。

6.1.2 计算机犯罪的范畴

对于计算机犯罪的范畴，我们应该从以下两个方面来理解：

首先，犯罪分子所犯罪行必须是通过计算机或网络系统实施的行为。在这里，犯罪分子实施犯罪可能是以信息网络为工具，也可能是以信息网络服务为目标。

其次，构成信息网络系统“犯罪”的必须是犯罪行为。

下面分别讨论以网络系统为工具的犯罪和以网络系统为侵害对象的犯罪。

1. 以网络系统为工具的犯罪

工具型的计算机犯罪是指以计算机信息系统为犯罪工具所实施的各种犯罪。例如：一些用户通过窃取口令等手段，从网络上登录到别的系统，取得对该系统的控制权，对计算机进行一些非法的操作，以达到自己的非法目的；通过修改企业（包括银行）的一些账户或重要文件来达到窃取电子货币或达到其他非法的经济目的；修改别人网站上的信息，利用网络传播一些反动的或淫秽的资料；或通过编写并传

播诸如梅莉莎一类的病毒来泄露受感染系统的机密，等等，都属于以信息网络为工具的犯罪。

2. 以网络系统为侵害对象的犯罪

对象型的计算机犯罪是指以计算机信息系统为犯罪对象的犯罪。例如：一些用户通过窃取 ISP 的账户控制权来非法使用信息网络服务，我国第一例以“破坏计算机信息系统罪”定罪的案例“上海热线”案就是杨某因侵入并窃用“上海热线”，1998 年 7 月被公安机关抓获，后被以“破坏计算机信息系统罪”的罪名逮捕并定罪的。也有一些用户出于报复或恶作剧等目的给其他人发“邮件炸弹”把被害人的邮箱撑破，致使被害人不能正常收发邮件；还有一些犯罪分子编写并传播病毒程序，使一些网络服务不能正常运行，等等，这些都属于以信息网络服务为目标的犯罪。我国针对破坏计算机信息网络系统的行为有专门的立法，刑法第二百八十六条规定：破坏计算机信息系统罪是指“违反国家规定，对计算机信息系统功能进行删除、修改、增加、干扰，造成计算机信息系统不能正常运行，后果严重的，处五年以下有期徒刑或者拘役，后果特别严重的，处五年以上有期徒刑。违反国家规定，对计算机信息系统中存储、处理或者传输的数据和应用程序进行删除、修改、增加的操作，后果严重的，依照前款的规定处罚。故意制作、传播计算机病毒等破坏性程序，影响计算机系统正常运行，后果严重的，依照第一款的规定处罚”。

以上两类犯罪总结起来有一个共性，就是没有计算机及网络系统，犯罪行为就不可能发生。在这里，我们理解时应该更偏重于网络的信息服务方面。有一些犯罪也造成了信息网络遭到破坏，但未必就是计算机网络系统犯罪。比如有一些不法分子偷盗信息线缆，这种行为也造成了信息网络系统的破坏，使各种网络服务中断，网络上的信息不能正常传递。但这种采用非技术手段破坏计算机信息系统的行为并不能算是信息网络系统犯罪，因为它既不是以信息网络为工具，也不是以信息网络系统为目标。在这里，犯罪分子用的工具可能是刀子，甚或是锄头，而非信息网络工具；他们的目标也仅仅是所偷盗的信息线缆本身，而非信息网络系统。我国刑法规定，这种用物理手段破坏计算机信息系统的行为应定故意毁坏财物罪，而非计算机犯罪。

3. 计算机犯罪的刑事违法性

我们说的信息网络系统犯罪除必须是利用信息网络实施的行为这一点外，还有一点需要强调的就是它必须是违反刑法的犯罪行为。

我国刑法对犯罪的规定是这样的：一切危害国家主权、领土完整和安全，分裂国家、颠覆人民民主专政的政权和推翻社会主义制度，破坏社会秩序和经济秩序，侵犯国有财产或者劳动群众集体所有的财产，侵犯公民私人所有的财产，侵犯公民的人身权利、民主权利和其他权利，以及其他危害社会的行为，依照法律应当受刑

法处罚的，都是犯罪，但是情节显著轻微，危害不大的，不认为是犯罪。

根据以上规定可以知道，并非所有危害社会的行为都是违法行为，也并非所有的违法行为都是犯罪。刑事违法性作为犯罪的三个特征之一是一般违法行为与犯罪的根本区别，网络犯罪作为一类新型犯罪也概莫能外。也就是说，并非所有通过信息网络实施的行为都是犯罪。拿我们通常所说的黑客行为作例子，词典上对黑客的定义是这样的："对计算机非常精通的狂热分子"或"试图获得对计算机系统的非授权使用的计算机用户"。最早的黑客只是对于网络技术十分推崇，出于好奇或对技术的研究的目的而对计算机系统进行"攻击"，他们从不伤害他人；相反，这种黑客行为客观上推动了安全技术的发展，以对付那些真正心怀叵测的网络罪犯。所以通常的黑客如果仅仅是侵入别人的系统（国家事务、国防建设、尖端科学技术领域的计算机信息系统除外），而没有任何诸如上面犯罪定义中的活动，即不符合实施犯罪的定义，就不应该认为是犯罪。事实上，到目前为止，只有刑法第二百八十五条规定"违反国家规定，侵入国家事务、国防建设、尖端科学技术领域的计算机信息系统的，处三年以下有期徒刑或者拘役。"只要黑客侵入的系统不在以上规定范围内，就不算犯罪行为。

然而，"高尚"的黑客与"阴险"的黑客只有一念之差。也许黑客在侵入别人的系统的同时，不经意间就侵犯了别人的隐私权等权利，也可能会经不起诱惑而进行一些经济犯罪或出于恶作剧动机而导致的犯罪。当然，利用病毒对他人系统进行破坏或窃取别人信息资料则属犯罪无疑。

4. 我国刑法对网络系统犯罪的规定[6]

由上面的定义可知，信息网络系统犯罪包括工具型的计算机犯罪和对象型的计算机犯罪。针对对象型的计算机犯罪，刑法规定有非法侵入计算机信息系统罪（刑法第二百八十五条）和破坏计算机信息系统罪（刑法第二百八十六条）。针对工具型的计算机犯罪定罪参照刑法第二百八十七条。

6.1.3 计算机犯罪的类型

1. 犯罪类型概述

如前所述，网络犯罪除了是利用网络进行的犯罪这一特点外，从本质上来讲，它依然是一种犯罪。这种犯罪仍然是适用于刑法的，只是在作案手段、工具以及场地等方面与传统的犯罪有所不同而已。网络系统犯罪有与传统犯罪相同的犯罪类型：盗窃、诈骗、破坏和不良信息传播等。

由于电子化银行业务和电子数据交换（EDI）的出现，越来越多的商业活动通过网络来实现。这给通过信息网络进行盗窃也提供了可能。犯罪分子通过侵入银行或企业的网络系统，非法取得控制权，对账户进行修改。在计算机系统中，货币

是以数字的形式存在的，罪犯只要取得控制权，把数字改动一下，就能够盗走比传统意义上盗窃多得多的金钱。电子盗窃的具体类型有许多，可能是直接修改银行账户；可能是盗窃信用卡号；也可能是窃取一些重要信息，如国家机密或一些重要商业机密等；还有通过信息网络盗窃一些网络提供商的服务，比如前面提到的“上海热线”案中，杨某通过侵入“上海热线”系统盗用其 Internet 服务。

信息网络中的诈骗犯罪多种多样，依靠先进的计算机网络技术，可以有多种手段，如 IP 地址欺骗、Web 电子欺骗、E-mail 电子欺骗、假冒身份进行商业诈骗等。这些手段将会在后面详细介绍。通过这些手段，犯罪分子可以进行各种金融、商业或个人诈骗。犯罪分子可能会冒充合法用户，向银行提出一些转账要求，银行错误地认定该罪犯具有转账的权限，而同意他的非法要求。也可能有手段高明的黑客通过技术手段，用自己的计算机取代银行服务器连到自动柜员机后面，当用户在取钱的时候，会误以为柜员机连的还是银行的服务器，这样，当用户在输入自己的账号和密码的时候，黑客就会看得一清二楚，从而用计算机诈骗的手段得到用户的账户信息。

网络上的破坏主要指利用计算机技术使信息网络中的一部分系统或网络服务不能正常运行。前面曾引用过的破坏计算机信息系统罪就是针对这种行为的。这种犯罪可能是从网络上侵入他人的计算机系统，对一些关键性文件进行增加、删除、修改等操作，使得该系统不能正常工作；也可能是利用不断地给别人的邮箱发邮件（称“邮件炸弹”），从而把该邮箱撑爆，使受害者不能正常收发邮件，从而造成经济上或感情上的损失。

不良信息传播主要指在网上传播一些反动的、淫秽的或其他一些国家禁止的信息。由于网上信息传送非常快，而且非常方便，所以在信息网络中传播不良信息的危害比传统的传播要大得多。一些不法分子做的主页上充满了上述不良信息，这些都是应给予取缔的；更有甚者，有些居心叵测的黑客私自篡改一些政府的网页，使本来宣传政策、法规的地方成了宣传反动言论的场所，这是不能容忍的。

2. 技术手段分类

下面从技术角度具体介绍几种犯罪类型。

（1）IP 地址欺骗　IP 地址欺骗是通过改变 IP 源地址的方式来实现欺骗的。在 TCP/IP 协议中，网络上的计算机一般是通过 IP 地址来相互识别的。计算机的 IP 地址是可以通过手工进行设置的，正常上网的组织通过申请可以有分配给属于自己的合法 IP 地址。罪犯可能通过一些技术手段，来盗用这些合法的 IP 地址。这样，该犯罪分子在网上传送信息时，所传的 IP 数据包中的源地址就是他盗用的 IP 地址，网络就会把他的计算机误当作前述合法组织的计算机，从而该犯罪分子就可以借此进行各种欺诈行为。

（2）Web 电子欺骗　Web 电子欺骗利用互联网的薄弱环节，在用户的浏览器

与要访问的网页之间插入一台计算机。用户在用浏览器访问一个网页的时候，会在浏览器上输入要访问的计算机的名字，然后浏览器通过域名解析、路由等过程找到目标计算机，从而把访问要求提交；被访问计算机会对该要求作出一个响应，根据客户机在提交请求时所附带的源地址把客户机所希望得到的信息传送给它。这样就完成了一次信息访问。黑客通过编写一些程序，把自己的计算机插入客户机和服务器之间，看起来好像所插入的计算机是一个中间地址或者就是网站的提供者服务器一样。这样，该黑客就可以任意地观看、窃取和修改客户与真正浏览器之间传递的信息。希拉里的竞选网页曾经有一段时间被黑客链接到竞争对手的网站，用的就是此类技术。

(3) 邮件滥发　邮件滥发是通过编制程序向目标邮箱连续不断地发送邮件，造成受害者花费大量的连接时间和资源来接收它，严重的，可能导致邮箱功能无法提供或丧失使用信息网络的机会。

(4) SYN denial of service　是一种拒绝服务攻击，是针对IP协议的三次初始信号握手实施的攻击。正常情况下，要浏览的客户计算机试图连接到另一台计算机上时，它的IP协议堆栈程序会发出一个叫SYN的同步数据包，里面装有该客户机的IP地址。服务器计算机在收到该同步数据包之后，会发出一个SYN-ACK的同步确认数据包，等待客户机的ACK确认数据包。当收到确认后，会话断开，真正的通信开始。在SYN攻击中，犯罪分子使用假的IP地址，向受害计算机发出SYN数据包，受害计算机回发SYN-ACK数据包。由于所发SYN-ACK数据包中包含的IP地址根本不存在，所以根本不可能收到浏览器的ACK确认数据包。因为受害者的计算机只能打开一定数量的话路，进攻者不断地发SYN，受害者的计算机就会在用尽连接内存后被关闭。1996年，Panix公司受到SYN攻击，曾被迫停业一周。

(5) IP路由欺骗　IP路由欺骗也是一种拒绝服务攻击。我们知道，在互联网上，一台计算机发出的信息要想达到另一台计算机，必须经过一定的路径。怎样选择，以及选择什么路径这样的一个过程就是路由。数据包所经过的机器上会有一张路由表，该路由表指示到目标机器有哪些路径，网络在选择路由的时候，会选择一条最近的路由。如果犯罪分子修改路由表，使最近的那条路由指向一台别的计算机，就会导致源计算机所发的信息不能到达真正的目标计算机。这样就形成了一个网络不能连通的假象，就造成了拒绝服务。当然，在实际中，实施路由欺骗的具体手段有很多种，这里只介绍了其中的一部分。

(6) sniffer攻击　sniffer是计算机程序。在信息网络中，某用户给另一用户发的信息在网上传送的时候，组成这些信息的数据包会流经许多敌对的计算机节点，这些敌对节点上运行的sniffer程序会搜查每个经过的数据包来抓取想要的信息并进行分析。例如截获某用户网络登录过程中的一些初始数据包用来分析用户

的口令，利用这种手段，也可以窥探用户在网络当中发送的金融账号，如信用卡号或现金账号等。目前，信息网络中，不论是互联网，还是内联网都在遭受着大范围的 sniffer 攻击。而实际上，很多黑客对别的网络进行攻击都是采取这种方法获得的口令。sniffer 攻击严格地说并不是一种犯罪，而是一种犯罪手段。但是在未来，犯罪分子会不断改进 sniffer 程序，扩展 sniffer 程序的功能，实施危害性越来越大的类似于自动犯罪的犯罪行为。

(7) E-mail 欺骗　E-mail 欺骗简单地说就是假冒别人的名义来发 E-mail。这里所说的 E-mail 欺骗并不是普通的使用某个人的 E-mail 地址作为自己所发信件的回信地址那么简单。因为那样只是一种很表面的伪装，并没有构成欺骗的能力。真正的犯罪分子往往通过一些黑客手段侵入受害人的 E-mail 账户系统，在这里假冒受害人的名义发 E-mail，就好像是受害人本人发的一样。一个著名的 E-mail 伪造案例发生在美国，当时作为这个案件关键证据的是女职员的上司　公司副总裁发给 CFO 的一封 E-mail。1997 年，公司要求法院调查该 E-mail 的真实性。调查结果证明是该女职员侵入副总裁的 E-mail 账户发出的这封曾经作为证据的可疑的 E-mail。

网络犯罪的类型多种多样，随着网络技术的发展，还会出现更多类型的犯罪。在这里，限于篇幅所限，仅介绍了其中比较常见的一些类型。

6.2　计算机犯罪现场的特征及勘查对策

一般来说，刑侦人员进行侦察办案的时候，勘查犯罪现场是非常基础、非常重要的工作，许多用于破案的侦破线索以及用于起诉罪犯的犯罪证据都是在犯罪现场发现的。传统犯罪的犯罪现场是指犯罪行为所发生的场所，不管是盗窃、抢劫、杀人，还是放火，总会发生在某个地方。当犯罪行为发生时，这个地方就是通常所说的犯罪现场。

犯罪现场对于刑侦工作是如此重要，那么，网络犯罪的现场又在哪里呢？网络系统犯罪是一种高技术犯罪，它有许多不同于传统犯罪的地方，所以网络系统犯罪的犯罪现场也不能用传统犯罪现场的概念来定义。信息网络跨的地域非常广，经常会有一些犯罪跨越不同的国家和地区。我们认为网络系统犯罪的现场应该包括犯罪分子实施犯罪所使用的终端和被害系统网络，严格地讲，还应该包括犯罪分了在实施犯罪的过程中所发出的控制信息经过的节点。

6.2.1　计算机犯罪现场的特征

作为一种新兴的犯罪类型，网络系统犯罪的现场有着与传统犯罪不同的特征，抓住了这些特征，刑侦机关才能够更好地组织破案，更有效地把犯罪分子绳之以

法。通常的网络犯罪现场都有以下三个特征：第一，犯罪现场的时间空间跨越性强；第二，犯罪证据易删改；第三，犯罪隐蔽性强。下面将分别对这三个特征进行阐述。

1. 犯罪现场的时间空间跨越性强

网络犯罪现场的时间空间跨越性强，这主要是指网络犯罪分子常常会跨过不同的网络，甚至经常跨过不同国家的网络来实施犯罪。这是由信息网络的特性所决定的。当今的互联网几乎已经连到了世界的各个角落，只要有一台计算机、一个modem(调制解调器)和一根电话线，就可以很容易地连到 Internet 上。上了 Internet，就可以很方便地浏览任何一台联网主机的信息。在网络给我们带来极大方便的同时，它也给犯罪分子实施犯罪创造了极为便利的条件。

一些技术高超的不轨分子可能坐在家里就把远在万里之外的一些极为重要的系统给“黑”了。例如，前一阶段由于李登辉制造“两国论”，两岸关系紧张的时候，大陆和台湾的黑客就曾经互相攻击，使一些站点遭受了不小的损失。对于高明的黑客而言，通过网络侵入异地的银行系统，把钱转到本地自己的账户上也不难办到。

以上例子都说明了网络犯罪现场的空间跨越性。一些犯罪分子可能会编写程序，让该程序在未来的某一个时间执行。当到了预定的时间，这些程序就会自动触发并执行，产生一些非常严重的后果。最明显的就是计算机病毒，病毒被它的作者编写出来之后，通过网络传播，不断地感染其他系统。一些病毒常在某些特定的日子发作，破坏计算机的软、硬件和各种重要信息。比如前一阵子大家谈虎色变的 CIH 病毒就常在每月的 26 日发作，发作时动辄破坏计算机主板。尽管 CIH 的制造者已在台湾落网，但直到现在，还常常见到一些机器被 CIH 病毒感染并破坏的报道。由以上分析可见，网络系统犯罪的时间跨越性之强。

2. 犯罪证据易遭破坏

网络犯罪中的证据主要是以电子数据形式存在的证据，是指依法收集的，与案件有联系的，能以其储存的文字、数据、图像等证明案件真实情况的各种电子化数据记录。

这种电子证据与传统犯罪的普通证据有很大的不同。对于传统的犯罪，我们通常使用的证据是一些具体的人和物，比如脚印、指纹、凶器、血衣，等等。

但网络犯罪的证据就不同了。在网络犯罪中，犯罪分子所用的犯罪手段可能就是通过网络侵入其他系统，然后对一些程序或其他文件进行修改。由于前面讲的犯罪现场的时空跨越性，所有这一切仅是用电脑在遥控进行，他本人根本就没有到受害系统所在的物理场所去，所以根本不可能留下任何如前所述的脚印、指纹一类的证据。司法机关所能够用来起诉他们的证据可能仅是一些他们登录系统或修

改文件时系统对他们的行为所记录下来的日志。

一旦犯罪分子取得系统的控制权之后，他们就会想方设法把那些可能记录他们罪行的日志进行一些他们认为需要的并且安全的修改。他们可能把日志中记录他们访问的部分删除，让人不能发现他们曾经访问过系统；也可能把日志中所记录的能标识他们身份的信息篡改成标识别人的信息，从而造成是别人作案的假象；或者本身在进入系统的时候就通过一些技术手段隐瞒自己的身份，不留下证据。

犯罪证据除了容易通过上面的网络技术遭到破坏以外，还由于它是以数字的形式存在于磁盘、磁带等物理介质上的，也极易遭到强磁场等物理原因的破坏。

电子证据与普通证据的不同之处主要有

(1) 电子证据的形成可以是异地操作，背靠背的，而非面对面的，也是非直接接触式的。

(2) 电子证据不像普通证据那样直观，更没有一个固化的外形，而是以电磁材料为载体被记录下来，有时还需要破译才能得知其真实内容。

(3) 一般普通证据形成的过程中，在介质上可能留下痕迹，如物体、凶器在墙壁、地面上划过会留下印迹；而电子证据形成时，在网络介质上划过时，不会留下直接的印痕。

3. 犯罪隐蔽性强

所谓犯罪隐蔽性强指的是网络犯罪的犯罪行为和侦破线索隐蔽性强，不易被发现。从前面介绍的犯罪类型可以看出，网络犯罪的直接行为通常都是通过网络对被害计算机中存储的文件进行一些增、删、改的操作，或给被害系统添加一些有害的程序，从而导致被害计算机在经济等各方面的损失，犯罪分子则从中获利。

的确，在网络时代会有许多原来被认为是异想天开的犯罪都有可能实现，且很不容易被发觉。在会计人员中流传着一个古老的“意大利腊肠”诈骗手段，实施这种犯罪技巧能获得很小数额的金钱，是从进行计算机账目收支平衡时的剩余累计形成的。在计算存款利息的时候，利息额后面会有多位小数，犯罪分子编写程序把小数后面的可能是几百分之一分钱截下来，与其他成千上万的余额相加，每凑够一分钱，就存到犯罪分子的账户中。这样聚沙成塔，犯罪分子可以从每个账户那盗走很多钱。分析上面的手段可以看出，这种犯罪行为是很不容易被发现的。

前面讲过，网络犯罪的证据和线索极易遭到破坏。一些技术高超，尤其是那些对网络操作系统非常熟悉的犯罪分子在实施完犯罪行为之后，常常会为自己“打扫”现场。他们更多地是一些与系统内部人员有勾结的犯罪分子，或者就是“内奸”。由于他们熟知所侵犯的系统会采用哪些日志，并且非常清楚系统采取哪些安全措施和第三方工具，所以，只要足够谨慎、足够仔细，他们就能把事情做得滴水不漏，使侦查人员在勘查的时候，很难发现线索。

20 世纪 80 年代曾有几名德国学生利用远程登录技术经过德国到日本再到美

国，进入了美国的军事系统。互联网络把一条信息从一地传到另一地，其间要经过成千上万台计算机和许多不同的中间环节，况且又是间接登录。所以，很难查到是谁做的，要想取得证据就更不容易。

6.2.2　计算机犯罪现场的勘查对策

针对以上介绍的特征，在网络犯罪现场进行勘查时可以采取如下对策：

1. 计算机犯罪现场勘查的对策

在勘查的时候，可以采取这样的对策：既要寻找并分析犯罪分子在作案时所遗留下来的一切线索以利于案件的侦破，又要妥善保护所有可能成为证据的电子信息。由于侦查人员在勘查现场时常常需要对可能记录犯罪分子信息的各种记录如日志等信息进行分析，在分析过程中如果操作不小心，很容易造成对这些信息的误删改。找到罪犯固然重要，但由于证据不足而不能依法惩处犯罪分子这种现象也不是我们希望看到的。而且，犯罪证据往往正是据以调查案件的犯罪线索。

2. 计算机技术与勘查技术之结合

从事与计算机相关的勘查应同时具备专业技术和侦查技能。没有人能掌握全部所需知识，如计算机软硬件、犯罪调查和法律等知识。在调查过程中，即使是对一台单机进行查封和鉴定，增加两个或更多的专业人员都将有助于迅捷高效地完成工作。实践证明，由经验丰富、具备计算机知识的侦查人员与懂得证据保存和鉴定的计算机专家合作组成的调查小组，是能成功地进行搜查及法律鉴定的优秀队伍。

无论一个人多么有经验和专业技能，都会在进行鉴定时被硬件或软件搞得晕头转向。这种情形发生时，便需要寻求计算机专家的帮助来处理手中的编程语言、硬件和软件。多数计算机专家都乐于帮助调查。当然在让他们接近犯罪现场和证据之前，每一个专家都须经过仔细考察，他们须在训练有素的侦查人员的领导下工作。应注意的是，计算机专家可能是计算机销售人员、编程工程师或信息系统工作人员，因此他们仅是计算机业内人士而非证据方面的专家。

计算机专家通常有高超的计算机培训技巧和学历背景，他们的弱点在于不理解证据维护的过程及原因。侦查人员虽具备大量的侦查经验，但又缺乏计算机侦查的技能培训，他们只好把搜查涉嫌计算机的任务交给并非专事刑事搜查及证据鉴定的计算机专家来进行。由此看来，计算机技术和刑事侦查经验及培训的结合对于正确地调查、搜查、保存证据以及妥善处理计算机犯罪而言是十分必要的。

我们已经看到，由于侦查人员缺乏计算机方面的经验，把搜查及鉴定计算机的任务交给从事计算机应用领域研究的专家学者，而引起一些问题。专家们让嫌疑人坐在电脑前，向嫌疑人演示在哪儿发现了犯罪文件。当然嫌疑人自己不会去找

犯罪文件。在此类调查中，应适用的规则一是不得改动原始证据；二是不允许嫌疑人操作自己的电脑。

曾有这样一个案例，一个经营公告牌的人被怀疑出售儿童色情刊物，当地刑事调查人员邀请计算机专家进行计算机犯罪证据鉴定。专家们在计算机犯罪证据的搜查与分析方面未经专门培训，而且他们也没有合适的设施进行系统支持。他们搜索了原始磁盘，并将之储存到替代磁盘。他们完全忽略了应检查嫌疑人计算机硬盘上被隐藏或被删除的文件和目录，结果是更改和毁掉了原始证据。幸亏后来拿到一个空白磁盘，准备用来拷贝嫌疑计算机，之所以称为空白是因为该磁盘没有标签。事实上，这个磁盘是一个 PCTOOLS 替代磁盘，它包含了嫌疑人计算机系统的增量备份盘，这个磁盘是惟一没有遭更改和毁坏的原始证据。最后找到了密码，保存了每一个增长了的扇区，并存到了磁盘上。这些被保存的文件正是调查人员要寻找的儿童色情文字。

在另一个案例中，负责医疗欺诈案件的调查人员对一些医疗服务部门实施了调查，查获了一台主机、一台微型机、一台手提式电脑和几台个人电脑。调查的关键是认定这些部门是否通过改变计算机程序而增加医疗账单来实施欺诈。调查人员通过网络管理人员的帮助关闭了网络，搜获了计算机。还有一些调查人员有计算机知识，但是无论是他们还是计算机专家都没有接受过计算机犯罪侦查的专门培训。

在处理过程中，计算机是否是在第一现场被搜获并不意味着该案的证据就确凿了。假如调查人员将 DEC 主机、微机和 PC 机上的网络电缆全部卸下，并且未作任何标记地将它们放在地下室里，然后将几十根相似的电缆放进地下室，再把它们安装回每一台计算机和打印机上，系统还能再次正常运转吗？

多数类型的网络电缆有不同的颜色，如银色、橘黄色、灰色或黑色等。有的调查人员在办案过程中从计算机后面拆下了几十根电缆，把它们扔到地板上，而不加任何形式的标记。

只要调查人员及相关人员接受过适当的培训、并有相应的设施来完成任务，上述所有问题本来是能够避免的。

本书下篇有关计算机相关证据的搜查和鉴定的基本原理是适用于全世界计算机犯罪调查者的标准原理，作者将这些原理编进本书来为没有经验的调查员提供规范的调查方法。虽然软件、操作系统、硬件会不断地变化，但是计算机犯罪证据的搜查、保存、鉴定的原理是保持不变的。在本篇中，作者将致力于帮助在这个较新的调查领域里的其他人不再犯同行犯过的错误。

3. 计算机犯罪现场勘查的步骤

在上面勘查对策的指导下，可以采取以下的具体步骤和方法对计算机犯罪现场进行勘查。

第一步，取得受害系统的系统管理员的配合。面对一个网络系统，如果我们不知道它所采取的网络方案，不知道它使用的是什么系统，不知道它采用的是什么安全策略，往往会不知该从何处入手，或者至少不能更好地进行侦破。所以，想办法取得系统管理员的积极配合非常重要。因为只有系统管理员才能提供以上信息，尤其是关于技术方面的策略。他们还可以提供系统的权限分配方案，什么人有什么样的访问权限。因为目前比较重要的系统，如金融行业或一些重要的商业、政府部门的系统，在建立的时候会采取一些技术水平相对比较高的安全措施。普通的犯罪分子在不了解系统内部情况、不知道口令的情况下，很难侵入系统实施犯罪。

拿修改银行账户的例子来说，犯罪分子首先应当能够获得进入系统的口令，以侵入系统；然后还应该知道系统是如何运行的，账户的计账方式是什么，如何才能修改账户以使自己得到利益。即使知道了这些，面对一个庞大的文件系统，如何找到这些应用程序或数据库的文件也是非常麻烦的。而如果犯罪分子就是系统的内部人员或与内部人员有勾结的话，这一切就很容易解决了。的确，没有人比制作和使用这些系统的人更了解这些信息了。

由此可见取得系统管理员的配合的重要性。因此，一定要取得他们的积极配合，调动他们的积极性。这样，他们除提供技术方面的配合外，还会提供一些诸如谁更可能接触到这些口令、应用程序，谁的嫌疑比较大等更有价值的信息。

第二步，还应该做一些非技术性的勘查。前面提到过，此类案件往往是那些熟悉内情的人做的。更多的是一些"内奸"。侦查人员在侦破的时候应该从这方面着手。据国内外多起成功破获的案例显示，在实际案件中，有很多是从这些非技术因素着手侦破成功的，或至少这些因素在案件侦破中起了很大的作用。

某些拥有口令的使用者对于自己账户口令的保管方面的安全警惕性不高。他们在计算机上输入口令的时候，并不避开其他一些不相关的人，这样他们的口令就会被一些头脑聪明且居心叵测的人看到。也有的甚至会被一些自己认为值得信任的人把口令及其他机密信息套出来。这在当前我国许多网络系统使用者对系统安全重要性认识不够的情况下很容易发生。对于这些情况，如果现场勘查人员能够详细了解的话，一般都能够得到很有价值的线索。

所以，在网络犯罪现场勘查的时候，一定要把非技术性的调查重视起来。这样往往能取得事半功倍的效果。

第三步，进行技术上的勘查。计算机技术的发展日新月异。最初的PC只有10MB的硬盘和低密软盘，支持PC的是DOS系统和少量软盘，由于没有多少程序和病毒，那时的计算机证据鉴定是件相当简单的事。而现在有了网络、外存、拨号网络、局域网络和广域网络等多种网络连接形式、多字节的磁盘、磁盘组、可视磁盘、只读光盘，等等。也就是说，事情变得越来越复杂，这就需要一个有机的系统来

保存和鉴定所有的信息。具体来讲，查找线索主要可以采用“审计跟踪(audit trails)”的策略。成熟的信息网络系统，对于用户的各项操作都会记录在一定的日志(log)中。了解这些日志中存放的各项用户操作对于追踪信息网络犯罪的蛛丝马迹是非常有用的。在多数情况下，对日志的追踪往往是最有效的方法。

前面讲过，手段高明的犯罪分子可以在作案之后清理“犯罪现场”。他们往往会把记录自己犯罪行为或可以提供警方侦破线索的日志做一些合适的修改，甚至可以不漏任何的蛛丝马迹。也就是说能做到只要他们退出系统连接，就没有人能够发现是什么人、什么时候侵入的系统。

但在现实当中，更多的是一些很幼稚的罪犯。由于互联网上到处充斥着一些免费的黑客软件，如 sniffer，john 等，这些黑客软件往往对那些对安全问题不够重视、有一定安全漏洞的系统非常有效。而且它们在使用方面都十分简单。只要是初通计算机网络知识的人，稍下工夫都很容易学会使用。而事实上，现在很多网络犯罪分子都属于使用这类黑客软件的人。

许多犯罪分子甚至连如何能够侵入网络系统都不会。比如 1998 年山东省潍坊市公安机关破获的孙某等 13 人团伙盗用互联网账号案中，公安机关查对上网资料发现有 13 部电话使用过被盗用的账号。以这 13 部电话为线索，公安人员顺藤摸瓜，对电话使用人采取分头传讯、集中分析、重点突破的方法，查清了潍坊市电信局公众信息网络公司工作人员孙某利用给该公司调试入网设备之便获知其互联网账号后，泄露给韩某等人。在这起案件中，罪犯韩某等人并不懂我们平时常听说的黑客技术，公安人员对网络访问记录稍加分析就查到了他们所使用的电话。

另一个案例是四川省交通厅信息中心网络遭黑客攻击案。嫌疑人刘某通过 169 网进入省交通厅局域网，发现其网管员 wzw 的口令与用户名相同，出于好奇和恶作剧，他盗用 wzw 的名义截获省交通厅所有用户的电子邮件地址，使用自己编程的破坏性邮件，以 wzw 和 webmaster 的名义不断地给省交通厅发送电子邮件，致使省交通厅 179 个用户不能正常使用邮件。案侦干警在省交通厅信息中心技术人员的大力配合下，通过对该破坏性电子邮件的原始代码及邮件服务器的工作日志中的数据对比，查明邮件来源于四川省广播电视大学的代理服务器。经过进一步调查，很快就破了案。

就目前而言，大多数的网络犯罪都是由于网络系统本身的安全漏洞太多，给了犯罪分子以可乘之机，其实，许多犯罪分子本身并没有太高的技术。难怪有专家预测，在未来的 5～10 年中，信息网络犯罪率将会先增长到一个最大值，然后才会逐渐降下来。

在实际勘查当中，应该把以上三个步骤结合起来，这样对于一般的网络犯罪是比较容易侦破的。

6.3 计算机犯罪现场勘查的重点

6.3.1 审计跟踪概述

前面讲过，网络系统犯罪是一种高技术犯罪。侦查人员在进行现场勘查的时候，如何找到犯罪分子在作案现场留下的一些蛛丝马迹，其中关键的一点是要对系统的日志性文件进行审计跟踪。

美国国家计算机安全中心在彩虹系列安全性发布中定义了审计跟踪："审计跟踪(audit trails)是系统活动的年记录，这些记录足以重构、评估、审查环境和活动的次序，这些环境和活动在一项事务的开始到最后结束期间能够围绕或导致一项操作、一个过程或一个事件。"一般而言，审计跟踪是记录用户的注册时间、在何处注册、要做什么样的文件等。如果使用得当，审计跟踪能提供有关追踪安全侵害和入侵企图的非常有价值的信息。所以，做好审计跟踪是信息网络系统犯罪现场勘查的重中之重。下面我们就对常见的 UNIX 系统和 Windows 系统的审计日志作一些介绍。

6.3.2 UNIX 系统的审计跟踪

UNIX 系统提供了大量有关审计和日志的工具和实用程序。许多日志由实用程序自动产生，其他日志实用程序要由管理员配置和使其生效。

(1) lastlog

该文件记录每个用户的最初目的地和最近一次登录时间。合法用户可以在登录之后得到系统从 lastlog 日志中提取的上一次登录的时间和控制终端。这样，当所提示的比如登录日期等信息如果与用户使用情况不符，就说明有可能是有人盗用账号进行非法登录。

(2) UTMP

UTMP 文件记录当前登录到系统中的所有用户。可以利用该日志跟踪、守候那些攻击嫌疑人。往往有一些黑客在第一次成功侵入别人系统之后，会再次重来。由于知道了系统的缺陷，他们再一次来的时候就会非常容易。比如某个网站的内容被居心叵测的犯罪嫌疑人修改，系统管理员发现之后，一定会再把主页的内容恢复正常。如果该黑客的目的未达到，他肯定会再次侵入系统，对网页进行修改。这时，由于 UTMP 日志文件可以记录当前登录到系统中的所有用户，所以，就可以利用该日志对入侵者进行守候，这样可得到入侵者的信息。

但是，由于一般用户都可以修改这个文件，因而该文件非常易于隐藏入侵者。

(3) WTMP

WTMP 文件记录用户登录和退出事件。与 UTMP 不同的是,它还记录用户登录的历史记录。可以使用 last 和 ac 命令来访问 WTMP 文件,其中 ac 命令可以按用户(ac- p)或按日期(ac—d)产生报告,这些报告能快速警告有关不适当的使用。如一个不太活跃的账户突然开始登录了很长时间,这可以很容易在 ac 的报告中显示出来。

(4) syslog

syslog 是一个非常有用的消息日志工具。它为日志条目的目标提供一个中心参考点,从而能够方便地记录各种程序产生的日志。该日志记录系统的紧急状态(如系统可能崩溃)、一般性错误、内核调试消息和授权失败消息(例如非法登录)等。

(5) sulog

切换用户命令 su 通过 syslog 记录它的使用情况。有些入侵者通过使用 su 命令切换到可以远程访问其他主机的用户名,这个活动也被记录在 sulog 中。通过使用 su 命令,经适当授权的用户可以作为另一个用户执行命令,而无需用那个用户的口令实际登录。

在 UNIX 系统中,超级管理员 root 的权限是非常大的。如果用户使用 root 进行登录的话,他就拥有了对系统的最大权限,他可以任意更改对其他用户或组的权限,对文件进行任意的增、删、改操作。如果那些心怀叵测的黑客获取了系统的 root 口令,他们在远程登录到系统之后,就可以对系统为所欲为。这样是非常危险的,这将对用户的正常使用甚至系统的稳定性等造成致命的威胁。所以,UNIX 一般建议,即使是系统管理员,如果没有必要的话,也尽量少用 root 身份登录。

为了系统的安全性,UNIX 的系统管理员会经常不允许以超级管理员的身份远程登录。这样,就可以防止非法入侵者从网络上用 root 身份远程登录系统,也就减少了一种安全威胁。

但是,大多数 UNIX 系统都支持 su 命令。当某人以一个一般用户的身份在远程登录之后,如果他知道 root 口令,他就可以用该命令把自己升级到 root 的身份,拥有 root 的权限,然后他就可以为所欲为。

su 命令通过 syslog 记录它的使用情况,这个信息存放在/var/admin 目录下的一个称为 sulog 的文件中。入侵者使用 su 命令切换到 root 用户或其他有特殊权限的用户名的活动都会被记录在这个日志文件中。

(6) aculog

当一个用户使用拨出设施(发送日志消息的程序称为设施),如 tip 或 cu 时,就会在 aculog 中建立一个日志条目。该日志包含了由用户名、时间和日期、拨出的电话号码和呼叫的完成状态组成的记录。与 UUCP 有关的命令也在 aculog 文

件中记录它们的信息。有时候入侵者为了减少长途费用或者避免直接电话的跟踪，可能会使用一个 UNIX 主机作为中间站，拨打到其他系统，这时检查 aculog 条目非常有用。

有预谋的入侵者常常会利用一些比较复杂的方法对系统进行攻击。他们可能会先登录到某一台 UNIX 主机，然后通过一些技术手段获得从该主机远程访问其他系统的权利，再利用 tip 或 cu 命令拨打到其他系统，以所登录的主机作为虚拟客户端非法登录该系统。这样，如果该入侵者对最终侵犯的系统采取一些违法操作，该最终系统会认为是中间的 UNIX 系统做的。幸好，aculog 文件可以记录这一过程。我们可以通过跟踪这个文件找到线索。

(7) cron

cron 守护程序是自动任务调度进程。cron 守护程序建立一个将要执行作业的内部列表，并在请求的时间间隔运行它们。如果入侵者能够操纵 crontab 文件或者该文件指定的程序和脚本，他们就能使用 cron 守护程序获得更高的权限。cron 产生的日志能够提供这种非正当使用的线索。

(8) sendmail 日志

sendmail 通过 syslog 完成它的日志。根据所产生消息的重要性，sendmail 产生的消息被标记为设施“mail”(邮件系统)和从“debug”(调试使用的消息)到“crit”(关键状态)的重要性级别。这个程序产生的所有消息在消息正文中都包括 sendmail 程序名。当入侵者试图从 SMTP 端口利用其中的漏洞时，sendmail 日志可以为系统管理员提供非常重要的线索。

sendmail 是 UNIX 中一个著名的邮件服务程序。很多 UNIX 系统都利用它来配置邮件服务系统。它的功能非常强大，除了作为服务器收、发邮件外，还可以实现许多与邮件有关的功能。然而，这个程序本身存在的漏洞很多。犯罪分子利用它的漏洞可以做很多诸如前面介绍的利用邮件系统进行的犯罪行为。

sendmail 的各种服务主要利用的是 SMTP 端口，也就是 25 端口。所以漏洞多是针对该端口而存在的，攻击也多是针对该端口的。如果现场勘查确定有人利用漏洞从 SMTP 端口进行攻击时，查看 sendmail 日志应该会对进一步勘查有些帮助。

(9) UUCP 日志

UUCP 实用工具可以把信息存储在各种日志文件中，在基于 BSD 的 UNIX 平台上，一个名为 logfile 的文件包含有关 UUCP 使用的信息。文件中的信息包括发出和接收的呼叫、发出的请求、发送者、发送时间和发送主机。UUCP 日志文件 syslog 显示每个 UUCP 事务的字节数、请求文件的用户名与站点、事务的时间与日期以及完成传送所需要的时间。Errlog 文件包含了在 UUCP 操作期间发生的任何错误。现在，大多数入侵者在他们的活动中并不利用 UUCP，因为许多主机

已不使用它或者根本就没有安装它。然而，如果入侵者使用了 UUCP，他们就可以从远程站点通过 UUCP 危害文件，因此要审计日志以便查出可疑活动。

(10) lpd 日志

lpd-errs 文件是使用打印机最常用的日志之一。多数情况下，该日志提供的信息对于安全调查并无太大作用。然而，最近发现的与 lpd 有关的故障表明，许多奇怪的错误都是入侵者试图利用某一故障的结果。进一步地说，任何进入系统的活动，只要没有使用行式打印机守护程序都有必要被调查。

(11) ftp 日志

ftp 守护程序 ftpd 使用 syslog 处理它产生的消息。ftpd 可被设置成记录入境的连接。

有很多入侵系统的案例都是这样的：入侵者先使用匿名 ftp 登录，然后获取/etc/passwd 文件，通过网上随处可得的(如 john 等口令)分析软件对所获得的密码文件 passwd 进行分析，找出用户的登录口令，然后利用所破译出来的正确口令重新登录系统，最后再对该系统进行一些有目的的非法操作。

对于这类犯罪，ftp 日志所提供的线索应该对勘查有帮助。

(12) HTTPD 日志

HTTPD 服务器在日志中记录每一次的 Web 访问，并且报告正常操作期间产生的错误，据此可产生包括哪些主机最常访问这个服务器、哪些页面最流行等内容的统计报告。HTTPD 服务器一般产生两个独立的文件，一个包含错误信息，而另一个包含访问信息。

(13) history 日志

shell 历史日志文件保存了用户最近输入命令的记录。C shell 和 Korn shell 都支持历史(history)命令功能。

我们说审计跟踪是现场勘查的一个很重要的方法，通过跟踪各种日志可以得到许多线索，以往的很多案子也都是通过这种方法得到线索之后才有了重大进展的。但是，犯罪分子也知道这一点。手段高明的犯罪分子在侵入系统，完成自己想要做的事情之后，会想尽办法对所有可能记录他们行径的日志进行修改，以使自己的罪恶行径不会被发觉。做现场勘查就是要查找任何的蛛丝马迹，以找到犯罪分子并最终使之受到法律的制裁。

即使手段非常高明的入侵者，他们对系统非常了解，知道如何比较彻底地清扫痕迹，但也常常会有一些疏忽。shell 历史记录就是容易疏忽的一个日志。许多入侵者在初次访问一个新系统时都会忘记清除他的 shell 历史记录。甚至在他们编辑其他日志并替代实用工具后，他们输入的每一条命令仍然可以在他们最初获得访问的账号下的 history 文件中清晰可见。

这样，当侦查人员进行现场勘查的时候，就可以通过 shell 历史记录来了解某

人在进入系统之后究竟执行了一些什么命令，从而分析他究竟做了哪些事情，然后进一步勘查。

(14) 进程记账日志

过去，用户需要为自己使用系统的资源而交纳费用，进程记账是为了记录用户使用了多少 CPU 时间。今天，虽然大多数系统都不再使用这种方式计费，但是进程记账所使用的日志经常能够帮助找出已访问系统的任何入侵者。日志文件通常是/var/adm/acct 或/var/adm/pacct。

可以用 lastcomm 和 sa 两个命令访问该日志。lastcomm 列出在系统上执行的所有命令信息，包括所执行的命令、执行命令的用户、用户使用的 tty、命令完成的时间、命令执行的时间和日期。从列出的信息，可以分析异常现象，从而展开勘查。举个例子，假如从列出的命令信息中观察到 root 命令的条目和某一账号发生在同一时间和同一 tty，而该账号并没有执行 su 或 sudo 命令。这就是一个疑点，很可能该账户利用系统的某个漏洞非法取得了 root 的权限，应该对这样的账户进行重点调查。

sa 命令可以根据每个用户或每条命令所占用的系统 CPU 时间输出，帮助查找某一用户或命令占用了多少 CPU 时间。如果某一用户突然占用了比以前多得多的时间，那当然也是值得怀疑的。

(15) 审计中的有用工具

许多其他工具对完成审计有极大的帮助。尽管这些实用程序并不使用特定的日志文件产生它们的信息，但可以收集这些实用程序的输出，结合其他日志综合描述系统的真实状态，如 ps，netstat，sniffer，asax 等工具。

6.3.3 Windows NT 的审计跟踪

几乎 Windows NT 系统中的每一项事务都可以在一定程度上被审计。在 Windows NT 的 Explorer 和 User Manager 两个地方可以设置审计策略。

(1) 使用事件查看器。下面说明利用 Windows NT 的日志文件进行审计的方法。

可以使用事件查看器的 Filter 选项根据一定条件选择要查看的日志条目，查看条件包括类别、用户和消息类型。Windows NT 在 3 个分开的日志文件中存放审计信息，它们分别为 Application Log，Security Log 和 System Log。其中 Application Log 文件包括用 NT Security Authority 注册的应用程序产生的信息；Security Log 包括有关通过 NT 可识别安全提供者和客户的系统访问信息，也可以跟踪非法的文件访问、无效口令输入、访问特权对象和账户名与口令的改变；System Log 包含所有系统相关事件的信息，对于许多正常的 Windows NT 审计信息，System Log 是默认的存储文件。

(2) NT 中也有记录 ftp 服务器服务的日志,可以跟踪 ftp 访问记录。

(3) NT 中也有记录 httpd 事务的日志。

(4) 用 Windows NT 的其他 TCP/IP 应用程序记录。

- SNMP 该服务能提供有用的通信量统计数字,这些统计数字来自本地网络、服务器本身及使用 TCP/IP 的应用程序。
- SQL Scrver SQL Server 自动在 Application Log 中记录它的事务请求。
- 系统管理服务器 这个工具对于监视 LAN 中来往的可疑通信非常有用。

前面用大段篇幅描述了审计跟踪。在现场勘查的时候,还要注意现场证据的保护。那些用以作为线索的日志文件,一定不能随意进行删改。

上面讲的现场勘查的对策、步骤以及重点只是作为参考。在实际案件中,案情是很复杂的,而且不同案件的具体情况也各不相同。在实地现场勘查的时候,没有必要严格按照上面的步骤进行,办案人员应该根据案件的实际情况采取相应的对策。其实计算机犯罪也跟普通犯罪一样,只不过勘查的时候需要使用一些技术手段而已。刑侦人员以前丰富的刑侦经验在这里完全有用武之地。

本篇本着传授方法的思路进行,将列举调查中的实际问题、软件知识、有条理解决问题的方案,并借此有机地再现犯罪的真实情节。当所有相关证据的查获与鉴定的细节均讲述完后,再把它们串联起来,形成一个从搜查逮捕到在法庭当庭出示证据的完整的调查过程。许多与计算机相关的案件由于缺乏调查技能而未能得到圆满解决,这主要是由于调查人员缺乏培训与经验。作者希望调查人员阅读本书后,能够有条不紊地进行计算机犯罪侦查,并记录整个调查过程,以便能为在法庭当庭质证做好充分的准备。

在接下来的章节中,会让读者对计算机犯罪现场勘查概述、现场勘查步骤、调查工具、证据类型等概念有一个初步了解,然后将讲述从单台计算机到整个网络犯罪现场的勘查、查获并备份计算机或计算机系统的方法,最后对计算机及其媒介上的证据作出切实的法律鉴定。本书将用一章来讲解涉及电子公告牌系统的调查方法与技巧,这是一门艺术,需要时间和准备才能成功地渗透到操作中进行在线调查。

第7章

计算机犯罪现场勘查

本章的内容只是一个案件侦查的范本，侦查人员在遇到实际情况时不要总是遵循这些步骤。犯罪现场勘查没有现成的指南，必须对每一个案子用心判断，有时需要据实际情况改变步骤。本章中的一部分步骤只能用于有搜查证的情况。

7.1 预先评估现场

为搜查作计划时，预先掌握一些信息是大有益处的。了解搜查的位置、类型和要取得的设备数量可以减少搜查过程中的无用功和拖延。

(1) 得到待勘查地区的图纸

尽可能画出地形或取得地面设计的副本，该信息可以从被调查地区的建筑承包商以及顾客或秘密工作者处得到。在地图中，标明包括计算机和打印机在内的所有计算机设备。如果有保险箱或地下室的话，把它们也标到地图上并标出里面可能有的东西。

(2) 查明计算机的类型和数量以及涉及的介质

计划需要的搜查设备以及用于备份嫌疑人设备的存储介质。应该尽量多地估计需要的介质，这将使勘查的时候不致于为另外需要的介质浪费时间和精力。

(3) 得到需要的软硬件

如果预计将需要特定的软硬件，那么应该及早准备。应知道在紧急情况下筹集资金非常困难，在这一步花的时间越多，准备得越充分，以后工作中的压力就会越小。

(4) 确保预先拥有工具箱里的所有工具名目

如果预先制作了所需要的工具或设备的列表，搜查的准备工作就会变得很容易。主清单可以包括需要的任何东西，当然也可以删去搜查时不需要的东西。

(5) 拥有备份和拷贝所必需的介质

7.2 建立调查队

即使搜查的只是一台单机，在只有一个调查人员的情况下，工作量也是相当大，必要时可由两个人完成所有的工作，当然，工作时间会随着训练有素的专业人员数量的增加而减少。在实际工作中也许找不到足够的人手，而只能一人身兼数职。这就需要了解搜查队成员的技巧和能力，以使每一个成员都能在他们最适合的岗位上发挥最大的作用，必要时可寻求外部专家的帮助。总的来说，所需时间与负责犯罪现场调查的人数以及用于备份系统的设备质量直接相关。作者建议，计算机犯罪调查人员最好都能配置安装了网卡的高性能手提或膝上型电脑，以便能通过 Laplink 拷贝犯罪现场计算机和通过并行、串行或网络端口来备份对等的网络软件。一个完整的计算机犯罪调查队应由以下几部分人员组成。

7.2.1 调查总监

调查总监应具备调查复杂案件的丰富经验，负责处理媒介关系、管理并安排人事和设备以及监督整个调查进程。在第一次进入现场之后，调查总监并非一定要终日驻守在现场。

7.2.2 讯问小组

该小组通常有一至两名成员，其人数取决于将被讯问的人数。他们的职责是询问每一个证人及犯罪嫌疑人，各成员应具备丰富的审讯技能。

7.2.3 素描及影像小组

该小组由一名以上人员组成。他们将速描下整个犯罪现场，对房间编号，并对整个现场内外的所有证据进行拍照。该小组可使用 35mm 的宝丽来相机或摄像机，当然两者结合使用最好，作者在此强烈建议使用摄像机。作者曾参与处理过一个案件，该案的胜负取决于一张门锁的照片，而我们在执行搜查时却根本没有意识到这一点。在庭审中，门锁是否在门上成为争论的焦点。需要注意的是，在使用摄像机时，全队都应时刻注意自己的言谈，因为现场所说的都将被录下来，法庭上播出的录像带中的低声耳语有可能令人尴尬不安。

7.2.4 物理搜查小组

该小组将安排一名以上成员搜查每一个房间。他们将找出每一证据的位置，并用有黏性的彩色小圆点标志出这些证据以便于证据查封小组的识别。这些成员

不必是计算机专家，但他们须对搜查的项目有详尽的了解，这些人还应具备周全认真的工作品质。

7.2.5 安全及逮捕小组

该小组将保护犯罪现场，保障人员及证据的安全。他们还将承担逮捕及运送犯罪嫌疑人的任务。在实际操作中，应尽可能地多配备该小组成员，其成员多由穿着制服的警察组成。

7.2.6 技术证据没收及笔录小组

该小组由两至三名成员组成。他们将没收证据，将证据资料输入计算机，把证据编号后放进工作包或工作盒内，并在对证据拍照之后在工作盒上贴上标签，该小组还负责对计算机拍照后的拆卸工作。该小组至少应有两名工作人员，一名是计算机调查人员，另一名是经证据处理和鉴定专门培训的计算机专家。在大多数情况下，该技术型小组还要指导证据的司法分析工作。当地方或更高级别的实验室准备好后，相关机构就会将计算机装箱并送至实验室作证据分析。

技术证据没收及笔录小组将在与调查总监讨论个案情况后决定采取适当的措施。他们把计算机硬盘数据备份到可移动的媒介上，驱动调查软件后，再关闭系统。接着他们应给所有的电缆作上标记，谨慎地将计算机、电缆线和附件包装好以备运输。他们还需确定所有的证据都已作上标记并已记录在案。

在涉案计算机数量较大的调查中，调查总监一般会指令一名同时精于调查和计算机技术的调查员或计算机专家，由他来负责计算机没收小组和全部技术问题两方面的工作。

7.3 建立一个攻击计划

用图表和清单写出计划，一份人人都懂的计划是调查成功的基础。清单有助于确保调查人员不会忘记该做的事情。在出发前往现场之前，所有小组成员在一起检查一下计划。一个简洁的方法是按照 SMEAC(位置 situation、任务 mission、执行 execution、进入撤退的道路 avenues 和通信 communications)来撰写计划，因为该五段式军事命令也同样适用于法律强制计划。

7.3.1 位置

对将调查的对象或面对的事物没有概念是十分愚蠢的。需要给自己即将面对的任何事物下定义，包括人数、设备类型和地理位置。

7.3.2 任务

任务是什么？是想在计算机旁抓到犯罪嫌疑人，还是想要计算机不被碰倒？在选择使用搜查令的同时，查明犯罪嫌疑人的类型也需要长时间的监视。

7.3.3 执行

怎样完成任务？一天之中的哪段时间是最好的？如果调查对象是一个商业单位而调查人员又不打算拿走设备，就可以考虑在该单位开门营业前进行调查以避免与顾客接触。另外，监视将有助于决定交通工具的类型。

7.3.4 进入和撤退的路径

怎样到达并处理现场？所采用的方法将因调查类型的不同而有所不同。通常安全及逮捕小组所采取的行动与有审计员参加的小组的行动有所不同。还应考虑怎样在出入犯罪现场时得到群众的帮助。一张好的地图应标示出哪里能够停车，哪里有潜在的障碍，哪里允许调查人员覆盖介质以及哪里可供装载搜获证据。

7.3.5 通信

小组成员间怎样保持联系？这相当简单，无线电和移动电话是常用的手段，只要每个人都处于相同的频率并且知道彼此的移动电话号码就可以了。

7.4 准备搜查令

对于涉及新技术的搜查令（或对于律师和法官而言是新技术），有必要花足够的时间去完成该搜查令。应把搜查令提交给富有经验的侦察员和公诉人检查以确保已涵盖所有要点。不要使用自己不熟悉或不懂的术语，当法官审批搜查令时，调查人员自己得花时间解释术语以使法官懂得整个搜查令。这些步骤将避免搜查令由于没有包括一些重要的证据而被否决，同时，也确保法官能明白他正在签署的是什么内容的事件。

7.5 执行搜查

执行搜查令的基本步骤也同样适用于涉及计算机的案件。即使在案发现场也不要对所作的搜查进行预先通知。由于计算机可以使用电池作为电源，不要切断建筑物的电源，不要随意地接近犯罪嫌疑人以免引起他的怀疑。调查人员要寻找

的数据完全有可能在消息泄露给犯罪嫌疑人后的几秒钟便消失殆尽。

7.5.1 敲门并通知

宣布办案人员自己的身份以及出现在那里的原因:“警察,我们有搜查令。”这样将有助于案件的调查过程。

7.5.2 逐字写出通知

如果有摄像机,一定要使用它。审讯期间录像带将会非常有用,它也有利于解决由搜查令引发的控告以及索赔。

7.5.3 保护现场

(1) 立刻确定建筑物内所有计算机的位置

随着计算机价格的降低,根据商业规模的大小现场可能有数十或数百台计算机。已经出现过一个家庭或公寓里有好几台计算机的先例。如果牵涉到一个网络,应立即定位服务器以断掉登录或现时的网络连接。

(2) 每台计算机都必须由专人施以物理的保护

如果无人管理,犯罪嫌疑人可在几秒钟之内把计算机里的证据完全删除。网络造价的降低也使得从远程登录销毁存于网络计算机中的信息成为可能。

(3) 找一个地方问讯犯罪嫌疑人和证人

这个地方应尽量远离所调查的计算机。

7.5.4 调查队成员各司其职

案件负责人应分配任务并有效地指导和解决问题。他最好不承担别的任务,以便于正确地评估和指导整个现场。画草图、问讯、照相以及搜查可以同时进行。每个分组安排一个人写报告。所有的报告、草图和相片都将们总交给案件负责人。一份问讯报告、照片和草图报告、拘捕和疑问报告、证据搜查和没收报告,以及计算机搜查和评估报告通常都是必需的。

注 在整个调查期间维持一个按时间编排的工作单,并对每个非司法人员强调该点。记录下来的即便最小的步骤在调查和起诉期间也可能是很重要的。许多计算机专家并不懂记录的需要和之后在审讯中的用途,所以有必要对他们进行必要的指导。

在犯罪嫌疑人的计算机中只能使用空白的写保护盘。不要使用犯罪嫌疑人计算机中的命令和软件,否则,有可能会改变证据。一些程序在执行时会改变数据和日期,而里面可能还存在 ANSI 炸弹或其他方案,一经运行就可能破坏、删除或格

式化计算机。

7.6 完成搜查

• 询问小组工作情况

在离开现场之前，询问小组情况并尽量解决未解决的问题。

• 新问题文档

将遇到的新问题记在为以后调查所备的进程笔记本中。本部分涉及处理规则和概念，而非法律。调查人员需要在计算机证据搜查和没收的现行法律内确定每次案件调查中什么需要做，什么不需要做。

第8章

勘查工具箱

集中所需工具完成任务是做好工作的基础，计算机犯罪调查也是如此。根据作者的经验，以下所列各项在调查中要么是必需的，要么是行之有效的。下列所有设备能够装进几个工具箱里并很轻松地携带。

注 应准备几份搜查证的副本和 Laplink 程序，因为可能需要进行另外的搜查，而自己的计算机和嫌疑人的计算机也同时都需要 Laplink。

8.1 硬　　件

8.1.1 常用的五金工具

应该使用高性能的工具，不要使用带磁性的工具。所带的工具中应有小刀，因为很多时候都需要打开涉嫌计算机或增加新的插件；一个电动改锥会派上大用场。电动工具是在调查中常常需要的，尤其当有许多计算机或硬盘需要分析的时候它也可以节省人力。在使用电动工具的时候，注意不要因工具的动力矩而损坏硬件或因驱动这些工具的发动机产生的磁场而擦掉证据信息。

8.1.2 用于备份的硬件

备份硬件可以是贝努里驱动器、光盘、移动硬盘或磁带备份。随着计算机容量的增加，把所有的数据都备份到软盘不再具有实际操作性，这将消耗大量的高密盘和时间。迄今为止，调查人员比较喜欢用贝努里磁盘来进行备份。用 2～6 张 230MB 的磁盘便可备份大多数的系统，还可用 G 字节的可再写光盘备份容量较大的磁盘。磁带可用于备份涉嫌计算机，如果决定使用磁带，就得保证计算机有足够的空间来保存磁盘以对证据进行分析。

8.1.3 桌面电脑

桌面电脑至少应采用如下配置

(1) Pentium 90, EISA 和 PCI 总线, 64MB 内存, 全高塔式机箱 Pentium 90MHz 处理器提供调查所需高速平台;EISA 总线提供通常操作使用的所有的卡可能需要的高速扩展槽;PCI 槽提供高速声音扩展和高速磁盘扩展;塔式机箱有多个驱动器口并且更容易拆卸放在里面的卡和驱动器。

(2) PCI 和 SCSI 卡 SCSI 卡提供对几乎任何 SCSI 设备最高速的支持。

(3) 内部 4GB 的 SCSI 硬盘 一个 4GB 的硬盘将会有足够的存储空间来存储应用程序和文件。还应该保留一些空间以备调查期间的使用。

(4) Iomega SCSI 压缩驱动器 Iomega SCSI 压缩驱动器可以实地备份计算机,它是调查用计算机的好伙伴。SCSI 接口为办公室工作提供附加功能。压缩盘的初始容量在一个小的可写软盘上是 100MB。

(5) Iomege Bernoulli 1-GB 可写光盘驱动器 基于长期存储的考虑,一个可重写光驱是存储整个案子的理想介质,它的内容在磁性环境里不易被破坏。也可以考虑买一个大容量的 WORM(写一次,读多次)来存储原始数据。

(6) 8 毫米磁带备份 应经常对自己的计算机进行备份。8 毫米磁带与录像机中的磁带外形相同,最小可存储 5GB。

(7) 有 16550 UART 的高速串行卡 当进行电信通信时,高速设备能很容易地通过其在时间和长度方面的节约来体现自己的价值。串行卡使用现代高速芯片(UART),可以从 modem 上提高 5%~20%的附加速度。许多计算机已经在主板上配备做为标准设备的 UART。

(8) 有 4MB 真彩显卡的 SVGA 监视器 当调查的案子涉及到计算机上的图片时,便需要一个能显示 1280×1024 像素和 32k,64k,16M 色的图形的显示系统。调查中使用更大一些的显示器将会更有利于工作。

(9) 鼠标或跟踪球 这在每一台计算机中都有,选哪一样全凭个人喜好。

(10) External U. S. Robotics Courier HST Daul standard FAX/modem 现有的所有调制解调器中,HST 双标准是 Rolls Royce。它可以连接到使用 V. 32, V. 34 和 HST 的 modem,甚至有连接 ISDN 的能力。这是市场上仅有的能够以这种方式连接的 modem,它的价格比新的 V. 34 modem 高,但它物有所值。内嵌传真将允许用户用字处理器或计算机上的其他应用程序收发传真。

(11) Lexmark Optra R 激光打印机 该系列打印机可以满足打印所有报表的需要。Optra 系列有最大每英寸 1200×1200 点(dpi)的打印方案,它的墨盒可以支持打印数千页纸。该打印机可以有两种速度,包括每分钟 12 页和 16 页。应确保打印机有 4MB 内存,8MB 内存更好。该类打印机兼有 PostScript 和 PCL 5 两者的特征。

(12) Epson LQ-2500(或设备高速点阵打印机) 一些案子需要一台高质量的高速点阵打印机,这样,激光打印机就派不上用场了。现在此类打印机的数目不

少，Epson 是比较常见的一个，它的色带和其他配件比较容易得到，一个串行接口也容易配置。

(13) Canon BJC-600e 喷墨打印机 Canon BJC-600e 打印机打出来的彩色效果非常好，适合在法庭上或其他特殊场所使用。使用这种型号打印机，可以很容易地在一些特殊胶片上做出彩色透明效果。当打印很多图片时，墨盒消耗得很快，应该在手边有多个备用的墨盒。

(14) 外置 SCSI CD-ROM 驱动器 许多应用程序和数据库可以从光盘上得到。为提高数据的读取速度，应选择高速驱动器。

(15) 1200-VA 在线电源备份 计算机最容易产生问题的部分是电源。停电或电源抖动可能破坏调查，删除硬盘上的数据。备份电源能提供恒定的、过滤过的电流，而不用去考虑电力公司提供的电流如何。

8.1.4 便携式电脑

便携式电脑至少应采用如下配置。

(1) 带底座的 IBM ThankPad 755CE IBM ThankPad 是调查人员较好的选择。IBM ThankPad 755 系列有 3 年的质量保证。假如计算机出了问题，也不会在修理店里浪费很多时间。755CE 有一个活动 TFT 彩色点阵显示，支持 16 位真彩。可用的处理器包括 486DX4/75，486DX4/100 和 Pentium。ThinkPad 有两个 Type II PCMCIA 插槽、一个内嵌 FAX/modem，这样就不必再使用 PCMCIA 或外置调制解调器。笔记本电脑的主板上有一个 16 位的声卡，有一个内置的麦克风和音箱；笔记本电脑的一侧有一个外置立体声音箱的接口和麦克风接口。ThinkPad 的其他特性还有很多，这里不再赘述。供 ThinkPad 使用的底座能够使用户的 ThinkPad 用起来像一台台式机。底座 I 备有两个 ISA 插槽和两个半高驱动器的空间，可配置软驱、光驱或硬盘驱动器。底座站还包括多媒体音箱，这些对于在法庭上显示色情录像或其他信息都是极其有用的。

(2) ISA SCSI 卡 一个内部 ISA 插槽应被用于插 SCSI 卡来连接内部和外部 SCSI 设备。这包括可拆装的硬盘和磁带驱动器。

(3) Iomega 并行压缩驱动器 这个可拆装驱动器是用于台式机上的 SCSI 版的好伙伴。并行版几乎可以连接任何并行打印机端口并在驱动器和所连接的计算机之间拷贝数据。驱动器使用的磁盘与 SCSI 版完全兼容。

(4) Xircom CE2 Combo CE2 Combo 是一个 PCMCIA 以太网接口，包括 10Base-T 和 10Base-2 两个适配器，驱动支持 DOS/Windows 和 OS/2。如果连接的设备支持的话，该适配器可以全双工模式运行。

(5) Cabletron 并行端口以太网适配器 当备份一台诸如 notebook 的计算机时，不能安装网络接口卡。Cabletron 接口将帮助调查人员通过并行端口把嫌疑计

算机与自己的便携式计算机的网络相连。虽然计算机性能将会受影响，但是仍然可以方便地用网络进行备份。

(6) Cabletron E222 以太网卡(3) 为连接一台嫌疑计算机到自己的便携机，需要在自己的计算机中安装一个网络接口卡。

(7) 具有同轴连接头的 Cabletron MR9TC 10Base-T 以太网 hub MR9TC 是小型的、其或袖珍的有同轴连接头的 10Base-T hub。

(8) Canon Bubblejet 打印机 一个好的便携式打印机，例如 Canon Bubblejet 打印机可以提供高质量的打印输出，并且便于携带到犯罪现场。根据用户的要求，这台打印机既可以打印彩色也可以打印黑白的。

(9) 400-VA 在线后备电源 这种后备电源很重，但它可以帮助用户解决电源问题，使用户在停电时可以照常工作。

(10) ThinkPad 提包 在携带一台笔记本和底座站时，应使用质量好的手提包，它们可以保护设备。

(11) 设备箱 有必要考虑用于装其他所有设备的设备箱。作者在办案过程中曾遇到因设备从车上掉下来而使设备受损的情况，一个箱子或运输包将防止这类损坏。这些箱子最好是为特定用途而专门制作的，如果没有特殊制作的箱子，那么就找找房间里有没有要丢弃的手提箱。在里面垫上泡沫塑料，这些箱子也同样能派上用场。

8.1.5 其他有用的工具

拆卸装有计算机及其辅助设备的工具箱是必需的，对大多数案件仅需要一套改锥。有许多工作要做时，手边有一个电改锥是很方便的。根据调查要做的工作和涉及的专业知识，可能需要别的更多的工具。

1. 运计算机的车

- 载重量大的可折叠式计算机手推车 越大越好。它有利于把所有调查装备一次性地从汽车运到嫌疑地。
- Bungee 绳 保持设备在车上的安全是至关重要的。

2. 介质

每次要使用大容量介质时，都应使用其备份。一些案子的证据需要保存的时间长达几个月或几年。作为一个调查人员，不能让所有介质在如此长的时间内多次频繁使用。

- 最少 10 张空白 ZIP 盘
- 最少 2 张可写光盘
- 最少 200 张格式化的 3.5 英寸高密软盘

- 最少400张格式化的3.5英寸低密软盘
- 最少200张格式化的5.25英寸高密软盘
- 最少400张格式化的5.25英寸低密软盘

3. 线缆

- 最少4根25英尺或更长的10Base-T(非屏蔽的,有RJ45头的双绞线)
- 最少2根50英尺或更长的10Base-T hub-to-hub线缆
- 最少4根25英尺或更长的10Base 2(带BNC插头的RG 58同轴电缆)
- 最少2根20英尺长的25针并行线
- 有RJ45串行线插口的Cabletron 9针和25针头

4. 包

收集手边所有的防静电包。在许多牵涉计算机的案件中对计算机设备进行长期存储是司空见惯的,这就存在着因潮湿或静电使证据受损的危险性,因此需要合适的包对证据进行保护。

5. 其他

- 打印线缆
- 系列端口连接器
- 用于通信的三相转接开关、断开盒和调制解调器线缆
- 送纸器型计算机用纸(该类型纸张可用于报告、收据、搜查令和其他文档)
- 用于证据盒的标签
- 3×5英寸的卡片
- 有粘性的彩色圆点(用于标示证据,不同的搜查房间用不同的颜色并标上执行搜查的调查人员的姓名首字母,以避免法庭上证据链出现问题)
- 用于现场绘图的图表纸和直尺
- 袖珍打印机和计算机
- 浪涌保护管、高负荷电缆和扩充塞绳
- 空白侦查报表
- 证据记录表
- 联系人员名单(通常包括调查小组成员、软硬件制造商以及其他能够提供现场及电话咨询的计算机和调查组织)
- 标示插件和电缆的粘性号码(任何计算机设备没有接通时,都有必要在连接的两头均作上独特的标记以确保以后的重新连接)
- 折叠箱
- 包装带
- 橡皮手套、漂白剂和一次性抹布(一些地方并不卫生)

- 闪光灯和高能电池
- 宝丽来相机和超长胶卷
- 35mm 相机、胶卷和电池
- 以备临时搜查之需的搜查令样本电子版或文件
- 放置证据的盒子
- 运送盒子和其他设备的手推车
- 毛毡头的钢笔或标示器
- 小型不间断电源以备设备之需(作者曾多次遭遇电源出了问题,所以最好带上 110 伏、配有 3 相和 2 相插头的转换器)。

注 根据作者的经验,需要准备购物清单和迅速到位的资金以购买软硬件、工具、磁盘以及聘请专家和技术人员。否则会因缺乏设备或技术协助而无法完成搜查任务。而在之后的证据鉴定中也会遇到同样的困难。

8.2 软件程序

对软件程序的建议是,尽所能地备有能收集到的所有软件。调查过程中,说不准什么时候就可能需要一个已过时的软件。在用户的计算机服务组废弃一些软件时,可以把它们拿过来加入自己的收集中,这样,用不了多长时间,就会收集到很多软件。下面是对调查人员有用的一部分软件程序。

8.2.1 计算机搜查程序

用户应在软盘或用于调查的计算机硬盘上存储这种程序。该程序是一个可以输入有关证据重要信息(证据标签上内容)的数据库程序;该程序还可用来制作证据搜获收据和证据细目清单。若用户擅长数据库程序,当然也可以设计自己的计算机搜查程序。

8.2.2 XTreePro Gold

XTreePro Gold 是一个实用的文件管理程序,它能帮助查找到网络或硬盘上几乎任何位置的文件。我们把 XTree 作为初步的调查工具来检查涉嫌计算机的硬盘和软盘。XTree 支持使用大多数程序的原始方式、或者用十六进制(HEX)和美国国家信息交换标准代码(ASCII)来读程序;它还将支持用户复制,寻找文字和文件名等等。该程序将支持按照日期检索文件以确认嫌疑人使用和未使用计算机的时间。我们曾调查过一个猥亵儿童案,该案嫌疑人热衷于从早到晚地在公告牌系统上玩游戏。他涉嫌在某日的凌晨 3 点~4 点猥亵婴儿床上的女婴。计算机显

示在此时间段嫌疑人一般都在家玩游戏，但在他住所附近的猥亵事件发生当日的3至4点，他却没有操作计算机。当然这并非结论性证据，但在整个案件的调查过程中也起到了一定的作用。整个 XTreePro Gold 软件包由于占用空间太大而不能被单张软盘容纳，而含有 XTree 的文档却会引导用户如何将单独的 XTree 程序安装在单张软盘上。应注意的是：XTree 不会出现在 DOS 系统中，用户得费点心思去寻找它。

8.2.3 Laplink

被查获的计算机在移动前必须备份是我们的一个基本原则，这是为了防止计算机在运输过程中受损而使所有证据遗失。我们也总是在嫌疑人磁盘的拷贝上作证据分析以免改变原始证据。Laplink 便能够借助一系列平行的电缆将数据从嫌疑人计算机拷贝到备份盘上。5.0 版本具备一些很有用的功能，但是有时 5.0 版不起作用，这时，就应该用 3.0 版。Laplink 在配备有 500MB 磁盘的计算机上运行得最好。如果用户需要拷贝大量磁盘、压缩盘或大容量的硬盘，Laplink 就会因受限于计算机和接口速度而要花费数小时来完成整个拷贝过程，这时，我们向用户推荐使用以太网卡(Ethernet card)的对等软件 Lantastic。通过以太网拷贝计算机要比 Laplink 快好几倍。最新设计的 Image MASSter Solo2 Forensics 系统可以每分钟 1GB 的速度将嫌疑硬盘的内容镜像获取到复制硬盘，传输的数据是嫌疑硬盘的准确的复本，在复制过程中没有任何改动、数据重排和紊乱。

8.2.4 McAfee，Norton 等查毒杀毒软件

在计算机上运行查毒软件可以发现被病毒入侵的程序并保护计算机。

8.2.5 AnaDisk/Viewdisk

普通版和法律版的 AnaDisk 和 Viewdisk 都可以从 Sydex 软件公司得到。这些软件包能对正在调查的软件进行审计追踪鉴定，该软件将支持用户检查非常规格式化的软盘。

8.2.6 类磁盘驱动程序

这些是用于格式化并制作启动盘的作为第三方的应用程序。该类程序中较为典型的是磁盘管理软件包。

8.2.7 Fried 和 Mares 应用程序

该类专为司法编写的应用程序具有多种特殊功能。根据该程序制作的概要盘

可以远距离地检查涉嫌计算机。也就是说，如果用 PKZIP 制作一个压缩了的随机存储盘，盘上的程序会依次检查涉嫌计算机的程序，然后执行这些程序，并把数据保存到软盘上。这就为调查人员提供了嫌疑人磁盘存储信息的概况。我们通常会运行大量的程序，从硬盘保护程序开始以防止破坏涉嫌计算机硬盘。接着我们保存引导扇区、CMOS，并复制 AUTOEXEC. BAT 和 CONFIG. SYS；列出涉嫌计算机的所有目录和文件（所有隐藏的、系统的和删除了的文件）；还要列出那些未经拷贝的文件。这便很好地为我们提供了嫌疑人磁盘的概况。

8.2.8 PC-Tools

PC-Tools 是一套支持用户更好地维护计算机的应用程序。其中包含的一个最常见的 PC-DOS 备份程序叫做 Central Point Backup，请注意该程序的不同版本之间并不总是相互兼容。我们总是习惯于保存 DOS 和应用程序的老版本以备不时之需，这对于 PC-Tools 也是如此，因为备份程序的新旧版本并不兼容。

8.2.9 Lantastic

这一网络对等软件可由软盘运行。注意在使用以太网卡和电缆快速拷贝涉嫌计算机时，不要在涉嫌计算机硬盘上写进东西。

注 针对其他的计算机操作系统也有相应的侦查软件。

8.2.10 disk copy fast

disk copy fast（简称 DCF，是一种共享软件）：DCF 支持用户用单个 pass 拷贝任一软盘并制作多个拷贝。DCF 在拷贝进行期间，使用用户的硬盘、EMS 及 XMS 存储器来保存软盘映像。DOS diskcopy 仅用常规内存，需要用户多次交换软盘。DCF 也把一个软盘映像存储到硬盘上，并通过调制解调器传给另一个人，这个人再接着使用 DCF 的拷贝制造软盘。

8.2.11 压缩程序

以下是一些常见的压缩程序：

PKZIP(共享)	USQ(共享)
LHARC(共享)	TAR(共享)
PAK(共享)	COMPRESS(共享)
ARJ(共享)	GZIP (共享)
ZOO(共享)	LIST(共享)

8.2.12 启动盘

为不同版本的DOS系统准备低密启动软盘仍是有必要的。MS-DOS 6.0通常适用于所有IBM兼容机，但是一些较老的机型需要MS-DOS 3.0或更低的版本。仔细检查嫌疑人的计算机是否使用了增强存储的软件，如Super Store，Double Space和Stacker来管理硬盘驱动器。如果是这样的话，就需要有包括相应驱动程序的启动盘，检查涉嫌计算机的CONFIG.SYS和AUTOEXEC.BAT以找到驱动程序。

启动盘是确保自己不受嫌疑人设置的陷阱欺骗的第一层保护。它的另一个好处是使用户可以在计算机启动时控制系统进程防止启动进程中出现问题。

1. 什么是启动盘

在知道了启动盘的用途之后，再来说说什么是启动盘。首先，磁盘(实际是软盘)是用于每一台计算机的可移动的存储介质。用户对此应该明白，可能不懂的是引导部分。引导(boot)来源于引导程序(bootstrap)，指在一台计算机上装载操作系统的过程。所以当我们说"引导计算机"时，要知道这意味着是加载操作系统。

2. POST检测

一台计算机在启动前是不可用的。操作系统允许人与计算机及其上面的程序进行交互。当用户打开计算机时，一个叫电源自检(power on self test)的程序开始运行。该程序将在计算机的只读存储器(ROM)中找到并执行，不同地方可能需要耗费的时间从几秒到几分钟不等。

POST检测通常包括检测内存、显示硬件、软盘和硬盘以及键盘。POST完成以后，POST软件加载从ROM中读出的程序以告诉计算机如何启动操作系统。对于多数计算机而言，该软件会按照先软盘后硬盘的顺序来寻找操作系统程序。一些计算机在系统建立时有一个配置选项可以改变先软盘后硬盘启动的顺序。为防止随意改变软盘硬盘启动顺序，用户需要有熟悉自检程序并懂得修改控制该选项的CMOS设置。

3. 引导过程

在引导过程中，基本操作系统被加载之后，其他程序也可能被加载。这些程序可能包括

- 常用于运行和管理诸如光驱、磁带驱动器、声卡、网络接口卡、可写硬盘、打印机接口、公告牌调制解调器、扫描仪和光盘驱动器等设备的驱动程序。
- 补充的文件系统如HPFS，FAT，NTFS或NFS等。
- 网络访问软件。

- 键盘增强程序(例如那些支持用户使用先前输入命令的程序)。
- 支持应用程序发传真的驱动器。
- 防止未授权访问的安全软件。
- 图形用户接口如 Windows。

对于特定用户来说,在此期间被加载的软件,一些可能是顺利操作计算机所必需的,一些可能是使用计算机的所有组件所必需的。这依赖于计算机将要作何用途,当评估一台特定计算机时,并非每一部分软件都需要加载。这可能会妨碍调查软件的运行而阻碍调查进程。

当用户用自己做的启动盘启动计算机时,不用加载硬盘上的 CONFIG. SYS 和 AUTOEXEC. BAT 中列出的驱动程序和软件,而只加载用户需要的程序。这使用户在不受其他程序干扰的情况下运用调查软件对计算机进行勘查。这一步骤对运行调查软件进行调查的效果有影响。

4. 制作启动盘

在 DOS 操作系统中制作启动盘非常简单,但当其他操作系统和文件系统介入时,制作过程就不那么简单了。该过程也依赖于用户作为目标的将用于勘查的文件系统。如果用户想把所有的数据存在一个高性能文件系统(HPFS)盘上,则需要运行支持在自己的调查盘上运行 HPFS 的软件,如 OS/2 操作系统。如果用户不知道怎样做,就需要一位专家来解决这个问题。

我们将会在 3.5 英寸盘和 5.25 英寸盘上分别做一个 DOS 引导盘,该启动盘将使用 DOS 6.0 版本。例如,我们给一台计算机装载 DOS 6.0 操作系统。A 是 3 英寸盘驱动器,B 是 5 英寸盘驱动器。盘是新的且没有格式化。做好之后的盘可以让我们启动一台计算机到 DOS 对话界面并用一个叫 HDSENTRY 的硬盘保护程序防止写硬盘(HDSENTRY 是可以从 Andy Fried 得到的程序)。

下面的例子引导制作一个 3 英寸启动盘的过程。要制作 5 英寸盘,只需把所有的参数从 A:改到 B:。记住,C:几乎总是代表硬盘,只有极少数的情况 C:不是硬盘。

第一步 用下面命令格式化磁盘:

```
FORMAT A:/S
```

这将把磁盘格式化为文件分配表(FAT)格式并装入 MS-DOS 6.0 的引导文件。这些引导文件包括 IO. SYS 和 MSDOS. SYS,它们将被标志为系统文件、隐藏和只读,同时该引导文件还包括命令处理器 COMMAND. COM。

第二步 生成 CONFIG. SYS 文件。

该文件含有操作系统怎样配置自身的信息,为生成这个文件,需要使用硬盘上的 DOS EDIT 程序。用于制作该文件的命令是

```
EDIT A:\CONFIG.SYS
```

这将提示系统编辑器生成 CONGIG.SYS 文件。在主编辑屏出现时，菜单里什么都没有，需要在空白编辑屏幕上输入以下信息：

```
DEVICE=A:\SETVER.EXE
FILES=50
BUFFERS=10
```

保存文件并退出。第 1 行命令将在 CONFIG.SYS 中加载一个驱动程序，以支持一些软件的旧版本在更新的操作系统中同样能运行。第 2 行命令允许操作系统一次最多打开 50 个文件。第 3 行允许文件缓冲区为 10。

第三步　生成 AUTOEXEC.BAT 文件。

该文件会保存特定操作环境配置、运行特殊应用和配置软件的信息。终止后驻留内层(TSR)程序通常是从这个文件执行的，因为系统被启动时它总是自动执行。生成这个文件的命令是

```
EDIT A:\AUTOEXEC.BAT
```

这将启动系统编辑器来生成 AUTOEXEC.BAT 文件。当主编辑器出现时，又需在空白编辑屏幕上输入

```
PATH A:\
    HDSENTRY
    PROMPT Safe  $P$G
    SET DIRCMD=/A/OGNE
```

保存文件并退出。第 1 行命令设置查找路径为 A:驱。第 2 行运行 HDSENTRY 程序，该程序在勘查期间将把嫌疑硬盘设定为不可写从而保护硬盘。许多类似的程序有硬盘锁的功能。如果尝试写磁盘操作，软件锁将阻止它执行并提示有一个写操作被尝试。第 3 行改变显示路径，以在当前路径名字前面显示“safe”。这将提醒用户正在使用的引导 DOS 的版本是洁净的。第 4 行设置 DIR 命令以列出目录中包括系统及隐藏文件的所有文件。结果列表将按名字排序并且目录名显示在文件名之前。

第四步　用下面命令把 SETVER.EXE 程序从硬盘拷贝到软盘：

```
COPY C:\DOS\SETVER.EXE A:\
```

用户需要关注 DOS 文件在硬盘上的位置。一些安装程序将把 DOS 文件存储在另外一些子目录如 DOS 62 或 DOS 6 中。

第五步　把 HDSENTRY 程序从自己的硬盘拷贝到软盘上，应在硬盘上备有该程序。

使用与第四步类似的程序命令将 HDSENTRY 程序从硬盘的调查软件目录下拷贝到软盘，但是需要改变一下路径和文件名以正确地标示该程序。

第六步 查磁盘上的病毒，然后写保护磁盘。

5. 制作启动盘可能遇到的问题

尽管生成一个引导盘非常容易(尤其是在制作过多次之后)，但仍需注意一些问题。下面是可能出现的问题及其解决方案。

(1) 在嫌疑人的计算机上不能读盘

这可能是在低密驱动器上使用高密盘引起的。仅用肉眼很难辨别出驱动器的类型，用户可能需要查看 CMOS 设置以确定其类型。如果使用的是低密驱动器，则用含有低密参数的格式化命令来格式化恰当的磁盘。完成该步骤的信息可在在线服务中查到。不要尝试把高密盘格式化成低密盘，这会导致一些问题，而且有时格式化不能进行。

(2) 使用低密盘发生错误

这可能是在高密软驱上格式化低密盘造成的。5 英寸盘容易出现此现象，而 3 英寸盘通常不会。为解决这个问题，可尝试重新格式化磁盘。不要选择快速格式化，因为这事实上不会重新格式化磁盘。如果用户新格式化的磁盘还是不能使用，便不得不找到配备低密软驱的计算机来进行格式化。有时还可能不得不再次使用低密软驱来拷贝数据文件。

(3) 操作系统不启动

这种情况的发生可能有几个原因。

- 用户正在一台非 PC 的计算机上引导 PC 操作系统。对一些新得到的计算机，识别应使用何种操作系统并不容易。用户可能错误地把一个新型 Macintosh 或 Power PC 认为是传统的 PC。许多计算机的外观在未经训练的人看来(甚至根本就没有看)都是一样的，而仔细观察，就会发现有说明计算机制造商的小标记，通过这些小标记可以说明该机是否是 PC。
- 硬件有问题。硬件问题包括脏的或坏的磁盘驱动器、破坏了的硬盘分区、不正确的 CMOS 设置、坏的内存、坏主板、坏处理器以及坏的电源设备等。
- 误操作。用户的操作可能不正确，例如在用 FORMAT 命令格式化磁盘时可能忘了使用/s 参数；可能用了 B:盘来引导；可能把 5 英寸盘插斜了或上下插反了。

从以上的建议来看，犯罪现场侦查需要很多东西；而事实上，即使再多的工具也难以尽如人意。记住墨菲的计算机侦查法则：

“你没有的设备正是你最需要的设备。”

第9章

计算机证据

9.1 计算机证据类型

9.1.1 书证

许多犯罪包括人身及财产犯罪都会留下书证。计算机相关案件一般也不会例外。在案件牵涉到计算机的情况下，有可能不会发现很多书证，但它们还是比想像得要多。

发现计算机或与计算机有关的证据或许是件令人高兴的事。用计算机保存数量众多的书籍可比用纸张要容易得多。打印出原件后，再将文件副本保存在计算机里是件很简单的事情。此外尚有许多实例能说明计算机是如何保存所需信息的。进一步地说，读者不妨想一下当自己想在纸上写什么内容时，而在计算机上是怎样操作的。在计算机可以履行的许多任务中，打印报告、通知、信件、棋盘式分析表和图表是最为常见的。计算机能够很快地完成长篇报告，而且打印技术在速度、质量、颜色各方面还在不断改善。使用个人电脑的人常常对基于家庭使用的电脑和打印机牢骚满腹，他们希望拥有与在办公室一样甚至是更好的设备。

9.1.2 计算机部件

调查过程中调查人员要面对的计算机有多种尺寸、形状及颜色。就算不熟悉计算机使用的人也能识别许多部件。大多数部件看起来像电路集成块，而其中一些设备需要特殊处理以维持其证据功能。

9.1.3 主机、键盘和显示器

几乎所有的人都能识别出主机、键盘和显示器。键盘外观都很相似，显示器看起来像电视机。在这三个部件，主机在处理时需要小心谨慎。尤其当处理的是更大型的计算机，则需使用另外的规则。

9.1.4 磁盘

磁盘的标签有时会包含重要信息，而有些磁盘却可能没有标签。调查人员必须分别检查每一个磁盘以确定其内容，因为有时一组磁盘可能储存着相关资料。当处理大量磁盘时，用户可以抽查一个磁盘以确定磁盘上的标签与存储内容是否一致。

9.1.5 磁带存储单元和媒介

磁带一般用来作为备份文件，它们是较廉价的用于储存大量数据的外存设施。个人计算机通常使用的磁带有 DC20×0、4mm 电子音频磁带、8mm 录像带、DC600 等等。数字代表着磁带的类型或标准代码。大多数磁带都较为小巧，能放进口袋中。

9.1.6 主板及元件

多数计算机使用者手边都没有主板，因为他们对摆弄计算机内件不感兴趣，他们最多在抽屉的盒子里放着一块旧主板。而总是修补自己计算机内件的计算机爱好者却例外，这类人也许在办公室或家中放有好几块主板。处理任一主板或电子元件时均需格外小心，因为一个人体内微小的静电流都可能导致精密的元件受损。不要漏掉在搜查令中列明的所有应该搜查的部件。如果读者使用本书中的搜查证例子作为典范，就应将几乎所有的计算机部件都列入搜查之列。

9.1.7 调制解调器

调制解调器“modem”的全称是“modulator/demodulator”。最初的调制解调器用于计算机通过电话线相互对话，而今天的调制解调器技术已发展到可通过它收发传真甚至作为语音应答机使用。调制解调器还是使用信息高速公路的重要工具，大多数在线服务商只允许用户通过调制解调器拨号来获得服务。相关设备都可能成为重要的证据。在调查时发现调制解调器时，应记下它的连接，如计算机电缆线和电话线；如果调制解调器与电话线相连，还应尽可能地记下电话号码。

9.1.8 打印机和其他硬拷贝硬件设施

硬拷贝设施有多种类型，包括激光、喷墨式、点阵式、菊花轮式以及热敏式等。

9.1.9 PCMCIA卡

小巧袖珍的PCMCIA (personal computer memory card international association,个人计算机存储器卡国际联合会)卡一般用于笔记本及膝上型电脑，一张PCMCIA卡的大小相当于一张厚的信用卡。便携式计算机上配有PCMCIA硬盘驱动器、网络接口、快速存储器、调制解调器、小型机系统接口、只读存储器和音响设施等。台式机上也配有可供使用PCMCIA卡的转接器。

9.1.10 软件及使用手册

不要忘记寻找计算机旁书桌或书架上的使用手册，这将使用户对计算机内的软件类型具备清醒的认识。

9.2 发现计算机相关证据

计算机相关证据的寻找与在常规侦查中证据的寻找并无不同[7,8,9]。用户需时刻牢记，一些计算机证据由于体积小、看起来无关紧要而容易被忽视。

桌面

桌面上可能放有多种书面材料，包括记录、分类账、清单、说明、便条、备忘录、计算机用纸、使用手册以及计算机配件和电缆、底片、小盒子、收音机、电视机、磁带和常见的办公用品等。这些材料经过正规的检查就有可能成为证据。

显示器

显示器是常用来粘贴记录的地方，这对于调查人员确定使用者和系统口令是十分有用的。许多计算机用户以及计算机罪犯都为他们经常登录的网络和系统设置多重口令。多数情况下，使用这些系统需时常改变口令，而总在大脑里记住这些变化的口令并非易事。

电话机旁

电话机旁能够找到的证据包括电话号码、口令、使用者姓名、便条以及具有证据价值的其他谈话记录。

钱夹里

身份证、信用卡、电话卡、便条、黑客姓名、数字和密码、时间表，甚至磁盘都有

可能在钱夹里找到。同样，在电子钱包日益普及的今天，也可能在电子钱包里发现上述物品来作为证据。

嫌疑人的口袋里

对于许多计算机工作者而言，衬衣口袋是最常用的携带软盘的地方。这些软盘一般包含大量信息。最新的磁光存储技术使得一个 128MB 的软盘能放进衬衣口袋里。

汽车能够容纳上述所有的证据。高性能的膝上型计算机、移动电话和配有 12V 供电设备的移动式调制解调器使汽车成为很多人的第二办公室。

9.3 查找计算机证据

大多数有计算机的地方都会留下使用过计算机的确切痕迹，正如汽车会留下轮胎痕迹和油污。废弃物里的计算机纸齿孔裁边能很好地证明计算机的存在，打印的报告、数量较多的信函及棋盘式分析表的复印件和打印的图表均是计算机存在的很好证据。千万不要忽视废弃物！大多数案件中，嫌疑人都是把关键的文件和磁盘证据扔进废弃物里，后来又被机警的调查人员发现。嫌疑人总是习惯于逐步地处理掉口令、黑客记录以及诸如此类的有用证据。有时键盘的背面等一些非常不起眼的地方就存放有计算机证据。

9.4 检 查 证 据

计算机可在极小的空间里存储很大的信息量，一张软盘可能体积很小，却可将它放进口袋里、藏进书中或粘在键盘底部等等。而这样的软盘可能含有足够的信息可为调查人员提供直接证据或间接证据。

如果牵涉到打印机，就得用大量的时间进行检查。不要盲目地将这一潜在的证据忽视，这样做的结果很可能是以整个案子为代价。在堆积如山的纸张里，说不定就有犯罪嫌疑人隐藏其资产的秘密银行账号或者在过去、现在和将来他侵害的受害人名单。

9.5 收 集 证 据

在计算机犯罪证据搜查中，遵循其他类型证据收集的一般步骤也是行之有效的。给查获物品拍照并做上记号、贴上标签以标明它们被发现的位置。在重新安装设备以进行检查和在法庭上说明搜查行动时，标签和相片将是至关重要的。当设备被查获时，调查人员应带走所有与搜获物品有关的手册、电缆和部件，因为这

些东西可能有助于以后的分析。调查人员应在运走被搜获计算机之前备份所有的系统内容。无论在搬动系统时如何小心，遗失系统内储存信息的风险还是很大，而很多信息是无法恢复或被替换的。调查人员应花费额外的时间来验证系统已经备份，搜查过程中的理智和冷静将使自己受益匪浅。

计算机相关证据具备的性质跟其他证据大体相同，只有一点例外：计算机的不稳定性使得它容易受损或被破坏。必须极其小心地处理所有计算机设备，按照既定程序来正确保存计算机和电子证据。以下的文字将为调查人员提供在法庭上的一些方法，以备当辩护律师想以可能的误操作为由提出证据无证明力时，调查人员能予以反击。作者建议在执行搜查令和之后对没收物品进行鉴定的过程中，只有具备足够计算机知识和操作经验的人员才能对计算机及其外部设备、软件、程序以及其他技术性和专用设备进行处理。以下例证中涉及的设备显得尤为重要。

9.5.1 大型计算机

大型计算机的体积很大，它通常需要一间拥有良好电源和空调设备的专用机房。大型机常用于大的商业和政府机构。搜查大型机时，有必要寻求熟悉大型机及其软件操作的人员，如系统程序员的帮助。多数配备大型机的机构都有自己的系统程序员，如果不信任现场的程序员，可与计算机制造商直接联系，因为他们一般都有这样的技术人员来为客户服务。

9.5.2 小型计算机

小型机与大型机相似，都需要经过专门培训的人员的维护。供应商通常也会为这一更小的系统提供相应服务。同大型机一样，在调查这类机型时，调查人员也可与供应商联系以寻求技术支持。

9.5.3 专用计算机

当调查人员接触到任何并非大型机或小型机的专用计算机，而其软件经过专门设计的情况下，求得熟练掌握此类计算机及软件操作人员的协助是十分必要的。该系统供应商也许能提供最好的技术帮助。

9.5.4 UNIX 工作站

UNIX 工作站在商业及家庭中日益普及。UNIX 是 Internet 的前身，它提供了一种归并到信息高速公路上的简单方法。调查中 UNIX 的出现给我们带来了有趣的挑战。调查人员必须特别小心地正确关闭 UNIX 机器以免破坏文件系统。由于该操作系统固有的复杂性，当调查人员的工作涉及到 UNIX 的特性时，应求

得专业帮助(有各种类型的 UNIX,包括 IBM 的 AIX)。

9.5.5 黑客系统

对于遇到的每一个黑客,我们都能给出一个不同的定义。黑客通常是电子迷、计算机迷或是软件迷(大多数黑客是十几岁的少年)。如果用户发现奇怪的图像从屏幕漂过或出现了奇怪的连接使旧有的设备联系和覆盖消失,那就有可能是遭遇黑客入侵了。

注 在案件牵涉到计算机被作为犯罪对象或手段的情况下,在现场不要忙于关掉计算机,直到能确保临时存储器中的数据都已保存。不要让嫌疑人接触或处理计算机系统,要知道有时只要他一敲键盘,信息就可能在瞬间丧失。

9.6 证据保存

调查人员得判断证据能否被收集和保存以备之后的证据分析,这可不像听起来那么容易。必须时常检查搜查令以确定什么物品是可以没收的而什么又是不能带走的,如果发现需要的某样东西未被涵盖,那就得在起诉之前修改搜查令。调查人员需时刻警记:一个错误就可能使自己前功尽弃。

注 在移动嫌疑人的计算机前应对其进行备份。

用一句形象的话来形容保存电子或计算机证据的规则,就是"在你感觉舒适的地方,计算机及其元件也会感觉舒适。"

保存证据的普遍规则

- 保存温度为 15.6℃~32.2℃。
- 保存在没有灰尘的环境中。
- 远离磁场(如不要将磁盘放在立体声扬声器的旁边)。
- 电子或计算机设备和元件由于案件的性质和复杂性可能会延长保存时间,那么就得长达数年地保存这些案件的证据。
- 许多计算机犯罪证据的储存房间也用于储存纵火罪证据,诸如装有火烧碎片的铁罐。这些碎片通常含有腐蚀性或破坏性物质(如汽油),所以调查人员得特别小心地将计算机证据与这类存在潜在破坏性的物质分开。
- 在可能的情况下,应将计算机相关证据与"普通证据"区分开并储存在专门的地方。计算机证据将保存很长一段时间,调查员和律师会不时来检查和鉴定这些证据。
- 把同一个案子的证据放在一起,因为通常需要重新安装计算机以进行测试、备份和演示。设备的一个部件或电缆的遗失都可能造成很大的困难,使调查人员无法工作。

- 尽可能地用木质搁物架和木柜来放置证据。
- 应确保每一证据项目都已贴上标签并标明是电子设备。有特殊的语言来为计算机证据命名。当要求寻找、检查某一证据或将之放回原处的时候，调查人员得弄明白标签上的文字意思，如“multi I/O board with 16550a UART”。
- 小的相似的物件如软盘应放在单独的信封和小盒子里，放好后再收集起来放进一个大的盒子。信封上应标明其中的物品名称，大盒子外的标签上也应注明其中的小信封和盒子。
- 被放进信封和盒子里的证据不易遭受磁场和灰尘的影响或损害。

9.7 警告及注意事项

所有的证据都需要某种形式的特别处理和维护以防止遭到污染和破坏，计算机及其媒介更是如此。如果不精心维护、小心工作，其结果很可能是辩护律师将在法庭当庭指证调查人员的证据由于程序不合法而丧失证明力。

下面列举一些对计算机及其媒介有影响的因素

1. 热量

热量是计算机和计算机介质的损坏的因素之一，不要把它们放到热源附近或阳光直射的汽车里。如果在白天被放进汽车，大部分计算机介质都将变软或变形而最终毫无用处，继续使用损坏了的介质将破坏计算机设备。热量对于计算机硬件而言倒不是大的问题，但让设备长期地远离热源总是有益无害的。

2. 磁场

计算机信息被存储在一种使用精确磁场的介质上，这类似于磁带录音。有时，磁介质很小程度地暴露在磁场中也会擦掉介质上的信息。汽车收音机、电动机、扬声器、磁夹子和冰箱都会产生磁场。如果调查人员不正确防范的话，磁场完全有可能破坏证据而使自己前功尽弃。

3. 暴露和无防卫的磁介质

如果处理不小心，甚至一个人皮肤上渗出的汗都可能损坏计算机介质。使用磁盘驱动器驱动已受损的介质将损坏磁头，继续使用受损磁头还将损害插入其中的其他介质。实际上，在确定污染了介质的情况下，调查人员完全可以请专家细心清洁介质，使它能够重新使用。

4. 暴露的线缆或电路板

电子元件极易受到静电的影响或损害。即使人的身体能够承受的静电也足以

破坏电子元件，这样的损坏并不明显且只有当设备不工作时才会被发现。暴露的线缆和电子元件也可能带上很高的电压而使调查人员受到伤害甚至丧命。

5. 塑料制品

塑料制品会产生相当数量的静电而持续地引起计算机设备的受损，这与通过触摸使计算机设备受损非常相似。

6. 小心谨慎地处理搜查对象

不要将计算机设备掉到地上，也不可随意抛扔。不要在设备上堆放重物。纸制品并不会产生使电子设备受损的磁场。

7. 不要光复制磁性介质

不要光复制，而要代之以照相。光复印机产生的热量和电子辐射可能使介质退磁。

8. 标示所有电缆和连接器

在移动每一电线、电缆或别的连接器之前，都应将它们以及所在的原始位置贴上明显的标签以使日后能够精确地重新安装。

9. 法律要求

调查人员可以遵循适用于其他类型证据的一般规则。不过，必须特别小心以确保设备不被破坏。如果有任何疑问，就应与具备专业知识的专家联系。在调查人员的调查报告中，应确保包含了如何保护证据、计算机运送的地点以及运送人等细节。这对防止辩护方试图针对后来重新组装的系统和介质中储存信息的合法性及其条件提出异议是十分重要的。

调查人员还有必要考虑一下在调查过程中是需要数据还是需要计算机本身。例如，有一提供成员间秘密交换电子邮件的公告牌，证据显示构成犯罪的信息在数个成员间被传送，但系统管理员并没有参与犯罪活动。搜查令将不得不受限于这一客观事实，只能对牵涉进犯罪活动的人进行搜查。搜查整个系统包括并未参与犯罪的用户的电子邮件将可能侵犯这些人的合法权益。

在另一案例中，计算机被运用在医疗方面存储病人病史和保险清单。嫌疑人改写了程序，使保险公司可能支付比实际金额更高的保险费。没收并带走计算机将威胁到病人的健康，而只有数据和程序才是需要的证据。

我们生活的世界在变化，规定计算机证据搜查的法律变得越来越复杂。有关计算机犯罪及其证据搜获的判例却仍然不多，新的法律出台的速度总是赶不上新问题出现的速度。总体而言，搜查一般类型证据的原则也适用于计算机证据的搜查。

9.8 证据评估和分析

9.8.1 证据表格

计算机化的证据往往表现为很多表格。侦查人员可以用标准操作系统命令或特殊的程序格式化证据信息而使之变为可读信息。

下面列举一些分析处理工具。

1. 字处理

现代字处理器用需要特殊程序进行清晰显示的格式来保存文档。字处理文档包括信件、故事、日记、会议记录、时间表、计划和财务信息等。

2. 棋盘式分析表

棋盘式分析表用于处理数字，极少数情况下也用于文字处理。棋盘式分析表常含有财务数据和工作计划方面的信息。

3. 数据库

数据库管理程序能够管理包含有数百万条记录的文件。数据库用于组织大容量的信息。数据库管理系统(DBMS)依据被管理数据的类型可以制作不同种类的报表。对数据库的简单应用是邮件列表和生日列表，更高级的应用是处理财务信息和商业交易。

4. 图像

在计算机中有许多不同的图表类型，包括商业说明图表、出版剪贴艺术、从风景到色情不等的一些扫描图像或彩色图片等。这些图表可以用手工绘制，用手提或平板扫描仪扫描到计算机当中，也可以从照相机或影视画面中提取。

5. Windows

Microsoft Windows 是运行在 PC 机 DOS 平台上的图形接口程序。Windows 本身是可以运行窗口程序和 DOS 程序的多任务操作系统，并随操作系统提供了大量的系统工具和应用程序，它们具备计算机需要的基本软件的所有特性。Windows 的一个优点在于它有一个交换文件和大量的临时文件，这便可为调查人员保存通常软盘无法保存的额外有价值信息。

6. 其他操作系统

现在 PC 操作系统的发展趋势是包括了“applets”(小型的应用程序)。用户必须对这些可能使用的小程序加以关注。

9.8.2 证据分析工具

以下是一些用于分析计算机信息的得力工具。其中有些工具是共享软件，共享软件产品是一种允许免费试用的产品。除了少数例外，这些软件的价格一般都在100美元甚至50美元以下。共享软件作者有时会应注册用户的特殊要求对该软件做一些特殊的修改。

1. WordPerfect

WordPerfect分析工具具有强大的索引和报告功能。

(1) 一致和索引 伴随索引特性，WordPerfect为在大的文本文件中定位特殊信息提供了强有力的工具。

索引功能的主要过程为：

- 将文本信息输入到WordPerfect，生成一个新的文档，包括要在每页上打印的页码。
- 生成包含用户希望在文本中找到的关键词短语的第二个文档。
- 在主文档的末尾加上索引码并指示出作为一致文档的包含关键词和短语的文档。
- 生成索引。WordPerfect将定位文档中所有的关键词和短语，以及在文档末尾的关联页码。当打印文档时，索引将支持用户快速定位案件调查所需要的信息。

(2) 关于报告 WordPerfect可以提供不同种类的报告类型。这些报告包括图表、格线和等式等。WordPerfect几乎有用户喜欢的所有打印机的驱动程序，也具备用户完成常规性侦查报表所需的所有特性。

2. XTreePro Gold

XTreePro Gold是可用于PC/MS DOS计算机的最大的磁盘和文件管理包之一，该程序可以为用户显示在单个或多个软硬盘上的包括隐藏和系统文件在内的所有文件。下面讨论2.5版本的功能，至于更老的版本，则可能并不全具备这些功能。

- 文件名查找 从硬盘启动XTreePro Gold时，用户将会看到树状的目录结构图。屏幕底端的一个小窗口将会显示出当前目录的所有文件。用户可展开这个视图使之包括磁盘上的所有文件，它甚至可以显示系统中记录的每一个磁盘上的文件。
- 按文检索 用户可以标志所有或一组文件然后进行文章检索。包含着被检索信息的该文件将被标记，以便于拷贝到其他的磁盘中或对其进行查看。

- 按属性检索 文件可以按属性标记。
- 格式化的文件视图 XTreePro Gold 能生成许多不同文件格式的完全格式化视图。
- 未加工的或格式化过的 HEX/ASCII 视图 在许多情况下，直接显示原始的文件内容可以提供许多使用格式化视图无法提供的线索。

3. Norton Utilities

Norton Utilities 具备在硬盘或软盘上显示信息的巨大灵活性。它最有用的一个特性是 UNERASE(撤销删除、恢复)，UNERASE 程序易于使用并拥有在线帮助和友好的用户接口。

该程序的主要功能有：

- UNERASE 到其他磁盘 如果用户发现一个已经删除却可能有用的文件，可以把文件恢复到其他的硬盘或软盘上。这使调查人员在保持证据完整性的同时也能看到已被删除的信息。
- 显示整个磁盘上被删除的文件 UNERASE 允许用户在恢复文件之前查看已删除文件的内容。该视图是一个格式化了的文件中所有字符的堆积。

4. Sydex

Sydex 软件包中的 AnaDisk 和 Viewdisk 可被用于分析具有不常见磁盘格式的软盘，使用不常见磁盘格式的软盘问题经常在黑客系统中碰到。AnaDisk 也可用于对某磁盘进行确切复制、用不同尺寸的扇区格式化磁盘，以及读非常规格式化和非 DOS 磁盘。AnaDisk 还能够识别出没有正确标志的 COM 和 EXE 文件。

5. Andy Fried 应用程序，Danny Mares 应用程序(Maresware)和 Gord Hamma（RCMP 侦查型应用程序）

这是美国财政部和美国国内安全中心的 Andy Fried，Danny Mares 和 Gord Hamma 专为调查人员编写的应用程序。这些都是专为法律实施而编写的非常实用的应用程序。

6. CSHOW（compushow，共享软件）

CSHOW 具备显示图表、图像文件的强大功能。如果没有计算机，调查人员应该把这些图像做成录像带以便在法庭上出示。

7. QUICKFLI（.FLI.共享软件）

FLI 是动画片制作文件。这些文件包括简单的卡通、商业多媒体显示、计算机辅助设计/生产过程和色情图片等。QUICKFLI 支持用户将这些动画显示在屏幕上。调查人员应该对发现的该类动画进行录像。

8. DL-VIEW（.DL，共享软件）

DL 文件在动画制作方面与 FLI 文件类似，但它们不如 FLI 文件和 GL 文件那样通用。应该把所有这些动画都录制下来。

9. GRASPRT（.GL，共享软件）

由于好几年以前人们就能在 BBS 上获得制作 GL 文件的程序，所以 GL 文件现在相当普遍。正像 FLI 和 DL 文件一样，该类文件也是动画。

10. ALCHEMY（图形文件转换器，共享软件）

该程序允许用户把各种图形文件显示在桌面上并打印它们，同时 ALCHEMY 也允许用户把图形文件转换成不同的格式。

9.8.3 证据分析

1. 制作 PROFILE.BAT 批处理程序并进行分析的过程

勘查计算机的基本规则是不要修改原始数据。对一台计算机上的数据进行分析可能需要几个小时到几个月的时间。分析时间随要勘查的计算机数据的数量和类型的不同而有所不同。

原始的 PROFILE.BAT 文件是由美国国内安全中心的程序员/检查员 Andy Fried 编写的。Fried 应用程序就包含了一个基于信息和归档的目的而制作计算机系统概貌的批处理文件，新的升级版本已经作了重大修改并使之可以运行在一张软盘上。PROFILE 盘是可以用来启动的，PROFILE 启动程序生成一个 RAM 驱动，把需要的文件拷贝到 RAM 盘，然后退出到 DOS 提示符下。这时，用户便可以为系统上每个既定的软盘逻辑驱动器运行 PROFILE。对于 100MB 以下的分区，仅需要一张高密数据软盘；对于再大一点的分区，可能需要两张高密盘。如果 PROFILE 生成的数据两张盘装不下，就得求助于网络驱动器，例如 Lantastic 或 NetWare。

使用 PROFILE 可以大大节约用户“审讯”计算机的时间，尤其是有多台计算机需要评估的时候。应在 PROFILE 盘中使用一些 DOS 系统中的应用程序和一些较易得到的免费或共享软件。

现行的“审讯”软盘使用 CONFIG.SYS，AUTOEXEC.BAT，AUTO2.BAT，PROFILE.BAT 和 PROFILE.EXE，该软盘是一个用 PKZIP 制作的自扩展的包含了调查程序的压缩文件，每个文件的文本和目录都在下面列了出来。这些文件兴许不能满足用户所有的需要，但对我们遇到的几乎所有 DOS 系统的计算机都能勘查。在实际操作中，我们也经常依据嫌疑计算机的配置而对“审讯”软盘做出相应修改。

以下是具体的程序实现。

PROFILE CONFIG. SYS

```
Device — a:\ramdrive. sys 330 512 64
Files — 30
Buffers — 20
Lastdrive = z
```

PROFILE AUTOEXEC. BAT

```
Echo off
Path = a:
Prompt $ p $ g
If exist auto2. bat call auto2. bat
@echo off
echo your drives in the system are:
ram_driv - q
```

PROFILE AUTO2. BAT

```
If errorlevel 5 goto E_DR

If errorlevel 4 goto D_DR
If errorlevel 3 goto C_DR
:E_DR
echo copying files to drive e:
copy PROFILE. BAT e:
copy prof. exe e:
copy COMMAND. COM e:
set comspec = e:\COMMAND. COM
e:
goto DONE

:D_DR
echo copying files to drive d:
copy PROFILE. BAT D:
copy prof. exe d:
copy COMMAND. COM d:
set comspec = d: \COMMAND. COM
d:
goto DONE
```

```
:C DR
echo copying files to drive c:
copy PROFILE. BAT c:
copy prof. exe c:
c:
goto DONE

:DONE
```

PROFILE. BAT

```
@echo off
Echo Suspect Computer Information Gathering Process
Echo ----------
Echo This batch file brought to you courtesy of the Hackers
@ Fresno P. D. (Ken and Frank)
Echo This process will save information from the suspect
computer to a
Echo floppy diskette. The parameters for the process is:
Echo PROFILE d1: d2: d3:
Echo Where :
Echo d1: is the drive you want to check.
Echo d2: is the drive you want to save the information to.
Echo d3: is the drive you are runninq PROFILE from.
Echo DO Not include the : for the drive letters.
Echo
Echo Runninq with the followinq parameters:
Echo   PROFILE %1 %2 %3

if "%1"——"" goto noparms

Echo d1: parameter present.

if "%2"==="" goto noparms

Echo d2: parameter present.

if "%3"--=="" goto   noparms

Echo d3: parameter present.
```

```
Echo Processing commencing.

REM-Load HDSENTRY to prevent destructive calls to hard
disk
prof -o hdsentry. com
HDSENTRY
del hdsentry. com

echo Please insert a clean formatted diskette in %2:
echo if hard disk is over 100MB. use high density disk
pause

REM  Record the date of the ROM BIOS
prof - o romdate. exe
ROMDATE > %2 : \ROMDATE. DAT
del romdate. exe

REM  Save CMOS memory to  file
Prof—o coms. exe
CMOS %2 : \CMOS. DAT>%2:\CMOS2. DAT
del cmos. exe

REM -Capture the master boot record and save to file
prof -o  getboot. exe

GETBOOT %1 %2 : \BOOTSEC. DAT
del getboot. exe

REM  -Examine fixed disk partition table
prof  o dospart. exe
DOSPART %1 > %2:\DOSPART. DAT
del dospart. exe

ECHO Please wait as PROFILE:
ECHO Obtains list of all directories and files
ECHO Obtains list of all files not backed up
ECHO Obtains list of all system files
ECHO Obtains list of all hidden files
ECHO and writes the data to files on your data disk
ECHO Please wait as PROFILE writes data to a file
```

```
Echo off

REM -Determine list of all directories and files
dir %1:\ /s/a > %2:\allfiles. dat

REM  -Determine list of all files not backed up
dir  %1:\ /s/a:a > %2:\riskfile. dat

REM -Determine list of all system files
dir %1:\ /s/a:s > %2:\sysfile. dat

REM -Determine list of all hidden files
dir %1 :\ /s/a:h > %2 : \hidden. dat

REM -Determine if  there are any erased files anywhere on disk
Prof—o  ferasc. exc
FERASE %1 > %2 : \FERASE. DAT
del ferase. exe
prof -o beep. com
REM -Beep to indicte proccssing finished
BEEP
goto done

:noparms
Echo .

:done
```

2. 其他分析过程

(1) UNERASE(取消删除)

使用 UNERASE 可以评估在计算机上找到的任何删除文件。该过程包括把文件恢复到另一个盘上,这是 Norton 的 UNERASE 应用程序能够做的,它可以让用户从软盘运行 UNERASE 程序并把恢复的文件存到软盘上。在这种方式下,原磁盘并未被修改。切记不要使用 UNERASE 程序将一个文件恢复到原始盘上以防破坏证据。

当使用被删除的文件作为证据时,应完整地记录下文件日期、目录位置以及该删除文件的重要性及原因。如果调查人员用了额外的时间来恢复文件,也应该记录下所采取的每一步骤。

(2) XTreePro Gold

用 XTreePro Gold 来定位和显示在硬盘和软盘上的任何数据文件和程序。

(3) 其他程序

计算机勘查的接续工作的内容有赖于前期步骤所发现的东西。接下来的工作可能包括显示图像、阅读和打印文档、显示扩展选单和数据库以及读通信日志文件等,可能需要计算机专家来协助处理一些文件以便准确地将数据呈递给法庭。

从当前勘查计算机犯罪的一些经验可以得出如下结论:

不要让自负来妨碍你的勘查,如果有疑问就寻求外界帮助。

在没有正确的知识和经验的情况下去做调查会导致作为证据的计算机遭到破坏、案件侦查的失败,甚至可能承担相应的法律责任。

第10章

勘查计算机及软盘

10.1 一般步骤

10.1.1 制作案件进展工作单

(1) 列出计算机的日期、时间及其系统配置。

(2) 列出那些帮助自己或目击自己搜查活动的人的名字。

(3) 列出执行搜查的日期、时间和行动。

(4) 记录可能用于以后继续跟踪的勘查线索。

(5) 列出评估计算机的日期、时间和使用的程序。

10.1.2 评估计算机状况

(1) 计算机处于开机还是关机状态?

(2) 如果计算机处于开机状态,它正在做什么? 假如计算机是开着的,它就可能在做某些事情(例如,运行 Windows、会计软件、BBS、字处理软件等)。

(3) 评估在诸如天气、电子和磁场等外界因素威胁下的数据遗失的可能性。

(4) 查明计算机是否通过网络或 MODEM 与其他计算机相连。随着网络设备价格的降低,网络日益普及,普通的家庭用户都能支付简单的网络设备费用。

(5) 根据先前情况来决定是否关掉计算机或让它运行一段时间并用相机给屏幕拍照。试想:如果计算机有一个大的 RAM 内存,并且调查人员想要的证据都在 RAM 里,如果不保存就关机的话,那么证据将会怎么样呢?

10.1.3 给计算机拍照

(1) 用 35 毫米的宝丽来相机或/和摄像机给屏幕拍照。

(2) 对计算机的前面和后面部分拍照。

(3) 为线缆拍照。

(4) 为相连的硬件拍照。

(5) 为任何有价值或可用于证据的物品拍照。有可能是软盘的隐藏位置、打印材料、硬盘驱动器和其他硬件等。

10.1.4　从软盘启动计算机

(1) 决定从正运行的计算机上转到 A:\盘后重新从软盘启动。通常这种方式是有效的,可以避免软盘和硬盘被病毒感染。

(2) 如果计算机处于关机状态,应总是从一个干净、写保护的软盘系统盘启动。MS-DOS 6.0 可用来启动用户遇到的大多数计算机。具体操作请参见第 8 章“制作启动盘”。

(3) 查明是否有特殊驱动程序(例如 Staker,Super Store 或 Disk Manager);如果有,则在引导盘的 CONFIG.SYS 中加载该程序。

(4) 首先运行硬盘锁程序,这样对嫌疑计算机的破坏性的磁盘写操作就被禁止了。接着运行查毒软件,然后保存 CMOS、引导扇区、AUTOEXEC.BAT、CONFIG.SYS 以及软盘设备驱动程序,并保存嫌疑计算机的整个文件目录到软盘上。我们在使用 PROFILE.BAT 的盘上运行 Danny Mares 和 Andy Fried 的内部安全情报检索系统(IRS Internal Security)软件来自动完成上述工作。这些供司法人员使用的特殊计算机侦查程序可以从 Danny Mares 和 Andy Fricd 得到。

(5) 用 LapLink,Safeback 或网络软件将计算机备份到可写介质上。参见第 8 章介绍备份嫌疑人计算机的程序的相关内容。

10.1.5　标记所有的线缆和硬件

(1) 使用线标志和粘性标签以确保调查人员自己能够将计算机恢复到原来的设置。

(2) 如果查获的是多个计算机系统,首先应用数字标识每台计算机,然后用计算机编号来标识线缆和硬件,这样才能保证当把所有这些东西都送回工作室时,能很好地将它们重新组装起来。

10.1.6　准备把计算机运走

(1) 关闭计算机。

(2) 在进入搜查过程的证据描述阶段后,把计算机、线缆和其他的硬件打包到箱子里。

(3) 在运输和保存过程中把装有一台计算机设备的所有箱子都放在一起。

(4) 把第 1 个标签贴在相应的物品或包上。

(5) 把第 2 个标签贴在装这些东西的箱子上以标明箱内的每件物品。

10.1.7 获取软盘和其他可移动介质

(1) 通过 DiskCat 或简单的磁盘日志程序运行软盘并用数字适当地标记软盘。使用不易磨掉的带色标志或标签来做标记,不要使用铅笔或圆珠笔,因为它们可能会破坏磁盘介质。

(2) 不要把磁性介质与其他查获物品放在一起。这将有助于之后的磁盘检查,使调查人员不必浏览众多的盒子和信封来寻找磁盘。

(3) 按查获房间的不同把搜查磁盘分放不同的盒子,这将大量节约以后对它们进行分类的时间。

10.2 注 意 事 项

10.2.1 小心搜索

磁盘有时会藏在最意想不到的地方。我们搜查时经常在书里、键盘的底部、抽屉格子里、衬衫口袋里和其他出人意料的地方找到它们。

10.2.2 小心地把这些东西放到货车上

(1) 运输时把 CPU 和一些与计算机相关的软硬件放到一个安全的地方。

(2) 物品从包里掉出来或在车里颠上颠下、车载收音机里的磁铁和过度的热量都可能造成对存储介质或硬件的破坏。

10.2.3 磁性设备

小心可能存在被嫌疑人放在犯罪现场的磁性设备,这些秘密设施可能对整个计划造成致命的破坏。一个简单的指南针就可以探测出任何强电磁流。

注 如果正在搜查计算机设备,就应带走所有物件,因为被漏掉的任何计算机设备物件都可能是在以后的调查中需要的。而且,在调查人员离开之后,这些东西有可能全部消失。

10.3 勘 查 软 盘

有时,可能有大量的软盘需要勘查。采用以下勘查步骤将提高对软盘数据勘查的速度。

1. 使用一个勘查记录本。应记录下为出报告、勘查线索和法庭证据而进行的每一个步骤；列出任何问题，包括坏的扇区和遭破坏的介质等。

2. 写保护每一个磁盘。对于 5 英寸盘，一小片玻璃纸或一个保护胶带就可以很方便地达到目的。

3. 对每个磁盘做标签。使用一套对勘查的所有软盘都一致的数字方案。如果软盘是在不同的房间里找到的，可以考虑在标签上使用房间号。有关标签方案的例子如 A0001，A0002，B0001，B0002，其中 A，B 是房间代码，0001 和 0002 是磁盘编号。

4. 对磁盘编目录。使用磁盘目录程序列出每个磁盘，就是说，为每个磁盘上的所有文件列一清单放入一个数据库中，并可以按特定文件、日期和大小对其进行检索，还可以输出用于法庭的可读性高的报表。

经常采用以下软件工具。

- disk catalog system version 7.01(软盘目录系统 7.01 版)。该程序是一个支持给文件名加上勘查笔记的共享软件。但存在一些弊端，最主要的是它将使用已存在的磁盘本身的卷标做标记，它也会问用户是否想给磁盘写一个卷标，对于这个问题应总是回答 NO。
- MareWare 的 DISKCAT。

5. 查病毒。在勘查期间，为防止自己的计算机遭病毒入侵，调查人员应该采用一个能作为 TSR(内存驻留程序)加载的查病毒程序。该类程序的一个好的佐证是 McAfee 的 VSHIELD，它可以从 McAfee 的 BBS 上得到。不要从原始盘删除病毒。一定要在被感染的盘上做标记，这样便不会粗心地在计算机上再次运行它上面的程序。如果确实找到了一个病毒，那很有可能在其他盘上也会找到病毒。

6. 将每张软盘的内容拷贝到自己的硬盘上。确保自己的硬盘有足够的空间来存放想要勘查的软盘内容。根据数量的不同有两种方式查看软盘。

(1) 仅适用于少数软盘

- 在 C:\> MD C:\DISKETTE 上建一个名为 DISKETTE 的目录。
- 使用 XTreePro Gold 或 LapLink 拷贝每个软盘到 DISKETTE 子目录下面，用磁盘的标签作为新目录的名字。两个程序都将拷贝隐藏文件和系统文件，它们也生成新目录并拷贝选择的文件进去。

(2) 比预期处理的软盘多(大量)的情况下

看目录列表。如果发现目录列表与原始磁盘标签一致，调查人员可以考虑不去查看那些显示简单程序文件的软盘，而是去查看自己感兴趣的为数不多的软盘。

7. UNERASE 已删除的文件。用 Norton UNERASE 应用程序把每个软盘上的已删除文件恢复到硬盘上与 DISKETTE 下使用软盘卷标的子目录平行的另一子目录下。当程序提示用户输入文件名的第一个字母时，统一输入字母 X 来保

持一致。

8. 打印每个磁盘的目录。调查人员可以将该列表用于勘查笔记和线索以及高亮显示可疑文件以便进一步勘查。注意:如果使用 Disk Catalog 7.01 版,用户可以把勘查笔记加入文件列表数据库,并随后将笔记和目录一同打出。

9. 用 XTreePro Gold 查找。按关键词、文件生成日期和文件扩展名来查找在 DISKETTE 子目录中的所有文件。用户也可以用它们的原始格式来显示图表、电子数据表、字处理和数据库文件等。

10. 打印。打印所有可疑文件或证据文件,用磁盘标签、文件名、日期、尺寸和时间来识别它们。

11. 用 AnaDisk 检查磁盘。在勘查黑客、程序员和可疑磁盘时,可用 AnaDisk 来检测原文件。AnaDisk 将分析错误命名的 EXE 和 COM 文件以及奇怪格式化、不常见扇区大小和空隙字节里的数据。AnaDisk 也可以用于拷贝不常见格式的磁盘。用户在拷贝前应先格式化目标盘来避免 AnaDisk 里的故障以免程序死锁。AnaDisk 将精确地拷贝那些写保护的磁盘。

第 11 章

勘查网络的基础知识

许多计算机犯罪勘查都将涉及到网络，一台连接到 Internet 上的计算机就被认为是联网工作的。打印机、调制解调器和磁带驱动器在网络环境中是重要的且通常是共享的组件。网卡价格的降低和低价位、易安装的网络软件的出现使得网络的普及成为可能。

在勘查中既可以利用网络发现证据，也可以利用网络销毁证据，这取决于网络的配置和使用。网络通常意味着几个人可以在不同地方的计算机上使用相同的数据存储，这些地方可以是同一个房间、同一层楼或同一幢大楼。在同一幢大楼里的网络访问是局域网（LAN），而当访问超出大楼范围时，它就被认为是广域网（WAN）了。远程访问意味着相互联网的计算机遍及世界的任何角落，随着数据通信速度的不断提高，远程用户（如在家中或远端办公室工作的雇员）变得越来越普遍。在美国，政府激励公司建立与员工的电子通信，并减少公司驾车上班族的数目，采用的措施常常是在职员的家里安装一台计算机并使其通过高速 modem 与公司的网络连接。

在本章中将讨论的这些技术主要是让读者对网络的组成及其规模产生一定的认识。当需要勘查计算机网络时，必须谨慎，必要时要寻求网络专家的帮助。这些技术使读者能够识别一个网络，并判断网络内部计算机的大概距离。距离可能是几英尺到几英里，这在调查人员需要写一个搜查令时是必不可少的信息。如果网络范围超过了调查人员自己的管辖范围，有必要得到其他地区调查人员的帮助。在调查人员到达搜查现场之前，很多计算机需要被保护以防嫌疑人销毁证据，在这种情况下，寻求该地区公安司法人员的帮助也是很有必要的。

11.1 网络利弊

1. 勘查涉嫌犯罪活动的网络存在的困难在于

- 难于确定谁访问过特定数据
- 难于在多站点定位多台计算机

- 难于在多站点隔离和定位服务器
- 大的数据存储能力
- 一个远端用户易于完全删除与案子有关的所有数据
- 用作证据的数据可被轻易地隐藏
- 大的布线中心
- 对辅助技术的需求
- 大的网络的司法管辖权问题

2. 勘查涉嫌犯罪活动的网络的有利之处在于

- 通过内嵌安全措施很容易查明谁访问过特定数据
- 规律性备份的可能性
- 对嫌疑人活动进行在线监视的可能性
- 专家作为参谋的参与
- 数据集中存储在服务器上

读者可能已注意到了两个列表中有相同的项目。决定用户的处境属于哪个列表有赖于安装的类型、网络软件以及网络管理员或安装者的技能。如果网络安全能够保证，网络对用户而言就很方便。如果网络安全很糟糕，用户或许不能准确地查明谁生成、编辑或删除了自己将用作证据的数据。如果能够找到一位网络专家，他也许就能帮助从涉嫌计算机系统中找出头绪并缩小嫌疑人的范围。同样，特定的软件产品也可以对访问网络和特定文件的行为进行审计跟踪。该软件甚至会告诉用户他们是从哪台计算机访问的网络，它将自动地帮助识别嫌疑人。网络操作系统支持网络管理员对文件和目录的访问权限进行分配，这也能帮助缩小嫌疑人的范围。系统审计跟踪还可以用于实时跟踪和个别计算机的访问跟踪。

当调查人员发现一个计算机犯罪的证据在某网络上，而服务器却位于另一司法管辖区，或者证据的一部分在另一管辖区时，司法管辖权问题就出现了。在类似的案件中，由于这种情况可能费时费资最终增加调查成本，调查可能遭到上级的反对。更糟糕的情形是，证据的所在地可能在其他国家，而该国的法律并没有规定调查人员正在调查的行为是犯罪。这无疑对调查人员和所调查的案子是一个打击。

11.2 网络的组成

给网络下一个简单的定义，网络就是一组连在一起共享程序和数据的计算机。所共享的可能是字处理、数据库、电子表格、电子邮件、因特网页和 Internet 新闻等。有多种类型的网络，但它们都存在很多共同之处。用户可能遇到的有关网络的专门术语将在本章末介绍。用户不必全部掌握，但是对其有一个基本的了解将会在与证人、嫌疑人、熟悉网络的情报员等相关人员谈话时有很大帮助。

网络由以下几部分组成。

1. 服务器

可把服务器设想成一个餐厅的服务者。它们将问用户需要什么，然后尽其所能地给予满足。服务器也是计算机，但是人们通常并不使用它。这种计算机甚至可以被装进壁橱，被设置为执行特定功能而不必进入系统。

2. 文件服务器

文件服务器是为网络上的其他计算机提供硬盘以进行信息存储的计算机。根据用途，一台服务器可能有 300MB 的硬盘或一个能够容纳数百 GB 的大磁盘。服务器也可以配备光驱以在网上共享光盘。相应于所安装硬盘的大小，服务器通常需配备大容量的 RAM 内存。在大型服务器中，用户可以看到超过 100MB 的内存，使用用户的计算机仍然可以对大内存的服务器进行调查。

3. 打印服务器

打印服务器在所有规模的网络上都是很普遍的。打印服务器支持所有类型的打印机(激光、点阵式或喷墨)或一个直接添加到网络上的绘图仪，在整个网络上所有授权的用户都可以使用这些打印机。如果嫌疑人正用彩色打印机打印假支票或纸币的话，关于打印机的信息就可能有用了。借助网络安全设施，一个专家可能帮助调查人员确定谁使用过该特定的打印设备。

4. 数据库服务器

数据库服务器用于支持用户服务器系统。这意味着与在文件服务器上只需选定目录便可访问数据相比较，用户需要特定的软件来访问数据库服务器上的文件。由于需用特殊软件，调查人员可以通过查明谁访问过数据库服务器以及服务器上特定的客户端软件来缩小嫌疑人的范围。为进行此类调查，调查人员需要网络专家来帮助自己破译每台网络计算机的软件。

5. 磁带服务器

磁带服务器支持使用单服务器类型机器上的多磁带驱动来备份多文件服务器、数据库服务器和网络上的工作站。磁带服务器通常可以在有多个其他服务器的大型网络上找到。在使用每个驱动器备份文件时，磁带服务器上的用于运行磁带驱动器的软件可以记录下所做备份工作的细节。这些日志可以提供有关某项活动进行时间的线索。当然要揭示该线索，也应寻求值得信任的网络专家的帮助。

6. 路由器

路由器是一个用于连接多网络拓扑的设备。这可能听起来有些复杂和高度技术化，但实际上这个概念是相当简单的。试把路由器想像成一个控制从人行道、分级公路、高速公路再到机场的交通路径的信号。当人们想从人行道上高速公路时，

他们会被配给一辆高速轿车；当他们想飞时，他们将得到一架飞机。

当用户在网络当中找到路由器时，需要立即推断一些由此产生的可能性。一个路由器能够支持接入 Internet，这就意味着嫌疑人的数据将可能在世界的任何地方。通常，路由器被用于连接大型网络，例如，公司会使用路由器和各种通信设备交换各种类型的数据以实现其分支机构和总部之间的联系。许多路由器看起来像服务器或普通的个人计算机。想要对路由器有一个感性的认识，用户需要向一个具备高级网络方面经验的人咨询。

7. 网关

网关用于连接某种类型的系统到一个完全非同种类型的系统。网关也用于连接网络到大型机和小型机，这种连接通常支持网络上的计算机仿效大型机或小型机的终端来连接它们。涉及到大型机和小型机时，网关又给调查增加了另一层复杂性，因为嫌疑人可能从网络的任何地方访问更大的系统。依赖于建立在网关上的安全措施，隔离对大型机的访问可能有些困难。

11.3 网络类型

1. 基于服务器的网络

基于服务器的网络至少有一台计算机用作文件服务器。文件服务器计算机将运行网络操作系统，并且通常有一个大的硬盘，该计算机保存网络用户的所有共享数据和程序。作为一个调查者，用户应该知道自己调查所需的大多数数据都存储在文件服务器上。

2. 端到端

端到端的网络通常没有一个专门提供资源的设备，它们使用每个工作站上的资源来提供共享程序和数据给局域网上的所有其他用户。对调查人员来说，端到端的网络又增加了调查的难度，因为调查所需要的数据可能存储于任何一台作为端服务器的端计算机上。端到端网络有利的一面是访问可以被控制，根据访问控制信息，专家就可能告诉调查人员访问的主体、地点和内容。

3. 公告牌系统

公告牌系统(BBS)已经成为一个非常流行的交际方式。它们通常不用付费，还提供大量的公共区域和共享软件。图形图像也变得非常流行，这些图像从卡通片到色情照片简直应有尽有。许多公告牌系统通过电话系统相互连接在一起，有些公告牌系统被设计成一个简化电子邮件和数据传输的空间。这些传输通常发生在夜间，此时电话占用率低。

11.4　网络的物理连接

物理连接指用于连接计算机的“线缆”，线缆可以提醒用户网络的存在。调查人员应该熟悉网络的类型、网络的硬件和布线，这些事物能够显示出服务器的数量、用户数和网络之间各组件的距离。当然，调查人员的调查范围可能只有一个房间，通常是两台计算机上使用端到端的网络软件、通过以太网线连接，并且共享一台打印机。调查人员可能遇到的另一个极端是有多台服务器，包括大型机、PC 服务器和路由器、网桥、光纤和 modem 架、微波以及到数百个用户的连接，所要找的信息可能在几百码或几千公里之外。下面是一些网络系统连接的例子，作为一个计算机犯罪的调查者，用户应该对这些了如指掌。

1. modem

modem 代表 modulator/demodulator(调制解调器)。简单地说，该设备能实现计算机能懂的信号和电信系统能懂的信号之间的相互转换。现在的技术支持使用 modem 进行高速的数据转换。

2. 专线 modem

速度最快的 modem 用在使用专用电话线的网络上。用户可能遇到的专线有 56Kb/s，准 T1 和 T1。这些 modem 稍稍有点像通常个人计算机上的 modem，它们通常体积更大，而且在前端有更多的灯和按钮。

3. ARCnet

ARCnet 曾是最早普及的网络拓扑。它具备 2Mb/s(2M 比特每秒，即 2M 字节每 8 秒)的数据传输率，该拓扑可以同时支持 255 个计算机。ARCnet 使用 RG62 同轴电缆，可以连接的距离达 2000 英尺。而如今 ARCnet 不怎么流行了。

4. 以太网

以太网是最流行的网络拓扑。以太网提供 10Mb/s 的数据传输率。该拓扑最多可同时连接几千台机器，但是为保证速度，连接的机器通常应该限制在 40～100 台之间。标准型以太网并不昂贵，以太网接口卡价值不超过 20 美元，这使它成为了现今最为流行的网络拓扑。

5. 粗同轴电缆网（thick-net）

粗同轴电缆网用于有过多干扰可能破坏网络通信的区域。它使用 RG8 同轴电缆，可以连接 1800 英尺远。由于购买和安装这些线的造价比较高，它主要用在喧闹和密度极大的建筑物内。

6. 细同轴电缆网（thin-net）

细同轴电缆网用于临近区域和干扰比较小的区域。它使用 RG58 同轴电缆，最大连接距离是 600 英尺。

7. 10Base-T

10Base-T 是细同轴电缆网的另一种形式，使用非屏蔽双绞线代替同轴电缆。10Base-T 缆线从各工作站布线到叫做 hub 或 concentrator 的中央集线器。10Base-T 在某种程度上比细同轴电缆还贵，但是附加的花费却对大型网络有帮助。10Base-T 网的集线中心非常复杂，一个好的网络专家能够帮助用户从这一大堆乱麻中理清头绪。

8. 令牌环

令牌环曾经风靡一时，但是它因造价高和专有（IBM）的属性而没有像以太网那样得到人们的广泛认同。令牌环只在作为辅助厂商生产的接口卡和布线中心时才被接受。过去，令牌环常在 IBM 的商店中的大型机上可以找到；现在它也被用在小型网络、处理控制系统和规则商业系统当中。

令牌环有不同的速度和电缆类型。典型的速度是 4Mb/s 和 16Mb/s，更快速度的令牌环还正在开发。电缆类型包括屏蔽和非屏蔽双绞线和光纤，双绞线用 RJ-45 连接头，光纤用的是标准的接头。

9. 微波

微波技术的发展使得我们能够把网络联网距离扩展到 16 英里，同时还能达到 10Mb/s 的以太网标准速度的最高值，而这一切花费还不超过 30 000 美元。应用微波技术的场合一般是在大楼或塔的顶部安装了直径从 17～30 英寸不等的环型天线。

如果调查人员在调查地的房顶上没有看到用于微波的环形天线，那么计算机房内就应该有一些微波系统存在的明确特征。由于这些系统不太常见，有可能会在微波工作设备上一个或多个可见区域看到“microwave”（微波）的字样。微波系统和网络设备之间通过正常的网络拓扑实现连接。旧式的微波系统的工作如同一个高速的调制解调器一样，直接连接一台服务器或一个路由器。

10. 综合业务数字网

综合业务数字网（ISDN）是电信公司提供的新服务，它支持从家庭或办公室到电话系统的真实的数据接口。ISDN 有一些开发中的数据通信应用程序，但目前却不能应用在所有地区。用于 ISDN 通信的设备与常规的用于电话线上的设备非常相似，只是有一点不同：从计算机出来的数字信号不再需要转化成模拟信号在电话系统中传输，ISDN 电话系统已经实现了数字化。由于数据不用从数字信号转

化成模拟信号以及再转回来，所以数字电话系统是一个更好的数据通信渠道。但对 ISDN 有一点需要注意，即在任何情况下都不要把自己的模拟调制解调器插入数字电话线中；否则用户可能在毫不知情的情况下烧掉自己的调制解调器。多数 ISDN 线用一个 RJ 45 连接头，这样便能更好地避免烧毁设备。

11.5　网络操作系统

拥有所有的硬件是件好事，甚至可以说这是必需的。但这并没有包括网络需要的所有东西，因为还需要软件。用来实现网络功能的软件就是网络操作系统(NOS)，它可能是一个专有的软件包或桌面操作系统的一部分。由于具备了可执行性、安全性和可靠性，大型网络一般都需要专有的网络操作系统。较小的网络有时使用非专用的网络操作系统，因为它价格低廉、并且支持和配置都很容易。

以下说明常用的网络操作系统。

1. Novell

Novell 公司开发了 NetWare 网络操作系统，它被认为是网络工业的标准型产品，该网络操作系统可为全网的工作站提供文件和打印服务。新版本的 NetWare 可以处理数 TB 的磁盘空间，尽管当前技术并不能支持这么大的空间。今天已有许多的 NetWare 网能在普通的服务器上支持数 GB 的磁盘空间。

2. NetWare 2.x

NetWare 的 2.x 系列包括版本 2.1，2.11，2.12，2.15，最新的 NetWare 2.2 版本是专门服务于小型办公室或部门操作的。尽管 Novell 现在已不再开发 2.x 系列，但它仍然被一些小型的商业系统使用。2.x 可同时支持最多 100 个用户。

3. NetWare 3.x

NetWare 3.x 系列包含 3.0，3.1，3.11，当前版本是 3.12。NetWare 3.x 兼容整个企业产品，也能够支持较小的部门和远端办公室。3.x 系列可以用一台服务器支持最多 1000 个用户(从 Novell 申请发给许可证的版本)和几个 GB 的磁盘空间。最近的市场趋势是用 3.12 版来替代 2.x 系列，当然以后又会由 4.x 系列来替代 3.x 系列。但是现在调查人员在调查过程中最可能碰到的还是 NetWare 3.12。

4. NetWare 4.x

NetWare 4.1 是 NetWare 的最新版本，用于拥有多文件服务器的企业级的网络服务。Novell 生产 NetWare 4.1 作为整个 NetWare 3.x 系列产品的代替品。NetWare 可以用一台服务器同时支持 1000 个用户上线，提供大于或等于 NetWare 3.12 所提供的容量支持。

5. NetWare Lite/个人 NetWare

NetWare Lite 是一个端到端的网络操作系统。它支持每台工作站给网络中的其他工作站提供文件和打印服务。在以数据集中管理和安全性为代价的情况下，该软件使计算资源得到了更好的应用。

6. Banyan Vines

尽管 Banyan 不是最时尚的网络操作系统提供商，它仍然有一定数量的追随者。他们的网络操作系统提供一种叫 Street Talk 的服务，可以给用户提供友好的网络接口来访问网络资源。

7. Lantastic

Lantastic 是一个由 Artsoft 制造的网络操作系统，是今天市场上最为流行的端到端网络操作系统。它可以同时支持几百个用户，并支持每个工作站提供文件和打印服务。Lantastic 还可以提供网上声音通信功能备用户选择，但这需要从 Artsoft 购买特殊的硬件。Lantastic 网络操作系统既然是一个端到端的操作系统，这便意味着网络上的任一计算机都能提供服务器功能，包括磁盘存储和打印共享。装有 Lantastic 的 E mail 系统支持网络上的任意一台机器作为 E-mail 服务器。Lantastic 可以在最少两台计算机之间运行，而据知最多可在单一网络中支持超过 100 台计算机。

8. Microsoft Windows 95

Microsoft Windows 95 是完全的图形接口、具有网络支持的 32 位的网络操作系统。Microsoft 已经把许多新的网络特性加入操作系统，包括端到端和各种其他基于服务器的网络操作系统入口。

9. Microsoft Windows for workgroups(支持工作组的 Windows)

Microsoft Windows for workgroups 是 Windows 3.1 的升级产品，提供端到端的网络功能。它们甚至可以在一个以服务器为基础的网络不使用服务器时也能正常工作。在不知道其使用者的情况下，运行 Microsoft Windows for workgroups 的计算机也可以显示在 Internet 上，这时使用 Microsoft Windows for workgroups 运行端到端模式没有网络大小的限制。由于 Internet 服务提供商动态地分配地址，当涉及到 PPP 和 SLIP 连接时，这种无限制便成为一个可怕的提议。Microsoft 在设计 Microsoft Windows for workgroups 时已包含了网络特性以支持 Windows NT 服务器和其他 Microsoft 网络产品。

10. Microsoft Windows NT 高级服务器

Microsoft Windows NT 高级服务器(NTAS)是 Microsoft 设计的用于与 Novell NetWare 竞争的产品。作为一个非专有网络服务器，NTAS 将提供文件、打印

和邮件服务给那些对其优势感兴趣的 Microsoft Windows for workgroups 和 Windows 95 用户。NTAS 需要高功率计算机以发挥功能，计算机需要的配置(内存容量、处理器速度和磁盘空间)决定于用户数和服务器支持的应用类型。

11. UNIX/Xenix/AIX

当大多数网络操作系统给单独工作站提供文件和打印服务时，UNIX 及其更新版本却不仅能为对端和客户服务系统提供文件和打印服务，还能为与之连接的终端提供中央处理。这些系统通常使用一个功能强大的计算机，如 VAX，RS/6000，SUN 或其他小型机和大型机。

第12章

勘查电子公告牌

随着BBS(电子公告牌系统)的激增,调查人员不应忽视对它的关注。许多BBS系统迎合隐秘群体的口味,包括了诸如黑客、盗用电话线路、病毒、无政府状态和恐怖主义(H/P/V/A/C/T)等版面。调查人员应能很轻松地识别出提供非法产品、服务和信息的公告牌,它们经常用各种各样的方法来标识自己,如通过做"warez"广告(有版权的商业软件通过下载或文件传输服务提供给其成员)或在广告中有关于H/P/V/A/C/T的栏目。

这些秘密公告牌在几年前是非常深奥的,需要很大努力去定位,得到访问权限很难,而且时常需要该特定公告牌的成员的引见。随着Internet的爆炸性增长和拥有在线软件的个人计算机数量的激增,进入到秘密公告牌的地址变得容易了。电子空间的迅速开放使许多事物都集中到了Internet上,这导致公告牌、在线服务和Internet的区别变得模糊起来。不同系统之间能非常容易地实现信息共享,这使得电子空间也成为了一个犯罪孳生地。事实上用户会发现几乎所有现实社会中可以犯的罪都能在网上实施,我们调查过的案件涉及到追踪儿童和传播儿童色情图片、信用卡诈骗以及在聊天室、在线服务和私人公告牌制造谣言等。

一些电子空间更像城市里的犯罪多发区,作者倾向于把所谓的信息高速公路比拟为文明和秩序都不复存在的边缘地带。由于该领域人口的激增,这就必然导致罪犯在网络居民中占有一定的比例,所以电子空间也就成了文明的边缘。假如平均一个城市有各种类型的犯罪分子500 000个,那么在拥有约30 000 000人(该数字还在增长)的电子空间里会有多少罪犯呢?该电子空间很奇怪的一点便是它是世界范围的,几乎没有规则。司法管辖不存在,甚至没有国家界线,没有一个个人、公司或政府来对其进行管理,也没有警察在这个电脑城市里巡逻。它时常看起来毫无秩序,而为刑事犯罪者提供了完美的犯罪环境。

注 基于文章讨论的目的,BBS和在线服务在此是同义词。

12.1　从哪里开始

首先需要定位非法活动可能发生的在线站点，这将保证调查人员冷静地开始调查。如果有人为调查人员透露信息，这一步就容易多了。在办过几个引人注目的案子后，调查人员就不再需要主动去寻找案源了，相关的人员将不断报告所在地区的网络犯罪。

以下的工作可以帮助查找可能发生非法活动的公告牌。

1.　从当地公告牌和 Internet 上下载 BBS 列表

在 Internet 上，检查 alt. bbs 分层里的 USENET 新闻组。对于列表上刊登维护公告牌数据库广告的公告牌应特别留意，这类公告牌常常会有其他公告牌的列表。通常在大约一小时内就能发现 15 000～30 000 个公告牌，它们中的一些几乎总是把用户引向非法活动。

以下是在我们的新闻服务器上找到的 Internet 新闻组，它们均属于 BBS 列表

alt. bbs，alt. bbs. ads，alt. bbs. allsysop，alt. bbs. doors，alt. bbs. first-class，alt. bbs. gigo-gateway，alt. bbs. internet，alt. bbs. lists，alt. bbs. lists. d，alt. bbs. majorbbs，alt. bbs. metal，alt. bbs. pcboard，alt. bbs. pcbuucp，alt. bbs. public-address，alt. bbs. searchlight，alt. bbs. unixbbs，alt. bbs. uupcb，alt. bbs. watergate，alt. bbs. wildcat，alt. bbs. wwiv.

正如读者所看到的，新闻服务器上存在许多 BBS 列表和数字。

2.　订阅 Boardwatch 杂志

Boardwatch 是一个世界范围的以 BBS 为主题的月刊，是介绍 BBS 的列表和保存列表的系统。

3.　查阅当地报刊

检查当地书店、成人书店、杂志出版商的报刊报纸、“zine”（电脑文化杂志）和按期出版的文化报纸等。这类载体上常刊登有关色情甚至是秘密公告牌的文章或广告。

4.　检查奇怪的名字

寻找带邪恶字眼的 BBS 名字，这些名字通常是典型的恐怖主义类型，例如那些使用 LaRgE 和 SMaLl 之类字母的或在单词拼写中用“ph”代替“f”的（如用“phun”代替“fun”），或那类看似宣传非法活动的广告。这类风格正迎合了想成为地下电脑文化成员的人的心理。

5.　寻找“精英”

黑客和电话盗用者（hackers and phreakers，H/P）经常称自己是“精英”，意思

是他们比别人懂得更多关于计算机和电话系统的知识。由于 H/P 就是他们的生活，所以很大程度上他们倒真可以胜任此称号。他们通常称其他人为“骇子”，并在“骇子”(如警察)想要登录 H/P/V/A/C/T 公告牌时，通过询问“精英”简称的含义来试探调查对方是否是“骇子”。

为有助于针对“精英”领域的犯罪侦查，在此提供一些“精英”们常用的简称。查找 alt. 2600 下的新闻组和其他以 H/P 命名的区域，以及许多“精英”的 BBS，可获得更多的信息。

AAB	Amazing Astrofest Bunch
AB2	Anarchy Burger II
ACE	Arcane Corporate Elite
ACID	ANSI Creators in Demand
AE	ASSII Express
AFC	ANSI Factory
AHP	AcidHell Productions
AI	Artificial Intelligence
ALF	Anarchist's Liberation Front
AMIS	Atari Message and Information System
AMP	Ampere
ANI	Automatic Number Indentifier
BAD	Bitchin' ANSI Designers
BVN	Banned Vision
CBX	Cybrix
CCI	Cyber Crime International
CF	Cyber Force
CIP	CiPHER
CPU	Central Processing Unit
CTR	Contour
CUD	Computer Underground Digest
DDD	Dr. Death & Darkhawk
DMP	Dual Mod Player
DOD	Drink or Die
DOM	Dominators
DSP	Dead Smoking Punx
ECR	Electronic Rats
ETE	Eternity

EXT	Extortion PCBoard Magazine
FDN	Foundation
FLT	Fairflight
FSH	Flash
FTH	Faith
HEMP	Hardocore ELITE Mother Phuckers
ICE	Insane Creators Enterprise
INC	International Network of Crackers
IND	Independent
ITU	Infinity Trainers Unlimited
LGD	Legend Production
LOD	Legend of Doom
LOP	Lamers of Power
MP	Micro Pirates
MSI	More Stupid Initials
NCA	Number Calling Area
NEUA	National Elite Underground Alliance
NT	Needful Things
NTA	Nocturnal Trading Alliance
NUAA	National Underground Application Alliance
NX	Nexus
OTL	Outlaws
PBX	Private Branch Exchange
PCI	Power Crisis International
PE	Public Enemy
PHT	Phantasm
PIL	Pirates in Legion
PLC	POLICE
PSD	Psycho Squad
PSY	Psychosis
PTG	Pentagram
PW	Physical Wish
PWA	Pirates with Attitude
RISC	Rise in Superior Couriering
RZR	Razor 1911

SIN	Software Innovation Network
SNB	Stones'n' Bones
SWAT	Special Warez Acquisition Team
TDT	The Dream Team
TERR	TERRATRON
TFC	The Future Crew
TFYC	The Fuck You Crew
THG	The Humble Guys
THP	The Hill People
TOAO	The One And Only
TRI	Trinity
TRIC	The Really Insane Couriers
TRSI	TriStar & Red Sector
TSAN	The Sysop Association Network
TSD	The Shining Darkness
UHG	Ultimate Hacking Group
UID	Utilities in Demand
UNT	Untouchables
VS	Virtual Shock
WC	Wild Cards
WSIWYG	What You See Is What You Get
WW	Wankers of Wimbledon
WWC	World-Wide Couricrs

6. 寻找“成人”图片集

查找登有大量“年轻 GIF”图片集广告的 BBS，或以法定年龄以下的青少年为对象的明显带有性意味的问卷调查的 BBS。这些图片集的多数观看者都是孩子。找出罪犯的惟一方法是下载这些图片并请儿童生长方面的专家，通常是小儿科医师对之进行分析。

7. BBS 对司法的限制

寻找那些对司法人员和政府公务员提出警告、否认司法的言论和横幅。横幅上宣称司法人员必须表明自己的执法身份，否则便将受到民事或刑事制裁；有些 BBS 甚至对欲访问的司法人员进行挑战或威胁；更有甚者，一些 BBS 声明法律执行人员和其他政府官员根本不能使用该系统。许多计算机犯罪者仍然认为：司法人员在调查期间当被问及是否是警察时应当表明自己的身份，否则该案就是陷害。

8. 与系统操作员交锋

怀疑那些在允许用户访问之前，要求用户先与系统操作员接触的 BBS。一些更奸诈的 BBS 可能还要求用户在获得访问权限之前做一些明显非法或不道德的行为，要找到这类 BBS 有一点困难。

9. 系统密码

怀疑那些在用户开始登录的时候，要求用户输入秘密"系统"口令的 BBS。

10. 入会和介绍

怀疑那些要求用户入会、询问用户经常访问的其他 BBS 名字以及用户的推荐人姓名的 BBS。

11. 有禁止访问区的常规系统

有些公告牌有一些特殊地区要求只有在会晤过系统操作员之后才能被访问，这些都应引起调查人员的注意。这很可能就是对一些非法活动的暗示。

12. 刺探调查表

分发有关诸如黑客/盗用电话线路或性行为和爱好的调查表是不合适的，可以想像到一旦某个用户说他不到年龄，性类型的调查表就会停止继续提问。如果该系统仅是为了迎合成年人，那么它就会切断不到年龄的用户。如果调查人员浏览整个调查问卷发现提问的问题越来越涉及到个人隐私，就应更加仔细地观察一下该系统。

13. 经常聊天

在调查人员上线期间，若有系统操作员插进来问一些与秘密活动有关的问题，如该 BBS 的地点、系统密码、你的性别、秘密缩略词的含义等等，那这样的公告牌便是非正常的。此时，调查人员或者是进入了一个新的系统，或者需要进行进一步的调查了。

14. 有许多用户同时上线的规则系统

Prodigy，Amcrica Online 和 Compuserve 等家庭用系统也有其阴暗面，要检查专为孩子们设计的领域的活动。有时调查人员会发现在这些区域有讨论不同生活方式或少年黑客的主题，这些区域可能会传输有关盗窃或信用卡诈骗方面的信息。许多成人假装成孩子在类似地区与孩子们进行带有性目的的接触，调查人员要注意一下是否有色情图片的交换和带有性意味的邮件或聊天。

这些办法似乎并不能满足调查人员想要找到非法公告牌系统的需要。找出如儿童色情画片一类的东西确实要费点功夫，但它们又确实存在。

12.2 开始勘查

当调查人员在 Internet 上找到可疑的 BBS 或区域时，下一步应做的是尽可能地建立起自己的基地。如果无法建立，可以挪到其他可疑的 BBS 系统上并继续查找，这使他更易保护自己不公开的身份。如果调查人员经常改变关注点或与在线中人发生联系，就可能因疏忽或失误暴露自己的身份。

记住在线调查并不适合每一个人，甚至那些在此类调查方面有天赋的人刚开始时也未必能做得很好。这正像其他事情一样，只有熟能生巧。刚开始时，调查人员不妨试着在不同的 BBS 上转悠，对 BBS 的设计和运行找点感觉，再试着下载信息和发信给别的成员和系统操作员。如果调查人员喜欢并明白自己在做什么，就拥有了成功地进行在线调查的机会。如果遇到了自己不能解决的问题，不要泄气，在线调查可能不是自己应从事的工作。记住：在线上的角色扮演也像从事任何其他秘密行动一样，调查人员必须投入到自己的角色里去，但是不要暴露身份。

12.2.1 如何避免陷阱、圈套和错误

从经验中我们可以学到在法庭作证时如何避免在调查期间已经犯过的错误。由于计算机犯罪调查是一个新领域，按照法官的专业标准而言，我们已经犯了很多错误。不过，我们所犯的错误并非是破坏性的。避免这些错误的方法是调查人员真正地意识到防范的意义。当起诉某网上案件时，一个好的辩护律师能通过使用准确的术语或基本准确的行话来严重影响法官和陪审团对所调查的某一方面情况的态度。为避免这个问题的出现，请记住下面的建议。

1. 不要用 ANSI 图形

ANSI 图形在屏幕上看起来很漂亮（如果图形的制作者精于此道并有一定的艺术天分），但它们在纸上会占用太多空间而且打印出来的效果并不好。ANSI 图形通常被那些出于保护自己系统并破坏他人系统目的人用作另外一个用途——ANSI 炸弹。通过使用 ANSI escape 码，嫌疑人便能对显示计算机的键盘程序进行重新编排，使它去调用一个病毒或格式化硬盘。调查人员应经常使用文件显示器如 LIST（共享软件）或 XTreePro Gold 来显示文本文件和二进制文件，这将保护自己免遭 ANSI 炸弹的轰炸，记住不要用 TYPE 显示文件。在线时 ANSI 炸弹不是一个严重的问题，通信软件都有它们自己的 ANSI 图像处理器。

2. 扮演角色

上网的很多时候调查人员都需要扮演秘密角色，如果想完全掌握，可能需要花数月时间。

以下是一些技巧。

(1) 制作一本“传记”

制作一本自己在每次勘查中所扮演的人(角色)的传记,列出包括被扮演者的名字、年龄、生日、地址、电话、所属的其他的 BBS、计算机知识、打字和拼写的能力、朋友、家庭成员等作为一个自然人需要自己记住并能告诉别人的所有的个人信息。在传记里记录下所有曾告诉别人的关于自己的信息,说不准什么时候某个人就会记起调查人员曾告诉他的休假的时间、读书的学校以及朋友等等。如果保存这么一个日志,在以后的会话中当别人问起关于调查人员个人的问题时,这些信息可以马上得到。

(2) 在办一个案子时扮演多个角色

制作多个传记并让其中的角色在 BBS 上进行彼此的照顾和相互确认,有时他们也会争吵和相互发脾气。在调查过程中还可以让一、两个人出局,这没关系——因为还有其他人在工作。调查人员应确保每次的角色登录时用不同的顺序,以免遭致怀疑。

(3) 使用多个调查人员

多个调查人员使用各自的传记,尤其他们处于不同的地理位置可以减少被怀疑的几率,使他们更快地被其他用户承认并取得证据。在获准访问某些敏感文件之前,系统管理员通常会要求与调查人员单独会晤,从另一个城市拨号来的用户也许就不用再进行个人认证而直接对敏感文件进行访问了。

3. 知道自己的讨论题目

是少年性犯罪、黑客、盗窃电话线路、信用欺骗、欺骗,还是邪恶?调查人员应知道自己正在谈论什么,并应了解和会使用该特定领域的行话。如果调查人员正在模仿一个同性恋者,就应该知道“bear”和“cub”是什么意思。不要虚张声势,除非别无选择。如果调查人员因虚张声势被揭穿,也不必惊慌,就说自己在别的什么地方看见过该术语并理解成了别的意思。调查人员通常在扮演一个新手的情况下会卓有成效,因为大多数嫌疑人都喜欢向没有经验的人夸耀他们的知识,一些嫌疑人也有可能想成为对方的老师。

4. 在“聊天”中识别别人

有几种方法可以用于在线聊天以识别谁说了什么(类似于“谁是第一”),一些程序(如 IRC 和 AOL Chat)通过识别谁在打字而使识别工作变得容易。调查人员应经常使用嫌疑人的名字,并总在自己的段落末尾加上两个回车以区分自己和嫌疑人打的字,这也是一个参加在线聊天的易被接受的常用方法。

12.2.2 工具及方法

1. 终端软件的使用

应使用不保存 ASCII 控制符到查获文件的终端软件。例如，Procomm Plus 会保存调查人员、嫌疑人和公告牌软件所做的每一次键盘操作，包括退格、删除和改写等。其结果是产生了一个可读性很差的文件，被用在法庭上作证时会问题百出，陪审团读这些打印文件并判断在公告牌聊天当中发言的主体和内容时可能会有困难。理想的软件应是能按照所见即所得的方式来存储在聊天方式下看到的对话。

2. 在线会话调查中录像带的作用

使用一个摄像机，调查人员便可以在聊天或 IRC 会话发生时，把它们录制下来。也可以在录像带上做一个口头注解以便在以后的调查中能有所帮助。录像带无异于在法庭上为调查人员提供了一只证人的眼睛，只不过调查人员要小心所作的声音注解，对方可能借用它们在审讯期间或民事诉讼中来反对。

3. 使自己的打字方式不同于别人

为了有助于识别谁在打字，用一种与对方不同的打字风格。如果对方用的是大小写混合的方式(正确的打字风格)，调查人员可以用所有都是大写或所有都是小写的格式。读者可参见所附的 BBS 聊天例证以获得更多信息。

4. 小心自己对其他用户说的话

系统操作员经常在他们自己的 BBS 中扮演多个角色。当调查人员在进行调查时，不要信任线上的任何人。

5. 保持语言一致

如果调查人员使用的是街头语言或行话，应知道所选择的每个词汇的正确用法。使用它们的时候要保持一致性，语言风格的明显转换可能使自己露马脚。

6. 在打字技术和拼写上保持一致

如果调查人员是一个初学打字者，保持自己的风格；如果写了错字并使用大量 typos，应保持前后一致；如果被揭穿，就说自己正跟着打字老师练习打字等等。

7. 使用获取或日志文件

用户的通信软件会生成日志或获取文件，它们将记下用户的计算机和远程系统之间的在线活动。保存获取或日志文件中的信息量大小取决于使用的通信软件，一些程序会截获通过 modem 的所有字符，另一些却只截获除退格等控制字符之外的纯 ASCII 文本。调查人员应确保自己的 modem 软件在每天或每次会话中

都已设置了独一无二的文件名，比如 090309. cap 或 sept9_1. cap，sept9_2. cap，sept9_3. cap 等。

8. 跟上自己的文字工作

一个在线会话调查完成以后，调查人员应立刻编辑一份获取文件的副本并标识出文件中任一言论的发出主体。可以使用黑体和下划线或两者结合来完成这项工作。应保持按时做最新进展的报告，包括会话活动的起止时间及会话摘要。千万不要对原始截获文件进行编辑。编辑过的拷贝作为笔记的一部分是用在调查和法庭上的，一些案子在罪犯被逮捕后一两年才能受到法庭审判。记住如果没做任何拷贝，直接修改所获取的文件时，兴许会修改掉原始证据。

BBS 聊天的例子

你现在处于聊天方式中：

I've been watching you for a few minutes.

HOW CAN YOU DO THAT, MARK?

The BBS lets me look at everything going on all the time.

WOW! THAT'S GREAT! SO YOU CAN ALWAYS SEE WHAT I'M DOING?

Yea. I can do anything I want on this system. I can cut users off, I can change access levels and I can send messages. Great power. What a trip.

WOW! CAN ANYONE ELSE DO THAT BESIDES YOU?

No, just me. By the way, you should not use all upper case. It is considered shouting. Use mixed case.

SORRY. WHEN I USE UPPER AND LOWER CASE I GET CONFUSED. I HOPE THIS IS OK.

Sure, no problem. If anyone else gives you any trouble, ignore them. If you have a problem, I'll take care of it for you.

THANKS. I APPRECIATE IT.

Well, I'll let you get back to using the BBS. I'll even give you a little more time on the system to look around.

THANKS. I'LL TALK TO YOU LATER.

Bye.

CHAT END.

这样你的时间又增加了 10 分钟。

9. 使用一条不忙的电话线

用户遇到的每一个 BBS 都要求提供用于声音验证的电话号码，有些甚至要求一个号码做自动回拨验证，BBS 计算机会立刻拨回给用户。调查人员将需要一至

两个可用电话号码给嫌疑人以便他们进行验证，这些电话号码一定不能有政府前缀，因为这对于疑心很重的嫌疑人来说是个无可挽回的暴露。有些系统不会允许一个号码多次使用，所以不要打算总是用一个数据线工作。由于系统需要一个惟一的电话号码，可以考虑把其他电话转到自己的电话上。

10. 取得足够的身份（identification）

一个人的身份可能就存在于驾驶执照、社会保险号码以及信用证资料中。有时可能需要包括学校身份或其他雇佣记录，这取决于所扮演的角色。调查人员应确保已实际制作出相应的记录以防嫌疑人去验证自己的雇佣情况、学校或信用卡。

11. 使用安全的信用卡

一些 BBS 要求用户购买会员资格、时间、图片或计算机上的软件，最简单的支付方法是使用信用卡。如果选择使用信用卡，应确保该卡不会被用来跟踪到自己的工作单位或该单位的其他雇员。另外一个安全支付方法是用现金订购，这两种方法都允许使用假名字但仍需保持证据痕迹。

12. 使用一个安全地址

几乎用户所遇到的每个 BBS 都想要在他们的记录中有用户的地址。有时提供一个邮局的信箱他们就接受了，但是另外一些时候他们却要一个真实的地址，该地址不能与调查人员的工作单位或其成员有任何联系。计算机犯罪者要求用户提供地址信息的通常想法是："没人会住在一个邮政信箱里"。

13. 有可用的声音

当要扮演一个少数民族、一个女人或某个不在公告牌上的人时，需要有某个具有合适声音的人来回答声音验证电话。这个人可以说一些类似于"我的 XX 不喜欢我用电话……"之类的话来尽量减少与嫌疑人通话的时间。调查人员可用妻子、丈夫、父母等头衔来替代 XX，协助调查的人可能是一个官员、信息提供者或一个普通公民。无论是哪种情况，调查人员都一定要从头至尾地指导他们了解自己扮演的角色、为他们设计的传记、他们的说话风格以及知识水平等，他们应阅读相关的获取文件以便能够在被电话验证时说话得体。

14. 尽可能地使用多条电话线

BBS 通常都备有多条电话线，这将支持多个人同时登录 BBS。一些线可能是专为其成员或其他特定的人保留的，当另一个同事在 BBS 上时，调查人员也能同时在线上从系统管理员处得到可能有助于案件的信息。

15. 使用脱机读邮件器

下载邮件后，要使用脱机读邮件器来准备回复并装入回复邮件，这样可以节约时间并避免与不是调查对象的人啰嗦。可以用几个程序来完成该工作。脱机读邮

件器可以在几乎任何一个 BBS 上找到。一些系统(如 Wildcat)也具备脱机的特征。最普遍的脱机读格式是 QWK。根据脱机格式的不同,可能需要准备几个不同的读写器。

16. 上线时间

在调查人员决定呼叫涉嫌 BBS 的频率及时间时,应充分考虑案子的类型和自己设计的传记。这将因扮演的角色不同而有所不同,如果扮演的是一个在校学生,应关注学校的放假及开学时间;另外当扮演的角色被推知应当在上课或睡觉时,他是不应该在 BBS 上出现的。

12.3　鉴别嫌疑人

12.3.1　使用监视

调查人员确定与自己在计算机上聊天的人的身份的惟一方法是派监视小组监视涉嫌地点的人员出入情况。在辩护律师在法庭上对所作的调查质询时,对 BBS 的实际使用人的身份的确认是他将提问的焦点之一,因此准备精确的监视日志是极其必要的。

应从计算机上尽可能地得到有关嫌疑人的个人信息。该信息可从其他渠道加以印证。例如下列信息:

- 名字:"嗨,这是谁?"
- 年龄或生日:"我的生日是 2 月 21 日,你的呢?"
- 交换图片或私人信件的邮件地址:"我有很多很酷的图片想给你看,我应该把它们发到哪?"
- 关于嫌疑人描述他们的嗜好、登录日期和记录的拷贝。
- 关于工作、优先地址和家庭成员的个人交谈。

12.3.2　通常的信息来源

(1) 机动车管理部门(驾驶执照、相片和指纹等)

(2) 犯罪历史记录

(3) 公用事业

- 汽油
- 水
- 垃圾
- 电话订购信息

(4) 信用机构

(5) 跳跃跟踪数据库,如 CDB Infotek,info America

- 国内电话簿
- 国内移动目录
- 国内订购信息
- 罪犯和国内档案管理
- 破产记录
- 工商管理登记(公司、有限合伙人)
- 不动产
- 社会福利记录
- 出生、结婚、离婚和死亡记录

(6) 选举登记记录

12.3.3 在逮捕和搜查期间鉴别嫌疑人

(1) 条件成熟时,找一个理由与嫌疑人直接碰头,如与黑客交换软件和设备、购买毒品或与小贩进行药品买卖、与诈骗嫌疑人交换信用卡或相关材料等。

- 选一个便于进行视觉监视的地点。
- 选一个足够安静能让录音设备很好工作的地点。
- 选一个人少的时间、地点,这样的监视不至于引人注目。

(2) 从与嫌疑人会面到由警察接管嫌疑人期间安排一切监视事宜。

注意 谨防被反监视。

(3) 如果可能的话,在与嫌疑人会晤时使用录音录像设备。

(4) 在会面期间,取得嫌疑人企图实施犯罪行为的证据和陈述。

(5) 对公告牌的位置进行录像和拍照,这使调查人员已得到的证据信息可以显示在胶片上。正如前文提到的,卧室门上挂锁的图片曾在法庭上为我们解了围。

(6) 会见大楼内与计算机系统的所有权和使用权有关的其他居住者。

(7) 检查计算机所在房间内的文档、衣服、图片和其他个人物品以断定谁使用过该计算机和房间。

(8) 检查能够表明计算机的拥有者和使用者的计算机软件,通过检查注册文档可能会发现盗版软件。不要用嫌疑人的计算机做这些工作。

12.4 需要注意的方面

- 反监视的可能性。
- 呼叫者身份鉴别能力 电话公司在某地区的电话具备来电显示功能。嫌

疑人有可能使用多个身份，就像调查人员做的那样。

- 对调查人员身份的保护。
- 防备逮捕实施之后调查人员成为攻击目标。

12.5　调查人员易暴露的方面

- 驾驶执照
- 车辆注册登记
- 选举注册
- 财产所有权/税单
- 信用卡申请/查询
- 电话清单
- 法庭记录
- 公用记录
- 内部信息
- 跟踪数据库/订购信息

12.6　建议保护调查人员的步骤

- 使用邮政信箱收发信件。
- 使用不列清单的电话号码。
- 告知车管部门不要登记调查人员。
- 要求相关公司不公布关于调查人员订购的信息。
- 要求信用代理在调查人员的文件上标注“警告”字样，以使调查人员的个人信息不可查询并在受到查询时及时与调查人员联系。

第13章

计算机犯罪勘查取证系统技术实现

在计算机犯罪中，计算机技术扮演着重要的、通常是必需的角色。在这个过程当中，计算机既是犯罪分子攻击的目标，也是犯罪分子攻击时使用的工具。对犯罪证据而言，最重要的是计算机上储存着与犯罪活动相关的电子数据。

计算机取证是将计算机调查和分析技术应用于对潜在的、有法律效力的证据的确定与获取上。它是能够为法庭接受的、足够可靠和有说服性的，存在于计算机和相关外部设备中的电子证据的确认、保护、提取和归档的过程。

对计算机网络进行扫描与分析，自动发掘与分析计算机犯罪现场的网络主机的操作系统、运行服务以及网络路由设备等环境状况，并自动绘制形成网络结构的拓扑图，对辅助办案人员进行现场勘查、取证，对侦查提供证据支持和决策参考是非常重要的。美国的 Purdue 大学在美国空军和高级（远景）研究计划局（DARPA）的支持下，早已开始对计算机系统运行环境自动采集与描述技术的研究。美国 ISS 公司的 ISS SafeSuite，System Scanner 和 NAI 公司的 CyberCop 等多个网络的分析和测试产品，也可以起到辅助分析的作用。

本章在前面研究的基础上，重点讨论计算机犯罪中系统运行环境勘查取证系统的技术实现。

13.1 国内外研究现状与趋势

计算机系统运行环境的勘查取证技术融合了网络扫描技术、系统扫描技术及网络侦听技术，是一项复杂的技术。

国内外关于此项技术研究的报道较少，美国 Purdue 大学早已经开始了此项技术的研究和应用，但国内关于此项技术的研究仍局限于基于主机和网络的漏洞扫描技术以及相对独立的网络监听技术，没有将三者融合起来做针对性的研究工作。

漏洞扫描技术是一项自动检测远端或本地主机安全脆弱点的技术，通过扫描程序查询 TCP/IP 端口并记录目标的响应，可以收集到如下信息：

- 当前正在运行什么服务？

- 哪些用户拥有这些服务？
- 是否支持匿名登录？
- 是否需要鉴别某些网络服务？

通过收集这些有用信息，对计算机运行环境的勘查取证可以起到一定的辅助作用。自 1995 年 Dan Farmer 公开 SATAN(以攻击方式进行漏洞扫描)软件后，基于主机和网络的漏洞扫描技术取得了迅猛发展，国外 ISS、NAI 等公司推出了自己的商业性的漏洞扫描工具，其功能相对更加强大，但内核技术未公开。国内虽有多家公司推出了自己的漏洞扫描产品，但与国外相比仍有一定的差距，主要表现在漏洞库的更新速度缓慢，无法及时跟进漏洞的出现速度。

随着网络的发展，网络上免费的漏洞扫描软件随处可见，以下就一些常用扫描器做一个简单的介绍。

(1) NSS(网络安全扫描器)　是用 Perl 语言编写的，可执行 sendmail，匿名 FTP，NFS 出口，TFTP，Hosts. equiv 和 Xhost 等常规检查。

(2) nessus　是一系列免费扫描程序中最新的一种，是由三个黑客用 C 语言在 Linux 下共同编写的一个 TCP 端口扫描程序，它可扫描拒绝服务、远端获得 root 权、Finger 滥用、FTP、远端文件访问和发送邮件等。

(3) strobe(超级优化 TCP 端口检测程序)　是一个 TCP 端口扫描器，可以记录指定机器的所有开放端口，快速识别指定机器上正在运行什么服务，提示什么服务可以被攻击。

(4) SATAN(安全管理员的网络分析工具)　用于扫描远程主机，发现漏洞。包括 FTPD 的漏洞和可写的 FTP 目录、NFS 漏洞、NIS 漏洞、RSH 漏洞、sendmail、X 服务器漏洞等。

(5) jakal　是一个秘密扫描器，它启动但并不完成与目标主机的 SYN/ACK 过程，因此可以扫描一个区域而不留下任何痕迹，能够避开端口扫描探测器的探测追踪。

(6) IdengTCPscan　是一个更加专业化的扫描器，能够识别指定 TCP 端口进程的使用者，即能够测出该进程的 UID。

(7) CONNECT　用于扫描 TFTP 服务器子网。

(8) FSPScan　用于扫描 FSP 服务器。

(9) XSCAN　用于扫描具有 X 服务器漏洞的子网或主机。

(10) SAFESuite　是快速、先进、全面的 UNIX 网络安全扫描器。可以对指定网络执行各种不同的攻击、探测网络环境中特定的安全漏洞，包括 sendmail，TFP，NNTP，telnet 和 RPC 等。

以上只是列举了众多扫描器中的一部分，除了商业性扫描器提供的功能比较全面外，大多数免费的扫描器的功能只是局限于某一部分。

网络监听技术是对计算机运行环境勘查和取证有辅助作用的另一项技术，是获取网络上传输信息的一项技术，它可截获网络中的传输报文，并可对其进行内容分析和流量分析。网络监听技术是一项比较成熟的技术，嗅探器就是这一技术的应用，嗅探器可以根据用户的设置获取想要的内容，以下是一些常见的嗅探器。

(1) Network Associates 公司的 ATM 嗅探式网络分析器　可对 250 种以上的 LAN/WAN 协议进行解码，包括 AppletTalk，BanyanVINES 和 IBM SNA 等。

(2) Shomiti 系统公司的 Century LAN 分析器　是一种功能强大的软硬件解决方案，支持 10/100Mbps 的以太网。

(3) Klos Technologies 公司的 PacketView　是一个基于 DOS 的软件包，支持以太网、令牌环网、ARCNET 和 FDDI。

(4) Network Associates 公司的 Network Probe 8000　是一个专用的 WAN 的软硬件解决方案。

(5) Precision Guesswork 公司的 LANWatch 嗅探器。

(6) IBM 的 DatagLANce 网络分析器　是专门针对局域网也是惟一的 OS/2 嗅探器程序。

(7) Net3 Group 公司的 ProConvert 嗅探器。

(8) Triticom 公司的 LANdecoder32　是 Windows 95 和 Windows NT 使用最为普遍的嗅探器之一。

(9) People Network 公司的 NetAnt 协议分析器　能够解码所有流行的协议。

(10) Cinco Networks 公司的 NetXRay Analyzer　是一个用于 Windows NT 的网络监视工具，是 Windows NT 嗅探器中最为复杂的一种。

以上列出的是众多商业嗅探器的一部分，网上还有许多免费和共享的嗅探器，其中大部分是针对 UNIX 设计的，在此不再一一列举。

网络拓扑结构的探测和可视化技术是一项自动探测网络内部结构并使之可视化的技术，它是计算机系统运行环境勘查取证技术综合的另一项重要技术。通过对网络拓扑结构的分析，可以发现其设计中的安全隐患，一个安全的网络拓扑结构可以有效地抵制嗅探器及扫描器的攻击。

关于网络拓扑及可视化，虽然目前已经有一些国外著名的网管软件在这方面做得非常出色，但是，一方面它的价格惊人，另一方面，它只适用于大型的网络构架上，而对一般规模的局域网无能为力，并且，它还需要对应的网络设备都启用 SNMP 协议，这在许多场合还是不适合的。所以，解决网络拓扑及可视化问题，主要通过收集指定 IP 地址范围内的主机、网络子网的互联信息，建立主机与主机之间、主机与子网之间、子网与子网之间的互联拓扑图。同时结合 SNMP 协议，以丰富网络拓扑信息。目前国内外关于此项技术的研究报道较少。

融合了漏洞扫描技术、网络监听技术以及网络拓扑结构的探测和可视化技术的计算机系统运行环境勘查取证技术，目前在国内尚未起步。虽然其融合的技术有些已经比较成熟，但仍需对其作进一步改进，网络拓扑结构探测和可视化技术仍有许多问题亟待解决。

13.2　关键技术

计算机系统运行环境的勘查取证系统，在保护系统（网络）环境原有运行状态的前提下，通过多层次的网络协议实现跨平台的网络通信，利用动态漏洞知识库实现了系统和网络的漏洞检查；利用模型检查，实现了安全协议分析，在现有的 ICMP 协议工具的基础上，利用有效的算法，实现了网络拓扑信息的搜索；采用 SNMP，DNS 等网络协议实现了网络隐藏信息的自动挖掘和关联搜索，并最终生成对涉案的全部系统网络描绘和证据提取。采用的关键技术主要有

- 网络设备、主机配置的自动扫描与分析技术；
- 基于常用网络管理协议（SNMP 等）的分析技术；
- 网络拓扑结构的自动发掘与分析技术；
- 系统中应用和服务等信息的自动采集与表达技术；
- 运行环境与拓扑结构的可视化技术；
- 利用模型检验技术，实现对系统的漏洞分析。

计算机系统运行环境的勘查取证系统的创新点主要有：

- 利用 TCP/IP 协议栈指纹识别技术进行操作系统类型探测；
- 多种端口扫描机制，使扫描更加隐蔽；
- 利用优化的多线程并发扫描机制，可使扫描效率大大提高；
- 利用漏洞规则库结合动态链接库技术进行漏洞扫描，便于系统升级和扩充；
- 基于插件技术的系统扫描技术，统一解决系统扫描的多版本问题。

13.3　系统模型的建立及框架结构和功能定义

随着计算机犯罪手段的日益高明，涉案主机和网络的运行环境的勘查和取证技术的发展也变得日益紧迫。

计算机技术是当今世界发展最快、更新最快的技术之一，形形色色的网络、众多操作系统的存在，决定了计算机及网络运行环境的勘查和取证是一项复杂的工程。

现有的技术手段如基于网络的漏洞扫描技术和基于主机的漏洞扫描技术，可

在一定程度上对计算机及网络的运行环境进行勘查，但由于设计方向的原因使其很难对取证提供更有力的帮助。

要对涉案主机及网络的运行环境进行全面的勘查与取证，须对其进行由外到内的全方位的扫描，即采用内外相结合的方式进行勘查与取证，只有内外相结合才能对主机的运行环境进行全面的了解。同时，网络的存在决定了数据的流动，数据具有动态可变性，相对静态的数据（存储在计算机中的数据）可待日后分析，但网络中流动的动态数据却很难在日后再恢复、再分析。可见只有将对可疑涉案主机进行案发前的数据监控和案发后的勘查取证结合起来，才能对案件破获提供更有力的支持。因此只有内外结合、动静结合、前后结合才能保证计算机运行环境的勘查和取证技术更为全面、详实[10]。

13.3.1 勘查取证系统模型

根据作者的工作经验和技术上的可行性，本书提出对计算机犯罪的勘查取证过程应该是立体的、多方位的。即三维勘查取证技术模型：外内、动静、前后。

- 所谓外内，外是指从犯罪人员的计算机（简称犯罪机）的外围对其进行勘查取证，包括对犯罪机周边网络环境等的勘查，这样的过程是在完全保护犯罪机的所有信息不受到任何改变的情况下获取有效信息。所谓的外部扫描、网络拓扑扫描、侦听监控都属于这里的“外”；内是指根据侦察需要，深入犯罪机的内部（由于需要进入系统安装软件，对系统的全貌有所改动），获取更加全面的、许多通过外部手段无法获取的信息。
- 所谓动静，指的是对犯罪信息的勘查取证不仅仅局限于各种静态的数据（如操作系统、网络环境等）的获取，而且需要考虑到一些计算机犯罪行为的跟踪记录及重现。就像传统侦查需要采集一些犯罪痕迹数据的同时，有时也需要一些动态的行为过程的数据（如目击、录像等），在数字犯罪侦查中更有必要获取一些动态的行为信息，以便有助于侦查工作的开展。
- 所谓前后，是指作案的前后。不仅要能对作案后的现场进行有效的勘查取证，而且还能够在作案前对犯罪嫌疑分子进行有效的跟踪取证，甚至还可利用陷阱设计诱导犯罪分子再次作案，并在作案时进行跟踪取证。

这样，计算机系统运行环境的勘查取证技术，综合网络扫描技术、系统扫描技术、数据监测技术、数据挖掘技术等，就可以做到由外到内，内外结合的全方位、立体勘查。下面具体综合说明。

从计算机系统外部进行勘查和取证是指“外”，所需手段主要是通过网络扫描技术和信息侦听监控技术，通过网络扫描技术可以从外对相对静态数据进行分析，信息侦听监控技术可以对网络中流动的动态数据进行分析，动静结合。

1. 从外部可获取的信息

(1) 通过网络扫描技术：网络扫描技术在此结合了网络漏洞扫描技术和网络拓扑结构扫描技术，网络漏洞扫描技术是从系统外部对系统的脆弱性进行安全评估的技术；网络拓扑结构扫描技术是对主机所在的网络结构进行探测的技术。结合这两大技术，从外可获取如下信息。

① 主机的操作系统类型、版本信息　利用操作系统指纹识别技术，可对现有绝大部分操作系统类型及版本进行准确的判别。通过建立操作系统指纹规则库，可实现对现有操作系统指纹识别技术的扩展和升级。

② 网络漏洞信息　现有的网络漏洞扫描系统，都是将其漏洞扫描库内嵌在程序中，不便于升级，容易引起漏洞误报；参照入侵监测系统中规则库的模式，通过建立动态漏洞知识库，并对其进行特征分析，逐步建立漏洞的规则库，从而获取全面的网络漏洞信息。对于无法建立规则库的漏洞，可再通过程序内嵌处理。

③ 主机开放端口服务信息　端口是系统对外开放的门户，通过分析开放的端口，可以确定系统开启的服务。结合木马探测技术，可从众多端口中进一步确定木马存在的可能性；结合后面的主机漏洞扫描技术可从系统内部得到进一步的确认。同时利用多种端口扫描技术(FIN、ACK 等)可使扫描更隐蔽，穿透能力更强，通过使用优化后的多线程扫描机制可大大提高端口的扫描效率。

④ 主机用户信息　获取到用户信息可使调查人员专注于用户口令的猜测，现有的用户口令猜测机制均比较简单，只有结合中国人使用密码的习惯，生成更为有效的密码字典，才能大大提高其口令猜测的命中率。

⑤ 网络周边设备类型信息　通过 ICMP，SNMP 等协议分析，结合系统扫描技术可准确确定网络中路由器、智能交换机的类型。

⑥ 网络拓扑结构信息　通过 ICMP 检测、遍历路由表检测、SNMP 分析技术进行拓扑扫描，结合获取到的网络周边设备的信息、扫描到的主机信息，应用可视化绘制模块可绘制出网络拓扑结构图，并提供用户修改的交互功能。

(2) 通过信息侦听监控技术：同电话监听一样，利用信息侦听监控技术，可对可疑主机在网络中流动的数据进行事前监控，构成一个网络动态取证系统。其主要分为内容监控和流量分析两部分，内容监控可对邮件、WWW 浏览、文件传输等内容进行全面监控和记录，并可进行历史回放和重现，同时根据内容过滤条件，提取符合条件的可疑内容；流量分析主要负责通信数据包的统计分析，提供协议分析和端口分析，并对攻击性的数据包进行示警、归类和整理。

所谓“内”是指从主机系统内部获取的信息，主要是以系统扫描技术和数据挖掘技术为主。系统扫描技术可对系统中的静态数据进行归类整理，数据挖掘技术则可对有用的数据进行提取、备份、分析及保护等。

2. 从内部可获取的信息

从主机内部获取信息主要通过系统扫描技术。根据操作系统类型分别设计系统扫描技术，通过对系统配置文件、注册表、数据文件等的扫描来获取必要的信息。

(1) 系统硬件配置信息(CPU、主板、网卡、硬盘、modem、打印机等) 包括CPU的主频、主板型号、网卡型号、硬盘型号和容量、有无配置modem和打印机等。

(2) 系统已安装软件的检测和分类整理信息(应用软件和系统软件) 对系统所安装的所有软件按照应用和系统软件进行分类整理，列出所安装软件的目录。

(3) 用户遗留历史数据的提取、分析、备份和保护(mail，oicq，浏览网站信息等) 主要对其遗留在本机的电子邮件、聊天记录和网站访问记录、文本文件等进行提取、备份、分析和保护，从中获取可能利用的证据。

(4) 常见系统漏洞信息 指获取基于主机的漏洞信息。

13.3.2 勘查取证系统框架结构

基于上面的系统模型，作者设计了勘查取证系统框架结构图，如图13-1所示。

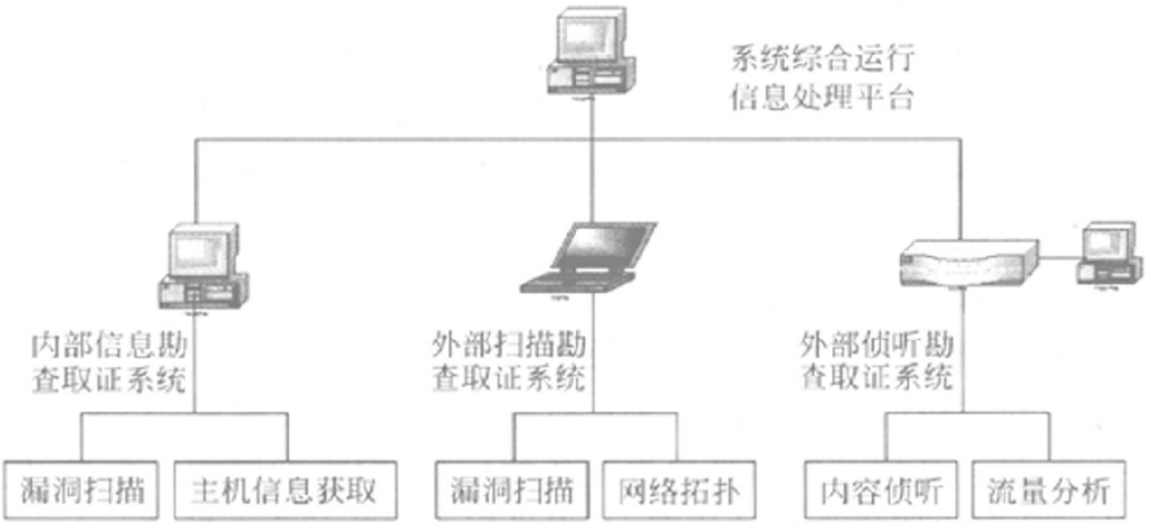

图13-1 勘查取证系统框架结构图

由上图可以看出，整个系统有一个综合运行信息处理平台，它负责将各个子系统作为套件有机地融入整个系统，使该系统具有良好的扩充性。同时它负责对各子系统勘查获得的信息进行综合的分析处理，使自身成为一种良好的分析决策工具。

它包含有三个主要的子系统，分别为内部信息勘查取证系统、外部扫描勘查取证系统和外部侦听勘查取证系统。其中，内部信息勘查取证系统运行在犯罪计算机上，对该主机运行环境进行勘查取证；外部扫描勘查取证系统运行在一台笔记本计算机上，通过网络或其他接口对犯罪主机进行勘查取证；外部侦听勘查取证系统

运行在网络的一些关键设备点上，对相关的数据进行截获分析。

13.3.3　勘查取证系统功能定义

1.　内部信息勘查取证系统

内部信息勘查取证系统是针对不同操作系统平台从系统内部获取必要信息的子系统，其针对平台主要可划分为 Windows 系列平台和 UNIX 系列（但支持 Linux，ScoUnix，FreeBSD，Mac 和 Solaris 等常见操作系统）平台两大类。

内部信息勘查取证系统设计由系统类型获取、主机基本配置扫描（软硬件配置）、主机漏洞扫描、主机文档搜索及信息提取组成。

系统类型获取　主要负责对主机的操作系统类型进行获取，根据操作系统的类型调用相应的内部信息获取。

主机基本配置扫描　主要通过检查相关配置文件（UNIX 系列）或注册表信息（Windows 系列），获取软硬件的安装及配置信息。

主机漏洞扫描　主要负责检查基于主机的漏洞信息。

主机文档搜索及信息提取　通过全机检索的方式，收集系统中的文档文件、log 文件、各种临时文件、E-mail 邮件、聊天记录文件、网站访问记录文件等，并可对上述文件进行备份及密码保护，可自动根据用户要求提取可疑信息。

2.　外部扫描勘查取证系统

外部扫描勘查取证系统主要是通过网络从主机外部获取必要信息的子系统，运行在 Windows NT 系列平台。同时，支持常见的网络协议，如 TCP/IP，NETBEUI，IPX/SPX，DLC 等；并且支持 Windows XX，Linux，UNIX，FreeBSD，Mac，Solaris 等常见的操作系统。

外部扫描勘查取证系统设计由操作系统类型获取、端口服务获取、用户信息获取、漏洞信息获取、网络拓扑结构获取和可视化、基于 SNMP，DNS 的信息挖掘等组成。

操作系统类型获取　采用基于 TCP/IP 协议栈的指纹识别技术和可扩展的指纹规则库，可准确获取现今的绝大部分操作系统。

端口服务获取　采用优化的多线程并发机制，相比现有的扫描程序，可大大提高扫描效率。

用户信息获取　获取主机上存在的用户信息。

漏洞信息获取　获取基于网络的漏洞信息，并提供详细的漏洞解决方案，可扫描现有操作系统的绝大部分普遍存在的漏洞。该模块采用漏洞动态知识库的方式，结合动态链接库技术，可方便地进行升级和扩展。

网络拓扑结构获取和可视化　通过收集指定 IP 地址范围内的主机、网络子网的互联信息，建立主机与主机之间、主机与子网之间、子网与子网之间的互联拓扑